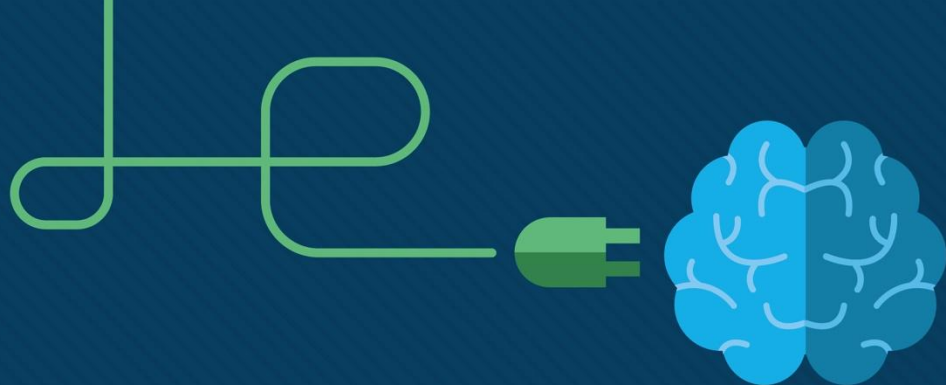
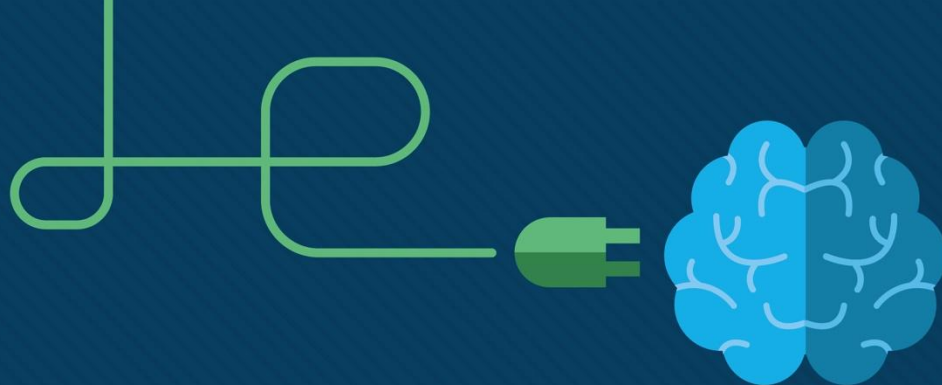




Wykrywanie zagrożeń i reakcja na incydenty





Module 0: Wprowadzenie

CyberOps Associate v1.0



Prowadzący

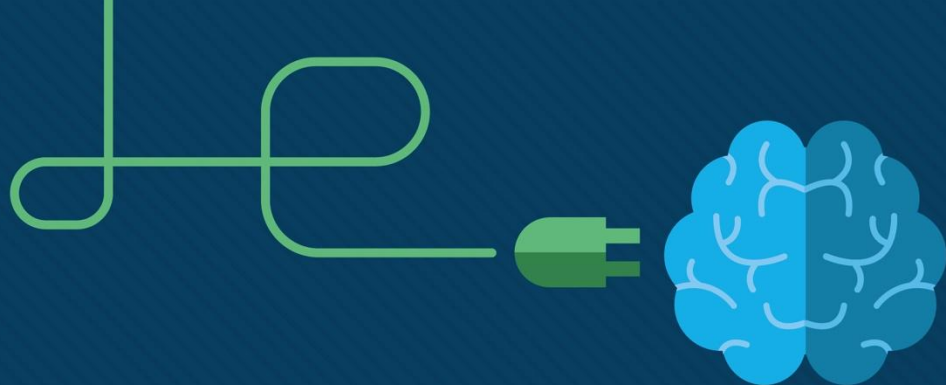
dr inż. Łukasz Pajewski

- Doświadczenie w tematyce:
 - Instruktor CISCO CyberOPS
 - Szkolenia SANS:
 - SEC503: Network Monitoring and Threat Detection In-Depth (H01_05_CM_8665)
 - SEC450: Blue Team Fundamentals: Security Operations and Analysis (I01_02_CM_9165)
 - SEC504: Hacker Tools, Techniques, and Incident Handling (H02_14_CM_8600)
 - SEC560: Enterprise Penetration Testing (H02_06_CM_8745)\
 - Współpraca z KIR (Krajową Izbą Rozliczeniową) – odpowiedzialni za systemy Elixir, Express Elixir, Szafir, mojID ...

Warunki zaliczenia

Ocena końcowa:

- F1 – wykład – ocena z kolokwium (test synchroniczny)
- F2 – laboratorium
- $P = 0,5F1 + 0,5F2$
- **Warunkiem uzyskania pozytywnej oceny podsumowującej jest uzyskanie pozytywnych ocen z wszystkich form zajęć prowadzonych w ramach kursu.**



Module 1: The Danger

CyberOps Associate v1.0



Module Objectives

Module Title: The Danger

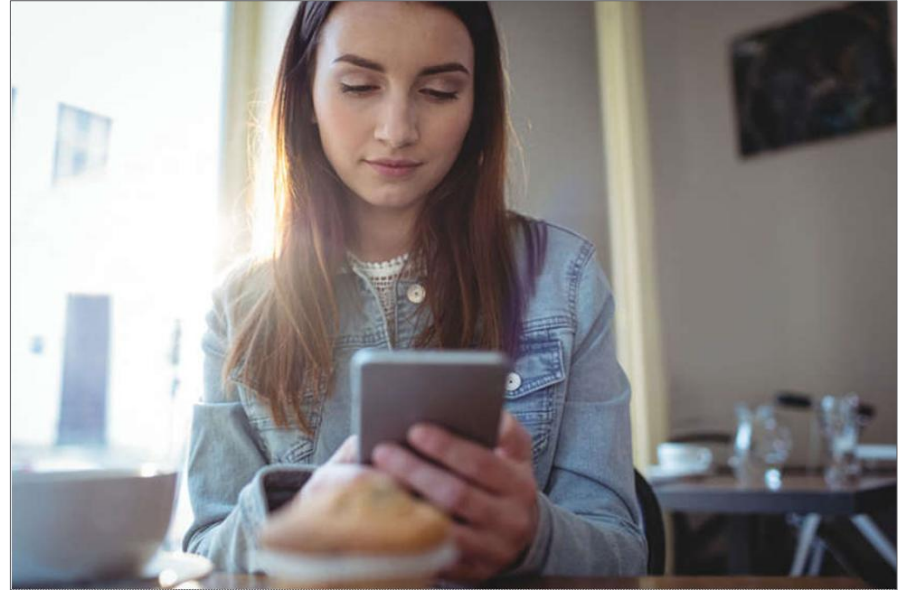
Module Objective: Explain why networks and data are attacked.

Topic Title	Topic Objective
War Stories	Explain why networks and data are attacked.
Threat Actors	Explain the motivations of the threat actors behind specific security incidents.
Threat Impact	Explain the potential impact of network security attacks.

1.1 War Stories

The Danger Hijacked People

- Hackers can set up open “rogue” wireless hotspots posing as a genuine wireless network.
- Rogue wireless hotspots are also known as “evil twin” hotspots.



Ransomed Companies

- Employees of an organization are often lured into opening attachments that install ransomware on the employees' computers.
- This ransomware, when installed, begins the process of gathering and encrypting corporate data.
- The goal of the attackers is financial gain, because they hold the company's data for ransom until they are paid.



The Danger Targeted Nations

- Some of today's malware is so sophisticated and expensive to create that security experts believe only a nation state or group of nations could possibly have the influence and funding to create it.
- Such malware can be targeted to attack a nation's vulnerable infrastructure, such as the water system or power grid.
- One such malware was the Stuxnet worm that infected USB drives and infiltrated Windows operating systems. It then targeted Step 7 software that was developed by Siemens for their Programmable Logic Controllers (PLCs).



1.2 Threat Actors

Threat Actors

- Threat actors are individuals or groups of individuals who perform cyberattacks. They include, but are not limited to:
 - Amateurs
 - Hacktivists
 - Organized crime groups
 - State-sponsored groups
 - Terrorist groups
- Cyberattacks are intentional malicious acts meant to negatively impact another individual or organization.



Threat Actors (Contd.)



Amateurs

- They are also known as script kiddies and have little or no skill.
- They often use existing tools or instructions found on the internet to launch attacks.
- Even though they use basic tools, the results can still be devastating.



Hacktivists

- These are hackers who publicly protest against a variety of political and social ideas.
- They post articles and videos, leaking sensitive information, and disrupting web services with illegitimate traffic in Distributed Denial of Service (DDoS) attacks.



Financial Gain

- Much of the hacking activity that consistently threatens our security is motivated by financial gain.
- Cybercriminals want to gain access to bank accounts, personal data, and anything else they can leverage to generate cash flow.



Trade Secrets and Global Politics

- At times, nation states hack other countries, or interfere with their internal politics.
- Often, they may be interested in using cyberspace for industrial espionage.
- The theft of intellectual property can give a country a significant advantage in international trade.

How Secure is the Internet of Things?

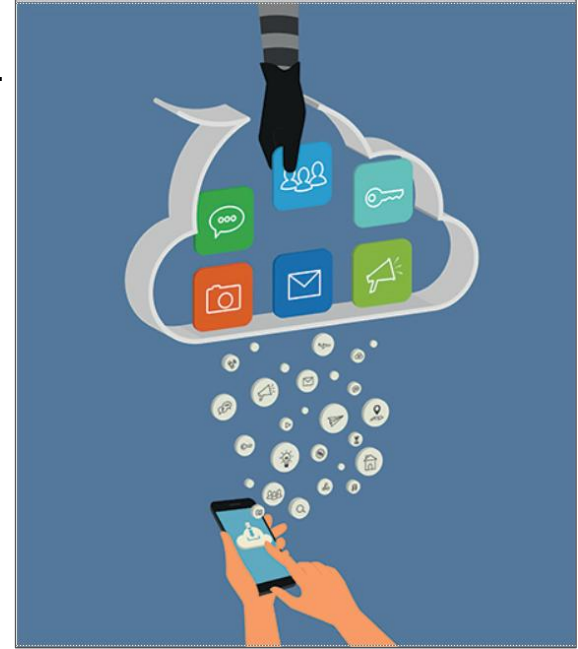
- The Internet of Things (IoT) helps individuals connect things to improve their quality of life.
- Many devices on the internet are not updated with the latest firmware. Some older devices were not even developed to be updated with patches. These two situations create opportunity for threat actors and security risks for the owners of these devices.



1.3 Threat Impact

PII, PHI, and PSI

- **Personally Identifiable Information (PII)** is any information that can be used to positively identify an individual, for example, name, social security number, birthdate, credit card numbers etc.
- Cybercriminals aim to obtain these lists of PII that can then be sold on the dark web. Stolen PII can be used to create fake financial accounts, such as credit cards and short-term loans.
- The medical community creates and maintains Electronic Medical Records (EMRs) that contain **Protected Health Information (PHI)**, a subset of PII.
- **Personal Security Information (PSI)**, another type of PII, includes usernames, passwords, and other security-related information that individuals use to access information or services on the network.



Lost Competitive Advantage

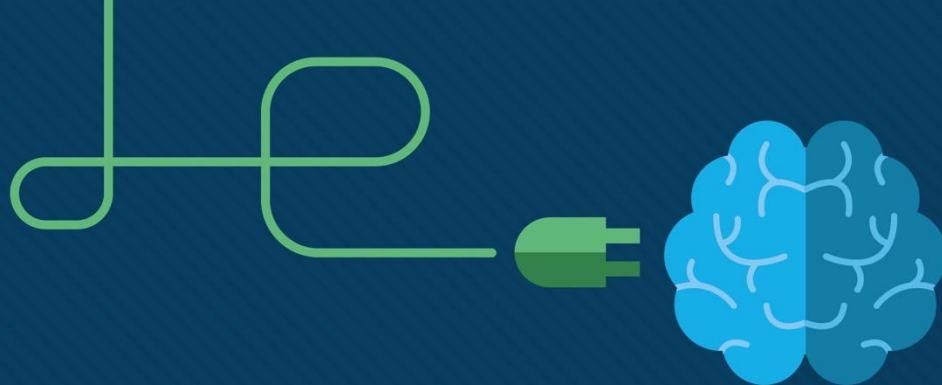
- The loss of intellectual property to competitors is a serious concern.
- An additional major concern is the loss of trust that comes when a company is unable to protect its customers' personal data.
- The loss of competitive advantage may come from this loss of trust rather than another company or country stealing trade secrets.

Politics and National Security

- It is not just businesses that get hacked.
- State-supported hacker warriors can cause disruption and destruction of vital services and resources within an enemy nation.
- The internet has become essential as a medium for commercial and financial activities. Disruption of these activities can devastate a nation's economy.

1.4 The Danger Summary





2. Bojownicy w wojnie z cyberprzestępczością

CyberOps Associate v1.0

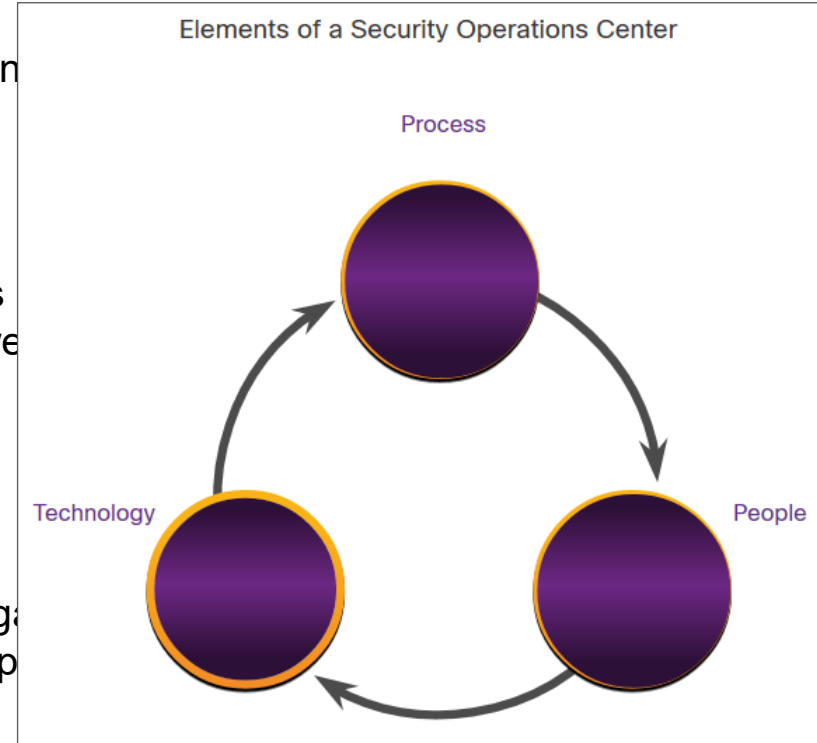


2.1 Nowoczesne Security Operations Center (SOC)

Nowoczesne Security Operations Center (SOC)

Elementy SOC

- W celu wdrożenia sformalizowanego, ustrukturyzowanego i metodycznego podejścia do obrony przed cyberzagrożeniami, organizacje najczęściej korzystają z usług specjalistów z Security Operations Center (SOC).
- W ramach struktur SOC świadczony jest szeroki zakres usług: od monitorowania i zarządzania, po kompleksowe rozwiązania mitygujące zagrożenia oraz dedykowane, hostowane systemy bezpieczeństwa.
- Jednostki SOC mogą funkcjonować jako struktury całkowicie wewnętrzne (in-house), stanowić własność przedsiębiorstwa, bądź ich poszczególne elementy mogą być zlecane zewnętrznym dostawcom zabezpieczeń (np. Cisco's Managed Security Services).



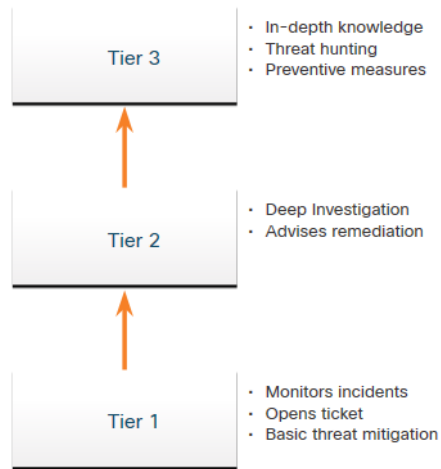
Personel SOC

Poziom	Obowiązki
Tier 1 Alert Analyst	Do zadań na tym stanowisku należy monitorowanie przychodzących alertów, weryfikacja wystąpienia rzeczywistego incydentu oraz, w razie konieczności, eskalacja zgłoszeń (tickets) do poziomu Tier 2.
Tier 2 Incident Responder	Osoba na tym stanowisku odpowiada za dogłębną analizę incydentów oraz doradztwo w zakresie działań naprawczych (remediation).
Tier 3 Threat Hunter	Są to eksperci w dziedzinie sieci, punktów końcowych (endpoint), analizy informacji o zagrożeniach (threat intelligence) oraz inżynierii wstecznej złośliwego oprogramowania (malware reverse engineering), których celem jest określenie wpływu infekcji i metod jej usunięcia. Głównym zadaniem tzw. łowców zagrożeń (threat hunters) jest proaktywne wyszukiwanie w sieci cyberzagrożeń, które nie zostały dotąd wykryte przez standardowe systemy.
SOC Manager	Rola ta polega na zarządzaniu wszystkimi zasobami operacyjnymi SOC oraz pełnieniu funkcji głównego punktu kontaktowego dla całej organizacji lub klienta.

Procesy operacyjne w SOC

- Do codziennych obowiązków analityka ds. cyberbezpieczeństwa (Cybersecurity Analyst) należy monitorowanie kolejek alertów bezpieczeństwa oraz badanie przypisanych powiadomień.
- W celu dystrybucji alertów do kolejki konkretnego analityka wykorzystywany jest system zarządzania zgłoszeniami (ticketing system).
- Należy mieć na uwadze, że systemy monitorujące mogą generować tzw. fałszywe alarmy (false alarms / false positives).
- Z tego względu konieczna jest weryfikacja przez analityka, czy przypisany alert stanowi rzeczywisty incydent bezpieczeństwa (true security incident). Po pozytywnej weryfikacji incydent przekazywany jest zespołowi śledczemu; w przeciwnym razie zgłoszenie jest zamykane jako fałszywy alarm.
- W sytuacji, gdy incydentu nie udaje się rozwiązać na poziomie Tier 1, podlega on eskalacji do zespołu Tier 2 Incident Responder w celu pogłębionej analizy. Jeśli problem wciąż pozostaje nierozwiązany, trafia on do personelu eksperckiego z poziomu Tier 3.

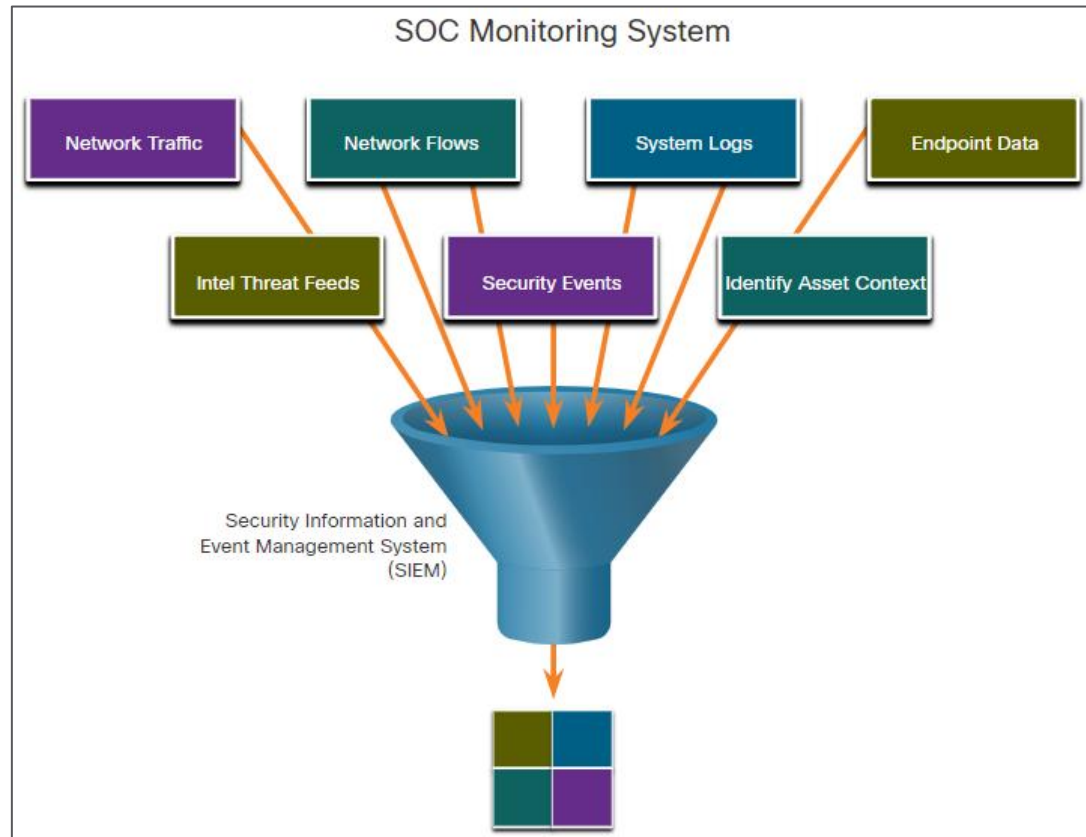
Roles of the People in a Security Operations Center



Nowoczesne Security Operations Center (SOC)

Technologie w SOC: SIEM

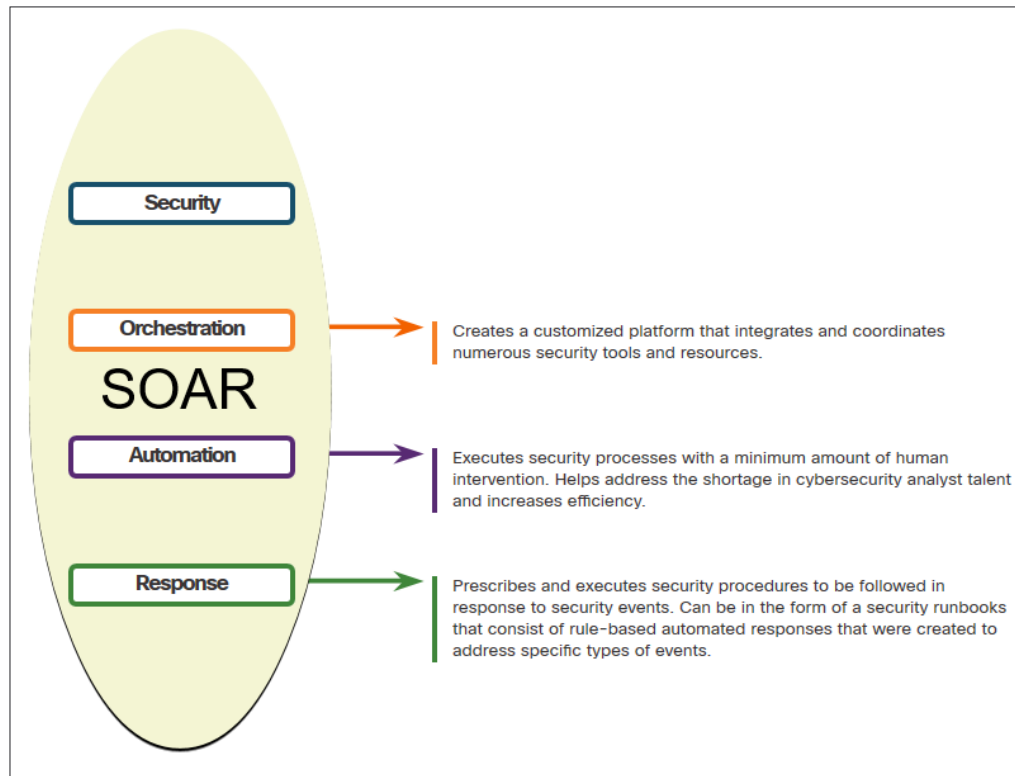
SIEM (Security Information and Event Management): Zastosowanie systemów SIEM w środowisku SOC jest niezbędne w celu agregacji i korelacji danych generowanych przez firewalle, urządzenia sieciowe, systemy wykrywania intruzów (IDS) i inne sensory. Rozwiązania te gromadzą, filtrują i klasyfikują dane, a także wykrywają i analizują potencjalne wektory ataku. Systemy te zarządzają również zasobami w celu wdrażania środków prewencyjnych.



Nowoczesne Security Operations Center (SOC)

Technologie w SOC: SOAR

- **SOAR (Security Orchestration, Automation and Response):** Ze względu na komplementarność obu rozwiązań, platformy SIEM i SOAR są często ze sobą integrowane. W rozbudowanych zespołach ds. operacji bezpieczeństwa (SecOps) obie technologie wykorzystuje się w celu optymalizacji i usprawnienia działania SOC.



Technologie w SOC: SOAR

- Systemy SOAR, podobnie jak SIEM, agregują i analizują alerty, jednak dodatkowo integrują dane z zakresu threat intelligence oraz automatyzują procesy robocze (workflows) w oparciu o ustalone przez zespół bezpieczeństwa scenariusze działania (playbooks).
- Kluczowym aspektem architektury SOAR jest integracja umożliwiająca automatyzację złożonych procedur reagowania na incydenty. Przekłada się to na skrócenie czasu reakcji oraz budowę elastycznych strategii defensywnych. Gotowe scenariusze (playbooks) mogą być inicjowane automatycznie na podstawie zdefiniowanych reguł bezpieczeństwa lub uruchamiane manualnie przez personel.

Metryki SOC

- W celu ewaluacji wydajności operacyjnej jednostki SOC, kadra zarządzająca wykorzystuje kluczowe wskaźniki efektywności (KPI). Do pięciu najczęściej stosowanych zalicza się:

Metryka	Definicja
Dwell Time	Czas, przez jaki aktorzy zagrożeń (threat actors) dysponują aktywnym dostępem do sieci, zanim zostaną wykryci, a ich dostęp – zablokowany.
Mean Time to Detect (MTTD)	Średni czas wymagany przez personel SOC na zidentyfikowanie wystąpienia krytycznych incydentów bezpieczeństwa w infrastrukturze.
Mean Time to Respond (MTTR)	Średni czas niezbędny na zatrzymanie ataku i wdrożenie działań naprawczych.
Mean Time to Contain (MTTC)	Czas wymagany do wyizolowania zagrożenia i zapobieżenia dalszej degradacji systemów lub wyciekowi danych.
Time to Control	Czas niezbędny na powstrzymanie propagacji złośliwego oprogramowania (malware) wewnątrz sieci.

Bezpieczeństwo a dostępność (Security vs. Availability)

- Z perspektywy inżynierii bezpieczeństwa kluczowe jest zrozumienie, że utrzymanie dostępności sieci (network availability) jest warunkiem koniecznym do realizacji celów biznesowych organizacji.
- Wdrożone mechanizmy kontrolne nie mogą być na tyle restrykcyjne, by zakłócać pracę personelu lub paraliżować procesy biznesowe.
- Wymagane jest ciągle dążenie do osiągnięcia optymalnego balansu (tradeoff) pomiędzy rygorystycznym bezpieczeństwem a zachowaniem operacyjnej wydajności przedsiębiorstwa.

Standardy dostępności – Reguła "Dziewiątek"

Poziom Dostępności	Dopuszczalny czas przestoju w ciągu ROKU	Przeznaczenie / Standard rynkowy
99%	3 dni, 15 godzin	Niewspierane systemy testowe (Dev/Test). Niedopuszczalne w produkcji.
99.9%	8 godzin, 45 minut	Podstawowy standard dla systemów biurowych.
99.99%	52 minuty, 35 sekund	Standard Enterprise. Wymagany poziom dla systemów SOC, zapór NGFW i infrastruktury korporacyjnej (wymaga klastrów High Availability).
99.999%	5 minut, 15 sekund	Infrastruktura krytyczna (Carrier-grade), np. systemy telekomunikacyjne, bankowość centralna, służba zdrowia.
99.9999%	31 sekund	Sektor wojskowy, systemy lotnicze i kosmiczne.

Przykład SOC

Architektura Technologiczna SOC – Przegląd Ekosystemu

- **Kompleksowy stos technologiczny (Technology Stack) wdrażany w celu agregacji danych i mitygacji zagrożeń:**
 - **SIEM (Zarządzanie Zdarzeniami):** IBM QRadar + Splunk Enterprise Security
 - **IPS (Zapobieganie Włamaniom):** Check Point Quantum + Cisco Secure Firewall (Firepower)
 - **WAF (Ochrona Aplikacji Webowych):** F5 Advanced WAF (BIG-IP)
 - **XDR_SVR (Rozszerzona Detekcja dla Serwerów):** Trend Micro Deep Security
 - **XDR_USR (Rozszerzona Detekcja dla Użytkowników):** Trend Micro Apex One + konsola Vision One
 - **EX (Ochrona Poczty Elektronicznej):** Trellix Email Security (dawniej FireEye EX)
 - **NDS_SEC (Bezpieczeństwo Sieci i DNS):** Cisco Umbrella
 - **Proxy (Bezpieczna Brama Sieciowa):** Forcepoint Web Security
 - **DLP (Zapobieganie Utracie Danych):** Forcepoint DLP (+ polityki łagodne "Green mod")
 - **DAM (Monitorowanie Baz Danych):** Imperva Data Security
 - **MISP (Współdzielenie Informacji o Zagrożeniach):** MISP Threat Sharing (Open Source)
 - **Bezpieczeństwo Fizyczne (Physical Security):** Kantech + iProtect + Galaxy Control Systems + Alphasystems

Serce SOC – Systemy SIEM (Analiza i Korelacja Zdarzeń)

▪ Splunk Enterprise Security

- **Producent (2026):** Cisco (zakończenie gigantycznego przejęcia Splunka przez Cisco w 2024 roku).
- **Funkcja:** Agregacja potężnych ilości danych (Big Data), korelacja zdarzeń, tworzenie zaawansowanych dashboardów i reguł detekcji.
- **Licencja:** Komercyjna. Licencjonowanie oparte na indeksowanym wolumenie danych (GB/dzień) lub mocy obliczeniowej (vCPU/Workload). Bardzo drogie rozwiązanie (projekty od kilkudziesięciu do setek tysięcy dolarów).
- **Zalety:** Bezkonkurencyjny język zapytań (SPL), ogromna elastyczność i wsparcie społeczności.
- **Wady:** Wysokie koszty licencyjne i sprzętowe, stroma krzywa uczenia dla analityków Tier 1.

Serce SOC – Systemy SIEM (Analiza i Korelacja Zdarzeń)

■ IBM Security QRadar SIEM / Cortex XSIAM

- **Producent (2026):** IBM (wersje on-premise) / Palo Alto Networks (w 2024 IBM sprzedał chmurowe aktywa QRadar firmie Palo Alto).
 - **Funkcja:** Zautomatyzowane wykrywanie zagrożeń, korelacja sieciowa, analityka behawioralna (UBA).
 - **Licencja:** Komercyjna. Licencjonowanie klasycznie oparte na wskaźniku EPS (Events Per Second – zdarzenia na sekundę) oraz FPM (Flows Per Minute).
 - **Zalety:** Genialna analiza ruchu sieciowego i przepływów (Flows), silne reguły Out-of-the-Box.
 - **Wady:** Interfejs użytkownika bywa przestarzały (szczególnie w starszych wersjach on-premise).
- **Inne popularne rozwiązania:** Microsoft Sentinel (chmura natywna), Elastic Security (ELK Stack – opcja open-source z płatnymi modułami).

Ochrona Sieciowa i Aplikacyjna (IPS & WAF)

▪ Definicje i przeznaczenie:

- **IPS (Intrusion Prevention System – System Zapobiegania Włamaniom):** Rozwiązanie wdrażane na brzegach sieci w celu aktywnego monitorowania ruchu, wykrywania anomalii w czasie rzeczywistym oraz natychmiastowego blokowania złośliwych pakietów i prób eksploatacji luk w protokołach sieciowych.
- **WAF (Web Application Firewall – Zapora Aplikacji Webowych):** Wyspecjalizowany firewall wdrażany w celu filtrowania i monitorowania ruchu HTTP/HTTPS. Służy do ochrony warstwy 7 (aplikacyjnej) przed atakami takimi jak SQL Injection czy Cross-Site Scripting (XSS).

Ochrona Sieciowa i Aplikacyjna (IPS & WAF)

- **Zabezpieczenie na poziomie brzegu sieci i ochrony warstwy siódmej (aplikacji).**
- **IPS (Intrusion Prevention System): Check Point Quantum / Cisco Secure Firewall (Firepower)**
 - **Producenci:** Check Point Software Technologies oraz Cisco (dawniej Firepower).
 - **Funkcja:** Obie platformy to zaawansowane bramy sieciowe (NGFW/IPS) analizujące ruch i blokujące ataki na luki w oprogramowaniu i sieci w czasie rzeczywistym.
 - **Licencja:** Komercyjne (zakup sprzętu Appliance + roczne subskrypcje na sygnatury).
 - **Zalety:** Check Point słynie z najlepszych wskaźników detekcji "catch-rate" i zarządzania; Cisco świetnie integruje się z resztą swojego ekosystemu sieciowego.
 - **Wady:** Zarządzanie systemami Cisco bywa wysoce skomplikowane; Check Point bywa drogi w utrzymaniu przy dużej skali.
 - **Alternatywy:** Fortinet (FortiGate), Palo Alto Networks.

Ochrona Sieciowa i Aplikacyjna (IPS & WAF)

▪ **WAF (Web Application Firewall): F5 Advanced WAF (BIG-IP)**

- **Producent:** F5 Networks.
- **Funkcja:** Ochrona aplikacji webowych (L7), mitygacja ataków DDoS w warstwie aplikacji, obrona przed botami i wstrzykiwaniem kodu (SQLi, XSS).
- **Licencja:** Komercyjna (sprzęt, licencje wirtualne VE lub SaaS).
- **Zalety:** Absolutny standard rynkowy (Enterprise), potężne możliwości mikrozarządzania ruchem (język iRules).
- **Wady:** Ekstremalnie skomplikowana konfiguracja, wymaga dedykowanego specjalisty (F5 Inżynier).
- **Alternatywy:** Cloudflare WAF, Imperva WAF.

Ochrona Serwerów i Użytkowników Końcowych (XDR)

▪ Definicje i przeznaczenie:

- **XDR (Extended Detection and Response):** Platforma integrująca dane z wielu warstw bezpieczeństwa (stacje robocze, serwery, sieci, usługi chmurowe) w celu zautomatyzowanej korelacji alertów i szybszego reagowania na złożone incydenty.

▪ XDR_SVR: Trend Micro Deep Security

- **Producent:** Trend Micro.
- **Funkcja:** Modułowa ochrona serwerów (fizycznych, wirtualnych, chmurowych). Zapewnia ochronę antymalware, wirtualne patchowanie (Virtual Patching), kontrolę integralności.
- **Licencja:** Komercyjna (oparta na liczbie instancji serwerowych).
- **Zalety:** Perfekcyjna integracja ze środowiskami wirtualnymi (VMware NSX) i chmurą publiczną (AWS/Azure); wirtualne łątki chronią stare systemy.
- **Wady:** Niewłaściwa konfiguracja potrafi mocno obciążyć zasoby serwera (tzw. ciężki agent).

Ochrona Serwerów i Użytkowników Końcowych (XDR)

▪ **XDR_USR: Trend Micro Apex One z Vision One**

- **Producent:** Trend Micro.
- **Funkcja:** Ochrona stacji roboczych (Endpoint) z funkcjami EDR (badanie śledcze na urządzeniach). Vision One to nadrzędna platforma konsolidująca alerty (XDR).
- **Licencja:** Komercyjna (per użytkownik/stacja robocza).
- **Zalety:** Centralizacja alertów w jednym oknie (Vision One), szybka mitygacja zagrożeń na stacjach.
- **Wady:** Konsola Vision One wymaga czasu na wdrożenie się w analitykę korelacji.

▪ **Alternatywy XDR/EDR:** CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint.

Ochrona Wektorów Ataku: Email, DNS, Web

- **Definicje i przeznaczenie:**
- **EX (Email Security – Ochrona Poczty Elektronicznej):** Rozwiązania wdrażane w celu skanowania ruchu pocztowego, blokowania kampanii phishingowych oraz analizy behawioralnej nieznanych załączników w izolowanym środowisku (Sandboxing).
- **NDS_SEC (Network/DNS Security – Bezpieczeństwo warstwy DNS):** Mechanizmy stosowane w celu weryfikacji i blokowania zapytań do złośliwych domen zanim nastąpi zestawienie połączenia (mitygacja komunikacji z serwerami Command & Control).
- **Proxy (Secure Web Gateway – Bezpieczna Brama Sieciowa):** Oprogramowanie wdrażane w celu pośredniczenia w ruchu internetowym, deszyfrowania protokołów TLS/SSL oraz kategoryzacji i blokowania złośliwych witryn WWW.

Ochrona Wektorów Ataku: Email, DNS, Web

▪ **EX (Email Security): Trellix Email Security (dawniej FireEye EX)**

- **Producent:** Trellix (firma powstała z fuzji McAfee Enterprise i FireEye).
- **Funkcja:** Zaawansowana ochrona poczty elektronicznej, wykrywanie ataków spear-phishing i uruchamianie załączników w izolowanym środowisku (Sandboxing).
- **Licencja:** Komercyjna (zależna od liczby skrzynek pocztowych).
- **Zalety:** Wybitny silnik sandboxingowy (MVX), łapiący zagrożenia typu Zero-Day.
- **Wady:** Trellix wciąż przechodzi transformację interfejsów po fuzji obu gigantów. (Alternatywy: Proofpoint, Mimecast).

Ochrona Wektorów Ataku: Email, DNS, Web

▪ **NDS_SEC (Network/DNS Security): Cisco Umbrella**

- **Producent:** Cisco.
- **Funkcja:** Ochrona w warstwie DNS – blokuje zapytania do złośliwych domen zanim nastąpi połączenie IP.
- **Licencja:** Komercyjna (per użytkownik).
- **Zalety:** Niezwykle łatwe wdrożenie, znakomita prewencja przed ransomware i C2 (Command & Control).

▪ **Proxy (Secure Web Gateway): Forcepoint Web Security**

- **Producent:** Forcepoint.
- **Funkcja:** Filtrowanie ruchu WWW, dekrypcja SSL/TLS, kategoryzacja stron i blokowanie złośliwych treści internetowych.
- **Licencja:** Komercyjna.
- **Zalety:** Świetny silnik oceny ryzyka witryn w czasie rzeczywistym.

Ochrona Danych (DLP & DAM) i Threat Intelligence

- **Definicje i przeznaczenie:**
- **DLP (Data Loss Prevention – Zapobieganie Utracie Danych):** Narzędzia stosowane w celu identyfikacji, monitorowania oraz blokowania nieautoryzowanego transferu danych wrażliwych poza organizację (np. blokowanie portów USB, załączników). Tryb "Green mod" oznacza wdrożenie łagodnych polityk audytowych, stosowanych początkowo w celu mapowania procesów biznesowych bez blokowania pracy.
- **DAM (Database Activity Monitoring – Monitorowanie Aktywności Baz Danych):** Systemy wdrażane w celu ciągłej analizy zapytań SQL i ochrony integralności baz danych.
- **MISP (Malware Information Sharing Platform):** Platforma wykorzystywana przez analityków w celu ustrukturyzowanego współdzielenia wskaźników kompromitacji (IoC) ze społecznością.

Ochrona Danych (DLP & DAM) i Threat Intelligence

- **DLP (Data Loss Prevention): Forcepoint DLP (+ Green mod)**

- **Producent:** Forcepoint.
- **Funkcja:** Monitorowanie, blokowanie i audytowanie prób wyniesienia danych wrażliwych (np. USB, email, chmura). "Green mod" (moduły/polityki łagodniejsze) używane do mapowania procesów bez blokowania pracy.
- **Licencja:** Komercyjna.
- **Zalety:** Uważany za jeden z najpotężniejszych silników DLP na rynku (fingerprinting bazy danych, OCR).
- **Wady:** Wdrożenie DLP to proces wielomiesięczny; źle napisane polityki paraliżują pracę firmy.

Ochrona Danych (DLP & DAM) i Threat Intelligence

- **DAM (Database Activity Monitoring): Imperva Data Security**

- **Producent (2026):** Thales (grupa Thales sfinalizowała przejęcie Impervy w 2024 r.).
- **Funkcja:** Analiza wszystkich zapytań SQL do krytycznych baz danych, wykrywanie anomalii i kradzieży danych z wewnątrz i zewnątrz.
- **Licencja:** Komercyjna (per serwer bazy danych lub ruch).
- **Zalety:** Granularny wgląd w to, kto, kiedy i jak odpytał bazę danych. (Alternatywa: IBM Guardium).

Ochrona Danych (DLP & DAM) i Threat Intelligence

▪ MISIP (Malware Information Sharing Platform)

- **Producent:** Projekt wspierany przez m.in. CIRCL (Społeczność).
- **Model: Open Source (Darmowy).**
- **Funkcja:** Platforma dla analityków Threat Intelligence do dzielenia się wskaźnikami włamań (IoC - IP, hashe, domeny).
- **Zalety:** Ogromna sieć zaufanych partnerów na świecie wymieniających się danymi za darmo.
- **Wady:** Wymaga utrzymania serwera i "czyszczenia" danych, aby uniknąć fałszywych alarmów (False Positives) włączanych do SIEM.

Integracja systemów fizycznych z SOC

- **Dojrzały SOC monitoruje nie tylko cyberprzestrzeń, ale również środowisko fizyczne.**
 - Systemy Kontroli Dostępu i Fizycznego Bezpieczeństwa:
 - Kantech (własność Johnson Controls)
 - iProtect (własność TKH Security)
 - Galaxy Control Systems
 - Alphasystems (Systemy budynkowe)

Integracja systemów fizycznych z SOC

- **Kantech (Johnson Controls): Wewnętrznybudynekowa kontrola dostępu**
 - **Zakres odpowiedzialności:** Zarządzanie fizycznymi uprawnieniami pracowników. System kontroluje czytniki kart zbliżeniowych, elektroniczne zamki oraz kontrolery drzwiowe wewnątrz obiektu, ze szczególnym uwzględnieniem stref o podwyższonym ryzyku (np. dostęp do serwerowni).
- **iProtect (TKH Security): Zintegrowane zarządzanie bezpieczeństwem (Security Management System)**
 - **Zakres odpowiedzialności:** Centralizacja zróżnicowanych systemów bezpieczeństwa. Wykorzystywany w celu unifikacji kontroli dostępu, telewizji przemysłowej (CCTV), interkomów oraz systemów sygnalizacji włamania i napadu (SSWiN) w ramach jednej platformy, co znacząco ułatwia standaryzację danych wysyłanych do SOC.

Integracja systemów fizycznych z SOC

- **Galaxy Control Systems: Zaawansowana kontrola dostępu klasy Enterprise**
 - **Zakres odpowiedzialności:** Skalowalne zarządzanie tożsamością fizyczną w rozproszonych geograficznie obiektach. Obejmuje autoryzację z wykorzystaniem danych biometrycznych, systemy zarządzania windami oraz ścisłą integrację z tożsamością sieciową (np. Active Directory).
- **Alphatronics: Zabezpieczenia obwodowe i zarządzanie przepływem (Perimeter Security)**
 - **Zakres odpowiedzialności:** Ochrona fizycznej granicy (obwodu) obiektu. System steruje sprzętem ciężkim: szlabanami, kamerami stosowanymi w celu rozpoznawania tablic rejestracyjnych (ANPR/LPR), kołowrotami (turnstiles) oraz bramkami szybkiego dostępu (speedgates) dla pieszych i pojazdów.

Scenariusze korelacji incydentów w systemie SIEM (Use Cases)

- Korelacja logowania z fizyczną obecnością (Impossible Travel): System SIEM rejestruje alert logowania do sieci VPN ze zdalnego adresu IP (np. z terytorium obcego państwa). Równolegle weryfikowane są logi z systemu Kantech lub Galaxy. Jeśli karta tego samego pracownika została autoryzowana na czytniku wewnątrz biura w zbliżonym czasie, SIEM automatycznie generuje krytyczny alert o kompromitacji poświadczeń.
- Wykrywanie omijania zabezpieczeń (Tailgating): Algorytmy analizy obrazu wbudowane w system iProtect wykrywają fizyczne przejście dwóch osób przez strefę buforową, podczas gdy urządzenia obwodowe Alphasatronics (np. kołowrót) zarejestrowały autoryzację tylko jednego identyfikatora. Zdarzenie to jest natychmiast eskalowane do analityków SOC w celu weryfikacji potencjalnego wtargnięcia.

Szacunkowe koszty wdrożenia systemów SOC

- Zestawienie kosztów licencyjnych oraz sprzętowych dla infrastruktury obejmującej 1000 użytkowników końcowych w środowisku Enterprise:

System (Kategoria i Rozwiązanie)	Koszt licencji / subskrypcji systemu (na 1000 użytkowników rocznie)	Koszt zakupu sprzętu (Hardware) / wdrożenia bazowego aplikacji
SIEM (IBM QRadar + Splunk)	Ok. \$40,000 – \$150,000+ (zależne od wolumenu logów / wskaźnika EPS)	\$50,000+ (klastry sprzętowe lub wliczone w wyższą marżę chmurową)
IPS (Check Point Quantum + Cisco Firepower)	Ok. \$10,000 – \$30,000 (pakiety sygnatur i ochrony na bramach)	\$30,000 – \$80,000 (zakup dedykowanego klastra sprzętowego High Availability)
WAF (F5 Advanced WAF)	Ok. \$15,000 – \$30,000 (dla środowisk wirtualnych / SaaS)	\$40,000 – \$100,000+ (zakup dedykowanych platform sprzętowych - Appliance)
XDR_SVR (Trend Micro Deep Security)	Ok. \$15,000 – \$30,000 (wymagane licencjonowanie na serwery, założono pulę 100 serwerów)	Brak dodatkowego sprzętu (wdrażane w formie agentów programowych)
XDR_USR (Trend Micro Apex One + Vision One)	Ok. \$30,000 – \$60,000 (koszt agentów i konsoli dla 1000 stacji)	Brak dodatkowego sprzętu (architektura chmurowa SaaS)
EX (Trellix Email Security)	Ok. \$30,000 – \$70,000 (licencjonowanie na skrzynkę pocztową)	Wliczone w usługę chmurową (lub dedykowany sprzęt od \$15,000)

Scenariusze korelacji incydentów w systemie SIEM (Use Cases)

- Korelacja logowania z fizyczną obecnością (Impossible Travel): System SIEM rejestruje alert logowania do sieci VPN ze zdalnego adresu IP (np. z terytorium obcego państwa). Równolegle weryfikowane są logi z systemu Kantech lub Galaxy. Jeśli karta tego samego pracownika została autoryzowana na czytniku wewnątrz biura w zbliżonym czasie, SIEM automatycznie generuje krytyczny alert o kompromitacji poświadczeń.
- Wykrywanie omijania zabezpieczeń (Tailgating): Algorytmy analizy obrazu wbudowane w system iProtect wykrywają fizyczne przejście dwóch osób przez strefę buforową, podczas gdy urządzenia obwodowe Alphaswitches (np. kołowrót) zarejestrowały autoryzację tylko jednego identyfikatora. Zdarzenie to jest natychmiast eskalowane do analityków SOC w celu weryfikacji potencjalnego wtargnięcia.

Szacunkowe koszty wdrożenia systemów SOC

- Zestawienie kosztów licencyjnych oraz sprzętowych dla infrastruktury obejmującej 1000 użytkowników końcowych w środowisku Enterprise:

System (Kategoria i Rozwiązanie)	Koszt licencji / subskrypcji systemu (na 1000 użytkowników rocznie)	Koszt zakupu sprzętu (Hardware) / wdrożenia bazowego aplikacji
NDS_SEC (Cisco Umbrella)	Ok. \$20,000 – \$45,000 (licencjonowanie per użytkownik)	Brak sprzętu (rozwiązanie natywne dla chmury - Cloud-native)
Proxy (Forcepoint Web Security)	Ok. \$40,000 – \$80,000 (inspekcja SSL/TLS dla 1000 pracowników)	Ok. \$10,000 – \$25,000 (serwery proxy lub maszyny wirtualne)
DLP (Forcepoint DLP)	Ok. \$40,000 – \$70,000	\$100,000+ (wysokie koszty usług inżynierskich w celu mapowania procesów biznesowych)
DAM (Imperva Data Security)	Ok. \$40,000 – \$90,000 (licencje oparte na węzłach baz danych)	\$20,000+ (serwery audytowe i kolektory logów)
MISP (Threat Sharing)	\$0 (Oprogramowanie Open Source)	Koszty operacyjne: infrastruktura VM + roboczogodziny (ok. \$60,000 rocznie)
Physical (Kantech + iProtect + Galaxy + Alphasentrics)	Ok. \$5,000 – \$15,000 (utrzymanie subskrypcji serwisowych dla oprogramowania)	\$20,000 – \$150,000+ (zakup czytników, bramek, okablowania, kamer, central)

Szacunkowe koszty wdrożenia systemów SOC

SUMA (Szacunkowa)	Rocznie (\$)	Jednorazowo (\$)
	345,000 – 730,000+	285,000 – 685,000+

Dyskusja

Kiedy potrzeba SOC?

- Co decyduje o potrzebie SOC?

Ile osób jest potrzebne w SOC?

- a) mała firma?
- b) duża firma?
- c) czy każdą firmę stać na SOC?
- d) jakie są koszty prowadzenia SOC?

2.2 Jak zostać obrońcą?

Jak zostać obrońcą?

Certyfikacje i edukacja

- Na rynku edukacyjnym dostępny jest szereg branżowych certyfikacji przygotowujących do pracy w SOC, takich jak:
 - Cisco Certified CyberOps Associate,
 - CompTIA Cybersecurity Analyst, certyfikacje (ISC)²,
 - Global Information Assurance Certification (GIAC),
 - **Offensive Security Certified Professional (OSCP).**



OSCP

- **OSCP**, czyli **Offensive Security Certified Professional**, to jeden z najbardziej szanowanych certyfikatów w branży cyberbezpieczeństwa, jeśli chodzi o ofensywę, czyli testy penetracyjne (Ethical Hacking). Wydawany jest przez organizację **OffSec** (dawniej Offensive Security).
 - Zero pytań ABCD
 - Legendarny, 48-godzinny egzamin:
 - Kandydat otrzymuje połączenie VPN do izolowanej, nieznanej sieci (laboratorium) z kilkoma maszynami (Windows, Linux, Active Directory). Ma dokładnie 24 godziny na znalezienie luk, przełamanie zabezpieczeń i zdobycie najwyższych uprawnień (tzw. root / SYSTEM) na tych maszynach (zdobywa tzw. flagi).
 - Po upływie tego czasu, ma kolejne 24 godziny na napisanie i dostarczenie profesjonalnego raportu z testów penetracyjnych (opisującego krok po kroku, jak doszło do przełamania zabezpieczeń, aby klient mógł to załatać).

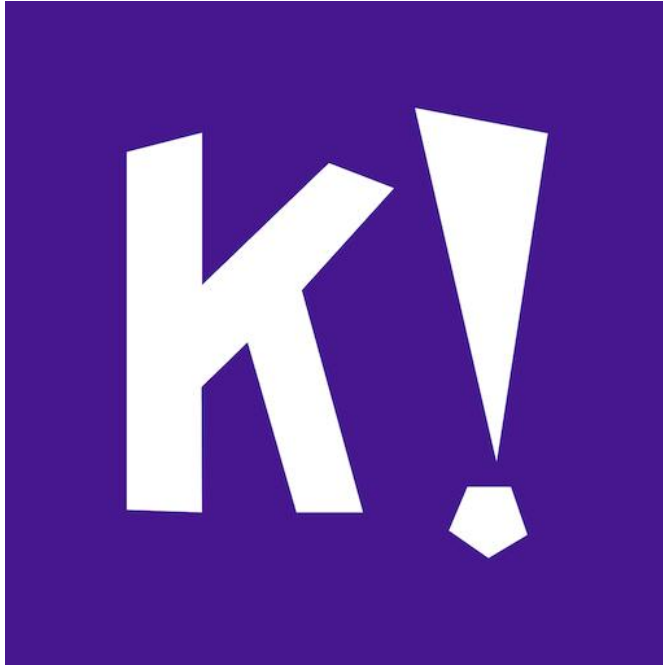
Jak zostać obrońcą?

Dalsza edukacja

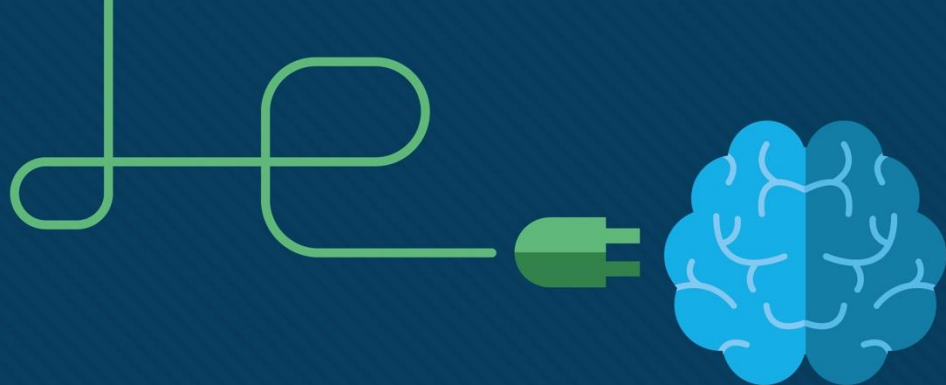
- Programowanie w języku Python: Znajomość tego języka stanowi jedną z kluczowych kompetencji dla osób planujących rozwój kariery w branży cyberbezpieczeństwa. Python jest rekomendowany jako pierwszy język skryptowy.
- Umiejętności w środowisku Linux: Biegłość w obsłudze i administracji systemami z rodziny Linux stanowi wysoce pożądaną umiejętność w procesie rekrutacyjnym, z uwagi na powszechne wykorzystanie tych systemów w architekturze sieciowej, środowiskach SOC oraz narzędziach ofensywnych/defensywnych.



2.2 Jak zostać obrońcą?







Infrastruktura bezpieczeństwa sieci

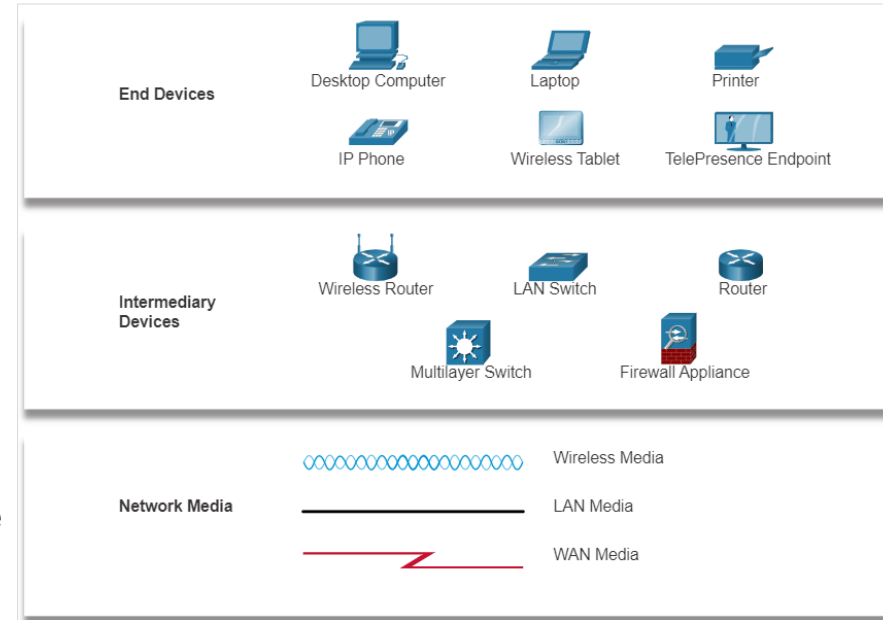
CyberOps Associate v1.0



3.1 Reprezentacje sieci i diagramy topologiczne

Kluczowa terminologia infrastrukturalna:

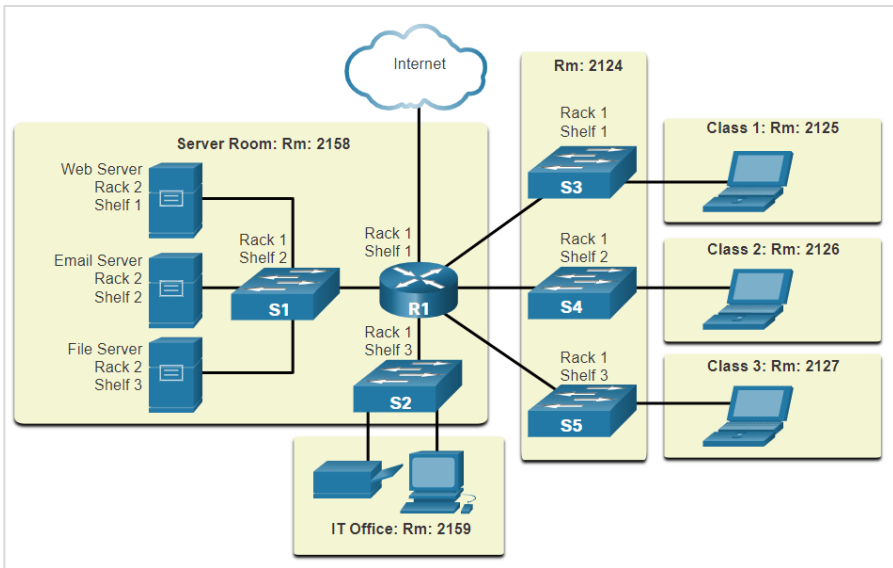
- **Karta sieciowa** (NIC - Network Interface Card): Układ sprzętowy umożliwiający fizyczne połączenie urządzenia końcowego z siecią.
- **Port fizyczny**: Sprzętowe gniazdo na urządzeniu (np. przełączniku, routerze), do którego bezpośrednio podłączamy nośnik (kabel). Warstwa 1 modelu OSI.
- **Interfejs**: Logiczny (programowy) punkt styku z siecią, do którego przypisywana jest konfiguracja (np. adres IP). Może być powiązany z portem fizycznym lub istnieć wyłącznie wirtualnie (np. interfejsy VLAN, tunele VPN).
(Uwaga: W praktyce inżynierskiej terminy "port" i "interfejs" są często używane zamiennie).



Rodzaje diagramów w dokumentacji:

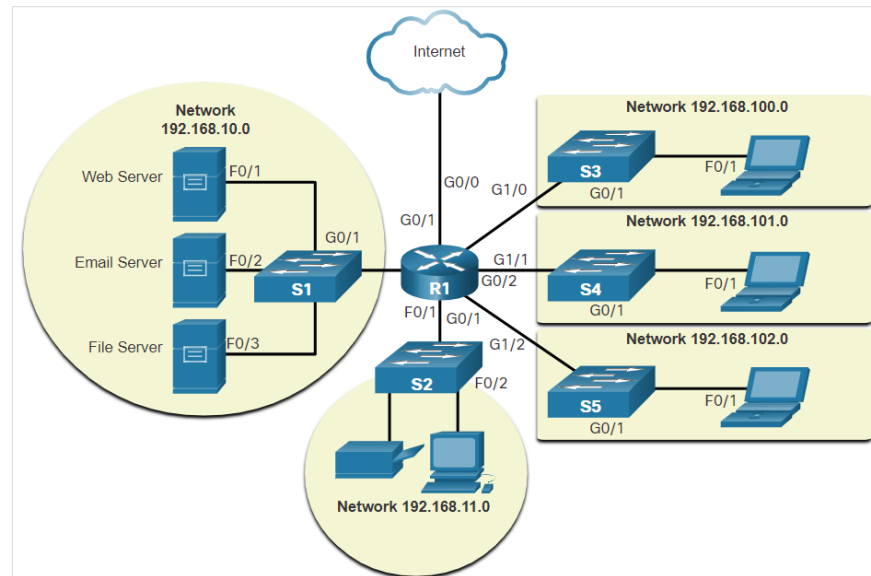
Topologia fizyczna (Physical topology):

Przedstawia rzeczywiste rozmieszczenie urządzeń (np. szafy RACK, serwerownie) oraz trasy instalacji kablowej.



Topologia logiczna (Logical topology):

Koncentruje się na przepływie danych. Obrazuje urządzenia, logiczne interfejsy oraz schemat adresacji IP (podsieci, VLAN-y).



Skala i klasyfikacja sieci

- **Małe sieci domowe:** Łączą kilka komputerów ze sobą i z Internetem.
- **Sieci SOHO (Small Office / Home Office):** Umożliwiają małym biurom i pracownikom zdalnym dostęp do centralnej sieci korporacyjnej.
- **Średnie i duże sieci (Enterprise):** Obejmują wiele lokalizacji, łączą setki lub tysiące urządzeń.
- **Sieci globalne:** Łączą setki milionów urządzeń na całym świecie (np. Internet).



Small Home



SOHO



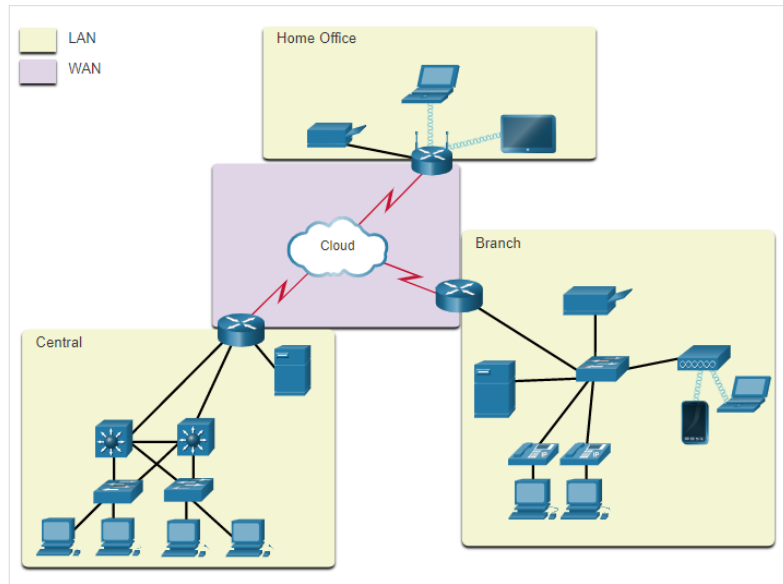
Medium/Large



World Wide

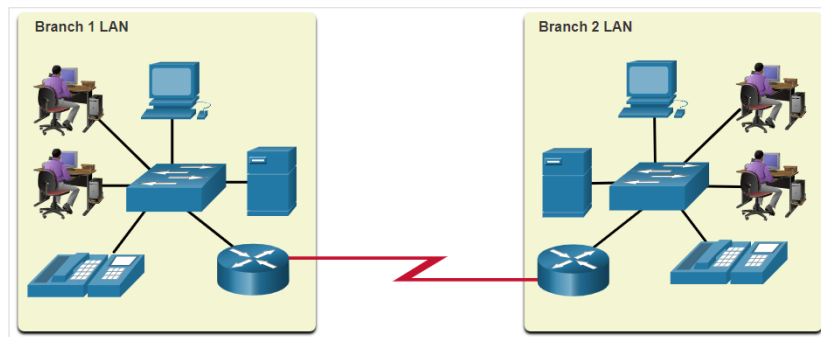
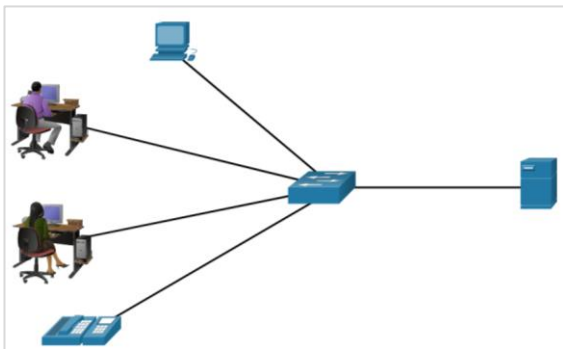
Topologie sieciowe - LAN i WAN

- **Główne różnice:** Rozmiar obszaru, liczba użytkowników, dostępne usługi.
- **Sieci LAN (Local Area Network):**
 - **Zasięg:** Mały obszar (pokój, biuro, budynek).
 - **Zarządzanie:** Jeden administrator / organizacja.
 - **Przepustowość:** Bardzo wysoka (szybka sieć wewnętrzna).
- **Sieci WAN (Wide Area Network):**
 - **Zasięg:** Bardzo duży obszar (miasta, kraje, kontynenty).
 - **Cel:** Łączenie oddzielnych sieci LAN.
 - **Zarządzanie:** Zewnętrzni dostawcy usług telekomunikacyjnych (ISP).
 - **Przepustowość:** Zazwyczaj niższa niż w sieciach LAN.



Network Topologies

Sieci LAN i WAN



LAN

Łączą urządzenia końcowe na ograniczonym obszarze geograficznym.

Administrowane przez jedną organizację lub osobę prywatną.

Zapewniają wysoką przepustowość dla wewnętrznych urządzeń końcowych i pośredniczących.

WAN

Łączą sieci LAN na rozległych obszarach geograficznych.

Zazwyczaj administrowane przez wielu dostawców usług telekomunikacyjnych.

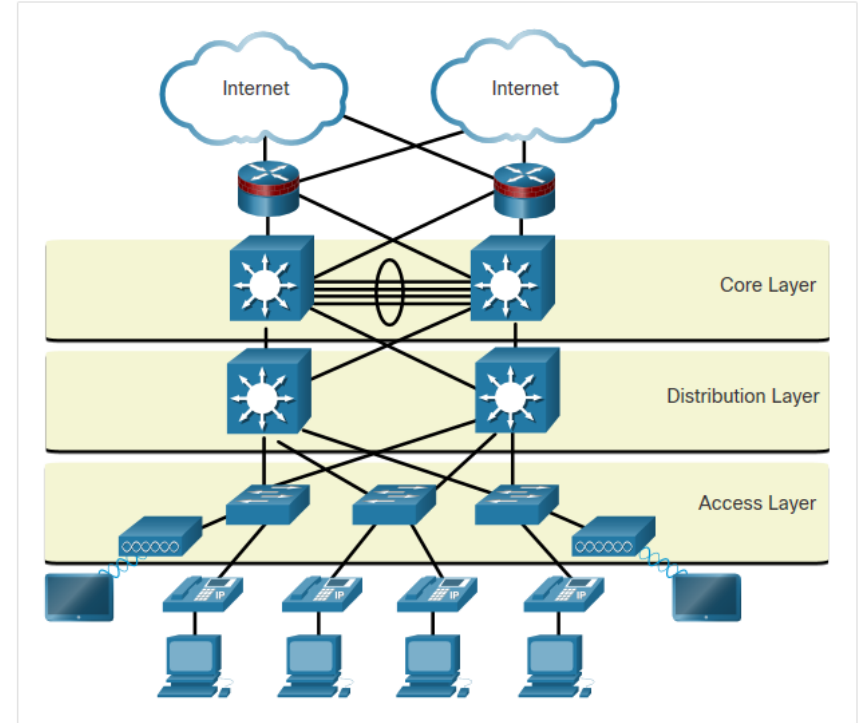
Zazwyczaj zapewniają wolniejsze łącza komunikacyjne między poszczególnymi sieciami LAN.

Trójwarstwowy model projektowania sieci

Hierarchiczny model LAN: Dzieli topologię sieci na modułowe grupy i warstwy.

- **Trzy główne warstwy:**

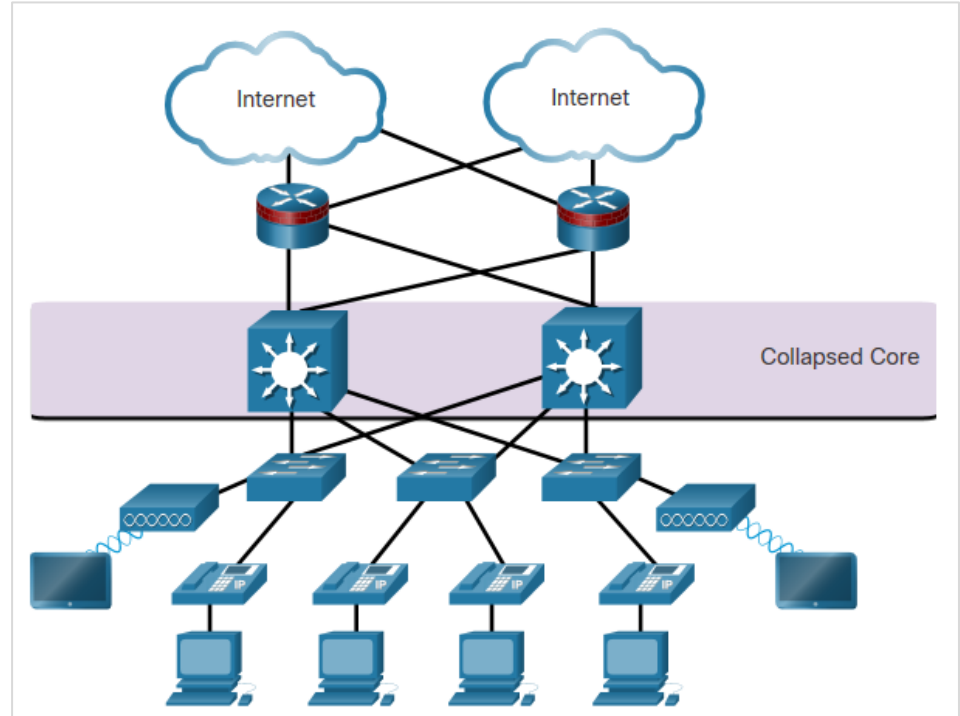
- **Dostęp (Access):** Zapewnia użytkownikom i urządzeniom końcowym bezpośredni dostęp do sieci.
- **Dystrybucja (Distribution):** Agreguje ruch z warstwy dostępu i zapewnia łączność z usługami.
- **Rdzeń (Core):** Zapewnia szybką komunikację między warstwami dystrybucji w dużych sieciach.



Hierarchical Design Model

Architektura zwiniętego rdzenia (Collapsed Core)

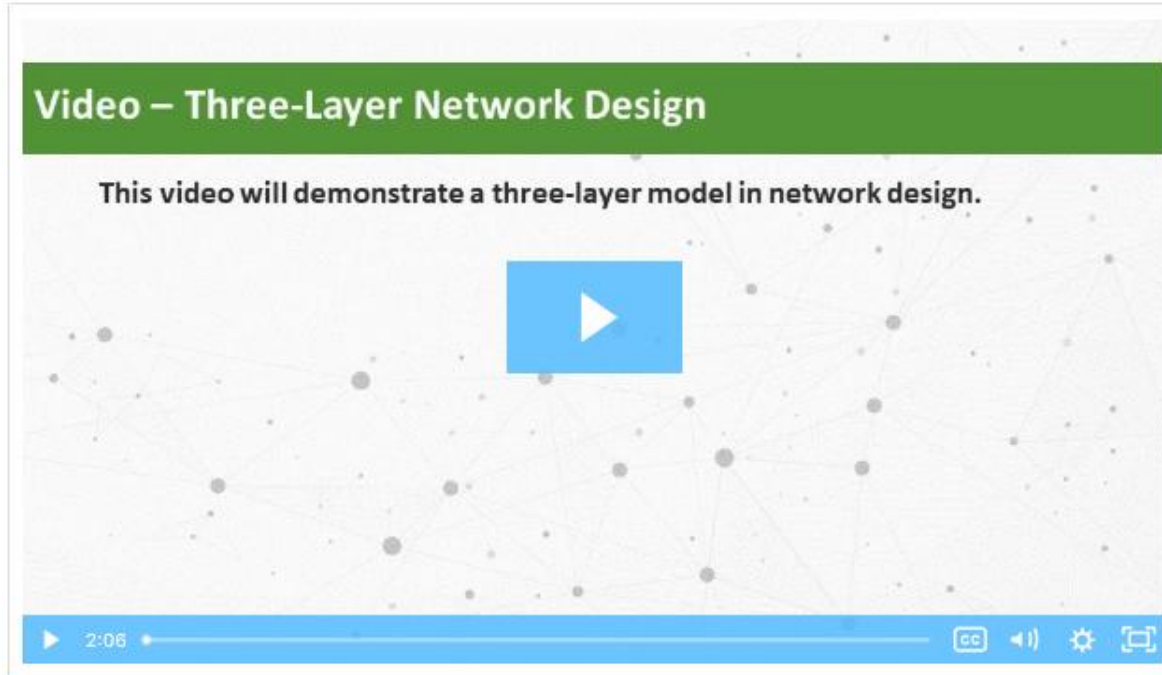
- **Alternatywa dla mniejszych sieci:**
 - **Model dwuwarstwowy:** Często wdrażany w mniejszych środowiskach korporacyjnych.
 - **Integracja:** Warstwa rdzenia i warstwa dystrybucji zostają połączone w jedną wspólną warstwę.
 - **Zalety:** Redukcja kosztów wdrożenia oraz zmniejszenie złożoności sprzętowej.



Collapsed Core

Video - Three-Layer Network Design

Play the video to view a demonstration of the three-layer network design model.



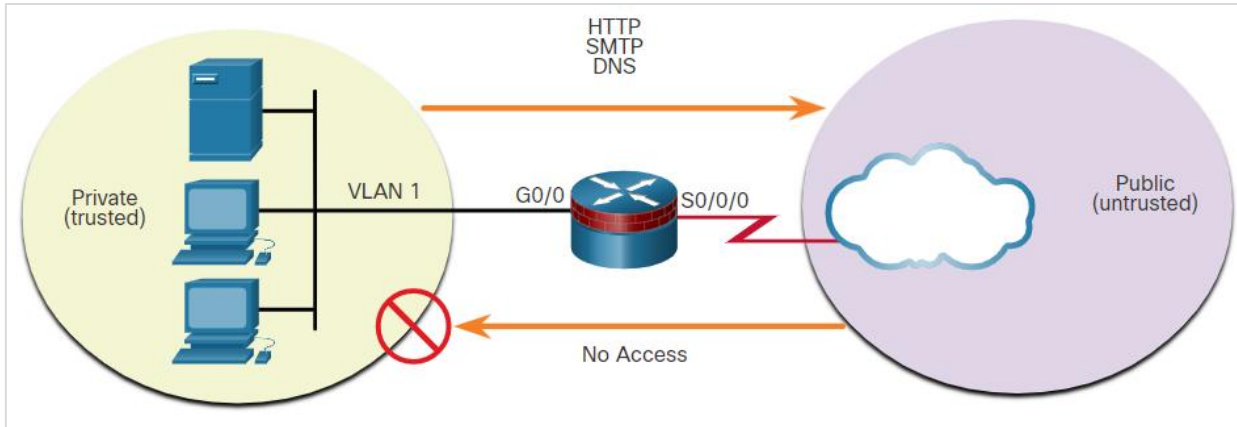
Powszechne architektury bezpieczeństwa

■ Projektowanie zapór sieciowych:

- Polega głównie na konfiguracji interfejsów urządzeń, tak aby zezwalały lub odrzucały ruch sieciowy w oparciu o adres źródłowy, docelowy i typ ruchu.

■ Trzy główne modele projektowe zapór:

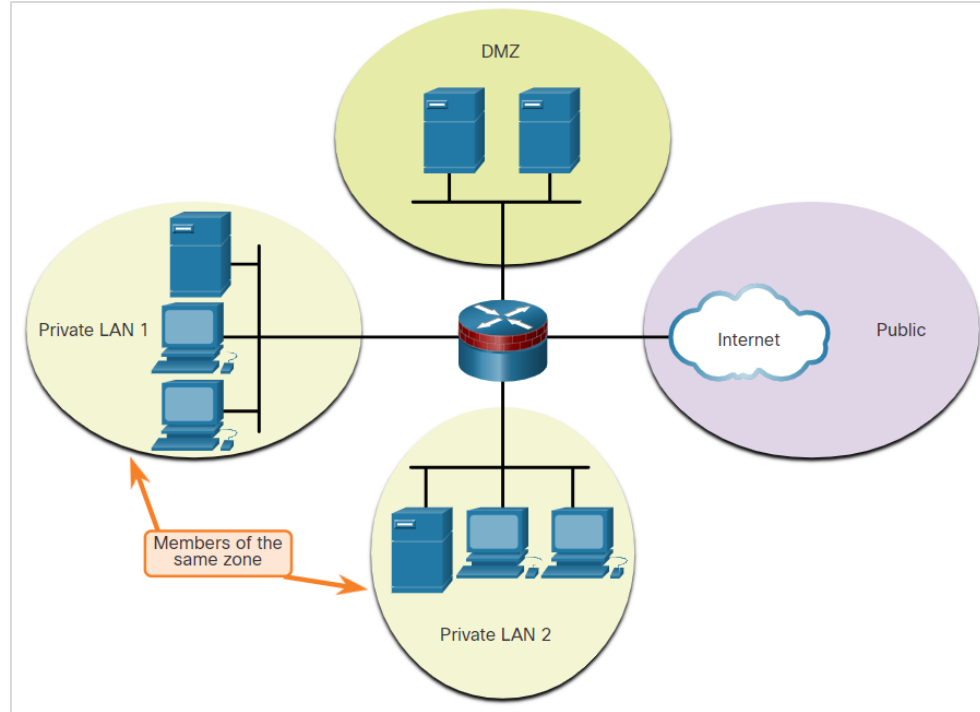
- **Sieć publiczna i prywatna (Public and Private):** Sieć publiczna (zewnętrzna) jest traktowana jako niezaufana, podczas gdy sieć prywatna (wewnętrzna) jest zaufana.



-
- The diagram illustrates a network topology with four main zones: Private (inside), DMZ, Internet, and Public (outside). A central router connects these zones. Traffic flow is indicated by colored arrows: green for 'Selectively permitted', orange for 'Blocked', and black for 'Inspected and permitted with little or no restriction'. Red 'X' marks indicate blocked traffic paths.
- Legend:**
- Green arrow: Selectively permitted
 - Orange arrow: Blocked
 - Black arrow: Inspected and permitted with little or no restriction
- Traffic Flow Analysis:**
- Private (inside) to DMZ:** Inspected and permitted (black arrow) with a blocked return path (orange arrow with red 'X').
 - DMZ to Internet:** Selectively permitted (green double arrow).
 - Internet to Public (outside):** Selectively permitted (green double arrow).
 - Public (outside) to Internet:** Inspected and permitted (black arrow) with a blocked return path (orange arrow with red 'X').

Powszechne architektury bezpieczeństwa

- **Zapory oparte na strefach (ZPF - Zone-based Policy Firewalls):**
 - ZPF wykorzystują koncepcję stref, aby zapewnić dodatkową elastyczność konfiguracji
 - **Czym jest strefa?** To grupa jednego lub większej liczby interfejsów o podobnych funkcjach lub cechach.
 - Strefy pomagają administratorom precyzyjnie określić, w którym miejscu powinna zostać zastosowana dana reguła lub polityka bezpieczeństwa Cisco IOS.



3.2 Urządzenia ochrony sieci

Urządzenia ochrony sieci

Video - Security Devices

This video will cover the following:

- Workgroup switches provide port security, dynamic ARP inspection (DAI), and DHCP Snooping
- Multilayer switches provide Layer 3 and Layer 4 firewalls
- Wireless access points provide WPA2 authentication
- Web, Email, and SSL proxy firewalls inspect traffic
- Intrusion detection systems (IDS) detect attacks
- An ASA provides a Layer 7 firewall and inline intrusion prevention system (IPS)
- Cisco Talos provides global threat intelligence

2:19

CC

⏮

⚙

🖥

Security Devices

Firewall

Czym jest firewall?

To system (lub grupa odpowiednich systemów), który wymusza politykę kontroli dostępu między sieciami.

Kluczowe cechy firewalli :

- **Odporność na ataki sieciowe:** Sam firewall musi być zabezpieczony przed próbami włamania.
- **Jedyny punkt tranzytowy:** Cały ruch sieciowy (między siecią wewnętrzną a zewnętrzną) musi przechodzić przez firewall – jest on „wąskim gardłem” kontrolnym.
- **Wymuszanie polityki kontroli dostępu:** Urządzenie aktywnie realizuje zdefiniowane zasady przepuszczania lub blokowania ruchu

Allow traffic from any external address to the web server.

Allow traffic to FTP server.

Allow traffic to SMTP server.

Allow traffic to internal IMAP server.

Deny all inbound traffic with network addresses matching internal-registered IP addresses.

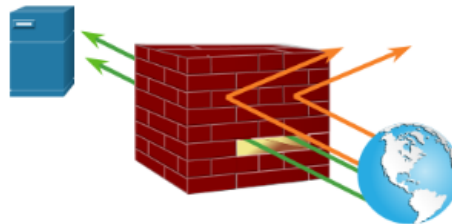
Deny all inbound traffic to server from external addresses.

Deny all inbound ICMP echo request traffic.

Deny all inbound MS Active Directory queries.

Deny all inbound traffic to MS SQL server queries.

Deny all MS Domain Local Broadcasts.



Security Devices

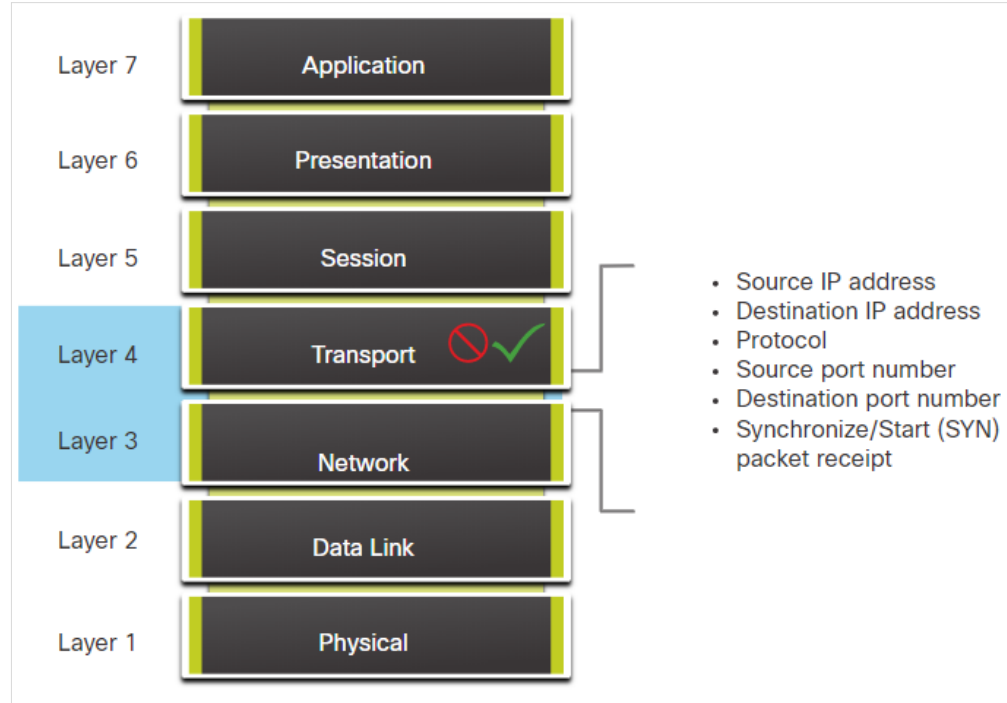
Firewall

Zalety	Ograniczenia
Ochrona zasobów: Zapobiegają wystawieniu wrażliwych hostów, aplikacji i danych na dostęp niezauważonych użytkowników.	Błędy konfiguracji: Źle ustawiona zaporę może stać się "pojedynczym punktem awarii" (Single Point of Failure) dla całej sieci.
Weryfikacja i oczyszczanie protokołów (Sanitize) Blokuje próby wykorzystania błędów (luk) w protokołach sieciowych.	Problemy z aplikacjami: Dane z wielu aplikacji nie mogą być przesyłane przez niektóre typy zapór.
Blokowanie złośliwych danych: Skutecznie odcinają szkodliwe dane płynące od serwerów lub klientów.	Próby obejścia: Użytkownicy mogą szukać sposobów na ominięcie zapory (np. aby dotrzeć do zablokowanych treści), co naraża sieć na ataki.
Uproszczenie zarządzania: Redukują złożoność zarządzania bezpieczeństwem poprzez centralizację kontroli.	Spadek wydajności: Proces filtrowania może powodować spowolnienie działania sieci.
	Ukryty ruch: Nieautoryzowany ruch może zostać przesłany w formie tunelowanej lub ukryty jako legalna komunikacja.

Typy zapór sieciowych

Bezstanowe filtrowanie pakietów (Stateless Firewall):

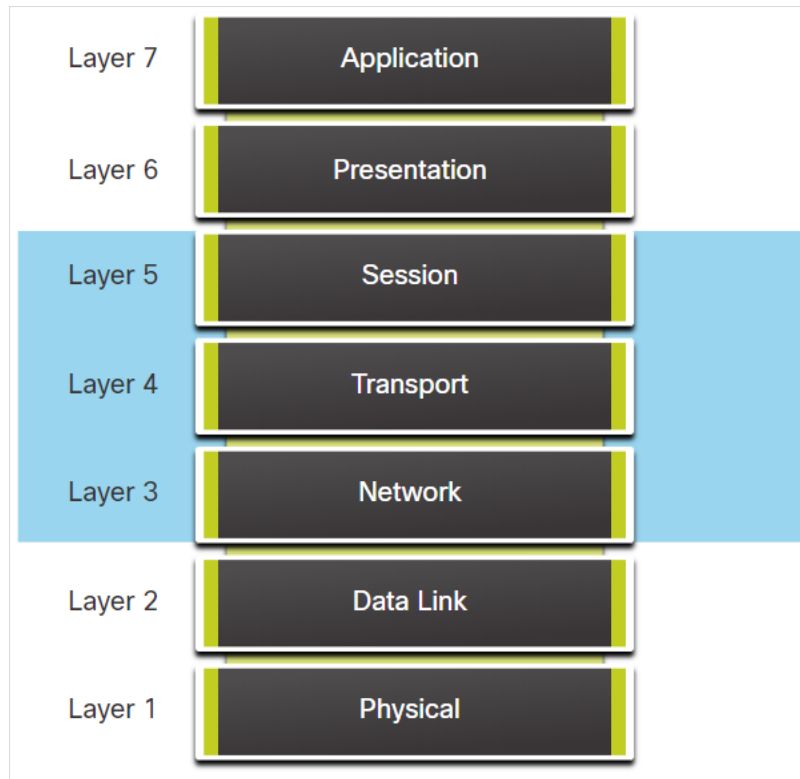
- Zazwyczaj stanowi część firewalla wbudowanego w router.
- Wykorzystuje informacje z warstwy 3 (Sieciowej) i warstwy 4 (Transportowej).
- Charakterystyka: Każda paczka danych jest oceniana osobno, bez kontekstu poprzednich pakietów.
- Stosuje proste tabele reguł (polityk) do filtrowania ruchu.



Typy zapór sieciowych

Zapory stanowe (Stateful Firewalls):

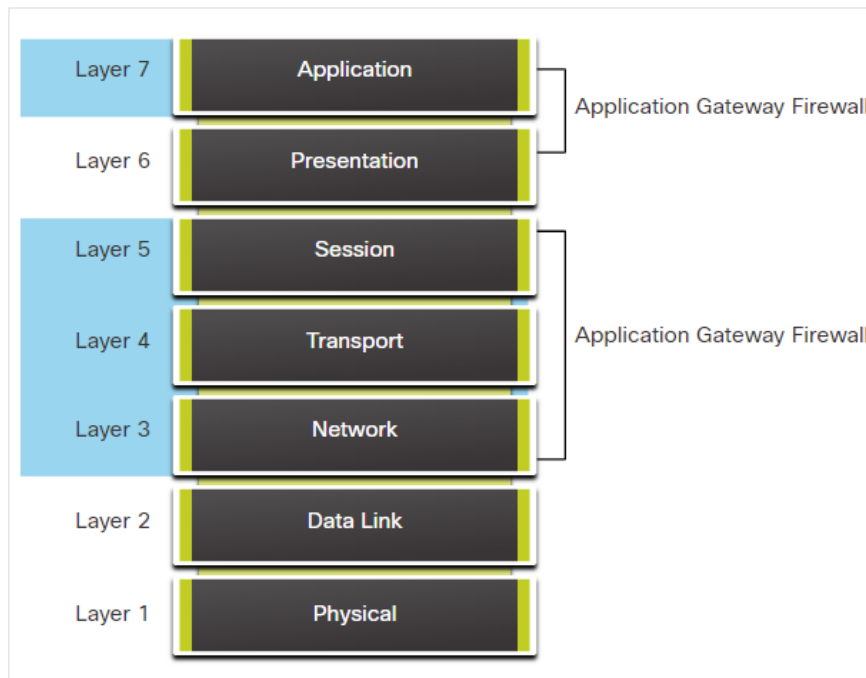
- Najbardziej powszechna i wszechstronna technologia.
- Zapewniają stanowe filtrowanie pakietów – śledzą stan aktywnych połączeń sieciowych.
- Wykorzystują tabelę stanów (state table), w której przechowywane są informacje o sesjach.
- Ruch powrotny jest automatycznie przepuszczany, jeśli należy do zatwierdzonej sesji.



Typy zapór sieciowych

Firewall typu brama aplikacji / proxy (Application Gateway Firewall):

- Filtruje informacje na poziomach 3, 4, 5 oraz 7 modelu OSI.
- Większość procesów kontroli i filtrowania odbywa się w warstwie oprogramowania.
- Działa jako pośrednik (proxy), całkowicie oddzielając klienta od serwera.



Security Devices

Typy zapór sieciowych

Cecha	Stateless (Filtr pakietów)	Stateful (Stanowy)	Application Gateway (Proxy)
Warstwa OSI	Warstwa 3 i 4 (IP, Porty).	Warstwy 3, 4 oraz częściowo 5.	Głównie warstwa 7 (Aplikacji).
Metoda działania	Sprawdza każdy pakiet z osobna na podstawie list ACL.	Śledzi stan połączeń w tablicy stanów (State Table).	Pośredniczy w połączeniu; całkowicie rozumie sesję klient-serwer.
Analiza sesji	Brak. Nie wie, czy pakiet jest odpowiedzią na zapytanie.	Pełna. Rozpoznaje pakiety powrotne i powiązane.	Głęboka. Rozumie konkretne komendy protokołu (np. HTTP GET).
Wydajność	Bardzo wysoka (minimalne opóźnienia).	Wysoka (zoptymalizowana sprzętowo).	Niska (wymaga dużej mocy do deszyfrowania i analizy).
Bezpieczeństwo	Niskie (łatwe do oszukania np. przez IP Spoofing).	Średnie/Wysokie (standard rynkowy, np. Cisco ASA).	Bardzo wysokie (pełna izolacja sieci wewnętrznej).
Złożoność	Prosta konfiguracja list ACL.	Średnia; wymaga definiowania stref i inspekcji.	Wysoka; wymaga dedykowanych modułów dla każdej aplikacji.

Typy zapór sieciowych

Zapory nowej generacji (Next-Generation Firewalls - NGFW):



To nowoczesne systemy, które wykraczają poza zwykłe sprawdzanie portów. Ich kluczowe cechy to:

- **Zintegrowany system IPS:** Posiadają wbudowane mechanizmy, które w czasie rzeczywistym blokują próby włamań i znane exploity.
- **Świadomość aplikacji:** Potrafią rozpoznać konkretny program (np. odróżnić czat na Facebooku od przesyłania plików), co pozwala na blokowanie konkretnych funkcji aplikacji, a nie całego ruchu WWW.
- **Inteligentne ścieżki aktualizacji:** Pozwalają na bieżąco dołączać zewnętrzne źródła danych o zagrożeniach (tzw. *threat intelligence feeds*), dzięki czemu zapora "wie" o nowym wirusie natychmiast po jego odkryciu na świecie.
- **Ewolucja ochrony:** Wykorzystują zaawansowane metody, takie jak analiza w chmurze czy sandboxing (uruchamianie podejrzanych plików w bezpiecznym, odizolowanym środowisku), aby wyłapać zupełnie nowe, nieznane wcześniej ataki.

Typy zapór sieciowych

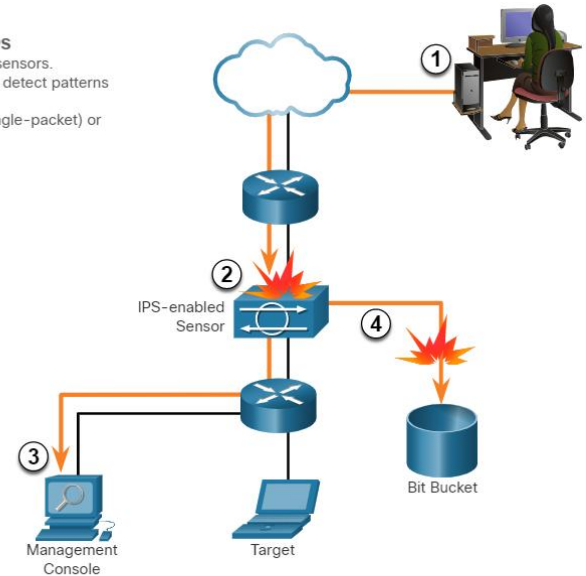
- Inne metody wdrażania zapór sieciowych:
 - **Zapora hosta (serwerowa i osobista) / Host-based firewall:**
 - Komputer PC lub serwer z uruchomionym oprogramowaniem typu firewall bezpośrednio na systemie operacyjnym.
 - **Zapora transparentna / Transparent firewall:**
 - Filtruje ruch IP pomiędzy parą interfejsów połączonych mostkowo (działa w warstwie 2, jest niewidoczna dla przesyłanych pakietów IP).
 - **Zapora hybrydowa / Hybrid firewall:**
 - Połączenie różnych typów zapór (np. połączenie filtrowania stanowego z funkcjami proxy lub zapory hosta).

Urządzenia wykrywania i zapobiegania włamaniom (IDS i IPS)

- Współczesne zagrożenia sieciowe (takie jak robaki, ataki typu zero-day czy zaawansowane exploity) wymagają rozwiązań, które potrafią analizować zawartość pakietów, a nie tylko ich nagłówki.
- Główne cele stosowania tych urządzeń:
 - Monitorowanie w czasie rzeczywistym: Ciągła analiza ruchu sieciowego pod kątem podejrzanych wzorców.
 - Wykrywanie anomalii: Rozpoznawanie działań, które odbiegają od normalnego zachowania sieci lub użytkowników.
 - Głęboka inspekcja pakietów (DPI): Sprawdzanie danych wewnątrz pakietu, aby upewnić się, że nie przenosi on szkodliwego kodu.

Common Characteristics of IDS and IPS

- Both technologies are deployed as sensors.
- Both technologies use signatures to detect patterns of misuse in network traffic.
- Both can detect atomic patterns (single-packet) or composite patterns (multi-packet).



1. Malicious traffic is sent to the target host that is inside the network.
2. The traffic is routed into the network and received by an IPS-enabled sensor where it is blocked.
3. The IPS-enabled sensor sends logging information regarding the traffic to the network security management console.
4. The IPS-enabled sensor kills the traffic. (It is sent to the "Bit Bucket.")

Zalety i wady systemów IDS oraz IPS

Typ	Zalety	Wada
IDS	• Brak wpływu na sieć (brak opóźnień/latencji). • Awaria czujnika (sensor) nie wpływa na ruch w sieci. • Brak wpływu przy awarii – jeśli sensor zostanie przeciążony, ruch nadal płynie.	• Nie może samodzielnie zatrzymać pojedynczego pakietu przed dotarciem do celu. • Musi współpracować z innymi urządzeniami (np. firewallami), aby zablokować konkretne adresy IP. • Wykorzystuje techniki "best-effort" do zatrzymywania ataków (np. resetowanie połączeń TCP), co nie zawsze jest skuteczne.
IPS	• Może natychmiast zatrzymać pojedynczy pakiet i przerwać atak. • Potrafi samodzielnie odciąć złośliwy ruch bez pomocy innych urządzeń. • Może korzystać z technik normalizacji strumienia danych, aby zapobiegać atakom maskującym.	• Powoduje opóźnienia w sieci (latencję) przez analizę każdego pakietu. • Awaria lub przeciążenie czujnika wpływa na działanie całej sieci (może ją odciąć). • Wymaga bardzo precyzyjnego dostrojenia, aby uniknąć blokowania poprawnego ruchu (False Positives).

Rodzaje IPS

▪ HIPS (Host-based Intrusion Prevention System):

- **Zadanie:** Oprogramowanie zainstalowane na konkretnym hoście (np. komputerze osobistym lub serwerze) do monitorowania i blokowania podejrzanych działań.
- **Zalety:**
 - Może monitorować zdarzenia systemowe i procesy, które nie są widoczne w ruchu sieciowym.
 - Może analizować ruch zaszyfrowany, ponieważ ma do niego dostęp po deszyfracji przez system operacyjny.
- **Wada:** Musi być zainstalowany na każdym urządzeniu z osobna, co utrudnia zarządzanie w dużej skali.

Rodzaje IPS

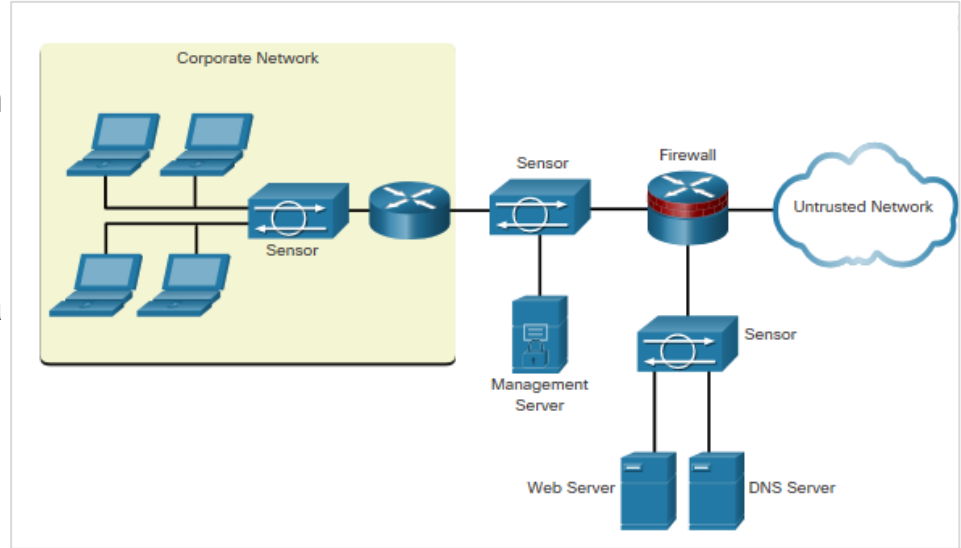
▪ NIPS (Network-based Intrusion Prevention System):

- **Zadanie:** Dedykowane urządzenie sieciowe zainstalowane w strategicznych punktach sieci (np. na styku z Internetem).
- **Zalety:**
 - Monitoruje cały ruch przepływający przez dany segment sieci, chroniąc wiele urządzeń jednocześnie.
 - Jest niewidoczne dla atakujących i nie zużywa zasobów procesora chronionych hostów.
- **Wada:** Nie widzi ruchu zaszyfrowanego (chyba że posiada funkcję deszyfracji SSL) i nie monitoruje zdarzeń lokalnych na komputerach.

Rodzaje IPS

• Network-based IPS

- Sposób wdrożenia: Systemy te są implementowane przy użyciu dedykowanych lub niededykowanych urządzeń IPS.
- Architektura bezpieczeństwa: Rozwiązania typu HIPS/HIDS (oparte na hoście) są integrowane z systemami NIPS (opartymi na sieci), aby zapewnić spójną i solidną architekturę bezpieczeństwa całej organizacji.
- Działanie sensorów: Czujniki wykrywają złośliwą oraz nieautoryzowaną aktywność w czasie rzeczywistym i mogą podjąć natychmiastowe działanie, gdy jest to wymagane.



Wyspecjalizowane urządzenia zabezpieczające

Cisco Advanced Malware Protection (AMP)	Cisco Web Security Appliance (WSA)	Cisco Email Security Appliance (ESA)
Ochrona przed zaawansowanym malware	Bezpieczeństwo WWW (Proxy)	Bezpieczeństwo poczty (SMTP)
Ciągła analiza plików, analiza retrospektywna (śledzenie pliku po czasie), wykrywanie zagrożeń typu APT (Advanced Persistent Threats) oraz ochrona typu "Sandboxing".	Filtrowanie adresów URL, skanowanie malware w czasie rzeczywistym, kontrola aplikacji (np. blokowanie konkretnych funkcji w social media) oraz raportowanie aktywności.	Blokowanie spamu, ochrona przed phishingiem, szyfrowanie wiadomości, DLP (Data Loss Prevention) oraz integracja z bazą Cisco Talos.

3.3 Usługi bezpieczeństwa

Security Services

Usługi bezpieczeństwa

Video - Security Services

This video will cover the following:

- Intrusion Detection Systems (IDS)
- Switched Port Analyzer (SPAN)
- Syslog
- Authentication, Authorization and Accounting (AAA)
- NetFlow
- SNMP

7:23

CC

Speaker icon

Settings icon

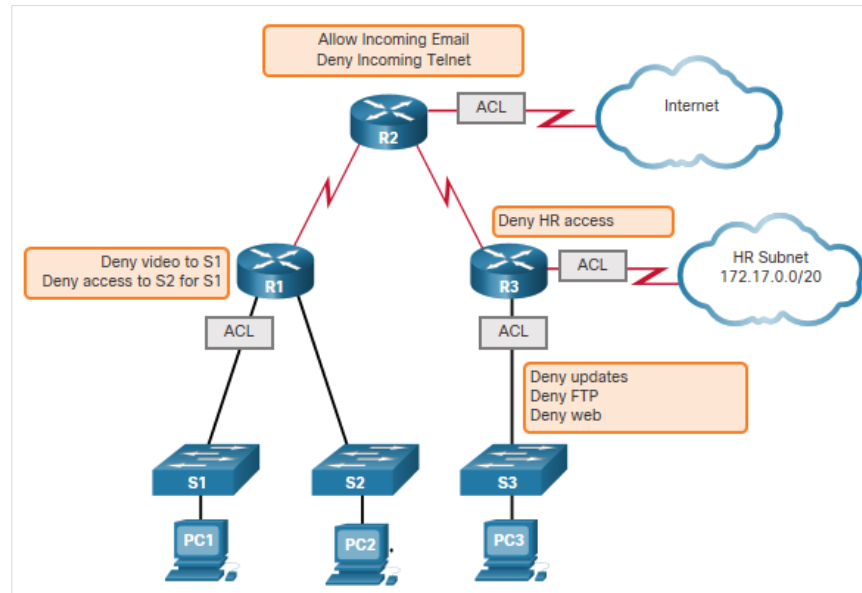
Fullscreen icon

Kontrola ruchu z ACL

- Lista kontroli dostępu (ACL) to seria komend, które określają, czy urządzenie ma przysyłać dalej, czy odrzucać pakiety na podstawie informacji znajdujących się w nagłówku pakietu..

Po skonfigurowaniu, listy ACL wykonują następujące zadania:

- **Ograniczanie ruchu sieciowego** w celu zwiększenia wydajności sieci.
- **Zapewnianie kontroli przepływu ruchu** (traffic flow control).
- **Zapewnianie podstawowego poziomu bezpieczeństwa** w dostępie do sieci.
- **Filtrowanie ruchu** na podstawie jego typu.
- **Weryfikacja hostów (Screening)** w celu zezwolenia lub odmowy dostępu do usług sieciowych.



Sample Topology with ACLs applied to routers R1, R2, and R3.

Porównanie implementacji ACL (różni producenci)

- zablokuj ruch z IP 192.168.1.10

System	Składnia (Komenda)	Wyjaśnienie logiki
Cisco (IOS)	<code>access-list 1 deny host 192.168.1.10</code>	Słowo <code>host</code> zastępuje maskę 0.0.0.0.
Linux (iptables)	<code>iptables -A INPUT -s 192.168.1.10 -j DROP</code>	Flaga <code>-s</code> (source), akcja <code>DROP</code> .
Juniper (Junos)	<code>term BLOCK-IP { from { source-address 192.168.1.10/32; } then discard; }</code>	Struktura blokowa, maska /32 dla pojedynczego IP.
MikroTik	<code>/ip firewall filter add chain=input src-address=192.168.1.10 action=drop</code>	Podobne do Linuxa, ale w ścieżce poleceń RouterOS.
Windows FW	<code>netsh advfirewall firewall add rule name="B-10" dir=in action=block remoteip=192.168.1.10</code>	Bardzo opisowe, wymaga nazw

Porównanie implementacji ACL (różni producenci)

- zablokuj ruch z sieci 192.168.1.10/24

System	Składnia (Komenda)	Wyjaśnienie logiki
Cisco (IOS)	<code>access-list 1 deny 192.168.1.0 0.0.0.255</code>	Wildcard: 0.0.0.255 (odwrócona maska).
Linux (iptables)	<code>iptables -A INPUT -s 192.168.1.0/24 -j DROP</code>	CIDR: /24
Juniper (Junos)	<code>term BLOCK-NET { from { source-address 192.168.1.0/24; } then discard; }</code>	CIDR: /24 wewnątrz struktury term.
MikroTik	<code>/ip firewall filter add chain=input src-address=192.168.1.0/24 action=drop</code>	CIDR: /24
Windows FW	<code>netsh advfirewall firewall add rule name="B-Net" dir=in action=block remoteip=192.168.1.0/24</code>	CIDR: /24

Porównanie implementacji ACL (różni producenci)

- zablokuj ruch ICMP

System	Składnia (Komenda)	Wyjaśnienie logiki
Cisco (IOS)	<code>access-list 101 deny icmp any any</code>	Musimy użyć Extended ACL (nr 101), bo Standardowa ACL nie rozumie protokołów (tylko IP).
Linux (iptables)	<code>iptables -A INPUT -p icmp -j DROP</code>	Flaga <code>-p</code> (protocol) wskazuje <code>icmp</code> .
Juniper (Junos)	<code>term BLOCK-PING { from { protocol icmp; } then discard; }</code>	Protokół jest określony w sekcji <code>from</code> .
MikroTik	<code>/ip firewall filter add chain=input protocol=icmp action=drop</code>	Bardzo podobne do Linuxa, wskazuje protokół i akcję.
Windows FW	<code>netsh advfirewall firewall add rule name="No-Ping" dir=in action=block protocol=icmpv4</code>	Trzeba sprecyzować, czy chodzi o <code>icmpv4</code> czy <code>icmpv6</code> .

Porównanie implementacji ACL (różni producenci)

- zablokuj ruch przychodzący ICMP

System	Składnia (Komenda)	Wyjaśnienie logiki
Cisco (IOS)	<pre>access-list 101 deny icmp any any echo access-list 101 permit ip any any</pre>	Blokuje tylko typ <code>echo</code> (zapytanie). Pozostały ruch ICMP (np. odpowiedzi dla nas) przejdzie przez <code>permit ip</code> .
Linux (iptables)	<pre>iptables -A INPUT -p icmp --icmp-type echo-request -j DROP</pre>	Precyzyjnie wskazuje typ <code>echo-request</code> . Odpowiedzi (<code>echo-reply</code>) nie pasują do tej reguły i przechodzą.
Juniper (Junos)	<pre>term NO-PING { from { icmp-type echo-request; } then discard; }</pre>	Juniper pozwala na wskazanie konkretnego typu komunikatu wewnątrz filtra.
MikroTik	<pre>/ip firewall filter add chain=input protocol=icmp icmp-options=8:0 action=drop</pre>	<code>8:0</code> to kod dla <code>echo-request</code> . Bardzo techniczne podejście oparte na kodach.
Windows FW	<pre>netsh advfirewall firewall add rule name="Block- Ping" dir=in action=block protocol=icmpv4:8,0</pre>	Cyfry <code>8,0</code> po dwukropku oznaczają typ 8 (request), kod 0.

Porównanie implementacji ACL (różni producenci)

- zablokuj ruch wymuszający z www

System	Składnia (Komenda)	Wyjaśnienie logiki
Cisco (IOS)	<pre>access-list 101 permit tcp any any eq 80 established access-list 101 permit tcp any any eq 443 established</pre>	eq 80/443 mówi: "tylko ten port". established mówi: "tylko jeśli to odpowiedź na nasze zapytanie".
Linux (iptables)	<pre>iptables -A INPUT -p tcp -m multiport --sports 80,443 -m state --state ESTABLISHED -j ACCEPT</pre>	-m multiport pozwala wymienić oba porty naraz. --sports (source ports) sprawdza, czy odpowiedź przychodzi z portu 80/443 serwera.
Juniper (Junos)	<pre>from { protocol tcp; source-port [80 443]; tcp- established; } then accept;</pre>	W Juniperze porty źródłowe serwera (source-port) wpisujemy w liście wewnątrz nawiasów.
MikroTik	<pre>/ip firewall filter add chain=input protocol=tcp src-port=80,443 connection-state=established action=accept</pre>	src-port=80,443 precyzuje, że wpuszczamy tylko pakiety wracające z serwerów WWW.
Windows FW	<i>(Reguła automatyczna)</i>	Jeśli twoja przeglądarka "wyjdzie" na port 80, firewall sam "wpuści" odpowiedź tylko z tego konkretnego połączenia.

Security Services

SNMP

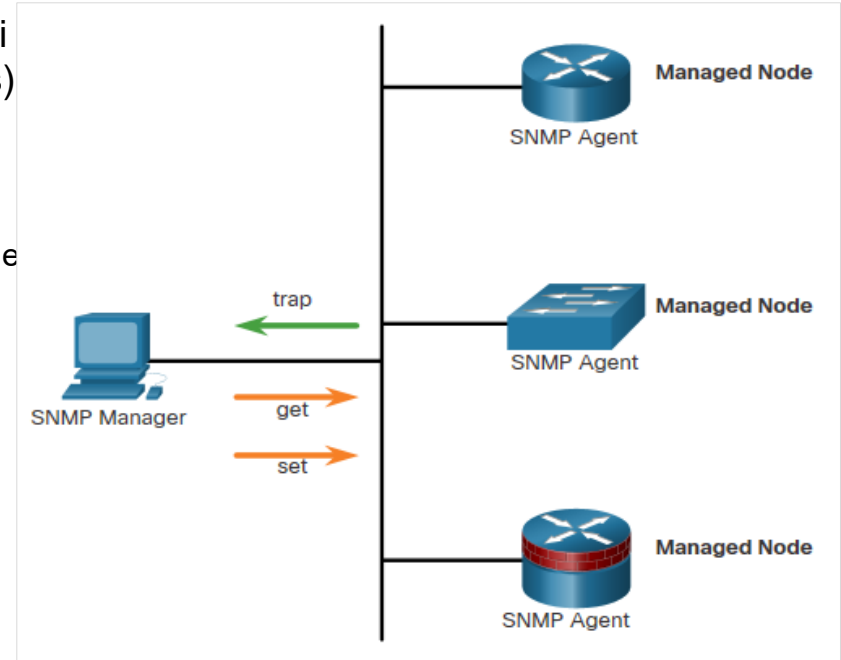
Protokół Simple Network Management Protocol (SNMP) to protokół warstwy aplikacji, który definiuje format wiadomości służących do komunikacji między **menedżerami** (managers) a **agentami** (agents).

SNMP pozwala administratorom sieci na wykonywanie następujących zadań:

- **Zarządzanie urządzeniami końcowymi**, takimi jak serwery, stacje robocze, routery, przełączniki oraz urządzenia zabezpieczające w sieci IP.
- **Monitorowanie i zarządzanie wydajnością sieci.**
- **Wykrywanie i rozwiązywanie problemów sieciowych.**
- **Planowanie rozwoju sieci.**

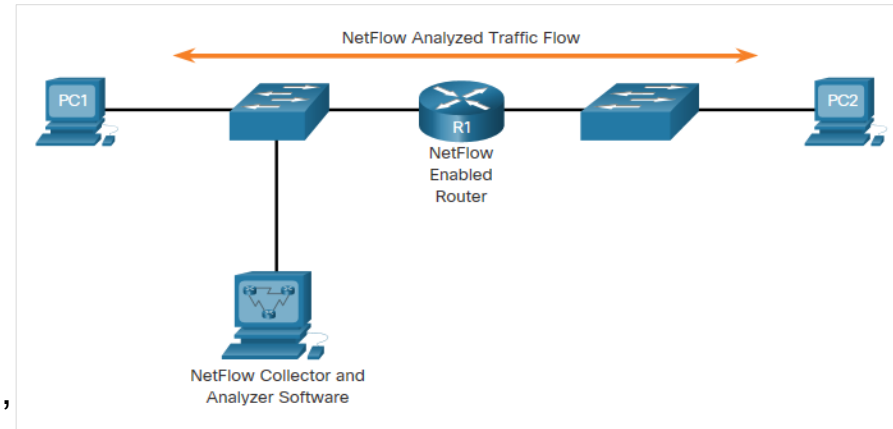
System SNMP składa się z dwóch elementów:

- **Menedżer SNMP (SNMP Manager):** Urządzenie (zazwyczaj serwer), na którym działa oprogramowanie do zarządzania siecią (NMS – Network Management System).
- **Agenci SNMP (SNMP Agents):** Węzły sieciowe (routery, switchy), które są monitorowane i którymi się zarządza.



NetFlow

- NetFlow to technologia Cisco IOS, która dostarcza statystyki dotyczące pakietów przepływających przez router Cisco lub przełącznik wielowarstwowy (multilayer switch).
- **NetFlow dostarcza danych umożliwiających:**
 - **Monitorowanie sieci i bezpieczeństwa.**
 - **Planowanie sieci.**
 - **Analizę ruchu**, w tym identyfikację "wąskich gardeł" (bottlenecks) w sieci.
 - **Rozliczanie IP (Accounting)** do celów bilingowych (rozliczanie kosztów).
- **Działanie:**
 - NetFlow potrafi monitorować połączenia aplikacji, śledząc liczbę bajtów i pakietów dla każdego indywidualnego przepływu (flow) danej aplikacji.
 - Następnie **przesyła (push)** te statystyki na zewnętrzny serwer zwany **NetFlow Collector**.



PC 1 connects to PC 2 using HTTPS

Port Mirroring (Monitorowanie Portów)

- Port mirroring to funkcja, która pozwala przełącznikowi (switch) na tworzenie kopii ruchu przechodzącego przez dany port (lub całą sieć VLAN), a następnie przesyłanie go do dedykowanego portu, do którego podłączony jest monitor sieciowy.
- **Najważniejsze cechy i zastosowania:**
 - **Kopiowanie ruchu:** Oryginalne dane płyną do celu bez zakłóceń, a ich kopia trafia do narzędzia analitycznego.
 - **Analiza ruchu:** Pozwala na użycie snifferów (np. Wireshark) do podglądania pakietów "na żywo".
 - **Systemy IDS/IPS:** Umożliwia systemom wykrywania włamań analizę danych w poszukiwaniu zagrożeń bez spowalniania głównej sieci.
 - **Rozwiązywanie problemów (Troubleshooting):** Pomaga zdiagnozować błędy w komunikacji między urządzeniami.

Port Mirroring (Monitorowanie Portów)

- **Source (Ingress/Egress) Port:**

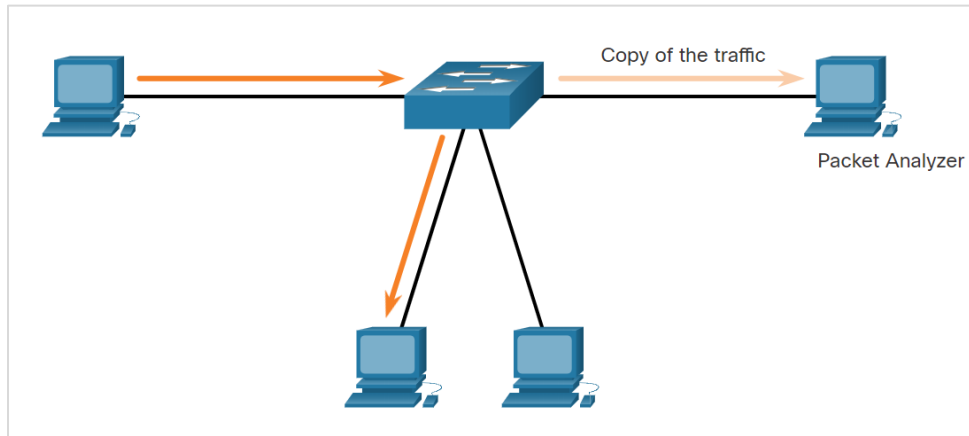
Port, który "podsluchujemy".

Możemy kopiować ruch wchodzący, wychodzący lub oba naraz.

- **Destination (Monitoring) Port:**

Port, do którego podpinasz laptopa z Wiresharkiem lub serwer IDS.

Ważne: Ten port zazwyczaj przestaje działać jako normalny port sieciowy – służy tylko do odbierania kopii danych.



Traffic Sniffing Using a Switch

Port Mirroring (Monitorowanie Portów)

- **SPAN (Switched Port Analyzer):** Jest realizowany programowo przez procesor switcha. Przy ogromnym obciążeniu sieci switch może zacząć "gubić" pakiety w kopii, priorytetyzując ruch oryginalny.
- **Network TAP (Test Access Point):** To osobne urządzenie fizyczne wpinane w kabel. Jest niezależne od switcha i gwarantuje 100% dokładności kopii, nawet przy maksymalnym obciążeniu.

Serwery Syslog

Najpopularniejszą metodą dostępu do komunikatów systemowych jest użycie protokołu **Syslog**. Protokół ten pozwala urządzeniom sieciowym na przesyłanie komunikatów o zdarzeniach przez sieć do dedykowanych **serwerów syslog**.

Syslog pełni trzy podstawowe funkcje:

- **Gromadzenie informacji logowania:** Umożliwia zbieranie danych w celu monitorowania i rozwiązywania problemów (troubleshooting).
- **Filtrowanie typów informacji:** Możliwość wyboru, jakie konkretnie zdarzenia mają być przechwytywane (np. tylko krytyczne błędy).
- **Określanie celu:** Możliwość wskazania, gdzie mają być wysyłane przechwycone wiadomości (np. do serwera, do pamięci RAM urządzenia lub na konsolę).

Poziomy powagi (Severity levels)

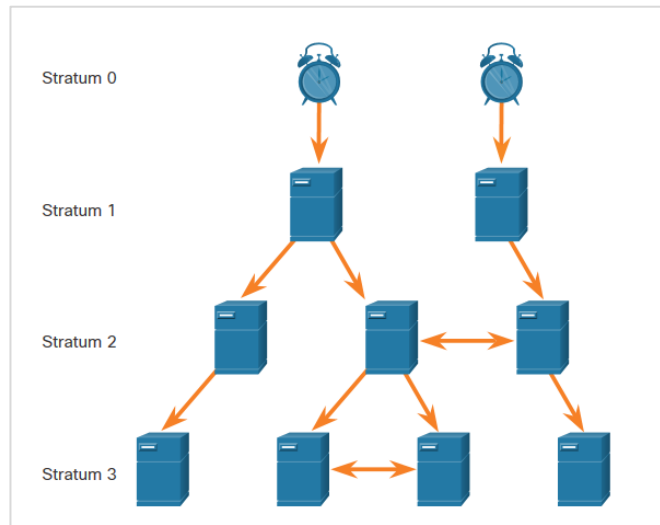
Poziom	Nazwa (Severity)	Opis zdarzenia
0	Emergency	System nie nadaje się do użytku (panika).
1	Alert	Wymagana natychmiastowa reakcja.
2	Critical	Sytuacja krytyczna (np. błąd sprzętowy).
3	Error	Błędy, które nie zatrzymują systemu, ale są problemem.
4	Warning	Ostrzeżenia o potencjalnych problemach.
5	Notification	Normalne, ale istotne zdarzenia (np. interfejs wstał).
6	Informational	Typowe wiadomości informacyjne.
7	Debugging	Bardzo szczegółowe dane techniczne.

Ważna uwaga techniczna: Domyślnie Syslog używa protokołu **UDP** na porcie **514**. Ponieważ UDP nie gwarantuje dostarczenia pakietu, w bardzo krytycznych środowiskach czasem stosuje się nowsze implementacje oparte na TCP (rsyslog, syslog-ng, RFC 5424, BEEP).

NTP (Network Time Protocol)

Synchronizacja czasu na wszystkich urządzeniach w sieci jest kluczowa. Ustawienia daty i godziny na urządzeniu sieciowym można skonfigurować na dwa sposoby:

- **Konfiguracja ręczna:** Ręczne wpisanie daty i godziny (niepolecane w dużych sieciach).
 - **Konfiguracja NTP:** Automatyczna synchronizacja z serwerem czasu.
- **Hierarchia stratum (Poziomy dokładności)**
- Sieci NTP używają hierarchicznego systemu źródeł czasu, gdzie każdy poziom nazywany jest **stratum**. Serwery NTP są ułożone w warstwy:
- **Stratum 0:** Autorytatywne źródła czasu. Są to urządzenia o najwyższej precyzji, takie jak zegary atomowe, zegary GPS czy cezowe. Nie są one bezpośrednio dostępne w sieci IP.
 - **Stratum 1:** Serwery bezpośrednio podłączone do źródeł Stratum 0. Pełnią rolę głównych serwerów czasu w sieci.
 - **Stratum 2 i niższe:** Urządzenia (np. routery, serwery, komputery), które synchronizują swój czas, pobierając pakiety NTP z serwerów Stratum 1. Stratum 3 pobiera czas ze Stratum 2 i tak dalej.



NTP Stratum Levels

NTP (Network Time Protocol)

Dlaczego to jest ważne?

- **Spójność Logów (Syslog):** Gdy analizujesz awarię, musisz mieć pewność, że zdarzenia na switchu A i routerze B wydarzyły się w tej samej sekundzie.
- **Certyfikaty bezpieczeństwa:** Wiele protokołów (np. HTTPS/SSL) przestaje działać, jeśli zegar urządzenia różni się od rzeczywistego o więcej niż kilka minut (certyfikat może zostać uznany za nieważny).
- **Uwierzytelnianie:** Systemy takie jak Kerberos czy niektóre VPN-y wymagają zsynchronizowanego czasu do poprawnego działania tokenów bezpieczeństwa.

Maksymalna liczba warstw (stratum) to **15**. Jeśli urządzenie zgłasza **Stratum 16**, oznacza to, że jego czas jest "niezsynchronizowany" (unsynchronized) i nie można mu ufać.

Architektura AAA (Authentication, Authorization, Accounting)

Model AAA zapewnia trzy niezależne funkcje bezpieczeństwa, które razem tworzą kompletny system kontroli dostępu.

Funkcja	Opis	Potocznie
Authentication (Uwierzytelnianie)	• Użytkownicy i administratorzy muszą udowodnić, że są tymi, za kogo się podają. • Odbywa się to za pomocą kombinacji nazwy użytkownika i hasła, pytań kontrolnych, kart tokenowych lub innych metod. • Zapewnia scentralizowany sposób kontroli wstępu do sieci.	"Kto Ty jesteś?" (Wpisanie loginu i hasła do konsoli routera).
Authorization (Autoryzacja)	• Po uwierzytelnieniu, usługi autoryzacji określają, do jakich zasobów użytkownik ma dostęp i jakie operacje może wykonywać. • Określa uprawnienia (co wolno, a czego nie).	"Co możesz robić?" (Użytkownik 'student' może wejść na serwer XYZ tylko przez SSH).
Accounting (Rozliczanie)	• Rejestruje, co użytkownik robi: do czego uzyskuje dostęp, jak długo z tego korzysta oraz jakie zmiany wprowadził. • Służy do śledzenia wykorzystania zasobów sieciowych.	"Co zrobiłeś?" (Użytkownik 'student' był zalogowany przez 15 minut i zmienił adres IP).

Serwery AAA

- Serwer AAA to zewnętrzna usługa (oprogramowanie działające na serwerze fizycznym lub wirtualnym), która przechowuje bazę użytkowników, ich uprawnienia oraz rejestruje ich aktywność. Urządzenia sieciowe (routery, przełączniki) pełnią wtedy jedynie rolę **klientów AAA**, którzy przesyłają zapytania do tego serwera.
- **Główne zadania serwera AAA:**
 - **Centralizacja poświadczeń:** Zamiast tworzyć konto "admin" na 100 routerach, tworzysz je raz na serwerze AAA.
 - **Integracja z bazami zewnętrznymi:** Serwer AAA może być połączony z **Active Directory (LDAP)**, co pozwala pracownikom logować się do routerów tym samym hasłem, którego używają do komputera.
 - **Skalowalność:** Pozwala na natychmiastowe odebranie dostępu pracownikowi w całej sieci naraz (np. po rozwiązaniu umowy).

Serwery AAA

- Serwer AAA może komunikować się z routerem za pomocą jednego z dwóch standardów. Wybór protokołu determinuje, jak ten serwer będzie się zachowywał:
 - **1. Serwer TACACS+ (Terminal Access Controller Access-Control System Plus)**
 - Jest to serwer wyspecjalizowany w **zarządzaniu administracyjnym**.
 - Traktuje każde działanie administratora jako osobny proces.
 - Po każdym wpisaniu komendy przez admina, router pyta serwer: *"Czy on może to wpisać?"*.
 - Zapewnia pełną poufność sesji (szyfruje całą komunikację między routerem a serwerem).
 - **2. Serwer RADIUS (Remote Authentication Dial-In User Service)**
 - Jest to serwer zaprojektowany do **obsługi dostępu masowego**.
 - Sprawdza na wejściu do sieci (np. przy logowaniu do Wi-Fi lub VPN).
 - Gdy użytkownik się połączy, serwer sprawdza hasło, "otwiera drzwi" i zaczyna liczyć czas/transfer.
 - Nie ingeruje w to, co użytkownik robi po uzyskaniu dostępu (nie sprawdza poszczególnych komend).

Security Services

Serwery AAA

Cecha	TACACS+	RADIUS
Funkcjonalność	Rozdziela funkcje AAA zgodnie z architekturą AAA (osobne procesy dla A, A i A).	Łączy uwierzytelnianie i autoryzację, ale rozdziela rozliczanie (accounting).
Standard	Wspierany głównie przez Cisco (standard własnościowy).	Standard otwarty / RFC (obsługiwany przez niemal wszystkich dostawców).
Transport	TCP (bezpieczniejszy, zapewnia potwierdzenie dostarczenia).	UDP (szybszy, ale mniej niezawodny w trudnych warunkach sieciowych).
Protokół CHAP (<i>Challenge-Handshake Authentication Protocol</i>)	Dwukierunkowe "wyzwanie i odpowiedź" (bidirectional), stosowane w protokole CHAP .	Jednokierunkowe "wyzwanie i odpowiedź" z serwera RADIUS do klienta RADIUS.
Poufność	Szyfruje cały pakiet (ukrywa wszystkie dane przesyłane wewnątrz).	Szyfruje tylko hasło (reszta danych pakietu jest widoczna).
Personalizacja	Zapewnia autoryzację komend routera dla poszczególnych użytkowników lub grup.	Brak opcji autoryzacji komend routera na poziomie użytkownika lub grupy.
Rozliczanie	Ograniczone.	Rozbudowane (pozwala na bardzo szczegółowe zbieranie statystyk).

VPN Wirtualna sieć prywatna

▪ Kluczowe Mechanizmy:

- **Tunelowanie (Encapsulation):** Prywatne pakiety danych są "pakowane" wewnątrz nowych pakietów IP, co pozwala im bezpiecznie podróżować przez publiczne routery, które widzą tylko adresy zewnętrzne tunelu.
- **Poufność przez Szyfrowanie:** Dane wewnątrz tunelu są szyfrowane (np. AES), co uniemożliwia ich odczytanie w przypadku przechwycenia w Internecie.
- **Wirtualne Połączenie Logiczne:** VPN łączy dwa punkty końcowe (endpoints) tak, jakby były w tej samej sieci lokalnej, niezależnie od fizycznej odległości.

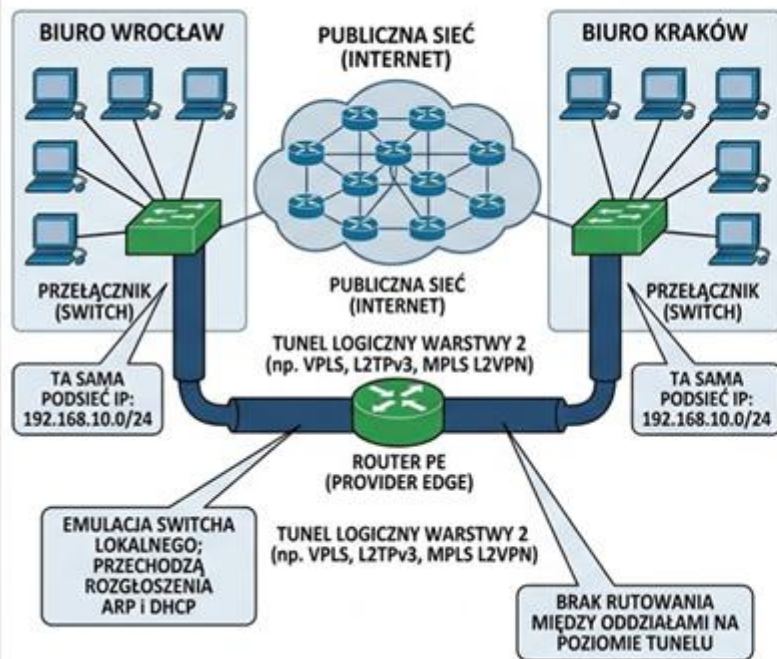
▪ Zakres działania w modelu OSI:

- **Layer 3 VPN (np. IPsec):** Najczęstszy model. Łączy całe podsieci. Urządzenia widzą się przez routery wirtualne.
- **Layer 2 VPN (np. MPLS, L2TP):** Pozwala na przeniesienie całej warstwy łącza danych. Urządzenia w różnych lokalizacjach zachowują się, jakby były wpięte do tego samego switcha (ta sama podsieć IP).

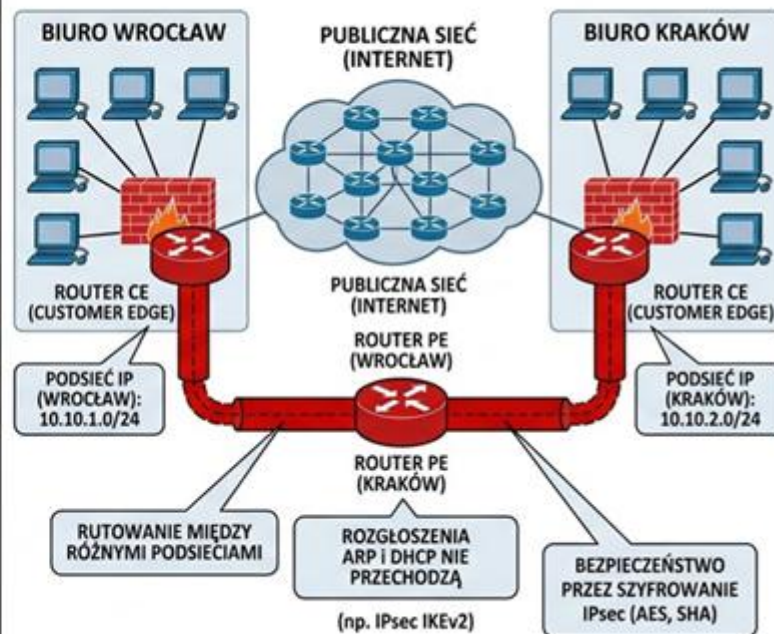
Virtual Private Network

VPN Wirtualna sieć prywatna

MODEL WARSTWY 2 (L2 VPN)



MODEL WARSTWY 3 (L3 VPN, np. IPsec)



VPN Wirtualna sieć prywatna

1. Izolacja ruchu

- **L3 VPN:** Routery na końcach tunelu odcinają ruch rozgłoszeniowy (Broadcast/Multicast). Jeśli w jednym biurze pojawi się wirus typu *worm*, który rozprzestrzenia się przez skanowanie sieci lokalnej (np. ARP poisoning), nie przejdzie on automatycznie do drugiego biura.
- **L2 VPN:** Przesyła wszystko. Atak na warstwę drugą (np. MAC Flooding) w biurze w Krakowie natychmiast uderza w switch w biurze we Wrocławiu, bo dla urządzeń to ten sam segment sieci.

2. Szyfrowanie

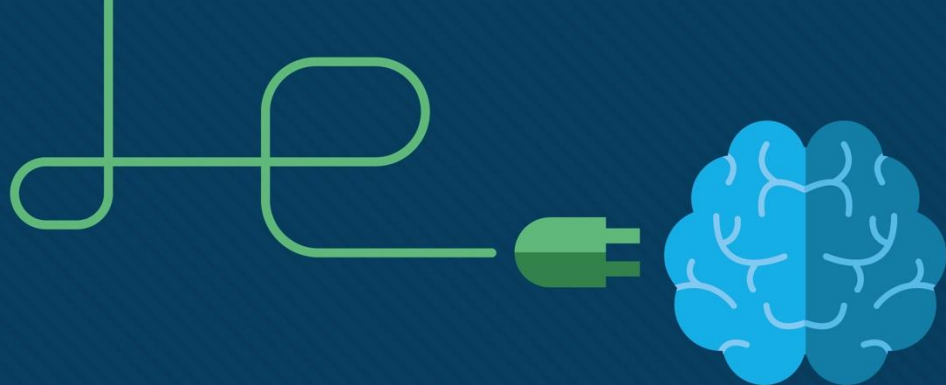
- **L3 VPN:** Standardem jest tu **IPsec**, który od podstaw został zaprojektowany z myślą o bezpieczeństwie. Oferuje silne szyfrowanie (AES-256), sprawdzanie integralności (SHA-2) i bezpieczną wymianę kluczy (Diffie-Hellman).
- **L2 VPN:** Wiele technologii L2 (np. starsze MPLS L2VPN czy VXLAN) domyślnie **nie szyfruje danych**. Tworzą one tunel (enkapsulację), ale pakiety w środku są "gołe". Aby je zabezpieczyć, trzeba nakładać dodatkowe warstwy ochrony, co komplikuje konfigurację.

3. Kontrola Dostępu (ACL i Firewall)

- **L3 VPN:** Ponieważ mamy do czynienia z routingiem, bardzo łatwo jest postawić Firewalla na styku tunelu i filtrować ruch (np. "tylko serwer SQL może rozmawiać z oddziałem").
- **L2 VPN:** Filtrowanie ruchu wewnątrz jednej podsieci (L2) jest znacznie trudniejsze i mniej wydajne (wymaga tzw. *Private VLANs* lub *Bridge-group ACLs*).

3.4 Podsumowanie





Atakujący i ich narzędzia

CyberOps Associate v1.0



4.1 Kto atakuje naszą sieć?

Zagrożenie, podatność i ryzyko



Zagrożenie, podatność i ryzyko

Termin	Wyjaśnienie
Zagrożenie	Potencjalne niebezpieczeństwo dla zasobu, takiego jak dane lub sama sieć.
Podatność	Słabość w systemie lub jego projekcie, która mogłaby zostać wykorzystana przez zagrożenie.
Powierzchnia ataku	Powierzchnia ataku to suma wszystkich podatności w danym systemie, które są dostępne dla atakującego. Opisuje ona różne punkty, przez które atakujący mógłby dostać się do systemu lub wyprowadzić z niego dane.
Exploit	Mechanizm używany do wykorzystania podatności w celu naruszenia zasobu. Exploity mogą być zdalne lub lokalne. Exploit zdalny działa przez sieć bez wcześniejszego dostępu do docelowego systemu. W przypadku exploita lokalnego, podmiot stwarzający zagrożenie posiada już pewien rodzaj dostępu użytkownika lub administracyjnego do systemu końcowego. Nie musi to koniecznie oznaczać, że atakujący ma fizyczny dostęp do urządzenia.
Ryzyko	Prawdopodobieństwo, że konkretne zagrożenie wykorzysta określoną podatność zasobu, co skutkuje niepożądanymi konsekwencjami.

Zagrożenie, podatność i ryzyko

- Zarządzanie ryzykiem to proces, który równoważy koszty operacyjne wprowadzania środków ochronnych z korzyściami uzyskanymi dzięki ochronie zasobu.
- Cztery sposoby zarządzania ryzykiem:

Strategia zarządzania ryzykiem	Wyjaśnienie
Akceptacja ryzyka	Gdy koszt opcji zarządzania ryzykiem przewyższa koszt samego ryzyka, ryzyko zostaje zaakceptowane i nie podejmuje się żadnych działań.
Unikanie ryzyka	Oznacza unikanie jakiejkolwiek ekspozycji na ryzyko poprzez wyeliminowanie danej aktywności, co skutkuje utratą wszelkich korzyści płynących z tej aktywności.
Redukcja ryzyka	Zmniejsza ekspozycję na ryzyko. Jest to najczęściej stosowana strategia mitygacji (łagodzenia) ryzyka. Wymaga ona starannej oceny kosztów straty, strategii łagodzenia oraz korzyści płynących z operacji lub aktywności, która jest narażona na ryzyko.
Transfer ryzyka	Część lub całość ryzyka zostaje przeniesiona na chętną stronę trzecią, taką jak firma ubezpieczeniowa.

Zagrożenie, podatność i ryzyko

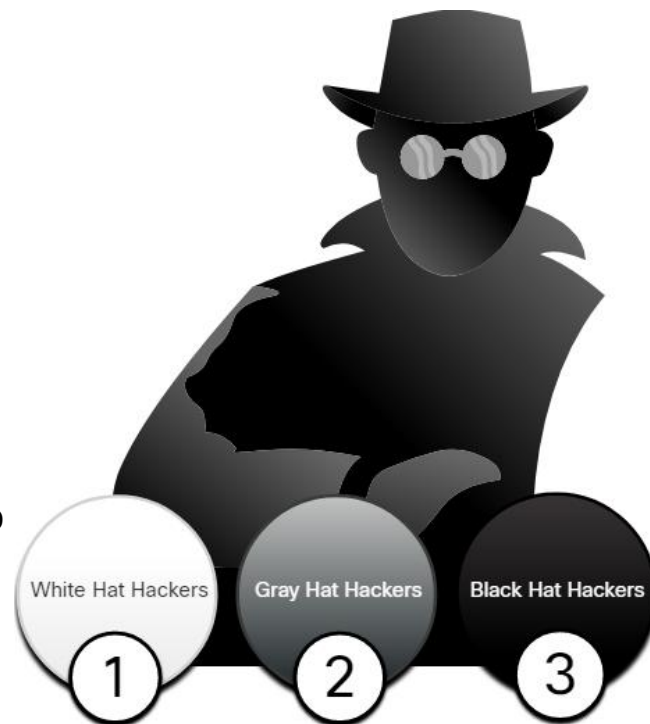
- **Powszechne terminy dotyczące bezpieczeństwa sieciowego:**
 - **Środek zaradczy (Countermeasure)** – działania podejmowane w celu ochrony zasobów poprzez łagodzenie zagrożenia lub zmniejszanie ryzyka.
 - **Wpływ (Impact)** – potencjalna szkoda dla organizacji, która zostaje spowodowana przez dane zagrożenie.
- **Uwaga:** Exploit lokalny wymaga dostępu wewnątrz sieci, na przykład poprzez użytkownika posiadającego konto w tej sieci. Nie jest jednak wymagane posiadanie konta w sieci, aby móc wykorzystać podatność tej sieci.

Hacker vs. Threat Actor (Haker a podmiot stwarzający zagrożenie)

- „Haker” to powszechny termin używany do opisania podmiotu stwarzającego zagrożenie. Słowo to ma wiele znaczeń, takich jak:
 - Błyskotliwy programista zdolny do tworzenia nowych programów i wprowadzania zmian w istniejącym kodzie, aby uczynić go bardziej wydajnym.
 - Specjalista sieciowy, który wykorzystuje zaawansowane umiejętności programistyczne, aby upewnić się, że sieci nie są podatne na ataki.
 - Osoba, która uruchamia programy w celu blokowania dostępu do danych na serwerach lub ich uszkodzania.
- **Typy hakerów:**
 - Biali hakerzy (White Hat)
 - Szarzy hakerzy (Gray Hat)
 - Czarni hakerzy (Black Hat)

Hacker vs. Threat Actor

- **Biali hakerzy (White Hat):** Biali hakerzy to etyczni hakerzy, którzy wykorzystują swoje umiejętności programistyczne w dobrych, etycznych i legalnych celach.
- **Szarzy hakerzy (Gray Hat):** Szarzy hakerzy to osoby, które popełniają przestępstwa i podejmują nieetyczne działania, ale nie robią tego dla osobistych korzyści ani w celu wyrządzenia szkód.
- **Czarni hakerzy (Black Hat):** Czarni hakerzy to nieetyczni przestępcy, którzy naruszają bezpieczeństwo komputerowe i sieciowe dla własnych korzyści.
- **Uwaga:** Termin „podmiot stwarzający zagrożenie” (ang. *threat actor*) jest używany w odniesieniu do osób lub grup, które można zaklasyfikować jako szarych lub czarnych hakerów.



Ewolucja podmiotów stwarzających zagrożenie

- Script kiddies – odnosi się do nastolatków lub niedoświadczonych osób, które uruchamiają gotowe skrypty, narzędzia i exploity, aby wyrządzić szkodę, ale zazwyczaj nie robią tego dla zysku.
- Brokerzy podatności (Vulnerability brokers) – odnosi się do szarych hakerów, którzy próbują odkrywać exploity i zgłaszać je dostawcom w zamian za nagrody (np. w programach Bug Bounty).
- Haktywiści (Hacktivists) – odnosi się do szarych hakerów, którzy jednoczą się i protestują przeciwko różnym ideom politycznym i społecznym.
- Cyberprzestępcy (Cybercriminals) – odnosi się do czarnych hakerów, którzy pracują na własny rachunek lub dla dużych organizacji cyberprzestępczych.
- Sponsorowani przez państwo (State-sponsored) – hakerzy wspierani przez rządy to podmioty, które kradną tajemnice państwowe, gromadzą informacje wywiadowcze oraz sabotują sieci obcych rządów, grup terrorystycznych i korporacji.

Ewolucja podmiotów stwarzających zagrożenie

- Haking narodził się w latach 60. XX wieku wraz z *phone phreakingiem*, co odnosi się do używania różnych częstotliwości audio w celu manipulowania systemami telefonicznymi.
- We wczesnych latach 60. osoby stwarzające zagrożenie zdały sobie sprawę, że naśladowając określony ton za pomocą gwizdka, mogą oszukać centrale telefoniczne i wykonywać darmowe połączenia międzymiastowe.
- W połowie lat 80. zaczęto pisać programy typu *war dialing*, które wybierały każdy numer telefonu w danym obszarze w poszukiwaniu komputerów, systemów typu BBS (Bulletin Board Systems) oraz faksów.
- Gdy znaleziono numer telefonu połączony z modemem, do uzyskania dostępu wykorzystywano programy do łamania haseł.

Ewolucja podmiotów stwarzających zagrożenie

Gwizdek z płatków śniadaniowych (2600 Hz)

- Najślynniejszy przykład to John Draper (znany jako **Captain Crunch**). Odkrył on, że zabawkowy gwizdek dołączany do płatków *Cap'n Crunch* wydaje dźwięk o częstotliwości dokładnie **2600 Hz**.
- 1. Haker wykonywał normalne połączenie (np. na darmowy numer informacyjny). W momencie, gdy połączenie zostało zestawione, haker gwizdał do słuchawki sygnał **2600 Hz**.
 - **Co myślała centrala:** "O, słyszę 2600 Hz na tej linii. To znaczy, że użytkownik odłożył słuchawkę. Muszę zwolnić tę linię i przestać naliczać opłaty za rozmowę".
 - **Co działo się naprawdę:** Centrala "oczyszczała" linię, myśląc, że rozmowa dobiegła końca, ale **fizyczne połączenie kablowe wciąż trwało**, bo haker wcale nie odłożył słuchawki.
- 2. W tym momencie haker przestawał gwizdać. Centrala widziała linię jako "wolną, ale gotową do przyjęcia instrukcji". Haker mógł wtedy użyć tarczy numerowej (lub generatora tonów DTMF), aby wykręcić dowolny numer na świecie.

Ewolucja podmiotów stwarzających zagrożenie

Red Box – symulowanie wrzucanych monet

- W budkach telefonicznych na monety, mechanizm po wrzuceniu pieniądza generował specyficzne sekwencje tonów (np. 1700 Hz i 2200 Hz), które informowały centralę: „Właśnie wrzucono 25 centów”.
- Hakerzy budowali urządzenia zwane **Red Box**, które odtwarzały te same nagrane dźwięki do słuchawki. Centrala „słyszała” wpadające monety i przedłużała czas rozmowy, mimo że automat był pusty. To było mechaniczne oszustwo „doładowania” sesji rozmowy.

Cybercriminals

- **Cyberprzestępcy** to podmioty stwarzające zagrożenie, których motywacją jest zarabianie pieniędzy przy użyciu wszelkich niezbędnych środków.
 - Czasami cyberprzestępcy pracują samodzielnie, innym razem są finansowani i sponsorowani przez organizacje przestępcze.
 - Każdego roku kradną miliardy dolarów konsumentom i firmom.
 - Działają w podziemnej gospodarce (tzw. *underground economy*), gdzie kupują i sprzedają dane osobowe oraz własność intelektualną skradzioną ofiarom.
 - Biorą na cel zarówno małe firmy i konsumentów, jak i wielkie przedsiębiorstwa oraz całe gałęzie przemysłu.



Zadania związane z cyberbezpieczeństwem

- Podmioty stwarzające zagrożenie biorą na cel użytkowników domowych, małe i średnie firmy, a także duże organizacje publiczne i prywatne.
- Z tego względu cyberbezpieczeństwo jest wspólną odpowiedzialnością, którą muszą praktykować wszyscy użytkownicy, aby uczynić internet i sieci bezpieczniejszymi.
- Organizacje muszą podejmować działania i chronić swoje zasoby, użytkowników oraz klientów. Muszą one opracowywać i realizować zadania z zakresu cyberbezpieczeństwa, takie jak te przedstawione na rysunku.



Wskaźniki zagrożeń cybernetycznych

▪ Wskaźniki naruszenia bezpieczeństwa (IOC – Indicators Of Compromise)

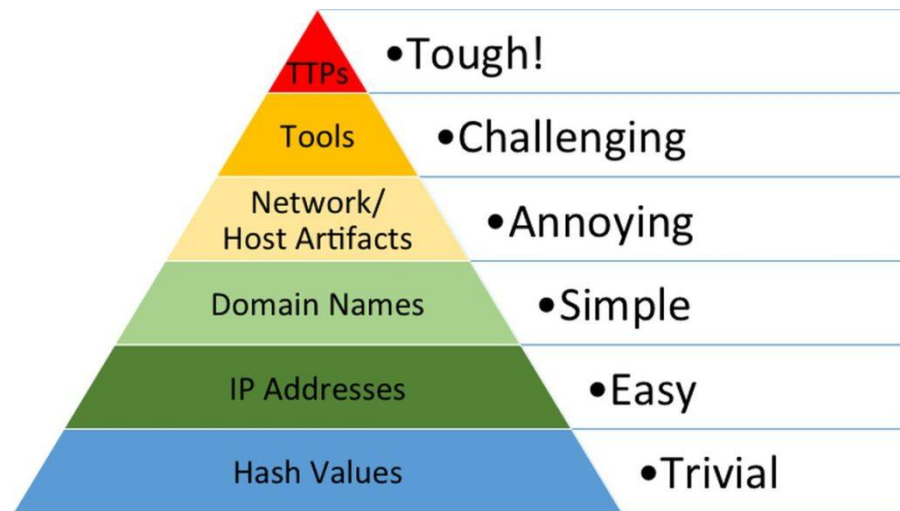
- IOC to dowody potwierdzające, że atak miał miejsce, a każdy atak posiada unikalne, możliwe do zidentyfikowania atrybuty.
- Wskaźnikami IOC mogą być między innymi cechy identyfikujące pliki złośliwego oprogramowania (malware), adresy IP serwerów wykorzystywanych w atakach, nazwy plików oraz charakterystyczne zmiany wprowadzone w oprogramowaniu systemu końcowego.
- Wskaźniki IOC pomagają personelowi odpowiedzialnemu za cyberbezpieczeństwo zidentyfikować przebieg ataku i opracować mechanizmy obronne przeciwko niemu.

Malware File -	"studiox-link-standalone-v20.03.8-stable.exe"
sha256	6a6c28f5666b12beecd56a3d1d517e409b5d6866c03f9be44ddd9efffa90f1e0
sha1	eb019ad1c73ee69195c3fc84ebf44e95c147bef8
md5	3a104b73bb96dfed288097e9dc0a11a8
DNS requests	
domain	log.studiox.link
domain	my.studiox.link
domain	_sips._tcp.studiox.link
domain	sip.studiox.link
Connections	
ip	198.51.100.248
ip	203.0.113.82

Summary of the IOC for a piece of malware

Wskaźniki zagrożeń cybernetycznych

- Koncepcja **Piramidy Bólu** (*Pyramid of Pain*), opracowana przez Davida J. Bianco, to jeden z najważniejszych modeli w nowoczesnym cyberbezpieczeństwie. Wyjaśnia ona, dlaczego niektóre wskaźniki ataku (IOC) są dla obrońców cenniejsze niż inne.
- Nazwa bierze się stąd, że im wyżej na piramidzie znajduje się dany wskaźnik, tym **więcej bólu (trudu i kosztów)** sprawiamy hakerowi, gdy uda nam się go zablokować.



Piramide of Pain

Wskaźniki zagrożeń cybernetycznych

Poziom	Wskaźnik	Dlaczego to „boli” hakera?
1. Fundament	Sumy kontrolne (Hashes)	Trywialne: Wystarczy zmienić jeden bit w pliku, by suma kontrolna była inna. Blokowanie konkretnych hashów to walka z wiatrakami.
2. Niski	Adresy IP	Łatwe: Haker może szybko zmienić serwer, użyć proxy lub VPN. Blokowanie IP to tylko chwilowa przeszkoda.
3. Średni	Nazwy domen	Denerwujące: Rejestracja nowej domeny kosztuje czas i parę dolarów, ale dla profesjonalisty to wciąż mały problem.
4. Wysoki	Atrybuty sieci/hosta	Wyzwanie: Jeśli zablokujesz specyficzny sposób, w jaki wirus komunikuje się z siecią, haker musi przepisać część kodu swojego narzędzia.
5. Bardzo wysoki	Narzędzia (Tools)	Trudne: Jeśli wykryjesz i zablokujesz konkretne oprogramowanie, którego używa atakujący, zmuszasz go do stworzenia lub zakupu zupełnie nowego narzędzia.
6. Szczyt	TTPs (Taktyki, Techniki i Procedury)	Bolesne: To „styl walki” hakera. Jeśli nauczysz się rozpoznawać jego zachowanie (np. jak porusza się po sieci), haker musi nauczyć się fachu od nowa . To kosztuje go miesiące pracy.

Wskaźniki zagrożeń cybernetycznych

▪ Wskaźniki ataku (IOA – Indicators of Attack)

- Wskaźniki IOA skupiają się bardziej na motywacji i strategiach stojących za atakiem oraz na metodach, jakimi atakujący próbują uzyskać dostęp do zasobów.
- Wskaźniki IOA pomagają wypracować proaktywne podejście do bezpieczeństwa, które może być stosowane w wielu kontekstach i przy różnych typach ataków. Obrona przed konkretną strategią pozwala tym samym zapobiegać przyszłym atakom.

▪ Porównanie IOC i IOA

Cecha	IOC (Indicators of Compromise)	IOA (Indicators of Attack)
Podejście	Reaktywne (po fakcie).	Proaktywne (w trakcie lub przed).
Pytanie	„Co się stało?” (np. znaleziony plik wirusa).	„Co się teraz dzieje i dlaczego?” (np. próba eskalacji uprawnień).
Przykład	Ślady stóp złodzieja na dywanie.	Ktoś sprawdza klamki w całym bloku po kolei.

Dzielenie się informacjami o zagrożeniach i budowanie świadomości cybernetycznej

- Rządy aktywnie promują obecnie bezpieczeństwo w cyberprzestrzeni:
- **Amerykańska Agencja ds. Cyberbezpieczeństwa i Infrastruktury (CISA)** prowadzi działaniom mającym na celu automatyzację bezpłatnej wymiany informacji o cyberbezpieczeństwie z organizacjami publicznymi i prywatnymi.
- CISA wykorzystuje system o nazwie **Automated Indicator Sharing (AIS)**, który umożliwia wymianę wskaźników ataku (IOC) między rządem USA a sektorem prywatnym natychmiast po zweryfikowaniu zagrożeń.
- **Agencja Unii Europejskiej ds. Cyberbezpieczeństwa (ENISA)** dostarcza doradztwo i rozwiązania w zakresie wyzwań związanych z cyberbezpieczeństwem dla państw członkowskich UE.
- CISA oraz National Cyber Security Alliance (NCSA) prowadzą co roku w październiku kampanię o nazwie **Narodowy Miesiąc Budowania Świadomości Cyberbezpieczeństwa (NCSAM)**, aby zwiększać wiedzę społeczeństwa na temat zagrożeń.

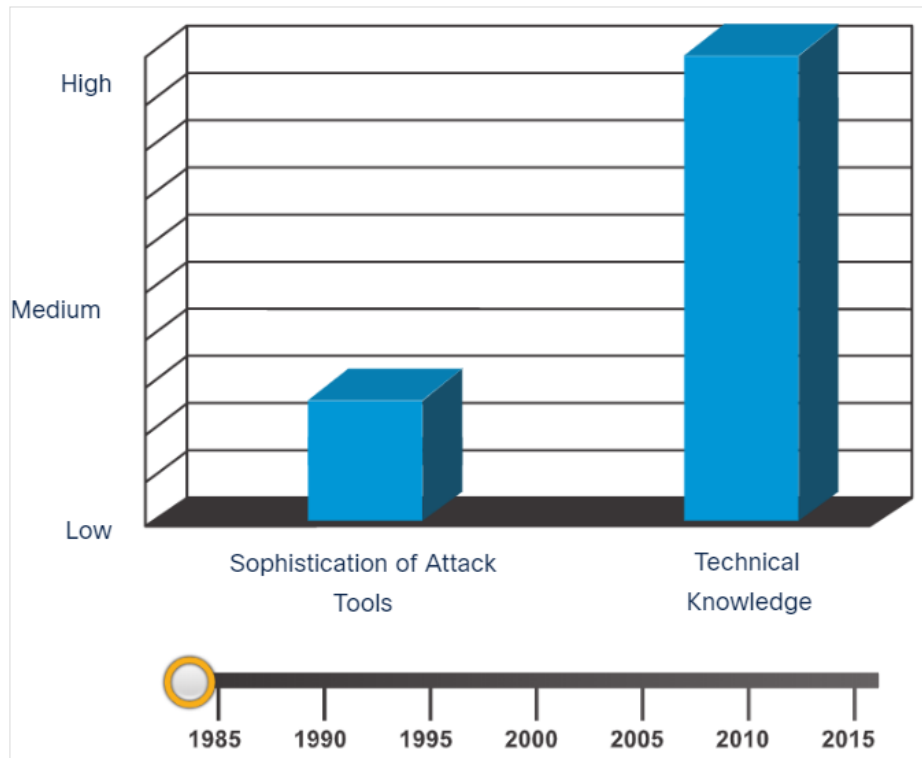
Dzielenie się informacjami o zagrożeniach i budowanie świadomości cybernetycznej

- Hasłem przewodnim NCSAM w 2019 roku było: **Own IT. Secure IT. Protect IT.**
- Tematy bezpieczeństwa poruszane w ramach kampanii:
 - Bezpieczeństwo w mediach społecznościowych.
 - Aktualizowanie ustawień prywatności.
 - Świadomość w zakresie bezpieczeństwa aplikacji na urządzeniach.
 - Dbanie o aktualność oprogramowania.
 - Bezpieczne zakupy online.
 - Bezpieczeństwo sieci Wi-Fi.
 - Ochrona danych klientów.
- Główne filary kampanii w 2025 roku to:
 - **Sztuczna inteligencja i głębokie fejki (Deepfakes):** Edukacja na temat tego, jak rozpoznawać zmanipulowane obrazy i głosy, które cyberprzestępcy wykorzystują do wyłudzeń (np. "oszustwo na szefa" z użyciem wygenerowanego głosu).
 - **Życie bez haseł (Passkeys):** Promowanie odchodzenia od tradycyjnych haseł na rzecz bezpieczniejszych kluczy dostępu (Passkeys), które wykorzystują biometrię (odcisk palca, skan twarzy).
 - **Ochrona tożsamości cyfrowej:** Skupienie na tym, jak minimalizować ilość danych, które zostawiamy w sieci, aby ograniczyć ryzyko kradzieży tożsamości.
 - **Odporność na socjotechnikę 2.0:** Uświadamianie, że phishing to już nie tylko "źle napisane maile", ale bardzo spersonalizowane ataki tworzone przez boty AI.

4.2 Narzędzia podmiotów stwarzających zagrożenie

Wprowadzenie do narzędzi ataku

- Aby wykorzystać podatność, podmiot stwarzający zagrożenie musi posiadać odpowiednią technikę lub narzędzie.
- Na przestrzeni lat narzędzia ataku stały się bardziej wyrafinowane i wysoce zautomatyzowane. Te nowe narzędzia wymagają mniejszej wiedzy technicznej do ich wdrożenia.



Ewolucja narzędzi bezpieczeństwa

- Etyczny hacking wiąże się z użyciem wielu różnych rodzajów narzędzi do testowania sieci oraz urządzeń końcowych.
- W celu sprawdzenia bezpieczeństwa sieci i jej systemów opracowano wiele narzędzi do testów penetracyjnych. Wiele z nich może być również wykorzystywanych przez podmioty stwarzające zagrożenie do przeprowadzania ataków.
- Podmioty stwarzające zagrożenie stworzyły również własne, różnorodne narzędzia hakerskie. Personel odpowiedzialny za cyberbezpieczeństwo musi wiedzieć, jak korzystać z tych narzędzi podczas przeprowadzania testów penetracyjnych sieci.
- **Uwaga:** Większość tych narzędzi opiera się na systemach UNIX lub Linux; dlatego profesjonalista ds. bezpieczeństwa powinien posiadać solidną wiedzę z zakresu tych systemów.

Ewolucja narzędzi bezpieczeństwa

KALI LINUX vs. SECURITY ONION: POTĘGA OFENSYWNA vs. DEFENSYWNA



KALI LINUX

DYSTRYBUCJA DO TESTÓW PENETRACYJNYCH



DLA ETYCZNYCH HAKERÓW I CZERWONYCH ZESPOŁÓW (RED TEAMS)



PREINSTALOWANE NARZĘDZIA:
NMAP, METASPLOIT, BURP SUITE, JOHN THE RIPPER, WIRESHARK



GŁÓWNE ZASTOSOWANIA:
SKANOWANIE PODATNOŚCI, EKSPLOATACJA, ŁAMANIE HASEŁ, INFORMATYKA ŚLEDZCZA (DIGITAL FORENSICS)





SECURITY ONION

OTWARTA PLATFORMA DO POSZUKIWANIA ZAGROŻEŃ I MONITOROWANIA BEZPIECZEŃSTWA SIECI



DLA OBRONCÓW I NIEBIESKICH ZESPOŁÓW (BLUE TEAMS)



GŁÓWNE NARZĘDZIA (CORE TOOLS):
ELK STACK (ELASTICSEARCH, LOGSTASH, KIBANA), ZEEK, SURICATA, STENOGRAPHER, WAZUH



GŁÓWNE ZASTOSOWANIA:
MONITOROWANIE BEZPIECZEŃSTWA SIECI (NSM), PEŁNE PRZECHWYTYWANIE PAKIETÓW (FPC), SYSTEMY WYKRYWANIA WŁAMAŃ NA HOŚCIE (HIDS), ZARZĄDZANIE I ANALIZA LOGÓW



CECHA	KALI LINUX	SECURITY ONION
GŁÓWNA ROLA	Ofensywna (Czerwony Zespół)	Defensywna (Niebieski Zespół)
UŻYTKOWNIK DOCELOWY	Etyczni Hakerzy, Testerzy Penetracyjni	Analitycy SOC, Administratorzy Systemów
KLUCZOWA FUNKCJA	Znajdowanie i wykorzystywanie podatności	Wykrywanie, analiza i reagowanie na zagrożenia
GŁÓWNY KOMPONENT	Zestaw narzędzi indywidualnych programów hakerskich	Zintegrowana platforma do zbierania i wizualizacji danych
TRYB PRACY	Aktywne zaangażowanie, bezpośrednia interakcja	Pasywne monitorowanie, analiza oparta na alertach
TYPOWE WDROŻENIE	Stacja robocza, Maszyna Wirtualna, Live USB	Serwer, Czujnik Sieciowy, Klaster Rozproszony

Ewolucja narzędzi bezpieczeństwa

Cecha	Kali Linux (Ofensywa)	Security Onion (Defensywa)
Główna rola	Atak i testy penetracyjne.	Obrona i monitorowanie sieci.
Główny cel	Znalezienie luki i uzyskanie dostępu.	Wykrycie ataku i ochrona zasobów.
Użytkownik	Etyczny haker, Red Teamer.	Analitik SOC, Blue Teamer.
Działanie	Aktywne (wysyła pakiety do celu).	Pasywne (nasłuchuje i analizuje ruch).
Narzędzia	Nmap, Metasploit, Burp Suite.	Zeek, Suricata, Kibana, Wazuh.

Ewolucja narzędzi bezpieczeństwa

Kategoria	Opis
Łamacze haseł (<i>Password crackers</i>)	Służą do łamania lub odzyskiwania haseł. John the Ripper, Ophcrack, Hashcat, L0phtCrack
Narzędzia do hackingu sieci bezprzewodowych	Używane do celowego włamywania się do sieci Wi-Fi w celu wykrycia luk w zabezpieczeniach. Aircrack-ng, Kismet, Wifite, Reaver
Narzędzia do skanowania i hackingu sieci	Służą do badania urządzeń sieciowych, serwerów i hostów pod kątem otwartych portów TCP lub UDP. Nmap, SuperScan, Angry IP Scanner, ZMap
Narzędzia do tworzenia pakietów (<i>Packet crafting</i>)	Używane do badania i testowania wytrzymałości zapór ogniowych (firewalli). Hping, Scapy, Nemesis, Netcat
Sniffery pakietów (<i>Packet sniffers</i>)	Służą do przechwytywania i analizowania pakietów w tradycyjnych sieciach Ethernet LAN lub WLAN. Wireshark, Tcpdump, Ettercap, Bettercap
Detektory Rootkitów	Narzędzia do sprawdzania integralności plików i katalogów, używane przez etycznych hakerów do wykrywania zainstalowanych rootkitów. AIDE, Netfilter, rkhunter, chkrootkit
Fuzzery do szukania podatności	Używane przez napastników do prób odkrywania luk w zabezpieczeniach systemów komputerowych. Skipfish, Wapiti, AFL (American Fuzzy Lop), Peach Fuzzer

Ewolucja narzędzi bezpieczeństwa

Fuzzery to narzędzia do automatycznego testowania oprogramowania, które polega na wprowadzaniu do programu **ogromnej ilości nieoczekiwanych, błędnych lub losowych danych** (tzw. "fuzz").

Jak to działa? Wyobraź sobie formularz na stronie, który prosi o podanie daty urodzenia. Fuzzer zamiast daty wpisze tam 10 tysięcy liter "A", znaki specjalne lub ujemne liczby.

Cel: Sprawdzenie, czy program się "wyłoży" (crash). Jeśli program przestanie działać, oznacza to, że haker może wykorzystać ten błąd do przejęcia kontroli nad systemem (np. poprzez przepełnienie bufora).

Dla kogo? Używane przez programistów do naprawiania błędów oraz przez hakerów do znajdowania luk typu **Zero-Day** (jeszcze nieodkrytych).

Ewolucja narzędzi bezpieczeństwa

Kategoria	Opis	Przykłady
Narzędzia informatyki śledczej (<i>Forensic tools</i>)	Używane przez etycznych hakerów do wykrywania wszelkich śladów dowodowych istniejących w konkretnym systemie komputerowym.	Sleuth Kit, Helix
Debugery (<i>Debuggers</i>)	Wykorzystywane przez napastników do inżynierii wstecznej plików binarnych podczas pisania exploitów, a przez obrońców podczas analizy złośliwego oprogramowania (malware).	GDB, WinDbg
Systemy operacyjne do hackingu	Systemy z fabrycznie zainstalowanymi narzędziami i technologiami zoptymalizowanymi pod kątem hackingu.	Kali Linux, Parrot Security OS
Narzędzia szyfrujące (<i>Encryption tools</i>)	Wykorzystują schematy algorytmiczne do kodowania danych, aby zapobiec nieautoryzowanemu dostępowi do informacji.	VeraCrypt, CipherShed
Narzędzia do wykorzystywania podatności (<i>Exploitation tools</i>)	Narzędzia służące do sprawdzania, czy zdalny host jest podatny na konkretny atak bezpieczeństwa.	Metasploit, Core Impact
Skanery podatności (<i>Vulnerability scanners</i>)	Skanują sieć lub system w celu identyfikacji otwartych portów oraz znanych luk. Mogą skanować maszyny wirtualne, urządzenia BYOD i bazy danych.	Nipper, Secunia PSI

Kategorie ataków

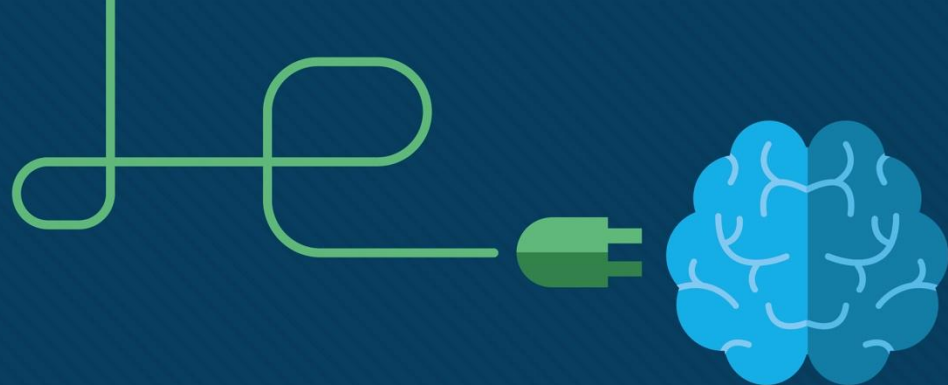
- Podmioty stwarzające zagrożenie wykorzystują wcześniej wspomniane narzędzia (lub ich kombinacje) do przeprowadzania różnorodnych ataków. Ważne jest, aby zrozumieć, że hakerzy używają szerokiego wachlarza narzędzi bezpieczeństwa do realizacji tych celów.

Kategoria ataku	Opis
Podśluch (Eavesdropping attack)	Atak polegający na przechwytywaniu i monitorowaniu ruchu sieciowego przez napastnika. Jest on również nazywany sniffingiem (<i>sniffing</i>) lub podglądaniem (<i>snooping</i>).
Modyfikacja danych (Data modification attack)	Występuje, gdy napastnik przechwytuje ruch wewnątrz firmy i zmienia dane w pakietach bez wiedzy nadawcy oraz odbiorcy.
Spoofing adresu IP (IP address spoofing attack)	Atak polegający na spreparowaniu pakietu IP w taki sposób, aby wyglądał on na wysłany z prawidłowego, zaufanego adresu wewnątrz sieci korporacyjnej.

Kategorie ataków

ategoria ataku	Opis
Ataki oparte na hasłach (<i>Password-based attacks</i>)	Występują, gdy napastnik przejmuje dane uwierzytelniające (login i hasło) do prawidłowego konta użytkownika.
Atak odmowy usługi (DoS)	Uniemożliwia prawidłowe korzystanie z komputera lub sieci uprawnionym użytkownikom. Atak ten może blokować ruch, co skutkuje utratą dostępu do zasobów sieciowych.
Atak człowiek pośrodku (MiTM)	Występuje, gdy napastnik umieszcza się na ścieżce komunikacji między źródłem a celem (np. między użytkownikiem a serwerem banku).
Atak z przejęciem klucza (<i>Compromised key attack</i>)	Występuje, gdy napastnik wejdzie w posiadanie klucza tajnego. Przejęty klucz może zostać użyty do uzyskania dostępu do zabezpieczonej komunikacji bez wiedzy nadawcy i odbiorcy.
Atak typu Sniffer	Sniffer to aplikacja lub urządzenie, które może czytać, monitorować i przechwytywać dane wymieniane w sieci. Jeśli pakiety nie są zaszyfrowane, sniffer pozwala na pełny wgląd w treść danych wewnątrz pakietu.





Broniący i ich narzędzia

CyberOps Associate v1.0



Wycieki danych osobowych

Wycieki danych osobowych

<https://haveibeenpwned.com/>



Informacje o tym czy adres email lub hasło do niego pojawiają się w przypadku znanych wycieków lub publikowanych baz danych.

Zadania:

Sprawdź adres email.

Sprawdź swoje hasło... Czy aby na pewno?

Co innego?

<https://socradar.io/>



Analiza reputacji i skanowanie linków

Baza złośliwych stron

<https://urlhaus.abuse.ch/>

UWAGA!: Nigdy nie kopiuj podejrzanego linku bezpośrednio do paska adresu przeglądarki, "żeby tylko zobaczyć, co tam jest". Nawet jeśli masz VPN, Twoja przeglądarka może wykonać złośliwy skrypt JS lub paść ofiarą ataku typu *Drive-by download*!

https://urlhaus.abuse.ch/browse/tag/nazwa_tagu/

Przykłady filtrów:

tag:emotet – szukanie linków dystrybuujących jednego z najgroźniejszych trojanów bankowych.

tag:agenttesla – popularny spyware kradnący hasła.

tag:pdf – szukanie złośliwych dokumentów PDF.

Baza złośliwych stron

Tag	Co to jest?	Dlaczego jest groźny?
emotet	Botnet / Trojan	Rozsyła spam i ułatwia instalację ransomware.
agenttesla	Spyware / Stealer	Kradnie hasła z przeglądarek, loginy do FTP i e-maili.
qakbot	Bankowiec	Wykrađa poświadczenia bankowe i infekuje sieć lokalną.
nanocore	RAT (Remote Access)	Pozwala hakerowi na pełny podgląd pulpitu i kamery ofiary.
redline	Infostealer	Obecnie najpopularniejszy soft do kradzieży loginów i sesji (cookies).

Narzędzia do weryfikacji

<https://www.abuseipdb.com/>

<https://urlscan.io/>

<https://www.iphunter.info/>

<https://www.browserling.com/>

<https://www.virustotal.com/>

Przykład:

<https://reifenquick.de/Scripts/hl8-8w4cs-6325/>

[203dd91522955695c6dc2a4266ded622a8e8ecef1e0f0710aca38d40d263fb8d](https://reifenquick.de/Scripts/hl8-8w4cs-6325/203dd91522955695c6dc2a4266ded622a8e8ecef1e0f0710aca38d40d263fb8d)

Jak zrobić hash

PowerShell: Get-FileHash "C:\Users\Jan\Downloads\plik.exe" -Algorithm SHA256

Linux: sha256sum plik

Analiza maili

Narzędzia do weryfikacji

<https://mha.azurewebsites.net/>

SPF (Sender Policy Framework) – podstawa, ograniczona lista adresów

DKIM (DomainKeys Identified Mail) – podpis cyfrowy

- Jak to działa:** Serwer wysyłający „podpisuje” maila kluczem prywatnym. Serwer odbiorcy pobiera klucz publiczny z DNS nadawcy i sprawdza, czy podpis pasuje.

- Zaleta:** Nawet jeśli mail przejdzie przez dziesięć serwerów pośredniczących, podpis DKIM pozostaje nienaruszony i potwierdza autentyczność.

DMARC (Domain-based Message Authentication, Reporting, and Conformance) – instrukcje co robić gdy odbierzemy a coś będzie nie tak

- p=none (Monitorowanie):** „Dostarcz maila, ale daj mi znać w raporcie, że coś było nie tak”.
- p=quarantine (Kwarantanna):** „Jeśli SPF/DKIM zawiedzie, wrzuć tego maila do Spamów”.
- p=reject (Odrzucenie):** „Jeśli to nie ja, w ogóle nie przyjmuj tego maila”.

Analiza ruchu

Narzędzia do weryfikacji

<https://www.malware-traffic-analysis.net/index.html>

Przykład z Remote Access Trojan:

<https://www.malware-traffic-analysis.net/2026/02/28/index.html>

Tutoriale

Tutoriale

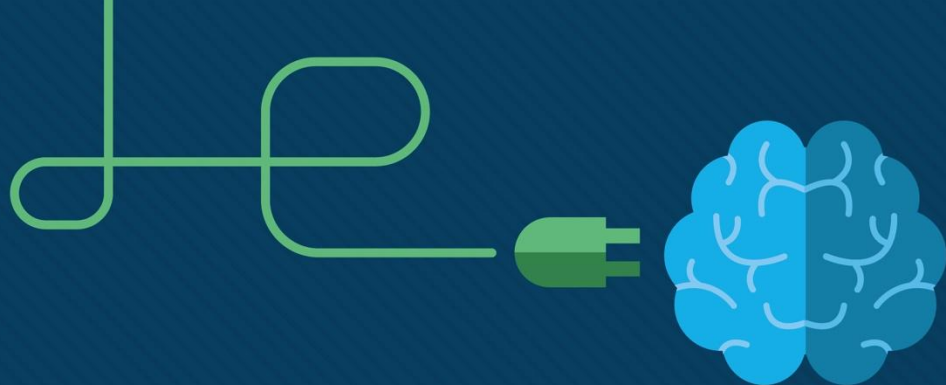
<https://overthewire.org/>

<https://www.hackthebox.com/>

<https://tryhackme.com/> - bardzo fajny dla początkujących

<https://blueteamlabs.online/> - to już test wiedzy





Monitorowanie sieci i atakowanie jej fundamentów

CyberOps Associate v1.0



6.1 Wstęp do monitoringu sieci

Topologia bezpieczeństwa sieciowego

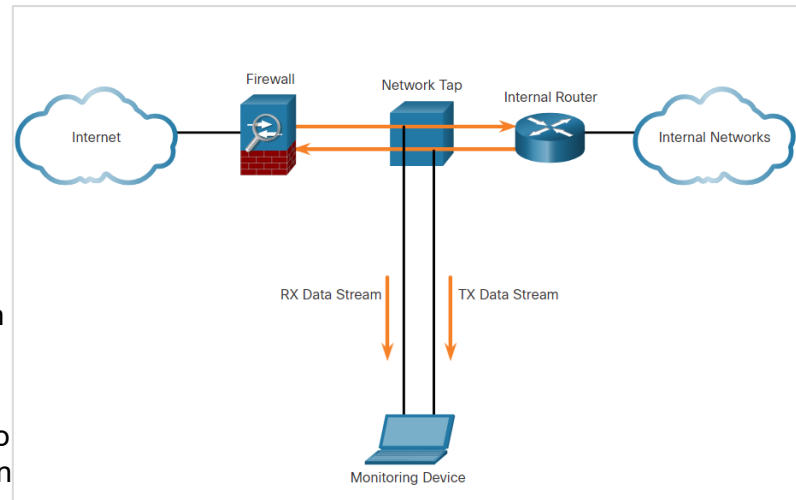
- Aby mitygować (łagodzić) zagrożenia, wszystkie sieci muszą być zabezpieczone i chronione.
- Sieć wymaga infrastruktury bezpieczeństwa składającej się z zapór ogniowych (firewalli), systemów wykrywania włamań (**IDS**), systemów zapobiegania włamaniom (**IPS**) oraz oprogramowania do zabezpieczania urządzeń końcowych (*endpoint security*).
- Metody te i technologie są wykorzystywane do wprowadzania zautomatyzowanego monitoringu, generowania alertów bezpieczeństwa lub automatycznego blokowania urządzeń wykonujących atak.
- W przypadku dużych sieci dodawana jest dodatkowa warstwa ochrony. Urządzenia takie jak firewalle i systemy IPS działają w oparciu o wstępnie skonfigurowane reguły – monitorują ruch i porównują go z tymi regułami. Jeśli wystąpi dopasowanie, ruch jest obsługiwany zgodnie z regułą.
- Ważnym zadaniem analityka cyberbezpieczeństwa jest przeglądanie wszystkich alertów generowanych przez urządzenia sieciowe i określanie ich zasadności.

Metody monitorowania sieci

- Codzienne funkcjonowanie sieci obejmuje przepływ ruchu, wykorzystanie przepustowości oraz dostęp do zasobów. Wzorce te pozwalają zidentyfikować normalne zachowanie sieci (tzw. *baseline*).
- Aby określić, jakie zachowanie sieci jest normalne, należy wdrożyć systemy monitorowania. Do tego celu wykorzystuje się narzędzia takie jak systemy IDS, analizatory pakietów, protokół SNMP, NetFlow i inne.
- Istnieją dwie powszechne metody przechwytywania ruchu i przesyłania go do urządzeń monitorujących:
 - **Network TAPs** – znane również jako punkty dostępu testowego (*Test Access Points*). Są to fizyczne urządzenia wpięte bezpośrednio w linię transmisyjną.
 - **Mirroring ruchu (SPAN)** – wykorzystanie funkcji *Switch Port Analyzer* (SPAN) lub innego rodzaju kopiowania portów na przełącznikach.

Network Taps (Fizyczne punkty dostępu)

- **Network Tap** to pasywne urządzenie rozdzielające, instalowane szeregowo (**inline**) pomiędzy badanym urządzeniem a siecią.
- **Kluczowe cechy działania:**
 - **Transparentność:** Tap przekazuje cały ruch, w tym błędy warstwy fizycznej, do urządzenia analizującego, jednocześnie pozwalając danym dotrzeć do pierwotnego celu bez opóźnień.
 - **Separacja kanałów:** Urządzenie jednocześnie przesyła strumień danych nadawczych (**TX**) z routera wewnętrznego oraz strumień danych odbiorczych (**RX**) do routera na oddzielnych, dedykowanych kanałach.
 - **Czas rzeczywisty:** Dzięki separacji kanałów wszystkie dane docierają do urządzenia monitorującego w czasie rzeczywistym, bez ryzyka buforowania czy odrzucania pakietów.
 - **Bezpieczeństwo Fail-Safe:** Tapy są urządzeniami typu "fail-safe". Oznacza to, że w przypadku awarii zasilania lub samego Tapa, połączenie fizyczne między zaporą ogniową (firewall) a routerem pozostaje nienaruszone – ruch sieciowy przepływa dalej.



Implementing a TAP in a Sample Network

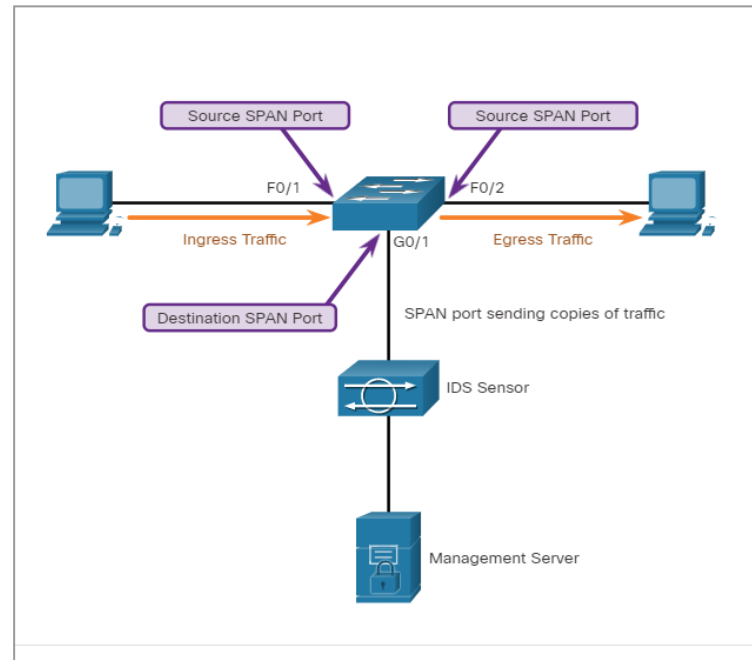
Mirroring ruchu i technologia CISCO SPAN

- Przechwytywanie danych na potrzeby monitorowania sieci wymaga zebrania całego ruchu.
- Aby ominąć segmentację sieci narzuconą przez przełączniki (switche), należy zastosować specjalne techniki, takie jak mirroring portów (port mirroring).
- Mirroring portów pozwala przełącznikowi kopiować ramki odebrane na jednym lub wielu portach do portu **SPAN (Switch Port Analyzer)**, który jest podłączony do urządzenia analizującego.

Termin SPAN	Opis
Ruch wejściowy (<i>Ingress traffic</i>)	Ruch, który wchodzi do przełącznika.
Ruch wyjściowy (<i>Egress traffic</i>)	Ruch, który opuszcza przełącznik.
Port źródłowy (SPAN)	Porty źródłowe są monitorowane, a ruch wchodzący do nich jest powielany (kopiowany) na porty docelowe.
Port docelowy (SPAN)	Port, który odzwierciedla (mirrors) ruch z portów źródłowych. Porty docelowe SPAN często łączą się z urządzeniami analizującymi, takimi jak analizatory pakietów lub systemy IDS.

Mirroring ruchu i technologia SPAN

- Powiązanie pomiędzy portami źródłowymi a portem docelowym nazywane jest **sesją SPAN**.
 - W ramach jednej sesji można monitorować jeden lub wiele portów.
 - W niektórych przełącznikach Cisco ruch z sesji może być kopiowany do więcej niż jednego portu docelowego.
 - Można określić **źródłowy VLAN** – w takim przypadku wszystkie porty należące do tego VLAN-u stają się źródłami ruchu SPAN.
- **Uwaga:** Odmiana technologii SPAN o nazwie **Remote SPAN (RSPAN)** pozwala administratorowi sieci wykorzystać elastyczność sieci VLAN do monitorowania ruchu na zdalnych przełącznikach.

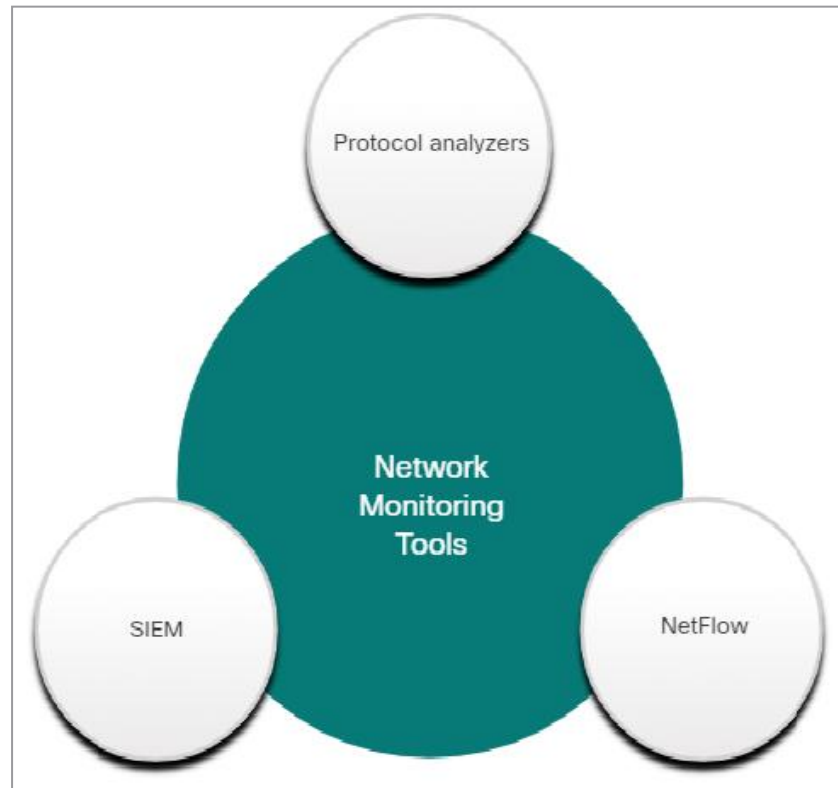


Switch interconnecting two hosts and mirroring traffic to an IDS and Network Management Server

6.2 Przydatne narzędzia

Narzędzia do monitoringu bezpieczeństwa sieci

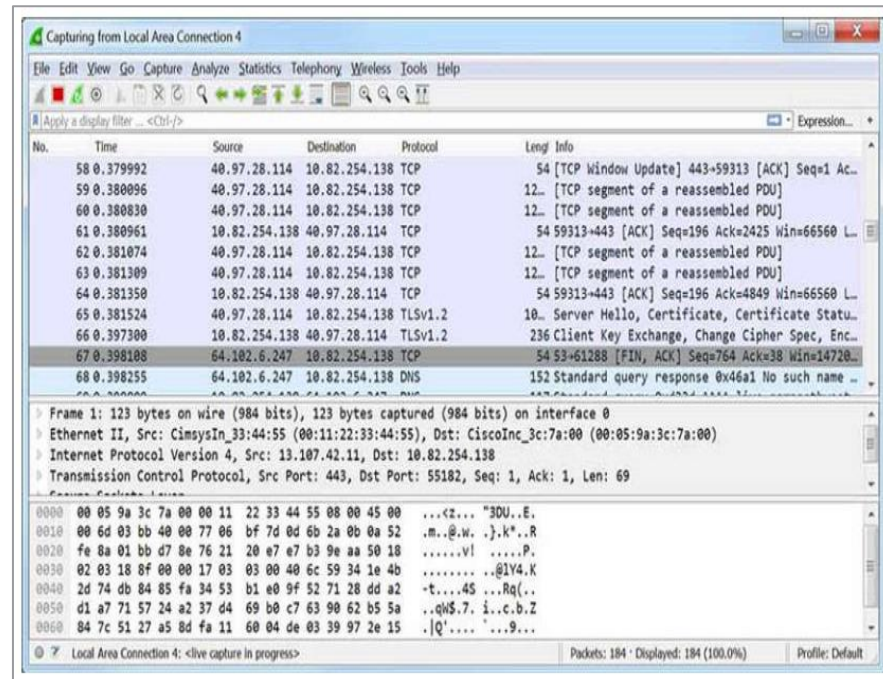
- **Popularne narzędzia stosowane do monitorowania bezpieczeństwa sieci to między innymi:**
 - **Analizatory protokołów sieciowych**, takie jak Wireshark i Tcpdump.
 - **NetFlow.**
 - **Systemy zarządzania informacjami i zdarzeniami bezpieczeństwa (SIEM).**
- Analitycy bezpieczeństwa powszechnie polegają na **plikach logów** oraz protokole **Simple Network Management Protocol (SNMP)** w celu badania (odkrywania) zachowań sieciowych.



Introduction to Network Monitoring and Tools

Analizatory protokołów sieciowych

- **Analizatory protokołów sieciowych** (lub aplikacje typu „packet sniffer”) to programy służące do przechwytywania ruchu.
- Analizatory protokołów wyświetlają to, co dzieje się w sieci, za pomocą graficznego interfejsu użytkownika (GUI).
- Narzędzia te są wykorzystywane nie tylko do analizy bezpieczeństwa, ale również do rozwiązywania problemów z siecią (troubleshooting), tworzenia oprogramowania i protokołów oraz w celach edukacyjnych.
- Jak pokazano na rysunku, **Wireshark** jest używany w środowiskach Windows, Linux oraz macOS. Jest to niezwykle przydatne narzędzie do nauki komunikacji w protokołach sieciowych.



Analizatory protokołów sieciowych

- Ramki przechwycone przez Wireshark są zapisywane w pliku **PCAP**, który zawiera informacje dotyczące ramki, interfejsu, długości pakietu, znaczników czasu (timestamps) oraz wszystkie dane binarne przesłane przez sieć.
- Wireshark potrafi otwierać pliki zawierające przechwycony ruch z innych programów, takich jak narzędzie **tcpdump**.

```
[root@secOps analyst]# tcpdump -i hl-eth0 -n
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on hl-eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
10:42:19.841549 IP 10.0.0.12 > 10.0.0.11: ICMP echo request, id 2279, seq 5, length 64
10:42:19.841570 IP 10.0.0.11 > 10.0.0.12: ICMP echo reply, id 2279, seq 5, length 64
10:42:19.854287 IP 10.0.0.12 > 10.0.0.11: ICMP echo request, id 2279, seq 6, length 64
10:42:19.854304 IP 10.0.0.11 > 10.0.0.12: ICMP echo reply, id 2279, seq 6, length 64
10:42:19.867446 IP 10.0.0.12 > 10.0.0.11: ICMP echo request, id 2279, seq 7, length 64
10:42:19.867468 IP 10.0.0.11 > 10.0.0.12: ICMP echo reply, id 2279, seq 7, length 64
^C
6 packets captured
6 packets received by filter
0 packets dropped by kernel
[root@secOps analyst]#
```

- **Uwaga:** **windump** to wariant programu tcpdump przeznaczony dla systemu Microsoft Windows. Z kolei **tshark** to narzędzie wiersza poleceń wchodzące w skład pakietu Wireshark, które działa w sposób zbliżony do tcpdump.

Analizatory protokołów sieciowych

Narzędzie	System operacyjny	Opis
tcpdump	Linux / Unix / macOS	Standardowe, najpopularniejsze narzędzie tekstowe do "sniffingu".
windump	Windows	Port tcpdumpa na Windowsa (wymaga biblioteki np. Npcap).
tshark	Wszystkie (Multiplatform)	"Wireshark bez okienek". Posiada te same potężne dekodery protokołów co Wireshark, ale działa w terminalu.

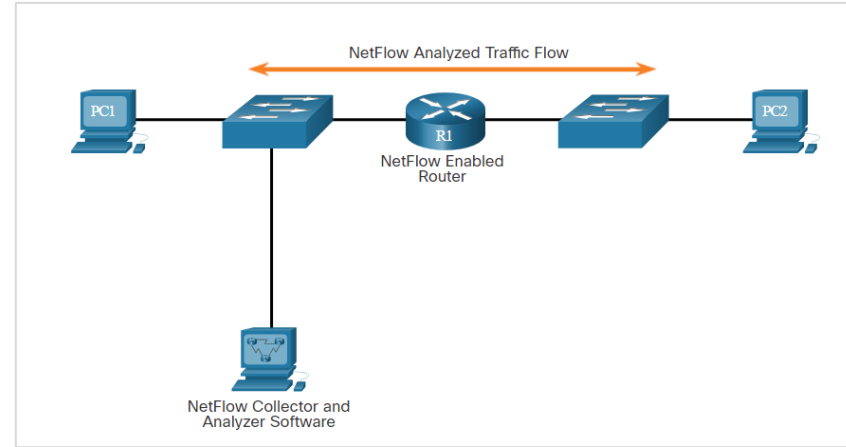
NetFlow

- **NetFlow** to technologia Cisco IOS, która zapewnia statystyki 24/7 na temat pakietów przepływających przez router Cisco lub przełącznik wielowarstwowy.
- **Kluczowe cechy NetFlow:**
 - **Standard zbierania danych:** NetFlow jest standardem gromadzenia operacyjnych danych IP w sieciach IP.
 - **Wszechstronne zastosowanie:** Może być używany do monitorowania sieci i bezpieczeństwa, planowania sieci oraz analizy ruchu.
 - **Pełna ścieżka audytu:** Zapewnia kompletny zapis podstawowych informacji o każdym przepływie IP (flow) przekazywanym przez urządzenie.
 - **Kolektor NetFlow:** Chociaż NetFlow przechowuje informacje o przepływach w lokalnej pamięci podręcznej (cache) urządzenia, powinien być zawsze skonfigurowany tak, aby przesyłał te dane do zewnętrznego **kolektora NetFlow**, który je magazynuje.

Introduction to Network Monitoring and Tools

NetFlow

- NetFlow może monitorować połączenia aplikacji poprzez śledzenie liczby bajtów i pakietów dla każdego indywidualnego przepływu (flow) danej aplikacji. Przesyła te statystyki do zewnętrznego serwera zwanego **kolektorem NetFlow**.
- Cisco Stealthwatch (obecnie znany jako Cisco Secure Network Analytics) gromadzi statystyki NetFlow w celu wykonywania zaawansowanych funkcji, takich jak:
 - **Flow stitching (zszywanie przepływów):** Grupuje pojedyncze wpisy w spójne przepływy danych.
 - **Flow deduplication (deduplikacja przepływów):** Filtruje duplikaty przychodzących wpisów pochodzących z wielu klientów NetFlow.
 - **NAT stitching (zszywanie NAT):** Upraszcza analizę przepływów poprzez łączenie wpisów sprzed i po translacji adresów NAT.



PC1 connected to PC2 using HTTPS

NetFlow

Cecha	Analiza pakietów (Wireshark/TAP)	NetFlow
Głębokość	Widzisz wszystko (treść wiadomości, hasła).	Widzisz tylko metadane (kto, z kim, kiedy).
Skala	Trudno analizować całą sieć naraz (ogromne pliki).	Pozwala na monitorowanie ogromnych sieci 24/7 przy niskim obciążeniu.
Analoga	Jak podsłuchiwanie i nagrywanie rozmowy telefonicznej.	Jak billing telefoniczny (kto dzwonił do kogo i jak długo).

SIEM i SOAR

- **Security Information Event Management (SIEM)** to technologia wykorzystywana w dużych organizacjach (enterprise) w celu zapewnienia raportowania w czasie rzeczywistym oraz długoterminowej analizy zdarzeń związanych z bezpieczeństwem.
 - Systemy SIEM obejmują następujące kluczowe funkcje:
 - **Analiza śledcza (Forensic analysis)** – możliwość przeszukiwania logów i zapisów zdarzeń z różnych źródeł oraz dostarczanie pełnych informacji na potrzeby analizy poincydentowej.
 - **Korelacja (Correlation)** – badanie logów i zdarzeń z różnych systemów lub aplikacji, co przyspiesza wykrywanie zagrożeń bezpieczeństwa i reagowanie na nie.
 - **Agregacja (Aggregation)** – redukcja objętości danych o zdarzeniach poprzez konsolidację (łączenie) duplikujących się rekordów.
 - **Raportowanie (Reporting)** – prezentowanie skorelowanych i zagregowanych danych w formie monitoringu w czasie rzeczywistym oraz długoterminowych podsumowań.

SIEM i SOAR

- **SIEM dostarcza szczegółowych informacji na temat źródła podejrzanej aktywności:**
 - **Informacje o użytkowniku:** takie jak nazwa użytkownika, status uwierzytelniania, lokalizacja.
 - **Informacje o urządzeniu:** takie jak producent, model, wersja systemu operacyjnego, adres MAC, metoda połączenia sieciowego i lokalizacja.
 - **Informacje o stanie (Posture information):** takie jak zgodność urządzenia z polityką bezpieczeństwa, aktualność baz antywirusowych oraz zainstalowane poprawki systemu operacyjnego (patche).
- **SOAR**
 - **Security Orchestration, Automation, and Response (SOAR)** stanowi rozszerzenie możliwości systemu SIEM.
 - SOAR pomaga zespołom ds. bezpieczeństwa w badaniu incydentów oraz dodaje zaawansowane mechanizmy gromadzenia danych i szereg funkcjonalności, które wspomagają reagowanie na incydenty bezpieczeństwa.

SIEM i SOAR

▪ Rozwiązania SOAR:

- **Dostarczają narzędzia do zarządzania sprawami (case management)**, które pozwalają personelowi ds. cyberbezpieczeństwa na badanie i analizowanie incydentów, często poprzez integrację wiedzy o zagrożeniach (*threat intelligence*) z platformą bezpieczeństwa sieciowego.
- **Wykorzystują sztuczną inteligencję (AI)** do wykrywania incydentów, co wspomaga ich analizę oraz reagowanie.
- **Automatyzują złożone procedury reagowania na incydenty i dochodzenia**, które są potencjalnie pracochłonnymi zadaniami wykonywanymi przez pracowników Centrum Operacji Bezpieczeństwa (SOC), poprzez wykonywanie scenariuszy działań (*run books*).
- **Oferują pulpity nawigacyjne (dashboards) i raporty** do dokumentowania reakcji na incydenty, co pozwala poprawić kluczowe wskaźniki efektywności (KPI) zespołu SOC oraz wzmocnić bezpieczeństwo sieciowe organizacji.
- **SOAR pomaga analitykom** reagować na zagrożenia.

Systemy SIEM

- Otwartoźródłowy produkt o nazwie **Security Onion** zawiera pakiet **ELK**, który zapewnia funkcjonalność systemu SIEM.
- **ELK** to akronim od nazw trzech produktów firmy Elastic:
 - **Elasticsearch** – zorientowana na dokumenty wyszukiwarka pełnotekstowa.
 - **Logstash** – system przetwarzania potokowego (pipeline), który łączy „wejścia” (inputs) z „wyjściami” (outputs), wykorzystując opcjonalne „filtry” (filters) pomiędzy nimi.
 - **Kibana** – oparty na przeglądarce pulpit nawigacyjny (dashboard) do analityki i wyszukiwania danych w Elasticsearch.
- **Uwaga:** SolarWinds Security Event Manager oraz Splunk Enterprise Security to dwa popularne, komercyjne (własnościowe) systemy SIEM wykorzystywane przez zespoły SOC.

Systemy SIEM

▪ Komponenty stosu ELK (Elastic Stack)

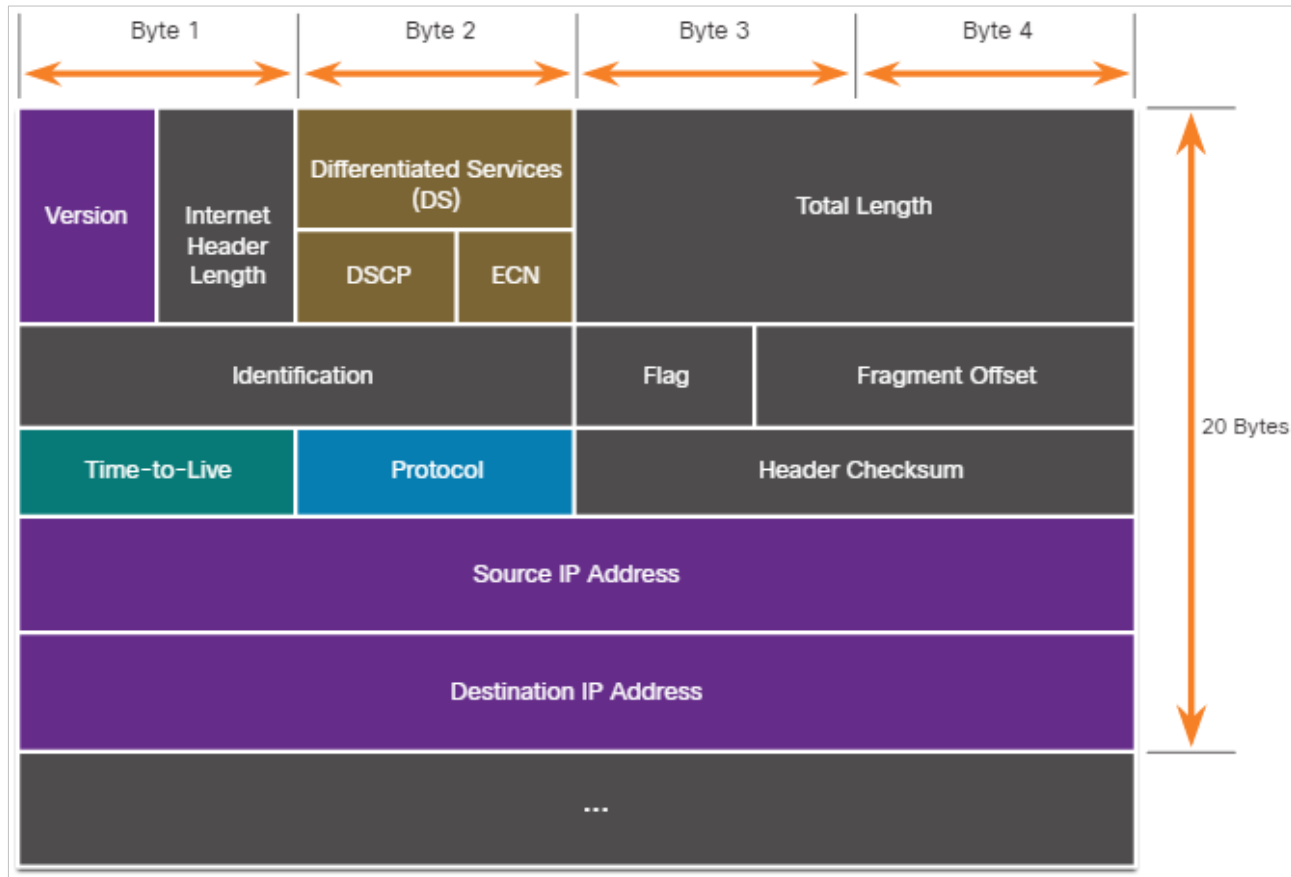
- **Logstash (Warstwa ingestii i przetwarzania):** Pełni rolę silnika do gromadzenia danych (data collection) oraz ich transformacji. Odpowiada za pobieranie nieustrukturyzowanych logów z rozproszonych źródeł, ich parsowanie, normalizację oraz wzbogacanie (np. o dane geolokalizacyjne), a następnie przekazywanie ich w zunifikowanym formacie do magazynu danych.
- **Elasticsearch (Warstwa indeksowania i analityki):** Rozproszony silnik wyszukiwania i analityki oparty na bibliotece Lucene. Przechowuje dane w formie dokumentów JSON i umożliwia ich niemal natychmiastowe przeszukiwanie (near real-time) dzięki zaawansowanemu indeksowaniu, co jest kluczowe przy analizowaniu dużych zbiorów danych (Big Data) w środowiskach SOC.
- **Kibana (Warstwa wizualizacji i zarządzania):** Interfejs graficzny umożliwiający interakcję z danymi zgromadzonymi w Elasticsearch. Pozwala analitykom na tworzenie zaawansowanych pulpitów nawigacyjnych (dashboards), wizualizację trendów zagrożeń w czasie rzeczywistym oraz przeprowadzanie doraźnych zapytań (ad-hoc queries) podczas badania incydentów.

6.3 Ramki IP

IPv4 i IPv6

- Protokół IP został zaprojektowany jako bezpołączeniowy protokół Warstwy 3. Zapewnia on funkcje niezbędne do dostarczenia pakietu z hosta źródłowego do hosta docelowego w systemie połączonych sieci.
- **Brak weryfikacji źródła:** IP nie podejmuje żadnych prób sprawdzenia, czy źródłowy adres IP zawarty w pakiecie faktycznie pochodzi z tego źródła. Z tego powodu cyberprzestępcy mogą wysyłać pakiety, używając **sfabrykowanego źródłowego adresu IP** (IP spoofing).
- **Manipulacja nagłówkiem:** Napastnicy mogą również manipulować innymi polami w nagłówku IP w celu przeprowadzenia ataków. Dlatego dla analityków bezpieczeństwa kluczowe jest zrozumienie poszczególnych pól zarówno w nagłówku IPv4, jak i IPv6.

Nagłówek pakietu IPv4



Odczytujemy albo szerokość wiersza albo kolumny. Jedna kolumna ma 1 bajt, jeden wiersz ma 4 bajty w sumie.

Source IP (4 bajty):
4 kolumny
lub jeden wiersz

The IPv4 Packet Header (Contd.)

Pole nagłówka	Opis techniczny
Version (Wersja)	Zawiera 4-bitową wartość binarną ustawioną na 0100, która identyfikuje pakiet jako IPv4. Pozwala to urządzeniom sieciowym na poprawne zinterpretowanie reszty struktury nagłówka.
Internet Header Length (IHL)	4-bitowe pole określające długość nagłówka IP. Ponieważ minimalna długość nagłówka wynosi 20 bajtów , a pole to mierzy długość w 32-bitowych słowach, minimalna wartość w tym polu to 5.
Differentiated Services (DS / DiffServ)	Dawniej znane jako Type of Service (ToS) . Jest to 8-bitowe pole używane do określania priorytetu każdego pakietu w celach QoS (Quality of Service). • 6 najbardziej znaczących bitów to Differentiated Services Code Point (DSCP). • 2 ostatnie bity to Explicit Congestion Notification (ECN), używane do powiadamiania o przeciążeniach sieci bez odrzucania pakietów.
Total Length (Całkowita długość)	Określa długość całego pakietu IP, wliczając w to nagłówki oraz dane użytkownika (payload). Pole to ma rozmiar 2 bajtów (16 bitów), co oznacza, że maksymalna teoretyczna wielkość pakietu IP to 65 535 bajtów .

The IPv4 Packet Header (Contd.)

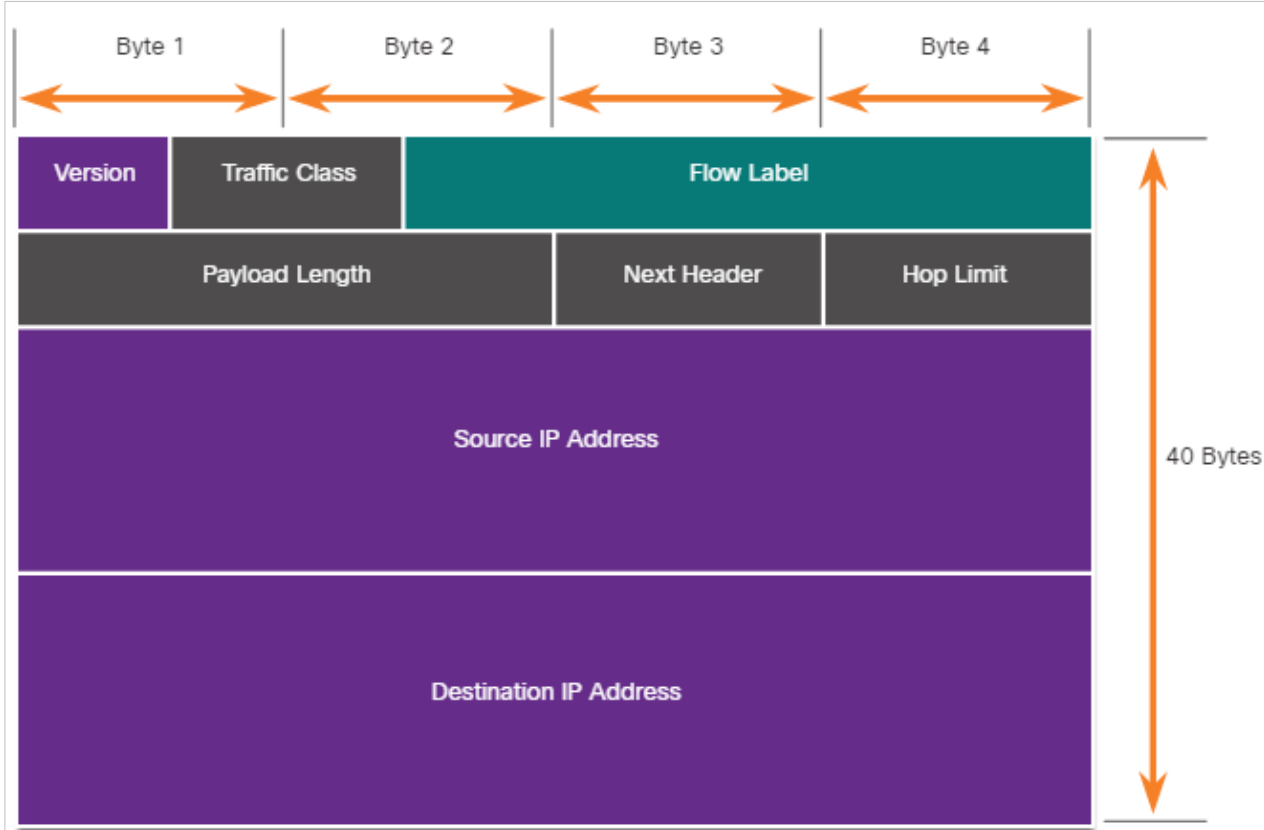
Pole nagłówka	Opis techniczny
Identification, Flags, Fragment Offset	Pola te są wykorzystywane do fragmentacji i ponownego składania pakietów. Gdy pakiet IP przemieszcza się przez sieć, może trafić na trasę, która nie obsługuje jego rozmiaru (przekracza MTU). W takim przypadku pakiet jest dzielony na mniejsze fragmenty, a te pola pozwalają hostowi docelowemu na ich poprawne uporządkowanie i scalenie.
Time-to-Live (TTL)	8-bitowe pole służące do ograniczenia czasu życia pakietu w sieci. Nadawca ustawia początkową wartość TTL, która jest zmniejszana o jeden przez każdy router na trasie. Jeśli wartość TTL spadnie do zera, router odrzuca pakiet i wysyła komunikat ICMP Time Exceeded do nadawcy. Zapobiega to krążeniu pakietów w nieskończoność w przypadku pętli routingu.
Protocol (Protokół)	8-bitowe pole identyfikujące protokół wyższej warstwy, który znajduje się wewnątrz pakietu (payload). Umożliwia to warstwie sieciowej przekazanie danych do odpowiedniego protokołu transportowego. Typowe wartości to: ICMP (1) , TCP (6) oraz UDP (17) .

The IPv4 Packet Header (Contd.)

Pole nagłówka	Opis techniczny
Header Checksum	16-bitowa wartość obliczana na podstawie zawartości samego nagłówka IP. Służy do sprawdzania, czy podczas transmisji nie wystąpiły błędy. Ponieważ pole TTL zmienia się w każdym routerze, suma kontrolna musi być przeliczana na każdym "skoku" (hop).
Source IPv4 Address	32-bitowa wartość binarna reprezentująca adres nadawcy. Zawsze musi to być adres typu unicast (indywidualny host), ponieważ pakiet musi pochodzić od konkretnego nadawcy. Zajmuje jeden pełny wiersz (4 bajty) w schemacie.
Destination IPv4 Address	32-bitowa wartość binarna reprezentująca adres odbiorcy. Może to być adres typu unicast, multicast lub broadcast. Również zajmuje jeden pełny wiersz (4 bajty).
Options and Padding	Pole o zmiennej długości (od 0 do wielokrotności 32 bitów). Jeśli same opcje nie wypełniają całego 32-bitowego wiersza, dodawane są zera (Padding), aby zapewnić, że nagłówek kończy się na równej granicy 4 bajtów.

Attacking the Foundation

Nagłówek IPv6



Ten wykres ma 10 wierszy!

Adres IPv6 ma 128 bitów, 16 bajtów, 4 wiersze

Attacking the Foundation

Nagłówek IPv6

Pole nagłówka IPv6	Opis
Version (Wersja)	To pole zawiera 4-bitową wartość binarną ustawioną na 0110, która identyfikuje pakiet jako IPv6 .
Traffic Class (Klasa ruchu)	To 8-bitowe pole jest odpowiednikiem pola Differentiated Services (DS) z nagłówka IPv4 (służy do priorytetyzacji ruchu).
Flow Label (Etykieta przepływu)	To 20-bitowe pole sugeruje, że wszystkie pakiety z tą samą etykietą powinny być obsługiwane przez routery w ten sam sposób (ułatwia obsługę strumieni danych).
Payload Length (Długość ładunku)	To 16-bitowe pole wskazuje długość samej części danych (ładunku) pakietu IPv6, nie wliczając w to nagłówka.
Next Header (Następny nagłówek)	To 8-bitowe pole jest odpowiednikiem pola Protocol z IPv4. Wskazuje typ danych, jakie niesie pakiet, co pozwala warstwie sieciowej przekazać dane do odpowiedniego protokołu warstwy wyższej (np. TCP lub UDP).

Attacking the Foundation

Nagłówek IPv6

Pole nagłówka IPv6	Opis
Hop Limit (Limit skoków)	To 8-bitowe pole zastępuje pole TTL z IPv4. Wartość ta jest zmniejszana o 1 przez każdy router, który przesyła pakiet. Gdy licznik osiągnie 0, pakiet jest odrzucany, a do nadawcy wysyłany jest komunikat ICMPv6 Time Exceeded , informujący, że pakiet nie dotarł do celu z powodu przekroczenia limitu skoków.
Source IPv6 Address (Adres źródłowy)	To 128-bitowe pole identyfikuje adres IPv6 hosta wysyłającego pakiet.
Destination IPv6 Address (Adres docelowy)	To 128-bitowe pole identyfikuje adres IPv6 hosta odbierającego pakiet.

- Pakiet IPv6 może również zawierać **nagłówki rozszerzeń (EH)**, które dostarczają opcjonalne informacje warstwy sieciowej. Nagłówki rozszerzeń są opcjonalne i umieszczają się je pomiędzy nagłówkiem IPv6 a ładunkiem (danymi). Nagłówki EH są używane do fragmentacji, bezpieczeństwa, wspierania mobilności i innych funkcji.

Nagłówek IPv4 vs IPv6

Cecha	IPv4
Długość adresu	32 bity (4 bajty)
Długość nagłówka	Zmienna (20–60 bajtów)
Liczba pól	12 pól (dużo małych klocków)
Fragmentacja	Obsługiwana przez routery i hosty
Suma kontrolna	Tak (Header Checksum)
Opcje	Wewnątrz nagłówka (pole <i>Options</i>)

6.4 Podatności

IP Vulnerabilities

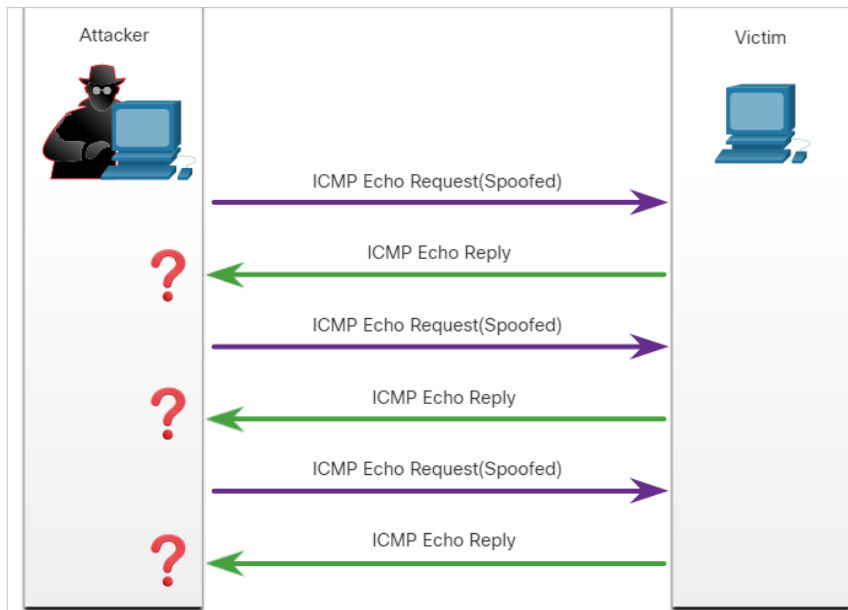
Podatności IP

Rodzaj ataku	Opis
Ataki ICMP	Napastnicy wykorzystują pakiety ICMP Echo (ping), aby odkrywać podsieci i hosty w chronionej sieci, generować ataki typu DoS (flood) oraz modyfikować tablice routingu hostów.
Ataki DoS (Denial of Service)	Próby uniemożliwienia legalnym użytkownikom dostępu do informacji lub usług (blokada usług).
Ataki DDoS (Distributed DoS)	Podobne do DoS, ale charakteryzują się jednoczesnym, skoordynowanym atakiem z wielu maszyn źródłowych .
Ataki z podrabianiem adresów (Spoofing)	Napastnicy podrabiają źródłowy adres IP (spoofing), próbując przeprowadzić spoofing "ślepy" (blind) lub "nie-ślepy" (non-blind).
Atak Man-in-the-Middle (MiTM)	Napastnicy umieszczają się między źródłem a celem, aby w sposób niezauważalny monitorować, przechwytywać i kontrolować komunikację. Mogą podsłuchiwać lub modyfikować pakiety przed wysłaniem ich dalej.
Przejmowanie sesji (Session hijacking)	Napastnicy uzyskują dostęp do sieci fizycznej, a następnie wykorzystują atak MiTM, aby przejąć aktywną sesję komunikacyjną.

Ataki ICMP

- Protokół ICMP został opracowany w celu przesyłania komunikatów diagnostycznych oraz zgłaszania błędów w sytuacjach, gdy trasy, hosty lub porty są niedostępne. Komunikaty ICMP są generowane przez urządzenia w momencie wystąpienia błędu sieciowego lub awarii.

Komenda **ping** to generowany przez użytkownika komunikat ICMP, nazywany **echo request** (żądaniem echa), który służy do weryfikacji łączności z celem. Napastnicy wykorzystują protokół ICMP do **rekonesansu** (zwiadu) oraz ataków typu **scanning** (skanowanie sieci). Napastnicy używają ICMP również do ataków **DoS** i **DDoS**, czego przykładem jest atak **ICMP flood** (zalewanie pakietami ICMP) przedstawiony na rysunku.



Uwaga: ICMP dla IPv4 (ICMPv4) oraz ICMP dla IPv6 (ICMPv6) są podatne na podobne rodzaje ataków.

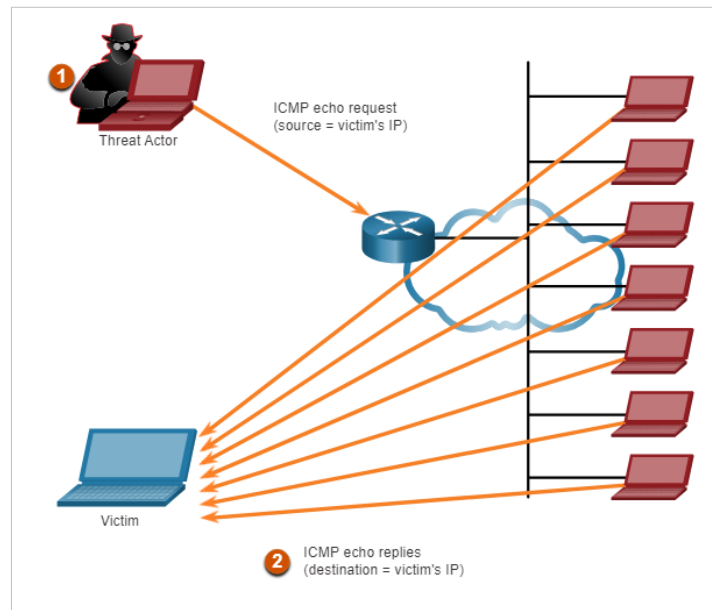
Ataki ICMP

- Sieci powinny posiadać rygorystyczne filtrowanie listami kontroli dostępu (ACL) dla protokołu ICMP na krawędzi sieci, aby uniknąć sondowania (probingu) ICMP z Internetu. Poniższa tabela przedstawia powszechne komunikaty ICMP, które znajdują się w kręgu zainteresowań napastników.

Komunikat ICMP	Opis
ICMP echo request / echo reply	Używane do weryfikacji dostępności hostów oraz do przeprowadzania ataków DoS (zalewania ruchem).
ICMP unreachable	Używane do przeprowadzania rekonesansu sieciowego oraz skanowania (pozwala określić, co jest blokowane, a co nie).
ICMP mask reply	Używane do mapowania wewnętrznej sieci IP (pomaga hakerowi poznać maskę podsieci i jej strukturę).
ICMP redirects	Używane do zwabienia hosta ofiary, by przysyłał cały ruch przez przejęte urządzenie (klasyczny wstęp do ataku MiTM).
ICMP router discovery	Używane do wstrzykiwania fałszywych wpisów do tablicy routingu docelowego hosta.

Ataki typu Amplification i Reflection (Wzmocnienie i Odbicie)

- **Ataki typu Wzmocnienie (Amplification) i Odbicie (Reflection)**
- **Ataki z wykorzystaniem wzmocnienia i odbicia:** Napastnicy często używają technik wzmocnienia oraz odbicia w celu generowania ataków DoS (blokady usług).
- **Atak Smurf:** Rysunek (na slajdzie) pokazuje, w jaki sposób technika wzmocnienia i odbicia, zwana atakiem Smurf, jest wykorzystywana do przeciążenia hosta docelowego.
- **Wzmocnienie (Amplification):** Napastnik przesyła żądania *ICMP echo request* (pingi) do wielu hostów jednocześnie. Wiadomości te zawierają sfałszowany adres IP źródła, który należy do ofiary.
- **Odbicie (Reflection):** Wszystkie te hosty odpowiadają na sfałszowany adres IP ofiary, co prowadzi do jej zasypania lawiną danych i przeciążenia.
- **Wyczerpanie zasobów:** Napastnicy stosują również ataki polegające na całkowitym wyczerpaniu zasobów (np. pamięci, mocy procesora lub pasma łącza) ofiary.



Uwaga: Obecnie wykorzystywane są nowsze formy ataków typu odbicie i wzmocnienie, takie jak ataki oparte na protokole **DNS** oraz ataki wzmocnienia **NTP** (Network Time Protocol).

Ataki typu Amplification i Reflection (Wzmocnienie i Odbicie)

▪ 1. Ataki oparte na DNS (DNS-based Reflection/Amplification)

- Haker wykorzystuje publiczne serwery DNS (tzw. open resolvers).
- **Zapytanie (małe):** Haker wysyła krótkie pytanie (np. o wszystkie rekordy DNS danej domeny). Oczywiście podrabia adres źródłowy na IP ofiary.
- **Odpowiedź (gigantyczna):** Serwer DNS wysyła do ofiary bardzo obszerną odpowiedź.
- **Wzmocnienie:** Stosunek zapytania do odpowiedzi może wynosić **1:50**. Oznacza to, że jeśli haker wysyła ruch o natężeniu 10 Mbps, ofiara zostaje uderzona falą **500 Mbps**.

▪ 2. Ataki NTP (Network Time Protocol)

- NTP służy do synchronizacji czasu w komputerach. Atak wykorzystuje często komendę monlist, która zwraca listę ostatnich 600 adresów IP, z którymi komunikował się serwer.
- **Mały pakiet:** Haker wysyła zapytanie o listę monlist.
- **Wielka odpowiedź:** Serwer wysyła kilkadziesiąt pakietów z danymi do ofiary.
- **Wzmocnienie:** Tutaj mnożnik może wynieść nawet **1:200** lub więcej! To jedna z najpotężniejszych metod DDoS.

Ataki polegające na podszywaniu się pod adres IP (Address Spoofing)

- Ataki typu IP spoofing występują, gdy napastnik tworzy pakiety z fałszywymi informacjami o źródłowym adresie IP, aby ukryć tożsamość nadawcy lub podszyć się pod innego, uprawnionego użytkownika.
- Napastnik może dzięki temu uzyskać dostęp do danych, które w innym przypadku byłyby niedostępne, lub obejść konfiguracje zabezpieczeń.
- Spoofing jest zazwyczaj częścią innego ataku, takiego jak atak Smurf.
- Ataki typu spoofing mogą być "nie-ślepe" (non-blind) lub "ślepe" (blind):
 - **Spoofing nie-ślepy (Non-blind spoofing)** Napastnik widzi ruch przesyłany między hostem a celem. Wykorzystuje tę metodę do inspekcji pakietu odpowiedzi od ofiary. Spoofing nie-ślepy pozwala określić stan zapory sieciowej (firewalla) oraz przewidzieć numery sekwencyjne. Może również służyć do przejęcia autoryzowanej sesji.
 - **Spoofing ślepy (Blind spoofing)** Napastnik nie widzi ruchu przesyłanego między hostem a celem. Spoofing ślepy jest wykorzystywany głównie w atakach typu DoS (blokada usług).

Ataki polegające na podszywaniu się pod adres IP (Address Spoofing)

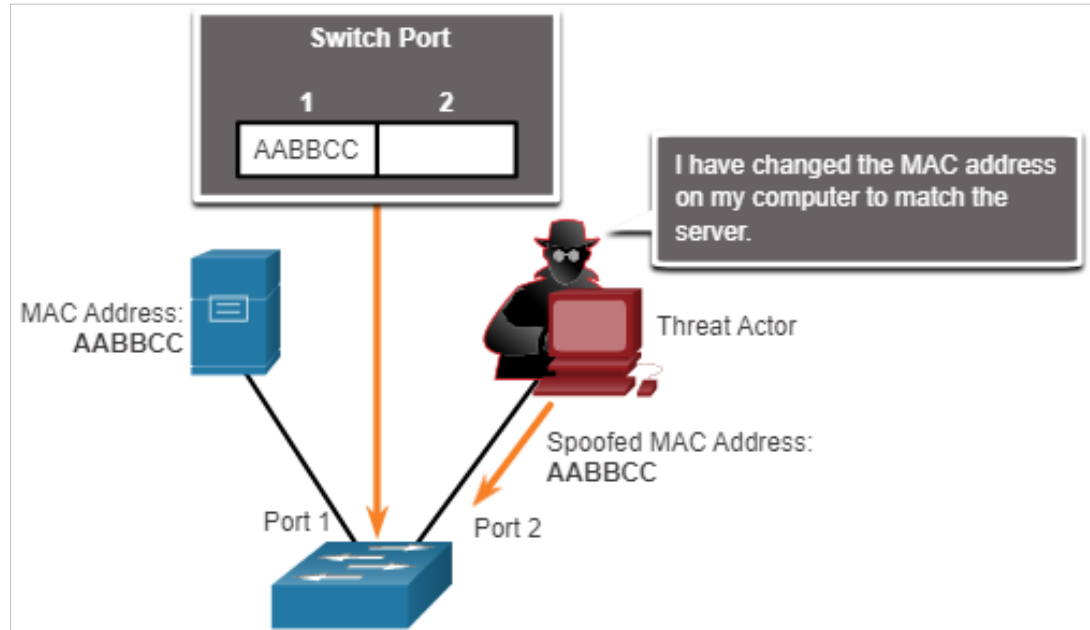
Ataki polegające na podszywaniu się pod adres MAC (MAC Address Spoofing)

Ataki z podrabianiem adresu MAC są stosowane, gdy napastnicy mają dostęp do sieci wewnętrznej.

Napastnicy zmieniają adres MAC swojego hosta tak, aby zgadzał się z innym, znanym adresem MAC hosta docelowego (ofiary), co przedstawiono na rysunku.

Host atakujący wysyła następnie w głąb sieci ramkę z nowo skonfigurowanym adresem MAC.

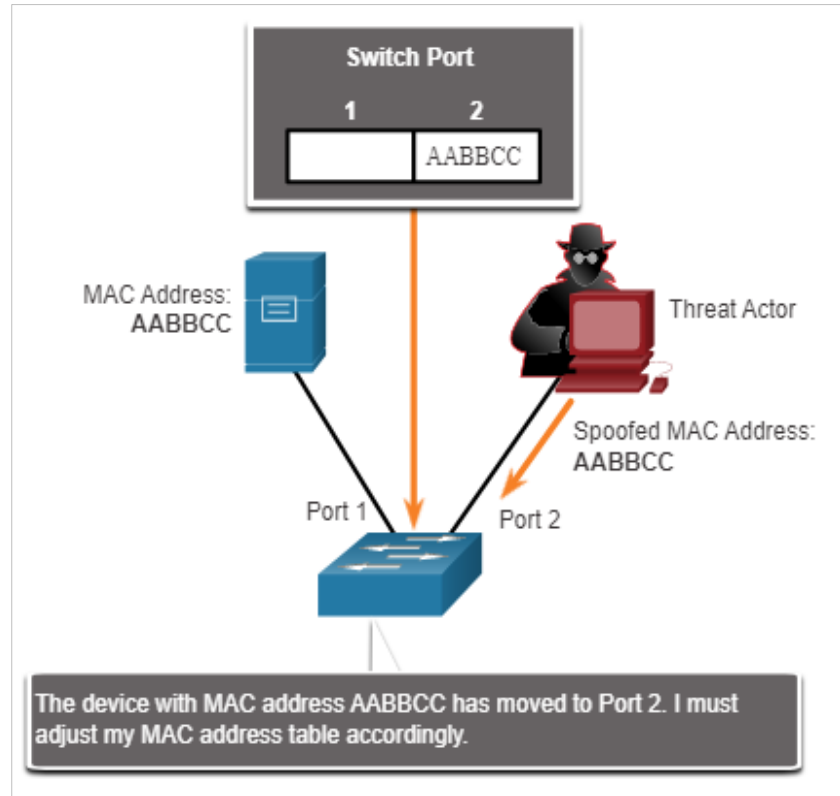
Gdy przełącznik (switch) otrzymuje taką ramkę, bada źródłowy adres MAC.



Ataki polegające na podszywaniu się pod adres IP (Address Spoofing)

Skutki ataku i spoofing usług

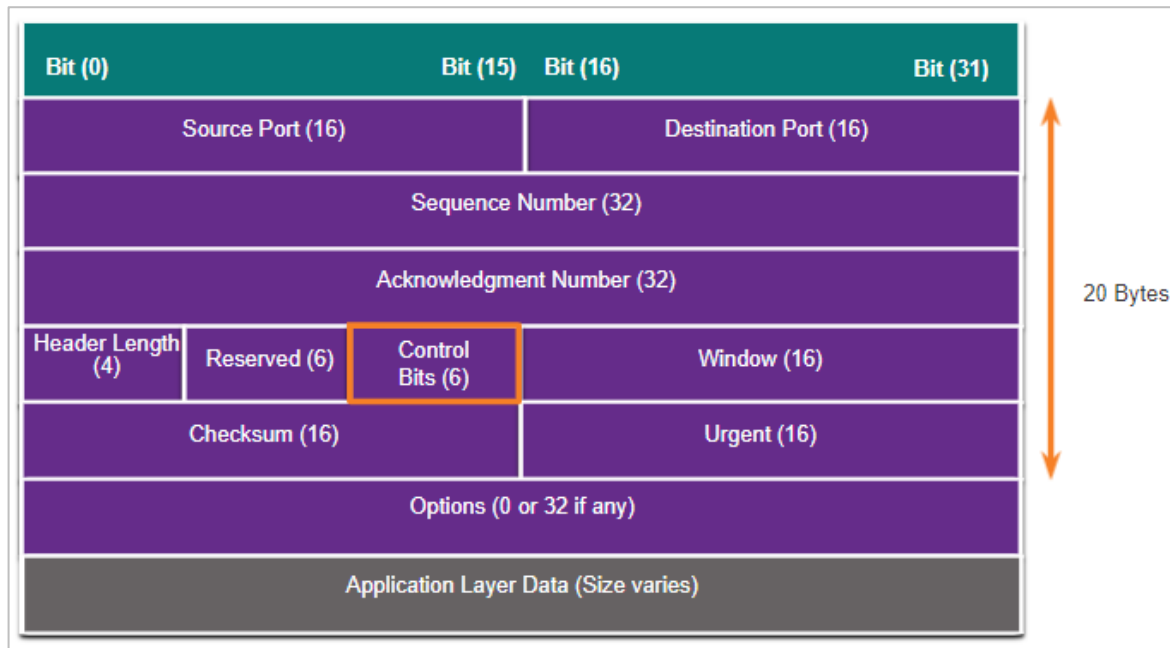
- Przełącznik nadpisuje bieżący wpis w tablicy CAM i przypisuje dany adres MAC do nowego portu, jak pokazano na rysunku.
- Następnie przełącznik przekazuje ramki przeznaczone dla hosta docelowego (ofiary) do hosta atakującego.
- Innym przykładem podszywania się jest spoofing aplikacji lub usług. Napastnik może podłączyć do sieci nielegalny (rogue) serwer DHCP, aby stworzyć warunki do ataku typu MiTM.



6.5 Podatności TCP i UDP

Nagłówek TCP

- Informacje o segmencie TCP pojawiają się bezpośrednio po nagłówku IP. Pola segmentu TCP oraz flagi pola bitów kontrolnych (Control Bits) są przedstawione na rysunku. Poniżej znajduje się sześć bitów kontrolnych segmentu TCP:



Nagłówek TCP

Bit (Flaga)	Znaczenie	Opis
URG	Urgent	Pole wskaźnika pilności (dane priorytetowe).
ACK	Acknowledgment	Pole potwierdzenia (potwierdzenie odebrania danych).
PSH	Push	Funkcja natychmiastowej wysyłki (nie czeka na zapełnienie bufora).
RST	Reset	Zresetowanie połączenia (natychmiastowe przerwanie).
SYN	Synchronize	Synchronizacja numerów sekwencyjnych (początek rozmowy).
FIN	Finish	Brak danych od nadawcy (koniec rozmowy).

Usługi protokołu TCP

- **Niezawodne dostarczanie (Reliable delivery)** – TCP wykorzystuje potwierdzenia, aby zagwarantować dostarczenie danych, zamiast polegać na protokołach wyższych warstw w kwestii wykrywania i naprawiania błędów. Jeśli potwierdzenie nie zostanie odebrane w odpowiednim czasie, nadawca ponownie przesyła dane. Wymóg potwierdzania odebranych danych może powodować znaczne opóźnienia. Przykłady protokołów warstwy aplikacji, które korzystają z niezawodności TCP, to m.in. HTTP, SSL/TLS, FTP oraz transfery stref DNS.
- **Sterowanie przepływem (Flow control)** – TCP implementuje sterowanie przepływem, aby rozwiązać problem wydajności. Zamiast potwierdzać każdy segment z osobna, wiele segmentów może zostać potwierdzonych za pomocą jednego, wspólnego segmentu potwierdzenia.
- **Komunikacja stanowa (Stateful communication)** – Stanowa komunikacja TCP między dwiema stronami zachodzi podczas procesu trójetapowego uzgadniania (three-way handshake). Zanim dane będą mogły być przesyłane za pomocą TCP, połączenie jest otwierane przez ten proces. Jeśli obie strony wyrażą zgodę na połączenie, dane mogą być wysyłane i odbierane przez obie strony przy użyciu TCP.

TCP and UDP Vulnerabilities

Usługi protokołu TCP

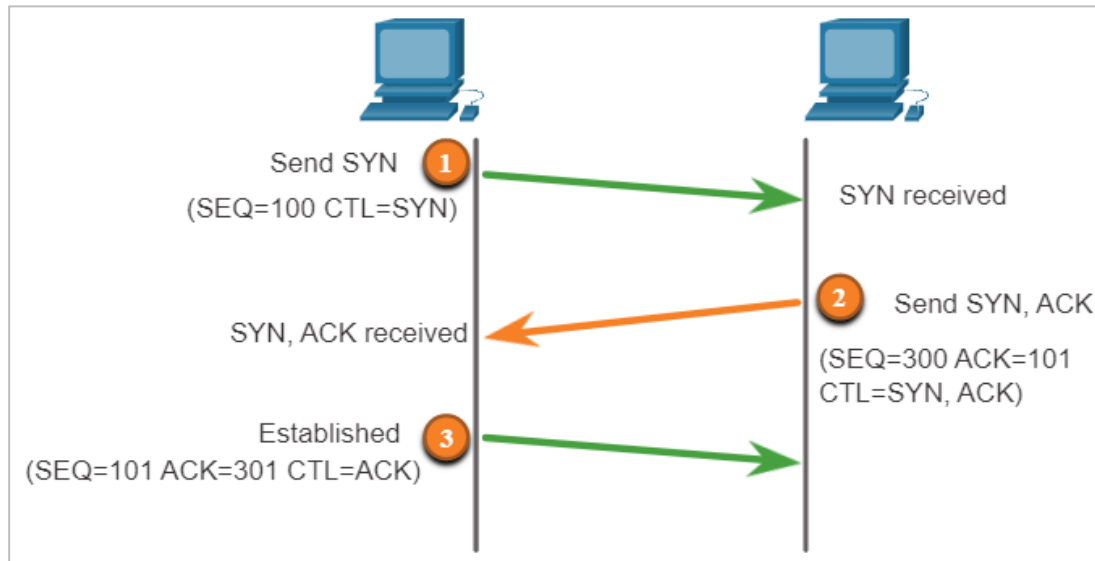
Trójetapowe uzgadnianie połączenia TCP (TCP Three-Way Handshake)

Połączenie TCP jest nawiązywane w trzech krokach:

1. Klient inicjujący wysyła do serwera prośbę o sesję komunikacyjną (klient-serwer).

2. Serwer potwierdza sesję komunikacyjną klient-serwer i wysyła własną prośbę o sesję komunikacyjną (serwer-klient).

3. Klient inicjujący potwierdza sesję komunikacyjną serwer-klient.

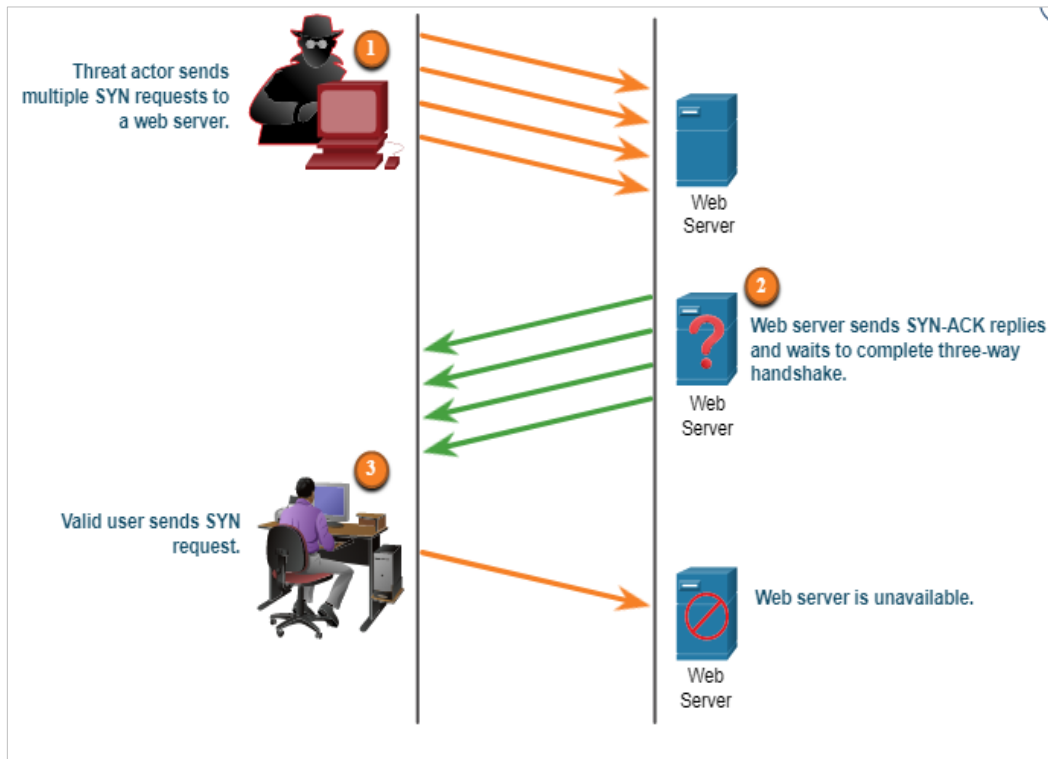


Ataki na TCP

Aplikacje sieciowe używają portów TCP lub UDP. Napastnicy przeprowadzają skanowanie portów urządzeń docelowych, aby odkryć, jakie usługi one oferują.

Atak TCP SYN Flood

- Atak TCP SYN Flood wykorzystuje proces trójetapowego uzgadniania połączenia TCP (three-way handshake).
- Rysunek przedstawia napastnika, który nieustannie wysyła do celu pakiety żądań sesji TCP SYN z losowo sfałszowanymi źródłowymi adresami IP.
- Cel odpowiada pakietem TCP SYN-ACK na sfałszowany adres IP i czeka na pakiet TCP ACK. Odpowiedzi te nigdy nie nadchodzą. Host docelowy posiada zbyt wiele "półotwartych" połączeń TCP, przez co usługi TCP stają się niedostępne dla legalnych użytkowników.

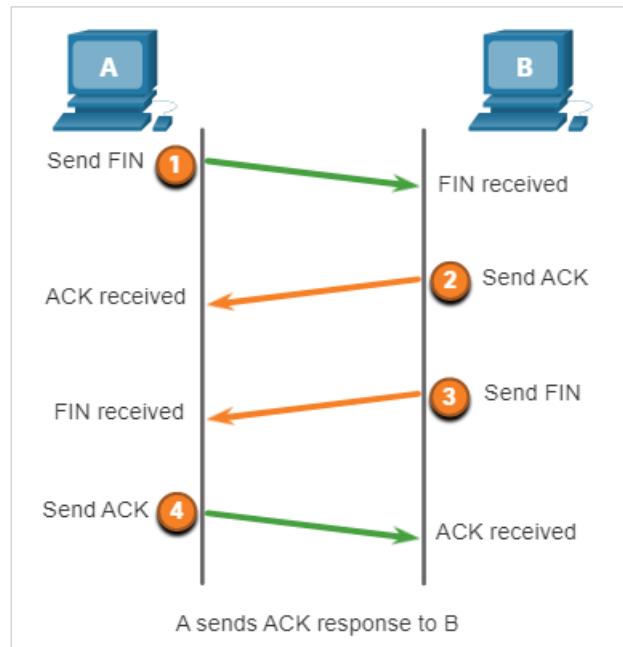


Ataki na TCP

- **Atak TCP Reset** może zostać wykorzystany do przerwania komunikacji TCP między dwoma hostami. Napastnik może przeprowadzić taki atak, wysyłając sfałszowany pakiet zawierający flagę TCP RST do jednego lub obu punktów końcowych (hostów).

Standardowe zamykanie sesji TCP odbywa się w procesie czteroetapowej wymiany (four-way exchange):

- Kiedy klient nie ma już więcej danych do wysłania w strumieniu, wysyła segment z ustawioną flagą **FIN**.
- Serwer wysyła **ACK**, aby potwierdzić odebranie flagi FIN i zakończyć sesję w kierunku od klienta do serwera.
- Serwer wysyła flagę **FIN** do klienta, aby zakończyć sesję w kierunku od serwera do klienta.
- Klient odpowiada flagą **ACK**, aby potwierdzić odebranie flagi FIN od serwera.



Ataki na TCP

Przejmowanie sesji TCP (TCP Session Hijacking)

Przejmowanie sesji TCP to kolejna podatność protokołu TCP.

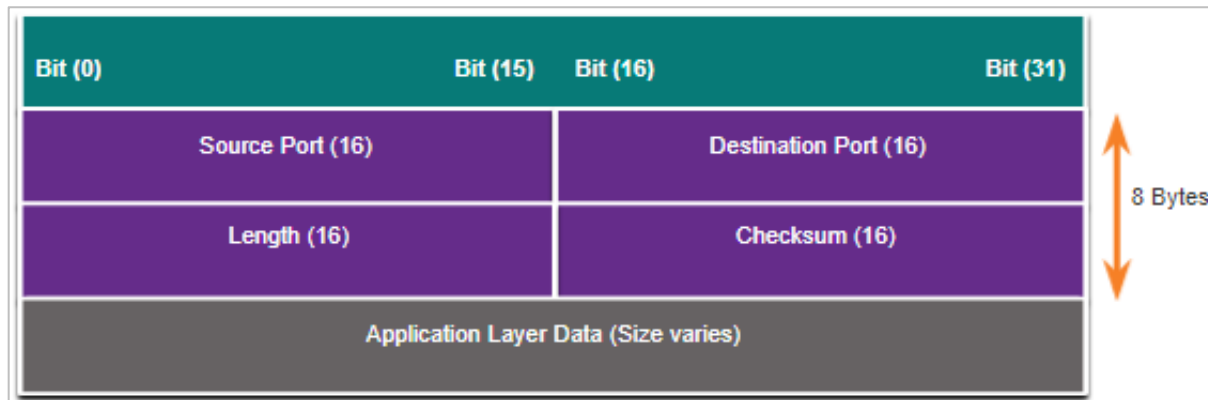
Napastnik przejmuje kontrolę nad już uwierzytelnionym hostem podczas jego komunikacji z celem.

Napastnik musi sfałszować adres IP jednego z hostów, przewidzieć następny numer sekwencyjny i wysłać pakiet ACK do drugiego hosta.

W przypadku powodzenia napastnik może wysyłać dane do urządzenia docelowego, ale nie może ich odbierać.

Nagłówek i działanie segmentu UDP

- UDP jest powszechnie używany przez protokoły takie jak DNS, DHCP, TFTP, NFS oraz SNMP.
- Jest on również wykorzystywany w aplikacjach czasu rzeczywistego, takich jak przesyłanie strumieniowe multimedialnych (streaming) czy VoIP.
- UDP jest bezpołączeniowym protokołem warstwy transportowej.
- Struktura segmentu UDP, przedstawiona na rysunku, jest znacznie mniejsza niż w przypadku TCP.
- Chociaż UDP jest zwykle nazywany niezawodnym, nie oznacza to, że aplikacje korzystające z UDP są zawsze niezawodne. Oznacza to, że funkcje te nie są zapewniane przez protokół warstwy transportowej i muszą zostać zaimplementowane gdzie indziej, jeśli są wymagane.
- Niski narzut protokołu UDP sprawia, że jest on bardzo pożądanym dla protokołów, które wykonują proste transakcje typu zapytanie-odpowiedź.



Ataki na UDP

- UDP nie jest chronione przez żadne szyfrowanie.
- Szyfrowanie może zostać dodane do UDP, ale nie jest ono dostępne domyślnie.
- Brak szyfrowania oznacza, że każdy może zobaczyć ruch, zmienić go i przesłać dalej do miejsca przeznaczenia.
- Ataki UDP Flood
 - W ataku UDP Flood zużywane są wszystkie zasoby sieciowe.
 - Napastnik musi użyć narzędzia takiego jak UDP Unicorn lub Low Orbit Ion Cannon (LOIC).
 - Narzędzia te wysyłają falę pakietów UDP, często ze sfałszowanego hosta, do serwera w podsieci.
 - Program przeszukuje wszystkie znane porty, próbując znaleźć porty zamknięte. Spowoduje to, że serwer odpowie komunikatem ICMP "port unreachable" (port nieosiągalny). Ponieważ na serwerze jest wiele zamkniętych portów, generuje to ogromny ruch w segmencie sieci, co zużywa większość przepustowości. Wynik jest bardzo podobny do ataku DoS.





Zrozumienie mechanizmów obronnych oraz kontrola dostępu

CyberOps Associate v1.0



7.1 Obrona w głąb

Aktywa, Podatności, Zagrożenia

- Analitycy cyberbezpieczeństwa muszą być przygotowani na każdy rodzaj ataku. Ich zadaniem jest zabezpieczenie aktywów (zasobów) sieci organizacji. Aby to zrobić, analitycy cyberbezpieczeństwa muszą najpierw zidentyfikować:
 - **Aktywa (Assets)** – Wszystko, co ma wartość dla organizacji i musi być chronione, w tym serwery, urządzenia infrastrukturalne, urządzenia końcowe oraz największy zasób – dane.
 - **Podatności (Vulnerabilities)** – Słabość w systemie lub jego projekcie, która mogłaby zostać wykorzystana przez napastnika.
 - **Zagrożenia (Threats)** – Każde potencjalne niebezpieczeństwo dla zasobu.

Identyfikacja zasobów

- Zbiór wszystkich urządzeń i informacji posiadanych lub zarządzanych przez organizację stanowi jej zasoby (aktywa). Zasoby te muszą zostać zinwentaryzowane i ocenione pod kątem poziomu ochrony niezbędnego do udaremnienia potencjalnych ataków.
- Zarządzanie zasobami polega na inwentaryzacji wszystkich aktywów, a następnie opracowaniu i wdrożeniu polityk oraz procedur mających na celu ich ochronę. Zadanie to może być zniechęcające, biorąc pod uwagę, że wiele organizacji musi chronić użytkowników i zasoby wewnętrzne, pracowników mobilnych oraz usługi oparte na chmurze i usługi wirtualne.
- Ponadto organizacje muszą zidentyfikować, gdzie przechowywane są krytyczne zasoby informacyjne i w jaki sposób uzyskuje się do nich dostęp. Zasoby informacyjne są zróżnicowane, podobnie jak zagrożenia wobec nich. Każdy z tych zasobów może przyciągać innych sprawców zagrożeń, o różnym poziomie umiejętności i motywacjach.

Identyfikacja podatności

- Identyfikacja zagrożeń dostarcza organizacji listę prawdopodobnych podatności dla konkretnego środowiska. Podczas identyfikowania zagrożeń ważne jest, aby zadać kilka pytań:
 - Jakie są możliwe **podatności** systemu?
 - Kto może chcieć wykorzystać te **podatności**, aby uzyskać dostęp do konkretnych zasobów informacyjnych?
 - Jakie będą konsekwencje, jeśli **podatności** systemu zostaną wykorzystane, a zasoby utracone?

Identyfikacja podatności

Identyfikacja zagrożeń dla systemu bankowości elektronicznej obejmowałaby:

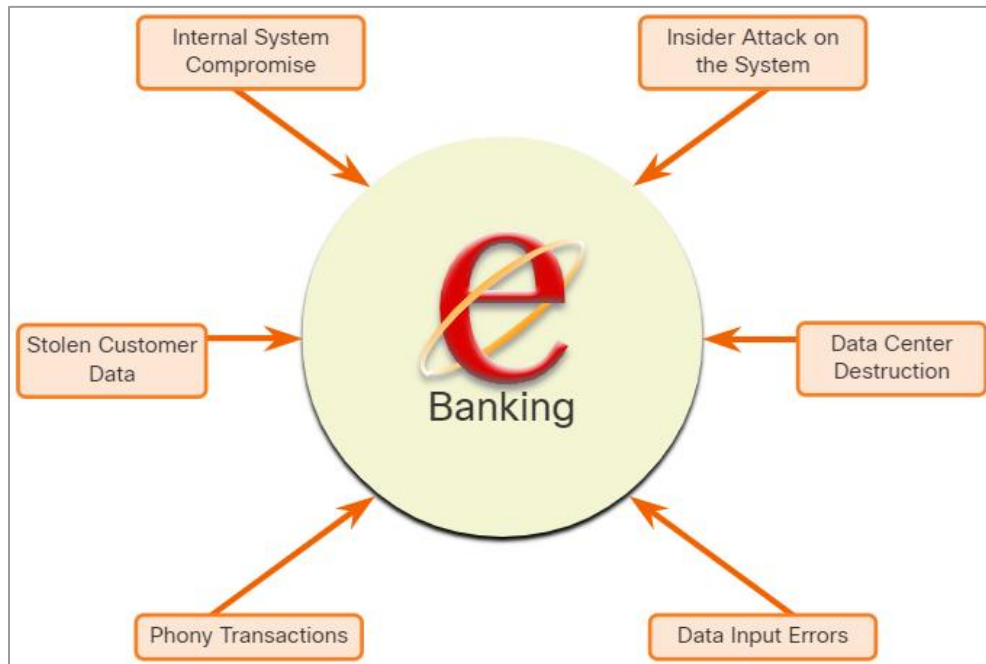
Skompromitowanie systemu

wewnętrznego – napastnik wykorzystuje wystawione na zewnątrz serwery bankowości elektronicznej, aby włamać się do wewnętrznego systemu bankowego.

Kradzież danych klientów – napastnik kradnie dane osobowe i finansowe klientów banku z bazy danych klientów.

Fałszywe transakcje z serwera

zewnętrznego – napastnik modyfikuje kod aplikacji bankowości elektronicznej i dokonuje transakcji, podszywając się pod uprawnionego użytkownika.

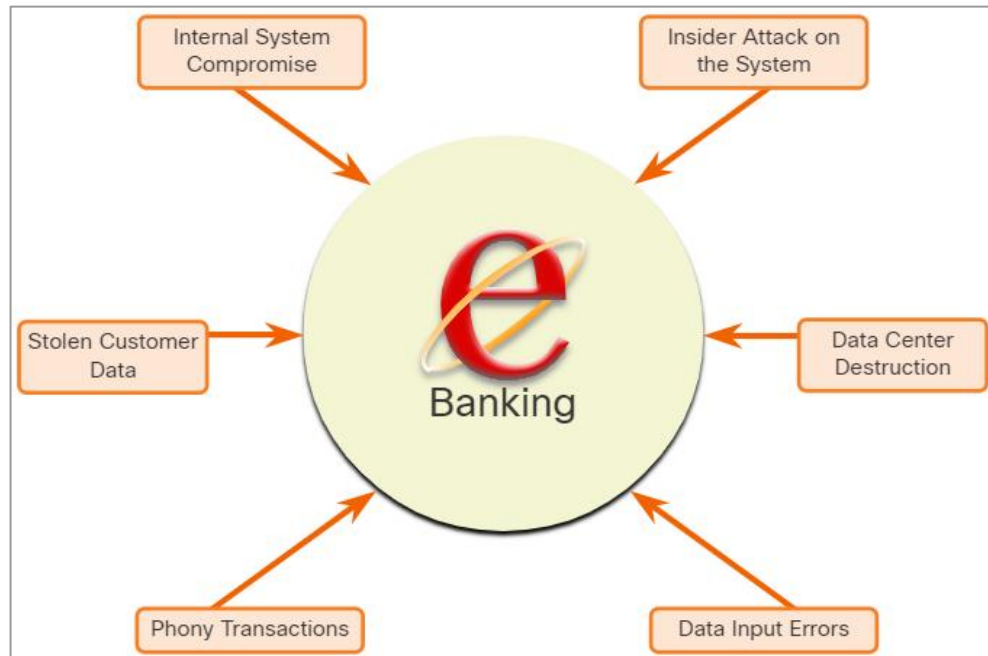


Identyfikacja podatności

Fałszywe transakcje z użyciem skradzionego kodu PIN lub karty procesorowej (smart card) – napastnik kradnie tożsamość klienta i dokonuje złośliwych transakcji ze skompromitowanego konta.

Błędy wprowadzania danych – użytkownik wprowadza nieprawidłowe dane lub składa błędne zlecenia transakcji.

Zniszczenie centrum danych – zdarzenie katastroficzne poważnie uszkadza lub niszczy centrum danych.



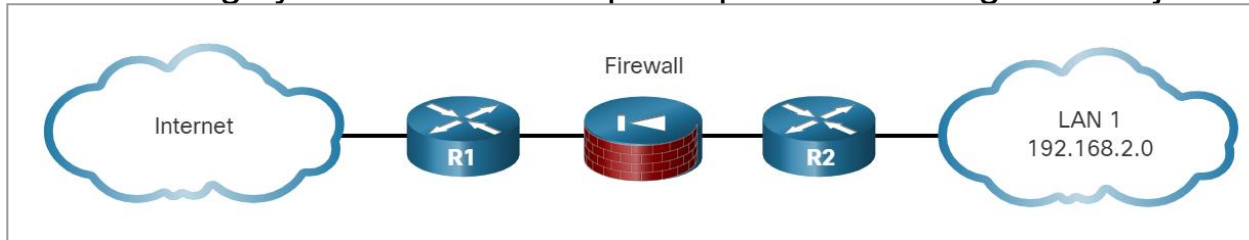
Identyfikowanie podatności w sieci wymaga zrozumienia ważnych aplikacji, które są używane, a także różnych podatności tych aplikacji i sprzętu. Wymaga to znacznej ilości badań ze strony administratora sieci.

Identyfikacja zagrożenia

- Organizacje muszą stosować podejście obrony w głąb (defense-in-depth), aby identyfikować zagrożenia i zabezpieczać podatne zasoby. Podejście to wykorzystuje wiele warstw zabezpieczeń na brzegu sieci, wewnątrz sieci oraz na punktach końcowych sieci.
- W tym podejściu router najpierw sprawdza ruch przed przekazaniem go do dedykowanego urządzenia typu firewall, na przykład Cisco ASA. Routery i zapory ogniowe nie są jedynymi urządzeniami stosowanymi w strategii obrony w głąb.
- Inne urządzenia zabezpieczające obejmują systemy zapobiegania włamaniom (IPS), zaawansowaną ochronę przed złośliwym oprogramowaniem (AMP), systemy bezpieczeństwa treści WWW i poczty e-mail, usługi tożsamości, kontrolę dostępu do sieci (NAC) i inne. W warstwowym podejściu obrony w głąb różne warstwy współpracują ze sobą, tworząc architekturę bezpieczeństwa, w której awaria jednego zabezpieczenia nie wpływa na skuteczność pozostałych.

Identyfikacja zagrożenia

- Rysunek przedstawia prostą topologię podejścia obrony w głąb (defense-in-depth):
 - **Router brzegowy** – Pierwsza linia obrony jest znana jako router brzegowy (R1 na rysunku). Router brzegowy posiada zestaw reguł określających, który ruch jest dozwolony, a który odrzucany. Przekazuje on wszystkie połączenia przeznaczone dla wewnętrznej sieci LAN do zapory ogniowej (firewall).
 - **Firewall** – Drugą linią obrony jest zapora ogniowa. Firewall to urządzenie kontrolne (checkpoint), które wykonuje dodatkowe filtrowanie i śledzi stan połączeń. Uniemożliwia on inicjowanie połączeń z sieci niezaufanych do sieci zaufanej, jednocześnie umożliwiając użytkownikom wewnętrznym nawiązywanie dwukierunkowych połączeń z sieciami niezaufanymi.
 - **Router wewnętrzny** – Kolejną linią obrony jest router wewnętrzny (R2 na rysunku). Może on stosować końcowe reguły filtrowania ruchu przed przekazaniem go do miejsca docelowego.

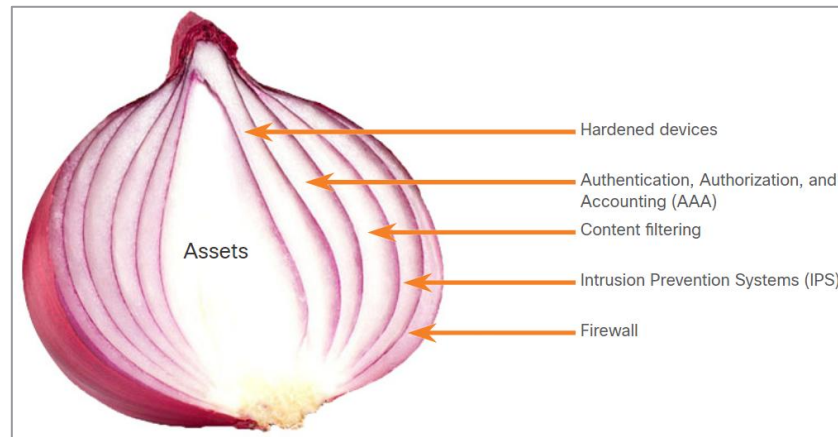


Cebula Bezpieczeństwa (The Security Onion) i Karczoch Bezpieczeństwa (The Security Artichoke)

Istnieją dwie popularne analogie używane do opisu podejścia obrony w głąb (defense-in-depth).

Cebula Bezpieczeństwa (Security Onion)

Popularną analogią używaną do opisania podejścia obrony w głąb jest tak zwana „cebula bezpieczeństwa”. Jak zilustrowano na rysunku, napastnik musiałby zdejmować kolejne warstwy obrony sieci jedna po drugiej, w sposób podobny do obierania cebuli. Dopiero po spenetrowaniu każdej z warstw napastnik dotarłby do docelowych danych lub systemu.



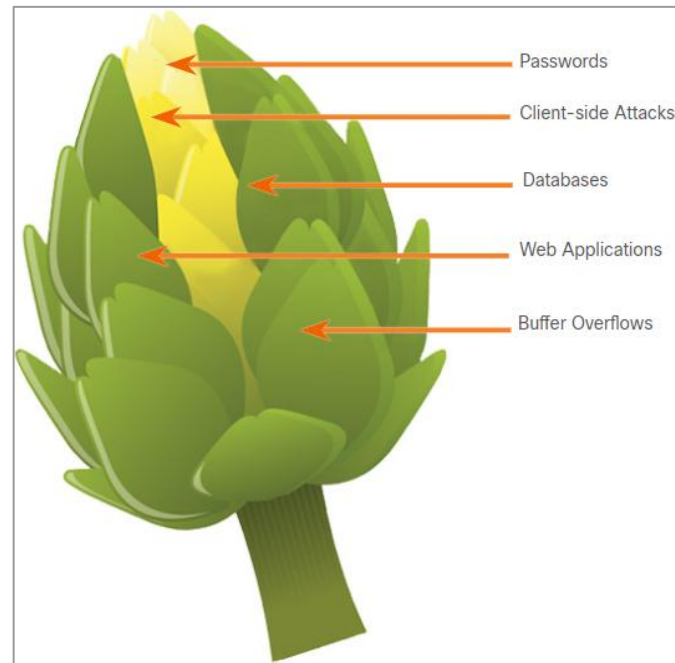
Uwaga: Opisana na tej stronie cebula bezpieczeństwa jest sposobem wizualizacji obrony w głąb. Nie należy jej mylić z pakietem narzędzi bezpieczeństwa sieciowego o nazwie Security Onion.

Cebula Bezpieczeństwa (The Security Onion) i Karczoch Bezpieczeństwa (The Security Artichoke)

- **Karczoch Bezpieczeństwa (Security Artichoke)**

Ewolucja sieci pozbawionych wyraźnych granic (borderless networks) zmieniła tę analogię na „karczocha bezpieczeństwa”, co sprzyja napastnikom. Jak zilustrowano na rysunku, sprawcy zagrożeń nie muszą już zdejmować każdej warstwy po kolei. Muszą jedynie usunąć niektóre „liście karczocha”.

- Dodatkową korzyścią dla napastnika jest to, że każdy „liść” sieci może ujawnić wrażliwe dane, które nie są dobrze zabezpieczone. Aby dostać się do serca karczocha, haker stopniowo wykrusza pancerz bezpieczeństwa wzdłuż obwodu. Choć systemy wystawione na działanie Internetu są bardzo dobrze chronione, wytrwali hakerzy znajdują lukę w tej twardej powłoce zewnętrznej, przez którą mogą wejść do środka.



7.2 Polityki bezpieczeństwa, regulacje i standardy

Polityki biznesowe

- Polityki biznesowe to wytyczne opracowane przez organizację w celu kierowania jej działaniami. Polityki te definiują standardy poprawnego zachowania dla firmy i jej pracowników.
- W dziedzinie sieci komputerowych polityki określają działania, które są dozwolone w sieci. Pozwala to na ustalenie punktu odniesienia (baseline) dla dopuszczalnego użytkowania. Jeśli w sieci zostanie wykryte zachowanie naruszające politykę biznesową, istnieje prawdopodobieństwo, że doszło do naruszenia bezpieczeństwa.

Polityki biznesowe

Polityka	Opis
Polityki firmy (Company policies)	• Ustanawiają zasady postępowania oraz zakres odpowiedzialności zarówno pracowników, jak i pracodawców. • Chronią prawa pracowników, a także interesy biznesowe pracodawców. • W zależności od potrzeb organizacji, różne polityki i procedury określają zasady dotyczące zachowania pracowników, obecności, dress code'u, prywatności oraz innych obszarów związanych z warunkami zatrudnienia.
Polityki pracownicze (Employee policies)	• Są tworzone i utrzymywane przez dział kadr (HR) w celu określenia wynagrodzenia, harmonogramu wypłat, świadczeń pracowniczych, grafiku pracy, urlopów i innych kwestii. • Często są przekazywane nowym pracownikom do zapoznania się i podpisania.
Polityki bezpieczeństwa (Security policies)	• Określają cele bezpieczeństwa firmy, definiują zasady zachowania dla użytkowników i administratorów oraz precyzują wymagania systemowe. • Cele te, zasady i wymagania zbiorczo zapewniają bezpieczeństwo sieci oraz systemów komputerowych w organizacji. • Jest to dokument podlegający ciągłym zmianom w oparciu o ewolucję krajobrazu zagrożeń, podatności oraz wymagania biznesowe i pracownicze.

Polityka bezpieczeństwa

- Polityki bezpieczeństwa służą do informowania użytkowników, personelu oraz kadry zarządzającej o wymaganiach organizacji w zakresie ochrony technologii i zasobów informacyjnych. Kompleksowa polityka bezpieczeństwa niesie ze sobą szereg korzyści, w tym:
 - **Potwierdza zaangażowanie organizacji w kwestie bezpieczeństwa.**
 - **Określa zasady oczekiwanego zachowania.**
 - **Zapewnia spójność** w działaniu systemów, nabywaniu i użytkowaniu oprogramowania oraz sprzętu, a także w ich konserwacji.
 - **Definiuje konsekwencje prawne naruszeń.**
 - **Daje personelowi odpowiedzialnemu za bezpieczeństwo wsparcie ze strony kierownictwa.**
- Polityka bezpieczeństwa precyzuje również mechanizmy niezbędne do spełnienia wymagań bezpieczeństwa oraz stanowi punkt odniesienia (baseline) do nabywania, konfigurowania i audytowania systemów komputerowych oraz sieci pod kątem zgodności.

Polityka bezpieczeństwa

Polityka	Opis
Polityka identyfikacji i uwierzytelniania	Określa osoby upoważnione do dostępu do zasobów sieciowych oraz procedury weryfikacji tożsamości.
Polityki haseł	Zapewniają, że hasła spełniają minimalne wymagania i są regularnie zmieniane.
Polityka dopuszczalnego użytkownika (AUP)	Określa aplikacje sieciowe i sposoby korzystania z sieci, które są akceptowalne dla organizacji. Może również określać konsekwencje naruszenia tej polityki.
Polityka dostępu zdalnego	Określa, w jaki sposób użytkownicy zdalni mogą uzyskiwać dostęp do sieci oraz co jest dostępne poprzez łączność zdalną.
Polityka konserwacji sieci	Określa procedury aktualizacji systemów operacyjnych urządzeń sieciowych oraz aplikacji użytkowników końcowych.
Procedury obsługi incydentów	Opisują sposób postępowania w przypadku wystąpienia incydentów bezpieczeństwa.

Polityki BYOD

- Koncepcja „Przynieś własne urządzenie” (BYOD – Bring Your Own Device) umożliwia pracownikom korzystanie z ich własnych urządzeń mobilnych w celu uzyskania dostępu do systemów firmowych, oprogramowania, sieci lub informacji. Zapewnia to przedsiębiorstwom kluczowe korzyści, w tym zwiększoną produktywność, obniżone koszty, lepszą mobilność pracowników i tym podobne. Korzyści te niosą jednak ze sobą również zwiększone ryzyko bezpieczeństwa, ponieważ BYOD może prowadzić do wycieków danych i większej odpowiedzialności prawnej organizacji.
- W związku z tym należy opracować politykę bezpieczeństwa BYOD, aby zrealizować następujące cele:
 - **Określenie celów programu BYOD.**
 - **Wskazanie, którzy pracownicy mogą przynosić własne urządzenia.**
 - **Określenie, które urządzenia będą wspierane.**
 - **Określenie poziomu dostępu przyznawanego pracownikom korzystającym z urządzeń osobistych.**
 - **Opisanie uprawnień do dostępu oraz działań personelu bezpieczeństwa dozwolonych na urządzeniu.**
 - **Wskazanie przepisów (regulacji), których należy przestrzegać podczas korzystania z urządzeń pracowników.**
 - **Określenie zabezpieczeń, które należy wdrożyć w przypadku skompromitowania urządzenia.**

Security Policies, Regulations, and Standards

Polityki BYOD

Najlepsza praktyka	Opis
Zabezpieczenie dostępu hasłem	Używaj unikalnych haseł dla każdego urządzenia i konta.
Ręczne sterowanie łącznością bezprzewodową	Wyłączaj Wi-Fi i Bluetooth, gdy nie są używane. Łącz się wyłącznie z zaufanymi sieciami.
Bieżące aktualizacje	Zawsze dbaj o aktualność systemu operacyjnego i oprogramowania. Zaktualizowane oprogramowanie często zawiera poprawki bezpieczeństwa chroniące przed najnowszymi zagrożeniami i exploitami.
Tworzenie kopii zapasowych danych	Włącz tworzenie kopii zapasowych urządzenia na wypadek jego zagubienia lub kradzieży.
Włączenie funkcji „Znajdź moje urządzenie”	Korzystaj z usługi lokalizacji urządzenia z funkcją zdalnego czyszczenia danych (remote wipe).
Zapewnienie oprogramowania antywirusowego	Dostarczaj oprogramowanie antywirusowe dla zatwierdzonych urządzeń BYOD.
Korzystanie z oprogramowania Mobile Device Management (MDM)	Oprogramowanie MDM umożliwia zespołom IT wdrażanie ustawień bezpieczeństwa i konfiguracji oprogramowania na wszystkich urządzeniach łączących się z sieciami firmowymi.

Zgodność z regulacjami i standardami

- Istnieją również zewnętrzne regulacje dotyczące bezpieczeństwa sieci. Specjaliści ds. bezpieczeństwa sieci muszą znać przepisy prawa oraz kodeksy etyczne, które są wiążące dla osób zajmujących się bezpieczeństwem systemów informacyjnych (INFOSEC).
- Wiele organizacji jest zobowiązanych do opracowania i wdrożenia polityk bezpieczeństwa. Przepisy dotyczące zgodności (compliance) określają, za co organizacje są odpowiedzialne oraz jaką ponoszą odpowiedzialność prawną w przypadku niedopełnienia tych obowiązków.
- Regulacje, których organizacja musi przestrzegać, zależą od rodzaju organizacji oraz typu danych, jakie ona przetwarza.

7.3 Konceptcje kontroli dostępu

Bezpieczeństwo komunikacji: CIA

- Bezpieczeństwo informacji zajmuje się ochroną informacji oraz systemów informacyjnych przed nieuprawnionym dostępem, użyciem, ujawnieniem, zakłóceniem, modyfikacją lub zniszczeniem.
- **Triada CIA** Triada CIA składa się z trzech komponentów bezpieczeństwa informacji:
 - **Poufność (Confidentiality)** – Tylko upoważnione osoby, podmioty lub procesy mają dostęp do wrażliwych informacji.
 - **Integralność (Integrity)** – Odnosi się do ochrony danych przed nieautoryzowaną zmianą (modyfikacją).
 - **Dostępność (Availability)** – Upoważnieni użytkownicy muszą mieć nieprzerwany dostęp do zasobów sieciowych i danych, których potrzebują.



Bezpieczeństwo Zero Trust

- Zero Trust (brak zaufania) to kompleksowe podejście do zabezpieczania każdego rodzaju dostępu w sieciach, aplikacjach i środowiskach. Podejście to pomaga zabezpieczyć dostęp uzyskiwany przez użytkowników, urządzenia końcowe, interfejsy API, urządzenia IoT, mikrousługi, kontenery i wiele innych elementów.
- Główną zasadą podejścia Zero Trust jest: **„nigdy nie ufaj, zawsze weryfikuj”**.
- Struktura bezpieczeństwa Zero Trust pomaga zapobiegać nieautoryzowanemu dostępowi, ograniczać skutki naruszeń (containment) oraz zmniejszać ryzyko poruszania się napastnika wewnątrz sieci (ruch boczny – lateral movement).
- W podejściu Zero Trust każde miejsce, w którym wymagane jest podjęcie decyzji o kontroli dostępu, powinno być traktowane jako obwód (perimeter).

Bezpieczeństwo Zero Trust

- **Trzema filarami Zero Trust są: pracownicy (workforce), obciążenia robocze (workloads) oraz miejsce pracy (workplace).**
 - **Zero Trust dla pracowników (Workforce)** – Ten filar obejmuje osoby, które uzyskują dostęp do aplikacji roboczych za pomocą urządzeń osobistych lub zarządzanych przez korporację. Zapewnia on, że tylko właściwi użytkownicy i bezpieczne urządzenia mogą uzyskać dostęp do aplikacji, niezależnie od lokalizacji.
 - **Zero Trust dla obciążeń roboczych (Workloads)** – Ten filar dotyczy aplikacji działających w chmurze, w centrach danych i innych środowiskach zwirtualizowanych, które wchodzi ze sobą w interakcje. Skupia się na bezpiecznym dostępie w sytuacjach, gdy interfejs API, mikrousluga lub kontener uzyskuje dostęp do bazy danych w ramach aplikacji.
 - **Zero Trust dla miejsca pracy (Workplace)** – Ten filar koncentruje się na bezpiecznym dostępie dla wszystkich urządzeń, w tym Internetu Rzeczy (IoT), które łączą się z sieciami korporacyjnymi, takich jak punkty końcowe użytkowników, serwery fizyczne i wirtualne, drukarki, kamery i inne.

Modele kontroli dostępu

- Organizacja musi wdrożyć odpowiednie mechanizmy kontroli dostępu, aby chronić swoje zasoby sieciowe, zasoby systemów informatycznych oraz same informacje. Analityk bezpieczeństwa powinien znać różne podstawowe modele kontroli dostępu, aby lepiej zrozumieć, w jaki sposób napastnicy mogą je przełamać.
- Poniższa tabela przedstawia różne typy modeli kontroli dostępu:

Modele kontroli dostępu	Opis
Uznaniowa kontrola dostępu (DAC – <i>discretionary access control</i>)	- To najmniej restrykcyjny model; pozwala użytkownikom kontrolować dostęp do swoich danych jako ich właścicielom. - Może wykorzystywać listy kontroli dostępu (ACL) lub inne metody, aby określić, którzy użytkownicy lub grupy mają dostęp do informacji.
Obowiązkowa kontrola dostępu (MAC – <i>mandatory access control</i>)	- Stosuje najsurowszą kontrolę dostępu i jest używana w zastosowaniach wojskowych lub krytycznych dla misji. - Przypisuje etykiety poziomu bezpieczeństwa do informacji i umożliwia użytkownikom dostęp na podstawie przyznanego im poświadczenia bezpieczeństwa.

Access Control Models (Contd.)

Modele kontroli dostępu	Opis
Kontrola dostępu oparta na rolach (RBAC – <i>role-based access control</i>)	• Decyzje o dostępie są podejmowane na podstawie ról i zakresu odpowiedzialności danej osoby w organizacji. • Do różnych ról przypisuje się uprawnienia bezpieczeństwa, a poszczególne osoby są przypisywane do profilu RBAC właściwego dla danej roli. • Model ten jest znany również jako rodzaj niedyskrecjonalnej kontroli dostępu.
Kontrola dostępu oparta na atrybutach (ABAC – <i>attribute-based access control</i>)	• Umożliwia dostęp na podstawie cech (atrybutów) obiektu, do którego użytkownik chce wejść, podmiotu uzyskującego dostęp oraz czynników środowiskowych dotyczących sposobu uzyskiwania dostępu.
Kontrola dostępu oparta na regułach (RBAC – <i>rule-based access control</i>)	• Personel odpowiedzialny za bezpieczeństwo sieci określa zestawy reguł lub warunków powiązanych z dostępem do danych lub systemów. • Reguły te mogą określać dozwolone lub zablokowane adresy IP, konkretne protokoły lub inne warunki. • Model ten jest również znany jako <i>rule-based RBAC</i>.
Kontrola dostępu oparta na czasie (TAC – <i>time-based access control</i>)	• Umożliwia dostęp do zasobów sieciowych w oparciu o konkretną godzinę oraz dzień tygodnia.

7.4 Koncepcja AAA (Authentication, Authorization, and Accounting)

Działanie AAA

- Sieć musi być zaprojektowana w taki sposób, aby kontrolować, kto może się z nią połączyć oraz co może robić po uzyskaniu połączenia. Wymagania projektowe tego typu są określane w polityce bezpieczeństwa sieci.
- Polityka ta precyzuje, w jaki sposób administratorzy sieci, użytkownicy korporacyjni, użytkownicy zdalni, partnerzy biznesowi oraz klienci uzyskują dostęp do zasobów sieciowych.
- Polityka bezpieczeństwa sieci może również nakładać obowiązek wdrożenia systemu rozliczania (accounting), który śledzi, kto się zalogował, kiedy to nastąpiło oraz jakie czynności zostały wykonane podczas sesji. Protokół AAA (*authentication, authorization, and accounting*) zapewnia niezbędne ramy (framework) umożliwiające wdrażanie skalowalnych zabezpieczeń dostępu.

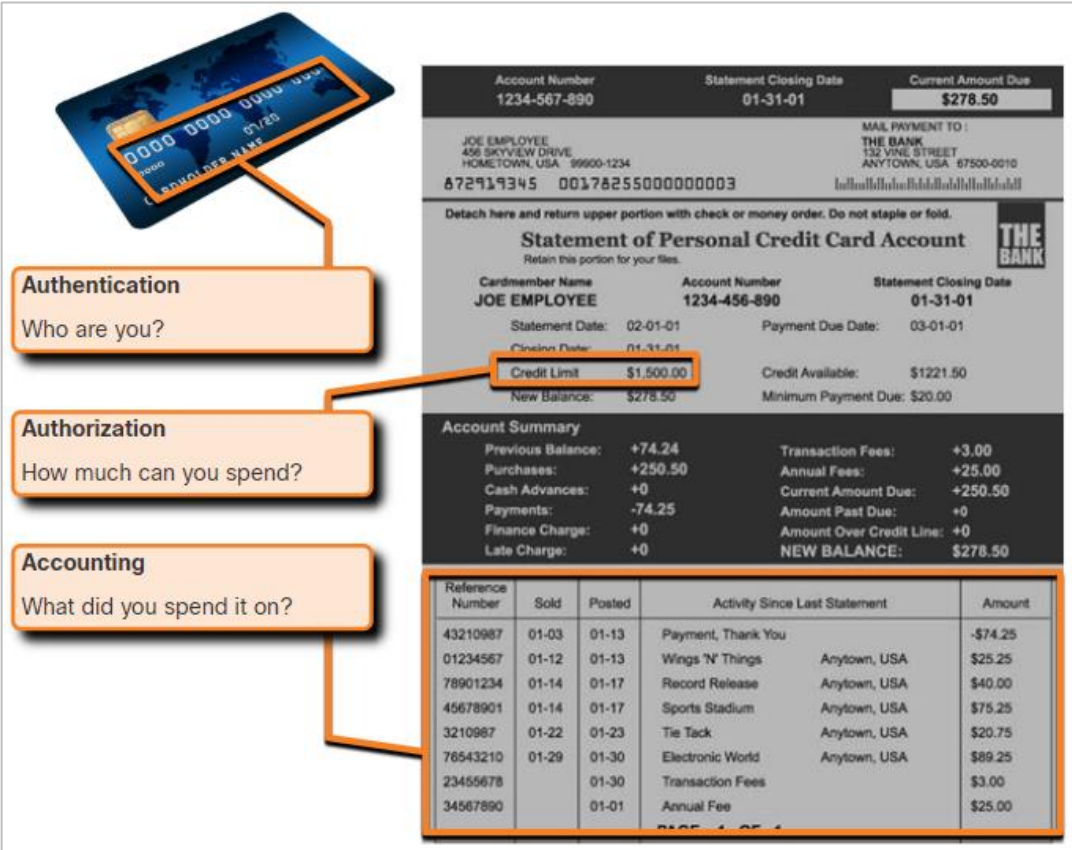
Działanie AAA

Komponent AAA	Opis
Uwierzytelnianie (authentication)	• Może być realizowane za pomocą kombinacji nazw użytkowników i haseł, pytań kontrolnych (challenge and response), kart tokenowych oraz innych metod. • Uwierzytelnianie AAA zapewnia scentralizowany sposób kontrolowania dostępu do sieci.
Autoryzacja (authorization)	• Po uwierzytelnieniu użytkownika usługi autoryzacji określają, do których zasobów ma on dostęp i jakie operacje może wykonywać. • Przykład: „Użytkownik może uzyskać dostęp do serwera XYZ wyłącznie za pomocą protokołu SSH”.
Rozliczanie (accounting)	• Rejestruje działania użytkownika, w tym uzyskiwany dostęp do zasobów, czas trwania sesji oraz wszelkie wprowadzone zmiany. • Pozwala na śledzenie sposobu wykorzystania zasobów sieciowych. • Przykład: „Użytkownik korzystał z serwera XYZ przez SSH przez 15 minut”.

AAA Usage and Operation

Działanie AAA

Koncepcja ta jest podobna do korzystania z karty kredytowej, co przedstawiono na rysunku. Karta kredytowa identyfikuje, kto może jej używać, określa, ile dany użytkownik może wydać, oraz prowadzi ewidencję przedmiotów, na które użytkownik wydał pieniądze.



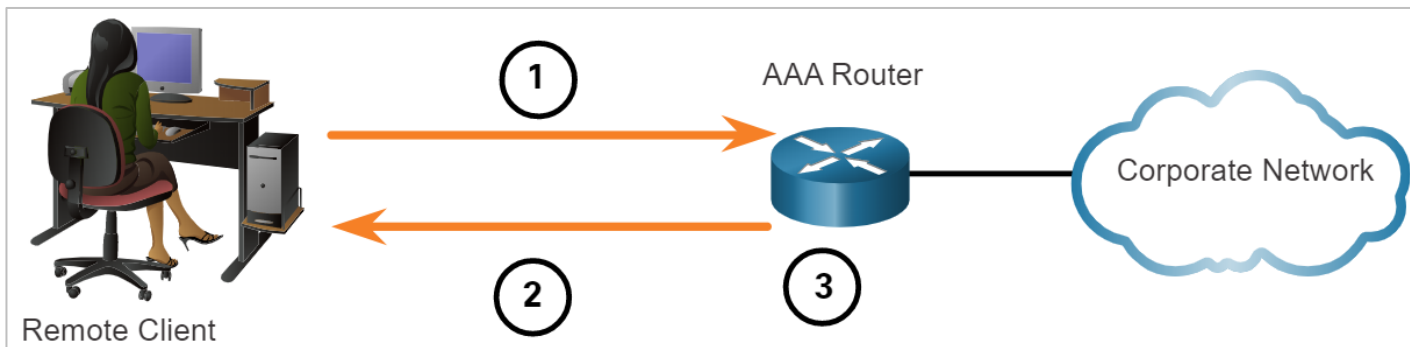
Uwierzytelnianie AAA

- Uwierzytelnianie AAA może być wykorzystywane do weryfikacji tożsamości użytkowników uzyskujących dostęp administracyjny lub dostęp zdalny do sieci. Cisco oferuje dwie popularne metody wdrażania usług AAA:
 - **Lokalne uwierzytelnianie AAA**
 - Metoda ta jest znana jako uwierzytelnianie autonomiczne (self-contained), ponieważ weryfikuje użytkowników na podstawie nazw użytkowników i haseł przechowywanych lokalnie na urządzeniu. Lokalne AAA jest idealnym rozwiązaniem dla małych sieci.

Uwierzytelnianie AAA

■ Proces lokalnego uwierzytelniania AAA

- Klient nawiązuje połączenie z routerem.
- Router AAA prosi użytkownika o podanie nazwy użytkownika i hasła.
- Router uwierzytelnia dane logowania, korzystając z lokalnej bazy danych, a następnie przyznaje użytkownikowi dostęp do sieci na podstawie informacji zawartych w tej bazie.



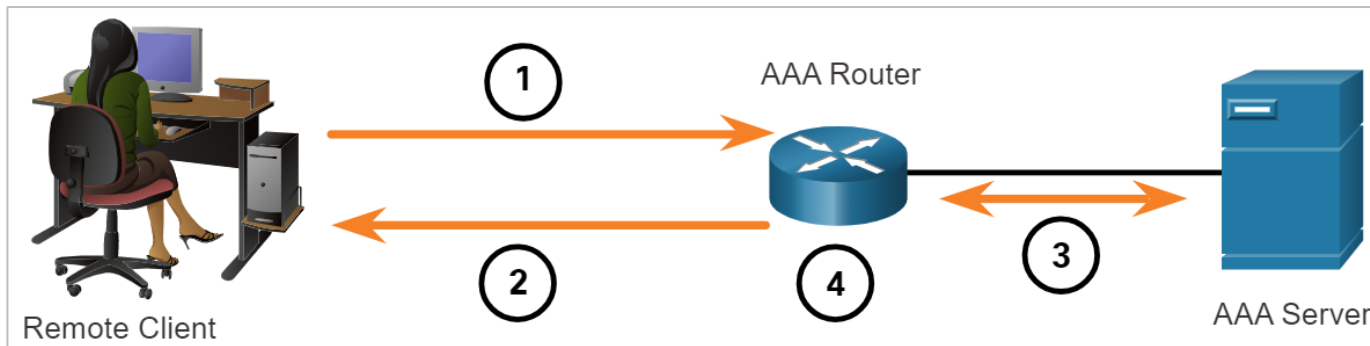
Uwierzytelnianie AAA

Uwierzytelnianie AAA oparte na serwerze

- Ta metoda przeprowadza uwierzytelnianie na centralnym serwerze AAA, który zawiera nazwy użytkowników i hasła wszystkich osób. Jest to idealne rozwiązanie dla średnich i dużych sieci.

Kroki procesu:

- Klient nawiązuje połączenie z routerem.
- Router AAA prosi użytkownika o podanie nazwy użytkownika i hasła.
- Router uwierzytelnia nazwę użytkownika i hasło, komunikując się z zewnętrznym serwerem AAA.
- Użytkownik uzyskuje dostęp do sieci na podstawie informacji zawartych na zdalnym serwerze AAA.



Uwierzytelnianie AAA

- **Scentralizowane AAA**
- Scentralizowane AAA jest bardziej skalowalne i łatwiejsze w zarządzaniu niż lokalne uwierzytelnianie AAA, dlatego jest preferowaną metodą wdrażania tego modelu.
- Scentralizowany system AAA może niezależnie utrzymywać bazy danych dla uwierzytelniania, autoryzacji oraz rozliczania. Może on wykorzystywać usługi takie jak Active Directory lub protokół LDAP (*lightweight directory access protocol*) do uwierzytelniania użytkowników i sprawdzania przynależności do grup, zachowując przy tym własne bazy danych autoryzacji i rozliczania.
- Urządzenia komunikują się ze scentralizowanym serwerem AAA przy użyciu protokołów RADIUS (*remote authentication dial-in user service*) lub TACACS+ (*terminal access controller access-control system plus*).

Uwierzytelnianie AAA

Funkcja	TACACS+	RADIUS
Funkcjonalność	Rozdziela funkcje uwierzytelniania, autoryzacji i rozliczania zgodnie z architekturą AAA. Pozwala to na modułowość implementacji serwera bezpieczeństwa.	Łączy uwierzytelnianie i autoryzację, ale rozdziela rozliczanie, co pozwala na mniejszą elastyczność wdrożenia niż w przypadku TACACS+.
Standard	Obsługiwany głównie przez Cisco (standard własnościowy/rozszerzony).	Otwarty standard (RFC).
Transport	Protokół TCP , port 49 .	Protokół UDP , porty 1812 i 1813 (lub starsze 1645 i 1646).
Protokół CHAP	Dwukierunkowe wyzwanie i odpowiedź (challenge and response), stosowane w protokole CHAP.	Jednokierunkowe wyzwanie i odpowiedź od serwera bezpieczeństwa RADIUS do klienta RADIUS.

Uwierzytelnianie AAA

Funkcja	TACACS+	RADIUS
Poufność (Confidentiality)	Szyfruje całą treść (body) pakietu , pozostawiając jedynie standardowy nagłówek TACACS+.	Szyfruje wyłącznie hasło w pakiecie żądania dostępu (<i>access-request</i>) od klienta do serwera. Reszta pakietu jest niezaszyfrowana, co pozostawia nazwę użytkownika, autoryzowane usługi i dane rozliczeniowe bez ochrony.
Personalizacja (Customization)	Umożliwia autoryzację komend routera dla konkretnego użytkownika lub grupy.	Nie posiada opcji autoryzacji komend routera na poziomie pojedynczego użytkownika lub grupy.
Rozliczanie (Accounting)	Ograniczone	Rozbudowane

Uwierzytelnianie AAA

▪ Kluczowe różnice:

- **Bezpieczeństwo:** **TACACS+** szyfruje całą treść pakietu, natomiast **RADIUS** szyfruje tylko hasło. Z tego powodu TACACS+ jest uważany za bezpieczniejszy do celów administracyjnych.
- **Niezawodność:** Dzięki zastosowaniu **TCP**, TACACS+ oferuje potwierdzenie dostarczenia pakietów, co czyni go bardziej stabilnym w zarządzaniu urządzeniami. RADIUS (używający **UDP**) jest szybszy i bardziej wydajny przy obsłudze tysięcy użytkowników końcowych (np. w sieciach Wi-Fi).

▪ Zastosowanie:

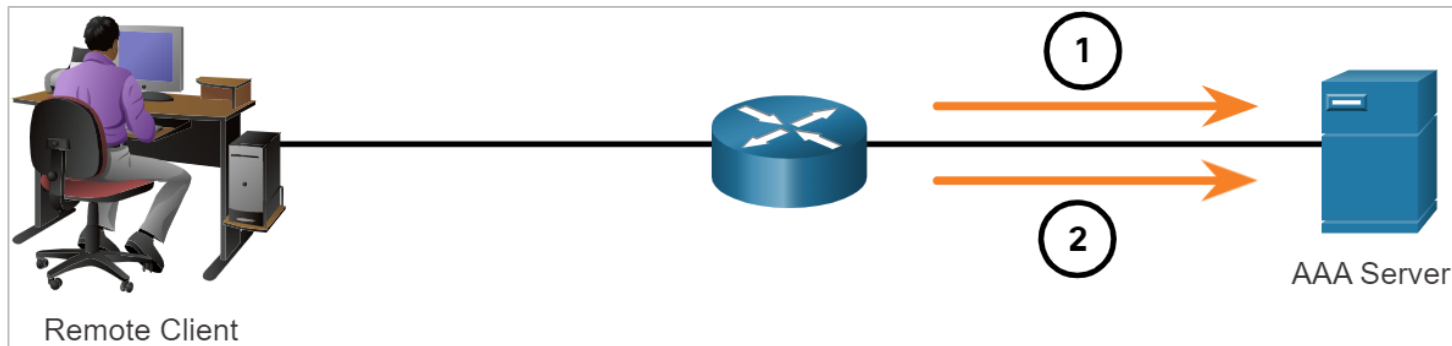
- **TACACS+** wybieramy zazwyczaj do **zarządzania urządzeniami** (Device Administration) – aby kontrolować, co administratorzy wpisują w konsoli routera.
- **RADIUS** wybieramy do **dostępu sieciowego** (Network Access) – dla użytkowników łączących się przez VPN lub Wi-Fi.

Logi rozliczania AAA

- Scentralizowany system AAA umożliwia efektywne wykorzystanie metody rozliczania (*Accounting*). Rekordy rozliczeniowe ze wszystkich urządzeń są przesyłane do scentralizowanych repozytoriów, co znacząco upraszcza audyt działań użytkowników.
- Rozliczanie AAA gromadzi i raportuje dane o użyciu zasobów w formie logów AAA. Logi te są niezwykle przydatne w audytach bezpieczeństwa. Gromadzone dane mogą obejmować:
 - czas rozpoczęcia i zakończenia połączenia,
 - wykonane komendy,
 - liczbę przesłanych pakietów,
 - liczbę przesłanych bajtów.
- Jednym z powszechnie stosowanych zastosowań rozliczania jest połączenie go z uwierzytelnianiem AAA. Pomaga to personelowi administracyjnemu w precyzyjnym zarządzaniu dostępem do urządzeń sieciowych.

Logi rozliczania AAA

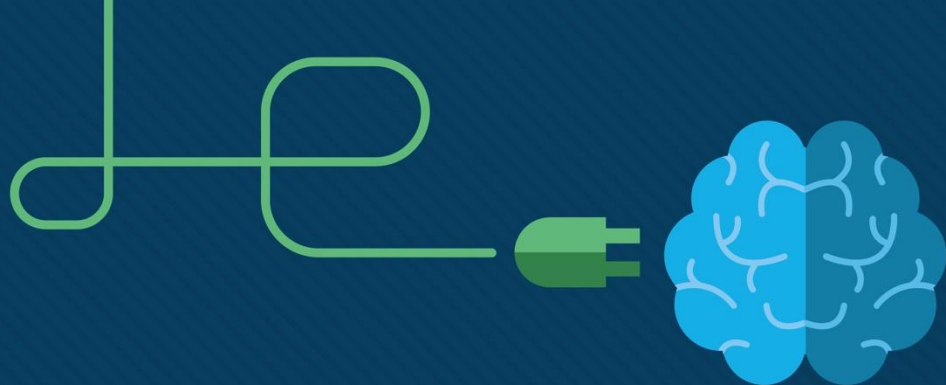
- Rozliczanie zapewnia wyższy poziom bezpieczeństwa niż samo uwierzytelnianie. Serwery AAA prowadzą szczegółowy dziennik (log) tego, co dokładnie uwierzytelniony użytkownik robi na urządzeniu.
- Obejmuje to wszystkie polecenia trybu **EXEC** (operacyjne) oraz polecenia **konfiguracyjne** wydane przez użytkownika. Proces ten przebiega następująco:
 - **Komunikat START:** Gdy użytkownik zostanie pomyślnie uwierzytelniony, proces rozliczania AAA generuje komunikat „start”, aby rozpocząć rejestrowanie sesji.
 - **Komunikat STOP:** Gdy użytkownik kończy pracę, rejestrowany jest komunikat „stop” i proces rozliczania dla tej sesji zostaje zakończony.



Logi rozliczania AAA

Typ rozliczania	Opis
Rozliczanie sieciowe (<i>Network Accounting</i>)	Rejestruje informacje o wszystkich sesjach protokołu PPP (Point-to-Point Protocol), w tym liczbę przesłanych pakietów oraz bajtów.
Rozliczanie połączeń (<i>Connection Accounting</i>)	Gromadzi dane o wszystkich połączeniach wychodzących nawiązywanych z klienta AAA (np. routera), takich jak sesje SSH.
Rozliczanie sesji EXEC (<i>EXEC Accounting</i>)	Rejestruje informacje o sesjach terminalowych użytkowników (tryb EXEC) na serwerze dostępowym, w tym: nazwę użytkownika, datę, czas rozpoczęcia i zakończenia oraz adres IP serwera.
Rozliczanie systemowe (<i>System Accounting</i>)	Gromadzi informacje o wszystkich zdarzeniach na poziomie systemowym (np. restart urządzenia, zmiany w oprogramowaniu).
Rozliczanie komend (<i>Command Accounting</i>)	Rejestruje informacje o komendach powłoki EXEC wydanych na określonym poziomie uprawnień, a także datę, godzinę oraz dane użytkownika, który je wykonał.
Rozliczanie zasobów (<i>Resource Accounting</i>)	Rejestruje rekordy „start” i „stop” dla połączeń, które pomyślnie przeszły proces uwierzytelniania użytkownika.





Rozpoznawanie zagrożeń i kryptografia

CyberOps Associate v1.0



8.1 Źródła informacji

Społeczności zajmujące się analizą zagrożeń sieciowych

- Aby skutecznie chronić sieć, specjaliści ds. bezpieczeństwa muszą być na bieżąco informowani o zagrożeniach i podatnościach. Istnieje wiele organizacji zajmujących się bezpieczeństwem, które dostarczają dane wywiadowcze (*network intelligence*), zasoby, warsztaty oraz konferencje, aby wspierać ekspertów w tej dziedzinie.
- Aby zachować skuteczność, specjalista ds. bezpieczeństwa sieciowego musi:
 - **Być na bieżąco z najnowszymi zagrożeniami** – obejmuje to subskrybowanie kanałów informacyjnych o zagrożeniach w czasie rzeczywistym (*threat feeds*), regularne przeglądanie stron internetowych poświęconych bezpieczeństwu, śledzenie blogów i podcastów o tematyce security oraz wiele innych działań.
 - **Stale podnosić swoje kwalifikacje** – obejmuje to uczestnictwo w szkoleniach, warsztatach i konferencjach związanych z bezpieczeństwem.
- **Uwaga:** Bezpieczeństwo sieci charakteryzuje się bardzo stromą krzywą uczenia się i wymaga pełnego zaangażowania w ciągły rozwój zawodowy.

Społeczności zajmujące się analizą zagrożeń sieciowych

Organizacja	Opis
SANS Institute (SysAdmin, Audit, Network, Security)	Zasoby Instytutu SANS są w dużej mierze bezpłatne na żądanie i obejmują: • The Internet Storm Center – popularny system wczesnego ostrzegania przed zagrożeniami w internecie. • NewsBites – cotygodniowy przegląd artykułów informacyjnych na temat bezpieczeństwa komputerowego. • @RISK – cotygodniowe podsumowanie nowo odkrytych wektorów ataków, podatności z aktywnymi exploitami oraz wyjaśnienia mechanizmów niedawnych ataków. • Flash security alerts – błyskawiczne alerty bezpieczeństwa. • Reading Room – dostęp do ponad 1200 nagradzanych, oryginalnych prac badawczych. • SANS opracowuje również profesjonalne kursy z zakresu bezpieczeństwa.
MITRE	Korporacja MITRE prowadzi listę Common Vulnerabilities and Exposures (CVE) – ustandaryzowany spis powszechnie znanych podatności i zagrożeń, z którego korzystają najważniejsze organizacje zajmujące się bezpieczeństwem na świecie.

Network Intelligence Communities (Contd.)

Organization	Description
FIRST (<i>Forum of Incident Response and Security Teams</i>)	Organizacja zajmująca się bezpieczeństwem, która zrzesza różnorodne zespoły reagowania na incydenty komputerowe (CSIRT) z organów rządowych, komercyjnych i edukacyjnych. Jej celem jest wspieranie współpracy i koordynacji w zakresie wymiany informacji, zapobiegania incydentom oraz szybkiego reagowania na nie.
SecurityNewsWire	Portal informacyjny o bezpieczeństwie, który gromadzi najświeższe wiadomości dotyczące alertów, exploitów oraz podatności.
(ISC)² (<i>International Information Systems Security Certification Consortium</i>)	Dostarcza neutralne pod względem dostawcy (vendor-neutral) produkty edukacyjne oraz usługi zawodowe dla ponad 75 000 profesjonalistów z branży w ponad 135 krajach.
CIS (<i>Center for Internet Security</i>)	Punkt kontaktowy w zakresie zapobiegania zagrożeniom cybernetycznym, ochrony, reagowania i odzyskiwania danych dla rządów stanowych, lokalnych, plemiennych i terytorialnych (SLTT) poprzez centrum MS-ISAC (<i>Multi-State Information Sharing and Analysis Center</i>).

8.2 Usługi rozpoznawania zagrożeń

Threat Intelligence Services

Cisco Talos

- Talos to jeden z największych komercyjnych zespołów analityki zagrożeń na świecie. Składa się ze światowej klasy badaczy, analityków oraz inżynierów.
- **Cel:** Ochrona użytkowników korporacyjnych, danych oraz infrastruktury przed aktywnymi przeciwnikami (hakerami).
- **Działanie:** Zespół gromadzi informacje o aktywnych, istniejących oraz nowo pojawiających się zagrożeniach. Następnie zapewnia swoim subskrybentom kompleksową ochronę przed tymi atakami oraz złośliwym oprogramowaniem.



Threat Intelligence Services

Cisco Talos

- **Integracja i narzędzia:** Produkty bezpieczeństwa Cisco korzystają z danych Talos w **czasie rzeczywistym**, co pozwala na szybkie reagowanie. Ponadto Talos udostępnia darmowe zasoby i zarządza regułami dla popularnych narzędzi, takich jak:

- **Snort.org** (systemy wykrywania włamań),
- **ClamAV** (program antywirusowy),
- **SpamCop** (walka ze spamem).



FireEye

- FireEye to kolejna firma z branży bezpieczeństwa, która oferuje usługi pomagające przedsiębiorstwom zabezpieczać ich sieci. Stosuje ona trzystopniowe podejście, łączące analitykę zagrożeń (*security intelligence*), specjalistyczną wiedzę ekspercką oraz technologię.
- Firma oferuje rozwiązania klasy **SIEM** oraz **SOAR** w ramach platformy bezpieczeństwa **Helix**. Platforma ta wykorzystuje analizę behawioralną oraz zaawansowane wykrywanie zagrożeń, a jej działanie wspiera globalna sieć analityki zagrożeń **FireEye Mandiant**.

FireEye

▪ System Bezpieczeństwa FireEye

- System bezpieczeństwa FireEye blokuje ataki przesyłane za pośrednictwem wektorów takich jak sieć **WWW** i **poczta e-mail**, a także ukryte (uśpione) złośliwe oprogramowanie znajdujące się w **zasobach plikowych**.
- **Skuteczność:** Potrafi blokować zaawansowane złośliwe oprogramowanie, które z łatwością omija tradycyjne zabezpieczenia oparte na sygnaturach i infekuje większość sieci korporacyjnych.
- **Cykl życia ataku:** Adresuje wszystkie etapy cyklu życia ataku dzięki silnikowi **bezszygnaturowemu** (*signature-less*), który wykorzystuje stanową analizę ataku (*stateful attack analysis*) do wykrywania zagrożeń typu **zero-day**.

Automatyczne udostępnianie wskaźników (AIS)

- Automatyczne udostępnianie wskaźników (AIS) to bezpłatna usługa oferowana przez Departament Bezpieczeństwa Krajowego USA (DHS).
- **Cel:** AIS umożliwia wymianę wskaźników zagrożeń cybernetycznych w czasie rzeczywistym pomiędzy rządem federalnym USA a sektorem prywatnym.
- **Działanie:** AIS tworzy ekosystem, w którym po rozpoznaniu zagrożenia informacja o nim jest natychmiast udostępniana społeczności. Pomaga to uczestnikom chronić swoje sieci przed tym konkretnym zagrożeniem w bardzo krótkim czasie.

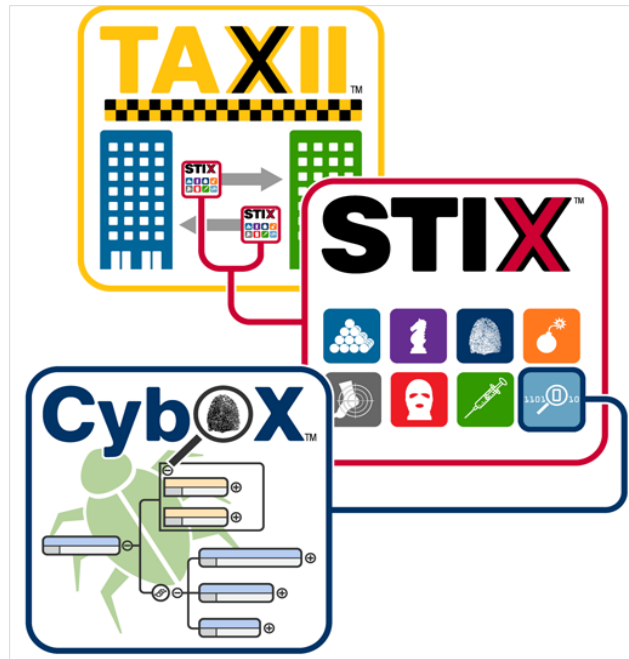
Common Vulnerabilities and Exposures (CVE) Database

- Rząd Stanów Zjednoczonych utworzył korporację **MITRE** w celu stworzenia i utrzymywania katalogu znanych zagrożeń bezpieczeństwa o nazwie **Common Vulnerabilities and Exposures (CVE)**.
- **Funkcja:** CVE służy jako słownik identyfikatorów (CVE Identifiers) dla publicznie znanych podatności w zakresie cyberbezpieczeństwa.
- **Cel:** Korporacja MITRE definiuje unikalne identyfikatory CVE, aby ułatwić wymianę danych dotyczących luk w zabezpieczeniach informacji pomiędzy różnymi systemami i organizacjami.

Standardy współdzielenia informacji o zagrożeniach

Istnieją trzy powszechnie stosowane standardy współdzielenia informacji o zagrożeniach:

- **CybOX (Cyber Observable eXpression)** – jest to zestaw ustandaryzowanych schematów służących do określania, rejestrowania, charakteryzowania i komunikowania zdarzeń oraz właściwości operacji sieciowych. Wspiera on wiele funkcji cyberbezpieczeństwa.
- **STIX (Structured Threat Information Expression)** – jest to zestaw specyfikacji służący do wymiany informacji o cyberzagrożeniach między organizacjami. Definiuje on „co” jest przesyłane (format danych).
- **TAXII (Trusted Automated Exchange of Indicator Information)** – jest to specyfikacja protokołu warstwy aplikacji, która umożliwia przesyłanie danych CTI (Cyber Threat Intelligence) przez protokół HTTPS. TAXII został zaprojektowany specjalnie do obsługi standardu STIX. Definiuje on „jak” dane są przesyłane (transport).



Standardy współdzielenia informacji o zagrożeniach

▪ Platforma wymiany informacji o złośliwym oprogramowaniu (MISP)

- MISP to platforma typu open source służąca do współdzielenia wskaźników kompromitacji (**IOC** – *Indicators of Compromise*) dotyczących nowo odkrytych zagrożeń.
- **Zasięg i wsparcie:** Projekt jest wspierany przez Unię Europejską i jest używany przez ponad 6 000 organizacji na całym świecie.
- **Automatyzacja:** MISP umożliwia zautomatyzowaną wymianę wskaźników IOC zarówno między ludźmi, jak i maszynami, wykorzystując standard **STIX** oraz inne formaty eksportu danych.
- <https://attack.mitre.org/>

Standardy współdzielenia informacji o zagrożeniach

▪ **WannaCry: Ransomware-Worm (Maj 2017)**

- WannaCry to hybryda złośliwego oprogramowania, która połączyła destrukcyjność **ransomware** z szybkością **robaka sieciowego** (*worm*). Był to pierwszy atak na taką skalę, który nie wymagał błędu użytkownika (np. kliknięcia w link), aby zainfekować komputer.
- **Mechanizm ataku):**
 - **Włamanie:** Wykorzystywał lukę w protokole Windows SMB (tzw. **EternalBlue**, CVE-2017-0144), aby samodzielnie "przeskakiwać" z jednego komputera na drugi w ramach sieci lokalnej i internetu.
 - **Szyfrowanie:** Po wejściu do systemu natychmiast szyfrował najważniejsze pliki użytkownika (dokumenty, zdjęcia, bazy danych), zmieniając ich rozszerzenia na .wnry.
 - **Szantaż:** Wyświetlał na ekranie czerwone okno z żądaniem okupu w wysokości **300-600 USD w Bitcoinach**.
 - **Destrukcja:** Próbował usunąć kopie zapasowe (Shadow Copies), aby uniemożliwić darmowe odzyskanie danych.
 - **Dlaczego był przełomowy?** Zainfekował ponad **200 000 komputerów w 150 krajach** w ciągu zaledwie kilku dni, paraliżując szpitale (np. brytyjski NHS), fabryki (Renault, Nissan) oraz systemy kolejowe i bankowe na całym świecie.

Standardy współdzielenia informacji o zagrożeniach

WannaCry

<https://learn.microsoft.com/pl-pl/security-updates/securitybulletins/2017/ms17-010>

<https://blog.talosintelligence.com/shadow-brokers/>

<https://blog.talosintelligence.com/wannacry/>

<https://attack.mitre.org/software/S0366/>

<https://nvd.nist.gov/vuln/detail/cve-2017-0144>

Platformy analizy zagrożeń

- Platforma Analizy Zagrożeń (TIP – *Threat Intelligence Platform*) to rozwiązanie, które **centralizuje zbieranie danych o zagrożeniach** z wielu różnych źródeł i w różnych formatach. Zamiast przeglądać dziesiątki osobnych raportów, analityk ma wszystko w jednym systemie.
- **Rodzaje danych w platformach TIP:**
 - **Wskaźniki Kompromitacji (IoC – *Indicators of Compromise*):** Techniczne ślady ataku, takie jak konkretne adresy IP hakerów, sumy kontrolne (hashe) złośliwych plików czy podejrzanе domeny.
 - **Narzędzia, Techniki i Procedury (TTP – *Tools, Techniques, and Procedures*):** Opis zachowania napastnika (np. to, co widziałeś na stronie MITRE ATT&CK – jak haker się porusza i jakich narzędzi używa).
 - **Informacje o reputacji:** Dane dotyczące wiarygodności konkretnych celów lub domen w internecie (np. czy dana strona jest znana z hostowania wirusów).

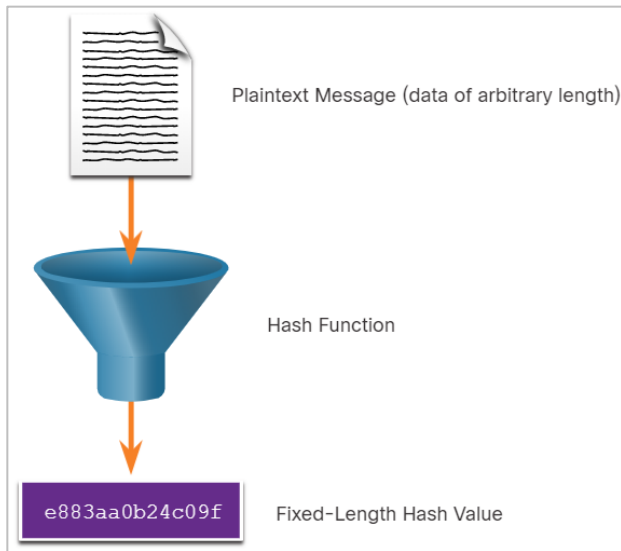
8.3 Integralność i autentyczność

Zabezpieczanie komunikacji

- Organizacje muszą zapewniać wsparcie w zakresie zabezpieczania danych zarówno wewnątrz, jak i zewnątrz. Cztery fundamenty bezpiecznej komunikacji to:
 - **Integralność danych (Data Integrity)** – Gwarantuje, że wiadomość nie została zmieniona (zmodyfikowana) podczas przesyłania.
 - **Uwierzytelnienie źródła (Origin Authentication)** – Gwarantuje, że wiadomość nie jest fałszerstwem i faktycznie pochodzi od osoby lub systemu, który jest podany jako nadawca.
 - **Poufność danych (Data Confidentiality)** – Gwarantuje, że tylko upoważnieni użytkownicy mogą odczytać treść wiadomości.
 - **Niezaprzeczalność (Data Non-Repudiation)** – Gwarantuje, że nadawca nie może wyprzeć się wysłania wiadomości ani kwestionować jej ważności.

Kryptograficzne funkcje skrótu

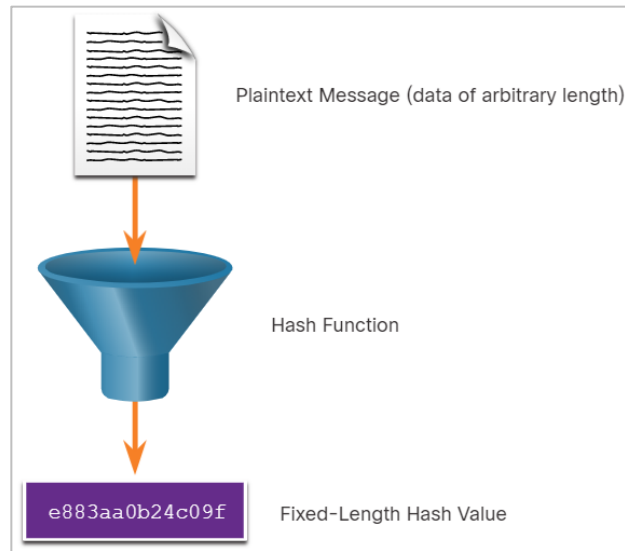
- Skróty (hashe) są używane do weryfikacji i zapewnienia **integralności danych**.
 - **Jednokierunkowość:** Haszowanie opiera się na jednokierunkowej funkcji matematycznej, która jest stosunkowo łatwa do obliczenia w jedną stronę, ale znacząco trudna (praktycznie niemożliwa) do odwrócenia.
 - **Działanie:** Funkcja skrótu przyjmuje blok danych binarnych o zmiennej długości (nazywany wiadomością) i generuje skondensowaną reprezentację o stałej długości, nazywaną **hashem**.
 - **Nazewnictwo:** Wynikowy hash jest czasami nazywany skrótem wiadomości (*message digest*), digestem lub **cyfrowym odciskiem palca**.
- **Kluczowe właściwości:**
 - **Brak kolizji:** W przypadku funkcji skrótu jest obliczeniowo niewykonalne, aby dwa różne zestawy danych wygenerowały ten sam wynik (hash).
 - **Czułość (Efekt lawinowy):** Za każdym razem, gdy dane zostaną zmienione lub zmodyfikowane – nawet o jeden bit – wartość skrótu również ulega całkowitej zmianie.



Kryptograficzne funkcje skrótu

- Brak kolizji a zasada Zasada Szufladkowa Dirichleta (ang. Pigeonhole Principle)
 - W kryptografii nie chodzi o to, że kolizje nie istnieją, ale o to, że są **obliczeniowo niewykonalne** (ang. *computationally infeasible*) do znalezienia. Klucz tkwi w skali liczb.
 - Standard **SHA-256**. Liczba możliwych skrótów to 2^{256} (liczba atomów w obserwowalnym wszechświecie jest szacowana na około 10^{80} , a liczba kombinacji SHA-256 to około 10^{77})

Uwaga: Ale jest też Paradoks Dnia Urodzin (Birthday Paradox), 23 osoby, 50% szans...

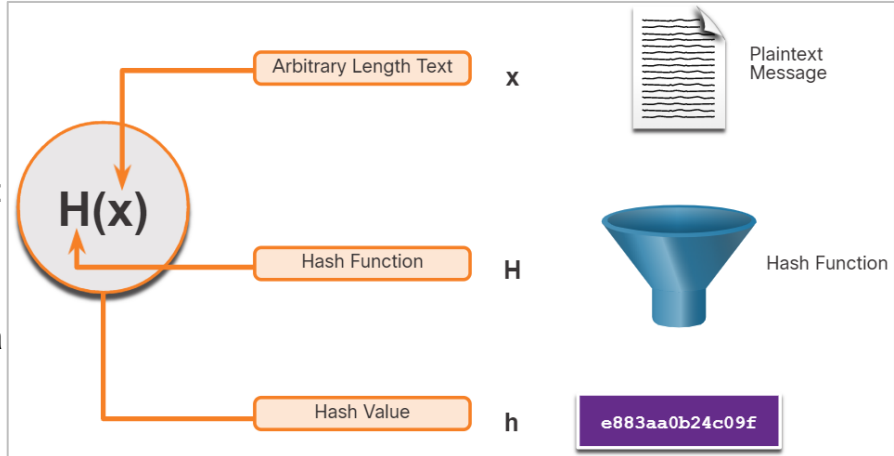


Operacja skrótu kryptograficznego

- Matematycznie działanie algorytmu skrótu opisuje równanie:

$$h = H(x)$$

- Gdzie funkcja skrótu H przyjmuje dane wejściowe x i zwraca wartość skrótu h o stałym rozmiarze.
- Aby funkcja skrótu mogła zostać uznana za bezpieczną pod względem kryptograficznym, powinna posiadać następujące właściwości:



- Dowolna długość wejścia:** Dane wejściowe (x) mogą mieć dowolną wielkość (od jednego znaku po cały dysk twardy).
- Stała długość wyjścia:** Wynik (h) ma zawsze tę samą, określoną liczbę bitów (np. dla SHA-256 jest to zawsze 256 bitów, niezależnie od tego, co haszujemy).
- Wydajność obliczeniowa:** Obliczenie $H(x)$ dla danych x jest stosunkowo łatwe i szybkie dla komputera.
- Jednokierunkowość:** Funkcja jest nieodwracalna. Mając h , obliczeniowo niemożliwe jest odzyskanie oryginalnego x .
- Odporność na kolizje:** Funkcja jest "wolna od kolizji", co oznacza, że dwie różne wartości wejściowe powinny skutkować różnymi wartościami skrótu.

MD5 i SHA

- Funkcje skrótu są używane do sprawdzania i zapewniania integralności wiadomości, chroniąc ją przed zmianami dokonanymi **przypadkowo** (np. błędy podczas przesyłania danych w sieci) lub **celowo** (np. ingerencja hakera).
- **Znane funkcje skrótu (Haszujące)**
 - **MD5 ze 128-bitowym skrótem:** Funkcja jednokierunkowa generująca 128-bitowy hash. MD5 jest algorytmem **przestarzałym (legacy)**. Nie powinno się go używać do ochrony danych, ponieważ możliwe jest szybkie wygenerowanie kolizji (dwóch różnych plików o tym samym hashu).
 - **SHA-1:** Bardzo podobny do MD5. Tworzy 160-bitowy hash i jest nieco wolniejszy od MD5. Obecnie również wycofywany z użytku ze względu na luki w bezpieczeństwie.
 - **SHA-2:** Rodzina algorytmów, w której zaleca się stosowanie wersji **SHA-256, SHA-384 oraz SHA-512**. Jest to obecnie obowiązujący standard w większości systemów zabezpieczeń (np. w bankowości czy przy weryfikacji plików malware).
 - **SHA-3:** Algorytmy nowej generacji, które powinny być używane wszędzie tam, gdzie jest to możliwe. Zostały zaprojektowane w sposób całkowicie odmienny od SHA-2, co czyni je odpornymi na ataki, które mogłyby teoretycznie zagrozić starszym wersjom.

Cryptography

MD5 i SHA

Skrót	Pełna nazwa	Twórca / Organizacja	Status i przeznaczenie
MD5	Message Digest 5	Ronald Rivest (MIT)	Legacy (Przestarzały). Bardzo szybki, ale podatny na kolizje. Nie używać do haseł!
SHA-1	Secure Hash Algorithm 1	NSA (National Security Agency – Krajowa Agencja Bezpieczeństwa USA)	Wycofywany. Złamany przez Google w 2017 r. (projekt SHAttered).
SHA-2	Secure Hash Algorithm 2	NIST (National Institute of Standards and Technology) przy współpracy z NSA	Standard. Obejmuje SHA-256 i SHA-512. Obecnie najpowszechniejszy w Internecie.
SHA-3	Secure Hash Algorithm 3	NIST (konkurs publiczny, zespół z Belgii i Włoch z algorytmem Keccak)	Nowa generacja. Odporny na inne typy ataków niż SHA-2. Bardzo przyszłościowy.

MD5 i SHA

- Choć haszowanie świetnie wykrywa przypadkowe błędy (np. błędy transmisji), nie chroni przed **celowym działaniem hakera**.
- **Brak unikalnej tożsamości:** W procedurze haszowania nie ma żadnej informacji, która identyfikowałaby nadawcę.
- **Dostępność dla każdego:** Każdy może obliczyć hash dla dowolnych danych, jeśli tylko zna algorytm (np. SHA-256). To publiczne narzędzie.
- **Podatność na ataki:** Samo haszowanie jest podatne na ataki typu **Man-in-the-Middle (MitM)** i nie zapewnia pełnego bezpieczeństwa przesyłanych danych.

Czy funkcje hashujące wystarczą?

- Haker (Ewa) przechwytuje przesyłkę.
- Zmiana danych: Ewa zmienia treść.
- Nowy hash: Ewa – używając tego samego algorytmu – oblicza nowy hash dla swojej fałszywej wiadomości (algorytm jest powszechnie znany).
- Oszustwo: Ewa wysyła podmienioną wiadomość i nowy hash.
- Odbiorca myśli, że wiadomość jest poprawna, bo hash pasuje do treści.

Czego brakuje?

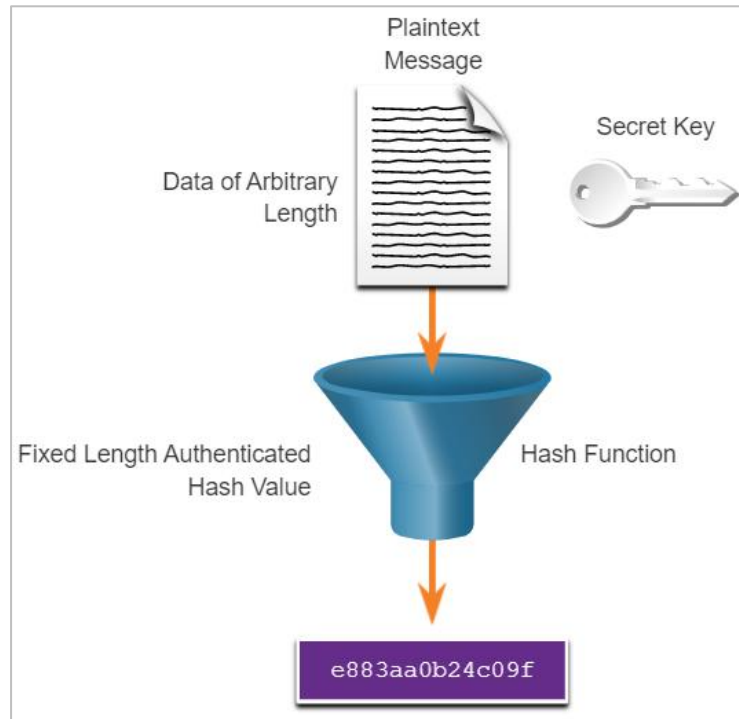
Uwierzytelnienie źródła

- Aby dodać uwierzytelnienie źródła oraz zapewnić pewność co do integralności danych, stosuje się **kod HMAC** (*Keyed-hash Message Authentication Code*).
- **Działanie:** HMAC wykorzystuje **dodatkowy tajny klucz** jako dane wejściowe do funkcji skrótu (hash).
- Istnieją inne metody kodów uwierzytelniania wiadomości (*Message Authentication Code* MAC), jednak to **HMAC** jest standardem używanym w najważniejszych systemach bezpieczeństwa, takich jak:
 - **SSL/TLS** (zabezpieczanie stron WWW).
 - **IPsec** (bezpieczne tunele VPN).
 - **SSH** (bezpieczne logowanie zdalne do serwerów).

Uwierzytelnienie źródła

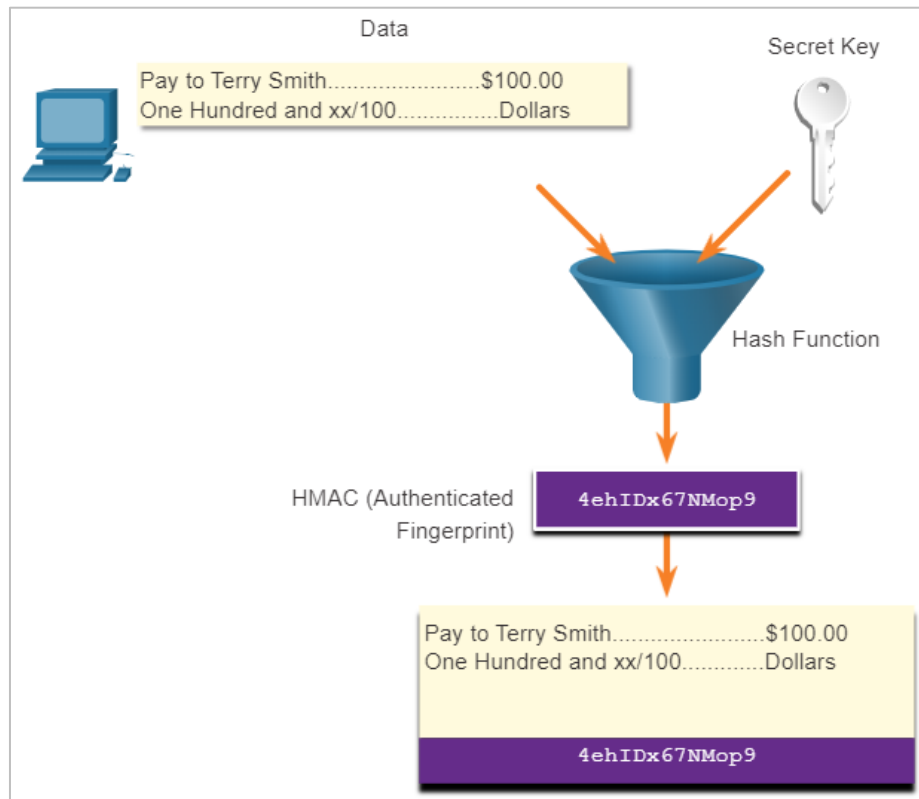
▪ Algorytm haszujący HMAC

- HMAC oblicza się przy użyciu dowolnego algorytmu kryptograficznego, który łączy kryptograficzną funkcję skrótu z tajnym kluczem.
- Tylko nadawca i odbiorca znają tajny klucz.
- Wynik funkcji skrótu zależy od danych wejściowych oraz tajnego klucza.
- Tylko strony, które mają dostęp do tego tajnego klucza, mogą obliczyć skrót (digest) funkcji HMAC.
- Jeśli dwie strony współdzielą tajny klucz i używają funkcji HMAC do uwierzytelniania, poprawnie skonstruowany skrót HMAC wiadomości, którą strona otrzymała, wskazuje, że to druga strona była nadawcą tej wiadomości.



Uwierzytelnienie źródła

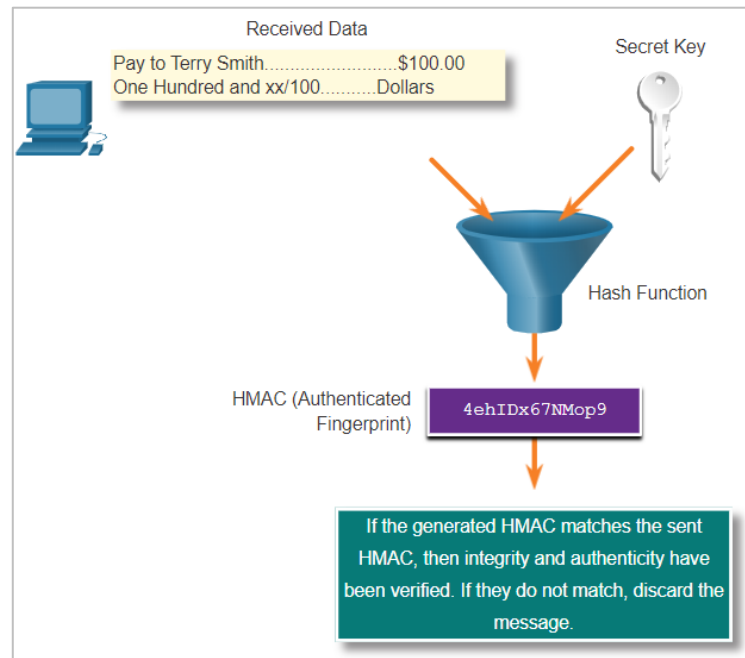
- **Tworzenie wartości HMAC**
- Urządzenie wysyłające wprowadza dane do algorytmu haszującego i oblicza skrót (digest) HMAC o stałej długości.
- Ten uwierzytelniony skrót jest następnie dołączany do wiadomości i przesyłany do odbiorcy.



Uwierzytelnienie źródła

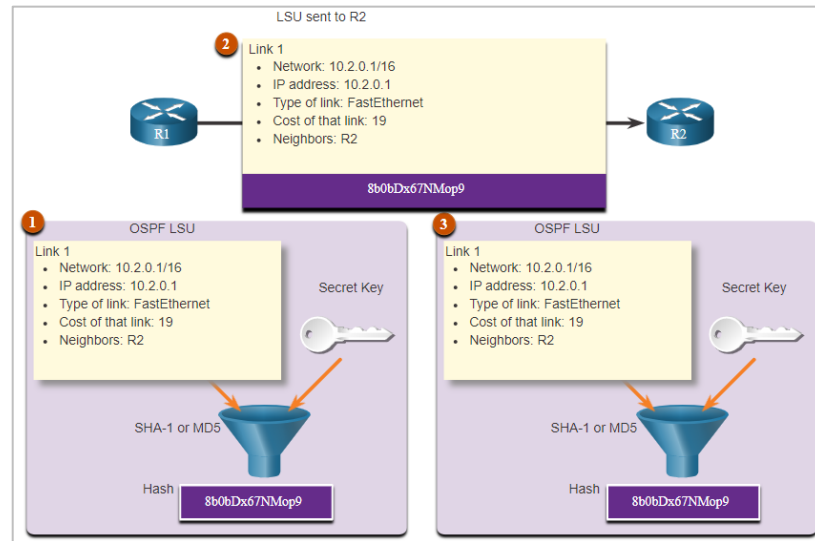
■ Weryfikacja wartości HMAC

- Urządzenie odbierające oddziela skrót (digest) od wiadomości, a następnie używa wiadomości tekstowej wraz ze swoim tajnym kluczem jako danych wejściowych dla tej samej funkcji haszującej.
- Jeśli skrót obliczony przez urządzenie odbierające jest identyczny ze skrótem, który został przesłany, oznacza to, że wiadomość nie została zmieniona.
- Dodatkowo, pochodzenie wiadomości jest uwierzytelnione, ponieważ tylko nadawca posiada kopię współdzielonego klucza tajnego.
- Funkcja HMAC zapewniła autentyczność wiadomości.



Uwierzytelnienie źródła

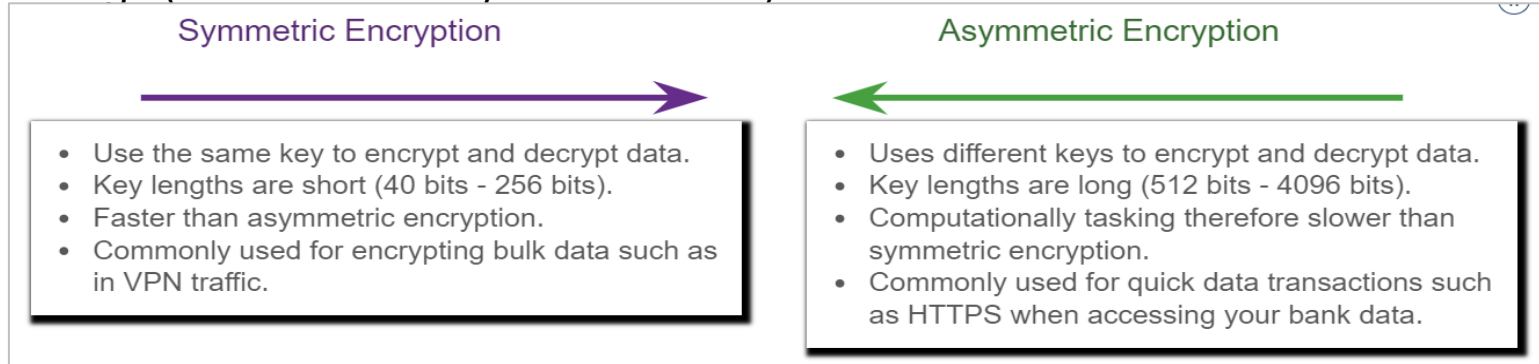
- Kody HMAC są wykorzystywane przez routery Cisco skonfigurowane do używania uwierzytelniania protokołu routingu **OSPF** (Open Shortest Path First).
- Router R1 wysyła aktualizację stanu łączy (**LSU** – Link State Update) dotyczącą trasy do sieci 10.2.0.0/16:
- **Obliczenia R1:** Router R1 oblicza wartość skrótu (hash), wykorzystując treść wiadomości LSU oraz tajny klucz.
- **Przesyłanie:** Wynikowa wartość skrótu jest wysyłana wraz z wiadomością LSU do routera R2.
- **Weryfikacja R2:** Router R2 oblicza wartość skrótu na podstawie otrzymanej wiadomości LSU i swojego tajnego klucza.
- **Decyzja:** R2 akceptuje aktualizację, jeśli wartości skrótu są identyczne. Jeśli się różnią, R2 odrzuca aktualizację.



8.4 Poufność

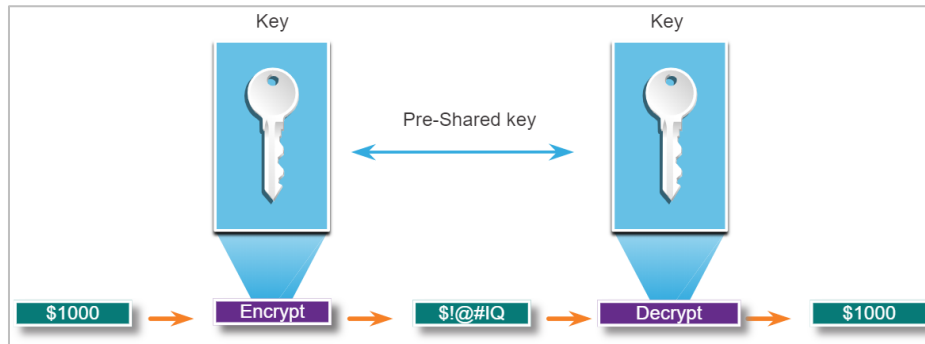
Poufność danych

- Istnieją dwie klasy szyfrowania używane do zapewnienia poufności danych: **asymetryczne** oraz **symetryczne**. Te dwie klasy różnią się sposobem wykorzystania kluczy.
- **Szyfrowanie symetryczne:** Algorytmy takie jak **DES** (Data Encryption Standard), **3DES** oraz **AES** (Advanced Encryption Standard) opierają się na założeniu, że każda ze stron komunikacji zna ten sam, wcześniej udostępniony klucz (**pre-shared key**).
- **Szyfrowanie asymetryczne:** Poufność danych można również zapewnić za pomocą algorytmów asymetrycznych, w tym **RSA** (Rivest, Shamir i Adleman) oraz infrastruktury klucza publicznego (**PKI** – Public Key Infrastructure).



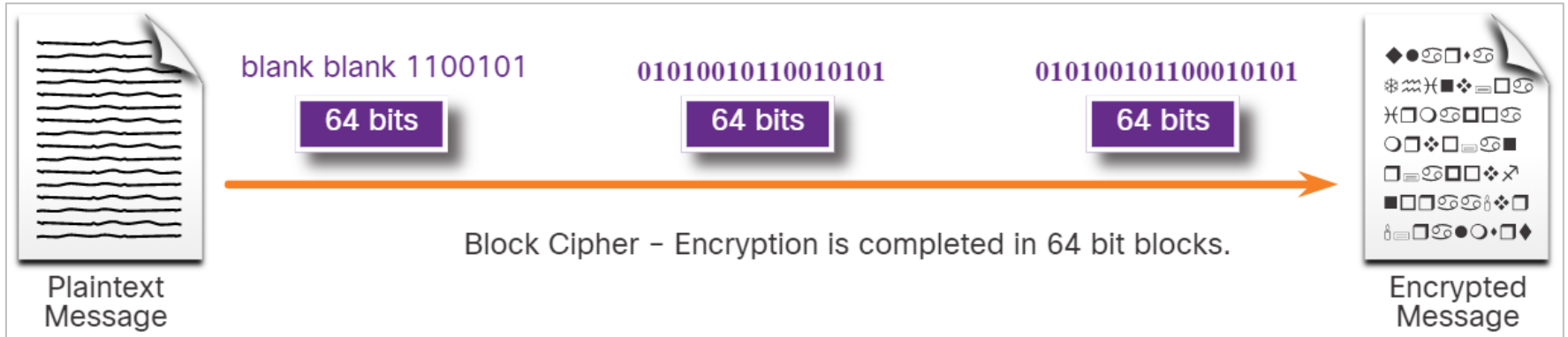
Szyfrowanie symetryczne

- Algorytmy symetryczne używają tego samego **pre-shared key** (klucza tajnego) do szyfrowania i deszyfrowania danych.
- Algorytmy szyfrowania symetrycznego są powszechnie stosowane w ruchu VPN, ponieważ zużywają mniej zasobów CPU niż algorytmy szyfrowania asymetrycznego.
- Podczas używania tych algorytmów, im dłuższy klucz, tym dłużej zajmie komuś jego odkrycie.
- Większość kluczy szyfrujących ma długość od 112 do 256 bitów. Należy używać dłuższego klucza dla zapewnienia bezpieczniejszej komunikacji.
- Algorytmy szyfrowania symetrycznego są czasami klasyfikowane jako szyfr blokowy lub szyfr strumieniowy.



Szyfrowanie symetryczne

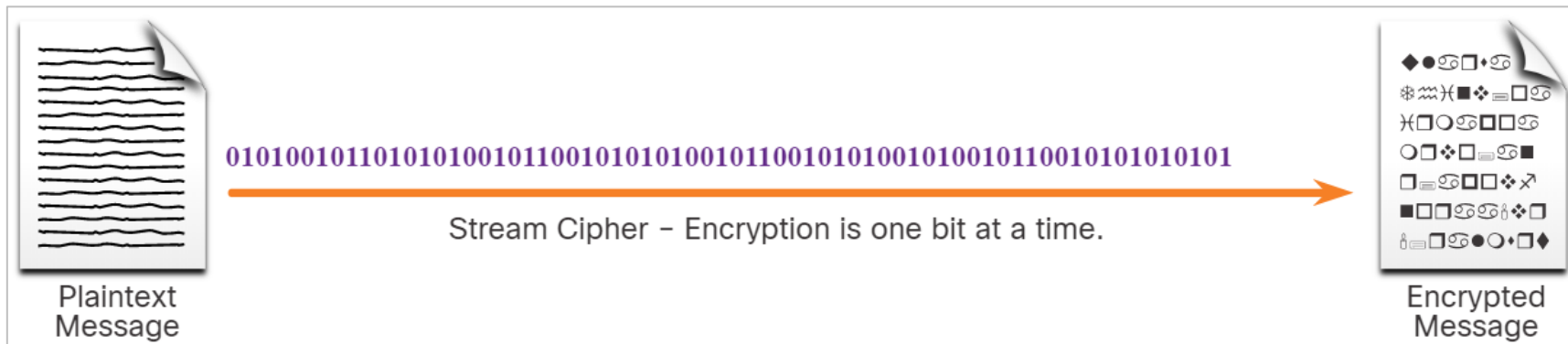
- **Szyfry blokowe (Block Ciphers)**
- Szyfry blokowe przekształcają blok tekstu jawnego (plaintext) o stałej długości w powszechny blok szyfrogramu (ciphertext) o wielkości 64 lub 128 bitów.
- Typowe szyfry blokowe to:
 - **DES** z rozmiarem bloku 64 bity, **AES** z rozmiarem bloku 128 bitów.



Szyfrowanie symetryczne

▪ Szyfry strumieniowe (Stream Ciphers)

- Szyfry strumieniowe szyfrują tekst jawny (plaintext) po jednym bajcie lub jednym bicie na raz.
- Szyfry strumieniowe są w zasadzie szyframi blokowymi o rozmiarze bloku wynoszącym jeden bajt lub jeden bit.
- Szyfry strumieniowe są zazwyczaj szybsze niż szyfry blokowe, ponieważ dane są szyfrowane w sposób ciągły.
- Przykłady obejmują **RC4** oraz **A5**, który jest używany do szyfrowania komunikacji w telefonii komórkowej GSM, (oba są już przestarzałe). **ChaCha20** wyparł RC4 **TLS 1.3** (HTTPS), **SSH** oraz w **VPN**.



Szyfrowanie symetryczne

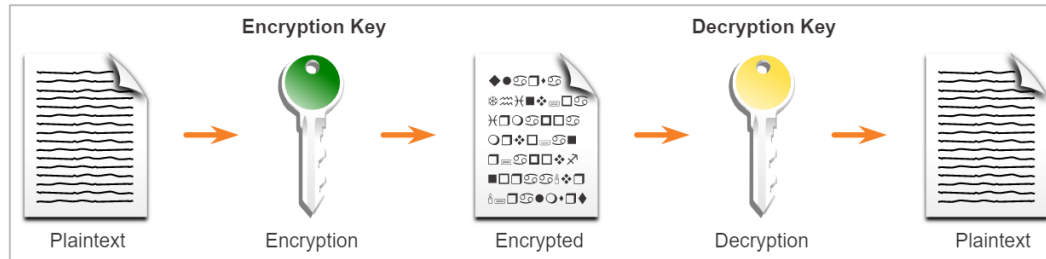
Szyfr	Status	Gdzie stosowany?
RC4	Wycofany	Stare routery Wi-Fi (WEP), archaiczne strony HTTPS.
A5/1 / A5/2	Złamany	Starsze sieci komórkowe 2G (hakerzy potrafią je podsłuchać w czasie rzeczywistym).
ChaCha20	Zalecany / Standard	Google, Cloudflare, WireGuard, nowoczesne smartfony.

Szyfrowanie symetryczne

Rok publikacji	Algorytm	Typ szyfru	Długość klucza (bity)	Status bezpieczeństwa
1977	DES (Data Encryption Standard)	Blokowy	56	Przestarzały: Podatny na ataki siłowe (brute-force).
1987	RC4 (Rivest Cipher 4)	Strumieniowy	40 – 2048	Niebezpieczny: Liczne luki w strukturze generowania strumienia.
1993	SEAL (Software-Optimized Encryption Algorithm)	Strumieniowy	160	Specjalistyczny: Niski wpływ na CPU, rzadziej stosowany obecnie.
1998	3DES (Triple DES)	Blokowy	112 lub 168	Wycofywany: Niska wydajność, oficjalnie uznany za przestarzały przez NIST.
2001	AES (Advanced Encryption Standard)	Blokowy	128, 192, 256	Standard: Globalnie akceptowany, brak znanych praktycznych ataków.
2005	Salsa20	Strumieniowy	128, 256	Bezpieczny: Alternatywa dla AES w implementacjach programowych.
2008	ChaCha20	Strumieniowy	256	Standard: Następca Salsa20, używany w TLS 1.3 i VPN (WireGuard).

Szyfrowanie asymetryczne

- Algorytmy asymetryczne, zwane również algorytmami klucza publicznego, są zaprojektowane w taki sposób, że klucze do szyfrowania i deszyfrowania są różne.
- Algorytmy asymetryczne wykorzystują klucz publiczny i klucz prywatny. Oba klucze mogą przeprowadzić proces szyfrowania, ale do deszyfrowania wymagany jest komplementarny klucz z pary.
- Proces jest również odwracalny. Dane zaszyfrowane kluczem publicznym wymagają klucza prywatnego do deszyfrowania.
- Algorytmy asymetryczne osiągają poufność i autentyczność poprzez stosowanie tego procesu.
- Szyfrowanie asymetryczne może wykorzystywać klucze o długości od 512 do 4096 bitów (8192 jest możliwe ale nieopłacalne).
- Algorytmy asymetryczne są znacząco wolniejsze niż algorytmy symetryczne.



Szyfrowanie asymetryczne

Rok publikacji	Algorytm	Długość klucza (bity)	Opis i zastosowanie
1976	Diffie-Hellman (DH)	1024, 2048, 4096	Pierwszy opublikowany protokół wymiany kluczy. Umożliwia bezpieczne ustalenie wspólnego sekretu przez niezabezpieczony kanał.
1977	RSA (Rivest-Shamir-Adleman)	2048, 3072, 4096	Najbardziej rozpowszechniony algorytm. Służy zarówno do szyfrowania, jak i tworzenia podpisów cyfrowych. Opiera się na trudności faktoryzacji dużych liczb.
1985	ECC (Krzywe eliptyczne)	224, 256, 384, 521	Teoretyczne podstawy kryptografii krzywych eliptycznych. Pozwalają na stosowanie znacznie krótszych kluczy przy zachowaniu wysokiego bezpieczeństwa.
1991	DSA / DSS (Digital Signature Algorithm)	1024, 2048	Standard rządu USA dla podpisów cyfrowych. Szybki przy podpisywaniu, lecz znacznie wolniejszy przy weryfikacji podpisu.
2005	ECDH / ECDSA	256, 384, 521	Praktyczne wdrożenia DH i DSA oparte na krzywych eliptycznych. Standard w nowoczesnym ruchu internetowym (TLS 1.3), VPN oraz kryptowalutach.

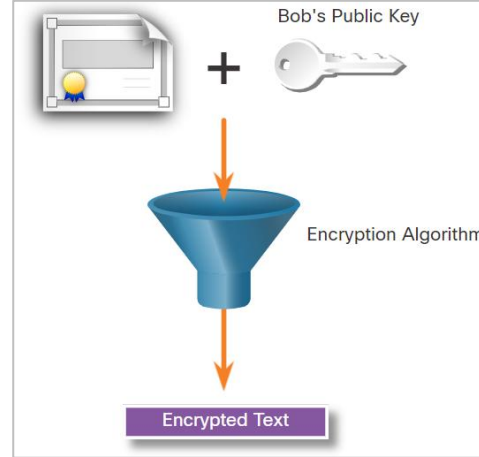
Szyfrowanie asymetryczne - poufność

- Alorytmy asymetryczne są wykorzystywane do zapewnienia poufności bez konieczności wcześniejszego współdzielenia hasła (**pre-sharing a password**).
- Cel poufności w algorytmach asymetrycznych zostaje zainicjowany w momencie rozpoczęcia procesu szyfrowania za pomocą klucza publicznego.
- Proces ten można podsumować za pomocą formuły:

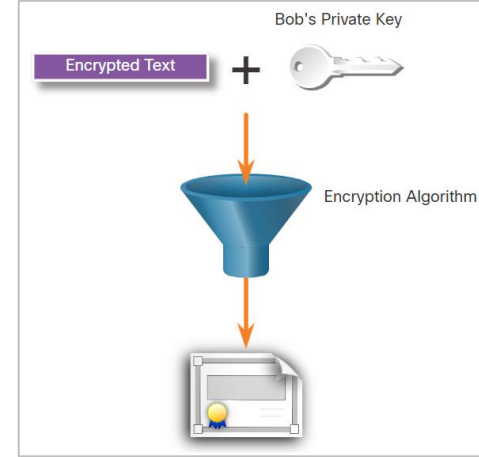
Klucz Publiczny (Szyfrowanie) + Klucz Prywatny (Deszyfrowanie) = Poufność

- Gdy klucz publiczny zostanie użyty do zaszyfrowania danych, do ich odszyfrowania musi zostać użyty klucz prywatny.
- Tylko jeden host posiada klucz prywatny; w związku z tym zostaje osiągnięta poufność.

Example: Data exchange between Bob and Alice



Alice acquires and uses Bob's public key to encrypt a message and then send it to Bob.



Bob decrypts the message with the private key and as he is the only one with the private key, confidentiality is achieved.

Szyfrowanie asymetryczne - uwierzytelnianie

- **Autentyczność w algorytmach asymetrycznych**
- Cel uwierzytelniania w algorytmach asymetrycznych zostaje zainicjowany wraz z procesem szyfrowania kluczem prywatnym.
- Proces ten można podsumować za pomocą formuły:

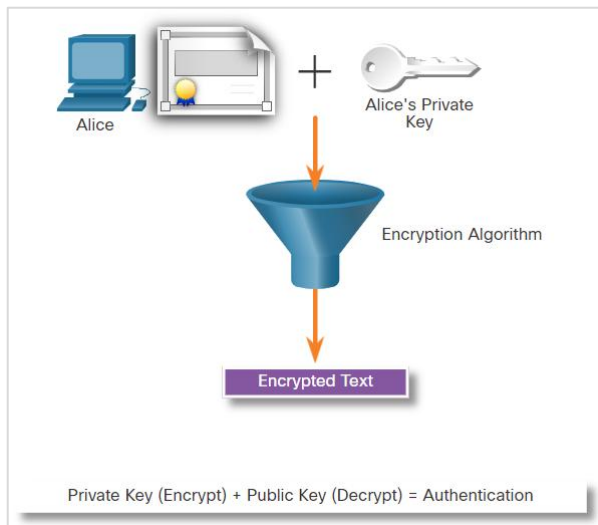
Klucz Prywatny (Szyfrowanie) + Klucz Publiczny (Deszyfrowanie) = Autentyczność

- Gdy klucz prywatny zostanie użyty do zaszyfrowania danych, do ich odszyfrowania musi zostać użyty odpowiadający mu klucz publiczny.
- Ponieważ tylko jeden host posiada klucz prywatny, tylko ten host mógł zaszyfrować wiadomość, co zapewnia autentyczność nadawcy.
- Gdy host pomyślnie odszyfruje wiadomość za pomocą klucza publicznego, przyjmuje się, że to klucz prywatny zaszyfrował wiadomość, co weryfikuje tożsamość nadawcy. Jest to forma uwierzytelnienia (autentyczności).

Szyfrowanie asymetryczne - uwierzytelnianie

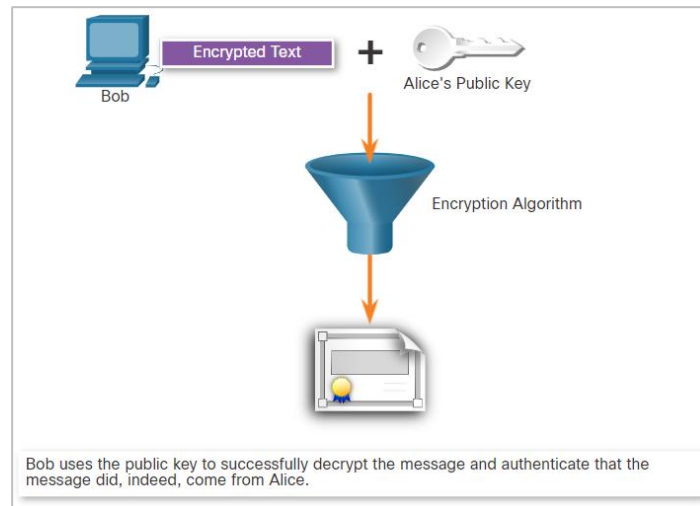
Alice używa swojego klucza prywatnego

Alice szyfruje wiadomość za pomocą swojego klucza prywatnego i wysyła ją do Boba.



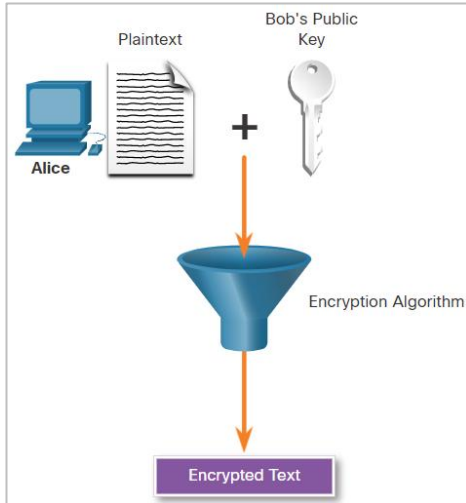
Bob deszyfruje za pomocą klucza publicznego

Gdy Bob uzyska klucz publiczny Alice, używa go do odszyfrowania wiadomości oraz do potwierdzenia autentyczności (uwierzytelnienia), że wiadomość została odebrana od Alice.

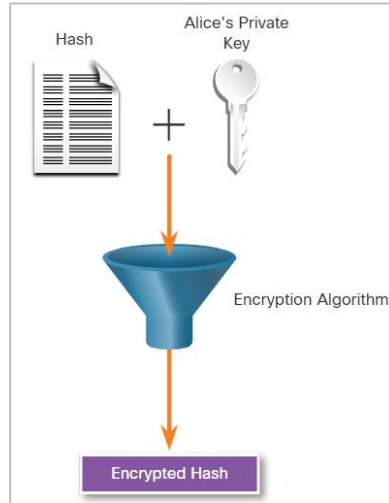


Szyfrowanie asymetryczne - integralność

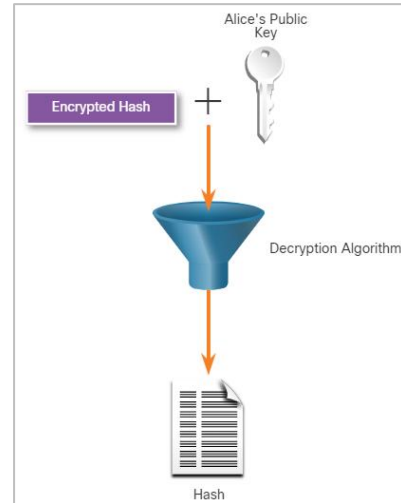
- Połączenie dwóch procesów szyfrowania asymetrycznego zapewnia poufność wiadomości, autentyczność oraz integralność. W tym przykładzie wiadomość zostanie zaszyfrowana przy użyciu klucza publicznego Boba, a zaszyfrowany skrót (hash) zostanie zaszyfrowany przy użyciu klucza prywatnego Alice.



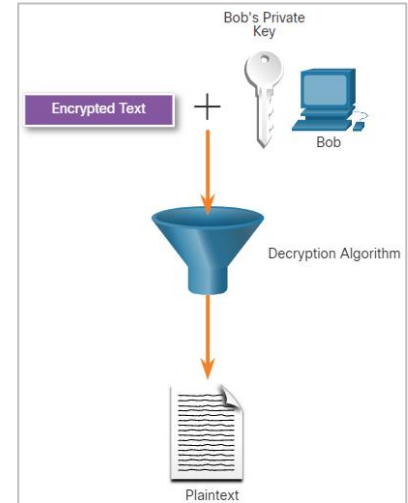
Alice uses Bob's
Public Key



Alice encrypts a
hash using her
private key



Bob uses Alice's
public key to
decrypt the hash

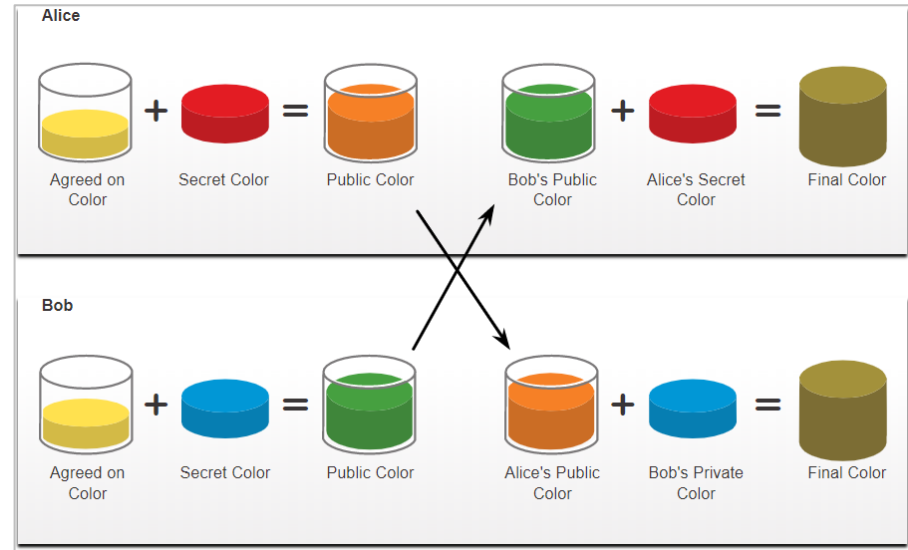


Bob uses his private
key to decrypt the
message

Confidentiality

Diffie-Hellman

- Algorytm Diffie-Hellman (DH) jest asymetrycznym algorytmem matematycznym, który pozwala dwóm komputerom wygenerować identyczny współdzielony sekret (shared secret) bez wcześniejszej komunikacji.
- Nowy współdzielony klucz nigdy nie jest faktycznie przesyłany między nadawcą a odbiorcą.
- Klucz ten może być wykorzystany przez algorytm szyfrujący do szyfrowania ruchu między dwoma systemami, ponieważ obie strony go znają.
- Poniżej znajdują się dwa przykłady sytuacji, w których DH jest powszechnie stosowany:
- Wymiana danych przy użyciu IPsec VPN.
- Wymiana danych protokołu SSH.
- Bezpieczeństwo DH opiera się na fakcie, że w swoich obliczeniach wykorzystuje on bardzo duże liczby.



DH operation

Diffie-Hellman

- **Grupy Diffie-Hellmana (DH)**
- Algorytm Diffie-Hellman wykorzystuje różne **grupy DH** do określenia siły (długości) klucza używanego w procesie uzgadniania kluczy. Wyższe numery grup są bardziej bezpieczne, ale wymagają więcej czasu na obliczenie klucza.
- Poniższa lista identyfikuje grupy DH obsługiwane przez oprogramowanie Cisco IOS oraz powiązane z nimi wartości liczb pierwszych:
 - **DH Grupa 1:** 768 bitów
 - **DH Grupa 2:** 1024 bity
 - **DH Grupa 5:** 1536 bitów
 - **DH Grupa 14:** 2048 bitów
 - **DH Grupa 15:** 3072 bity
 - **DH Grupa 16:** 4096 bitów
- **Uwaga:** Uzgadnianie kluczy DH może być również oparte na kryptografii krzywych eliptycznych (**Elliptic Curve Cryptography - ECC**). Oprogramowanie Cisco IOS obsługuje w tym zakresie grupy DH o numerach **19, 20 oraz 24**.

8.5 Public Key Cryptography

Kryptografia klucza publicznego – podpisy cyfrowe

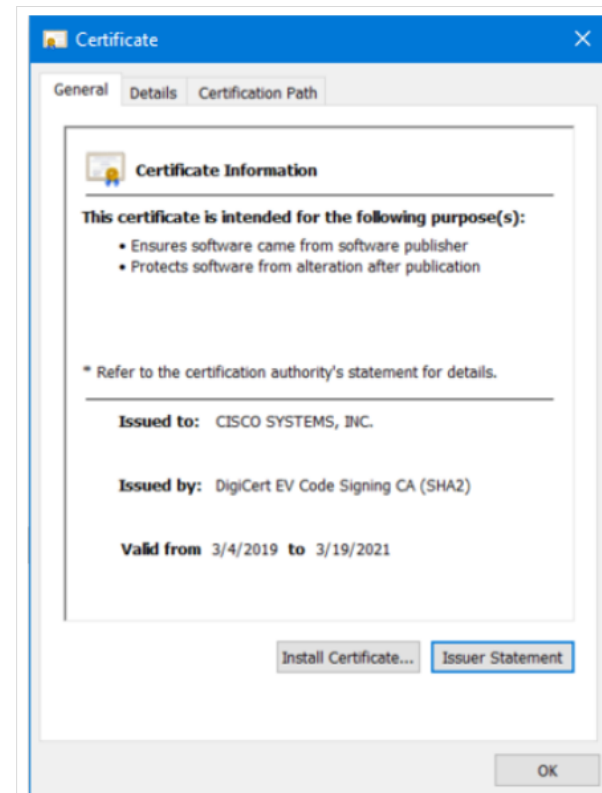
- Podpisy cyfrowe to technika matematyczna stosowana w celu zapewnienia **autentyczności**, **integralności** oraz **niezaprzeczalności** (nonrepudiation). Podpisy cyfrowe wykorzystują kryptografię asymetryczną.
- Podpisy cyfrowe są powszechnie stosowane w dwóch następujących sytuacjach:
 - **Podpisywanie kodu (Code signing)**: Służy do weryfikacji integralności plików wykonywalnych pobranych ze strony dostawcy. Wykorzystuje również podpisane certyfikaty cyfrowe do uwierzytelnienia i weryfikacji tożsamości witryny, która jest źródłem plików.
 - **Certyfikaty cyfrowe**: Są używane do uwierzytelniania tożsamości systemu w witrynie dostawcy i nawiązywania szyfrowanego połączenia w celu wymiany poufnych danych.
- Algorytmy standardu podpisu cyfrowego (**Digital Signature Standard – DSS**) używane do generowania i weryfikacji podpisów cyfrowych to:
 - **DSA** (Digital Signature Algorithm)
 - **RSA** (Rivest-Shamir-Adleman Algorithm)
 - **ECDSA** (Elliptic Curve Digital Signature Algorithm)

Podpisy cyfrowe w podpisywaniu kodu

- Podpisy cyfrowe są powszechnie stosowane w celu zapewnienia **autentyczności** oraz **integralności** kodu oprogramowania. Pliki wykonywalne są umieszczane w „cyfrowo podpisanej kopercie”, co pozwala użytkownikowi końcowemu zweryfikować podpis przed zainstalowaniem oprogramowania.
- Cyfrowe podpisywanie kodu daje kilka gwarancji dotyczących oprogramowania:
 - **Kod jest autentyczny** i rzeczywiście pochodzi od deklarowanego wydawcy.
 - **Kod nie został zmodyfikowany** od czasu opuszczenia siedziby wydawcy oprogramowania.
 - **Wydawca niezaprzeczalnie opublikował ten kod**. Zapewnia to **niezaprzeczalność** (nonrepudiation) aktu publikacji.
- Celem cyfrowego podpisywania oprogramowania jest upewnienie się, że kod nie został naruszony (nie było przy nim manipulacji) i że pochodzi z zaufanego źródła, zgodnie z deklaracją.

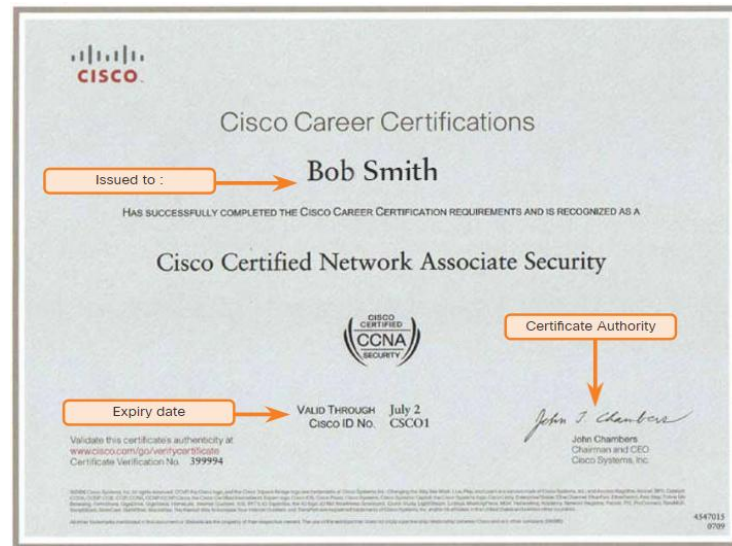
Podpisy cyfrowe w podpisywaniu kodu

Właściwość	Opis
Właściwości pliku	Ten plik wykonywalny został pobrany z Internetu i zawiera narzędzie programowe od firmy Cisco Systems.
Podpisy cyfrowe	Ta zakładka ujawnia, że plik pochodzi od zaufanej organizacji – Cisco Systems Inc.
Szczegóły podpisu cyfrowego	To okno pokazuje, że plik został podpisany przez Cisco Systems, Inc. z podaniem konkretnego roku, miesiąca i godziny.
Informacje o certyfikacie	Zakładka "Ogólne" (General) dostarcza informacji o tym, dla kogo certyfikat został wystawiony oraz przez kogo. Wyświetla również okres ważności certyfikatu.
Ścieżka certyfikacji	W tej zakładce można zobaczyć, że plik został podpisany przez Cisco Systems, co zostało zweryfikowane przez urząd certyfikacji DigiCert.



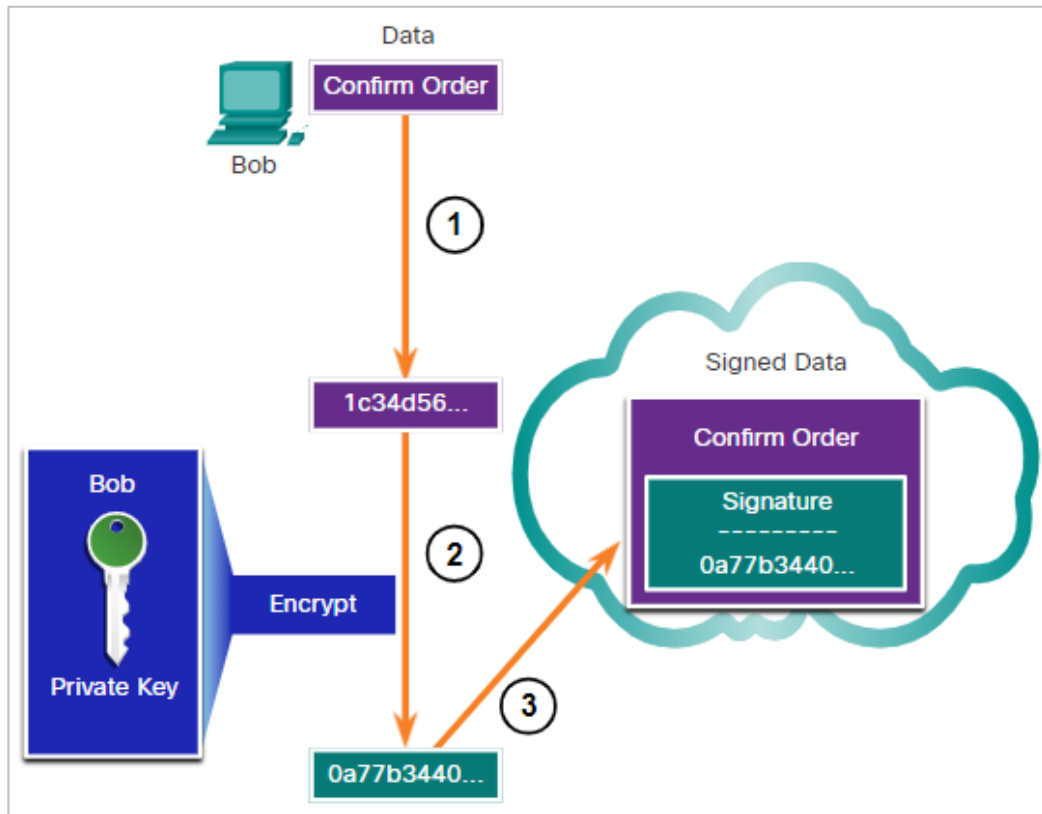
Podpisy cyfrowe w certyfikatach cyfrowych

- Certyfikat cyfrowy umożliwia użytkownikom, hostom i organizacjom bezpieczną wymianę informacji przez Internet.
- Służą on do uwierzytelniania i weryfikacji, czy użytkownik wysyłający wiadomość jest tym, za kogo się podaje.
- Certyfikaty cyfrowe mogą być również używane do zapewnienia **poufności** odbiorcy poprzez umożliwienie zaszyfrowania odpowiedzi.
- Certyfikaty cyfrowe są podobne do certyfikatów fizycznych (np. dyplomów czy dowodów osobistych).
- Certyfikat cyfrowy niezależnie weryfikuje tożsamość.
- Innymi słowy: **certyfikat weryfikuje tożsamość, a podpis weryfikuje informacje pochodzące od tej tożsamości.**



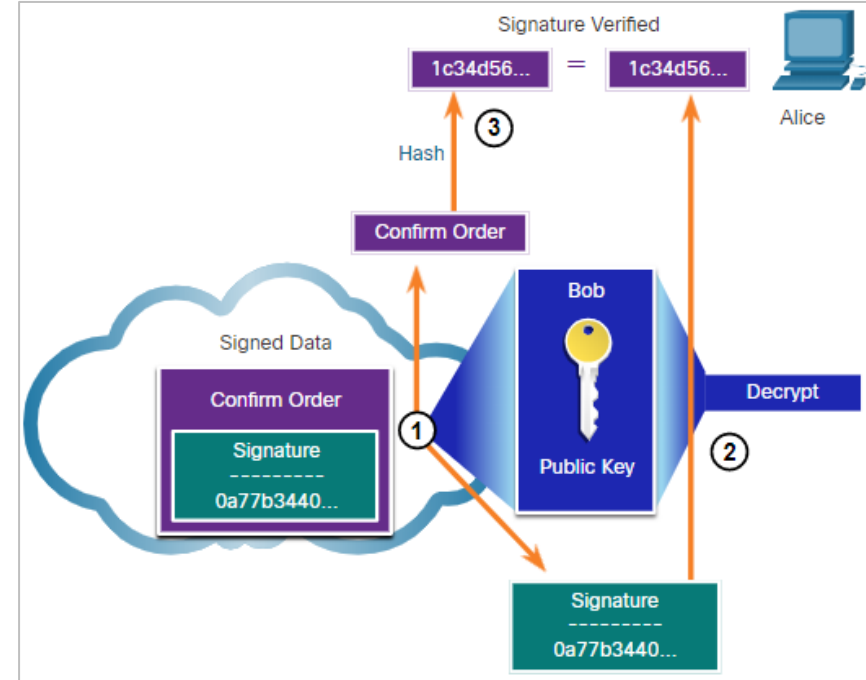
Podpisy cyfrowe w certyfikatach cyfrowych

- Bob potwierdza zamówienie złożone przez Alice na jego stronie internetowej.
- Bob zatwierdza zamówienie, a jego komputer tworzy **hash** (skrót) tego potwierdzenia.
- Komputer szyfruje ten hash za pomocą **klucza prywatnego Boba**.
- Zaszyfrowany hash, który stanowi **podpis cyfrowy**, zostaje dołączony do dokumentu.
- Potwierdzenie zamówienia zostaje następnie wysłane do Alice przez Internet.



Podpisy cyfrowe w certyfikatach cyfrowych

- Gdy Alice otrzymuje podpis cyfrowy, następuje następujący proces:
 - Urządzenie odbiorcze Alice przyjmuje potwierdzenie zamówienia wraz z podpisem cyfrowym i uzyskuje **klucz publiczny Boba**.
 - Komputer Alice deszyfruje podpis za pomocą klucza publicznego Boba, co ujawnia **oryginalną wartość skrótu (hash)** wygenerowaną przez urządzenie nadawcze.
 - Komputer Alice tworzy własny skrót (hash) otrzymanego dokumentu (bez dołączonego podpisu) i porównuje go z hashem uzyskanym po odszyfrowaniu.
 - Jeśli skróty są identyczne, dokument jest **autentyczny**. Oznacza to, że potwierdzenie zostało wysłane przez Boba i nie zostało zmienione od czasu podpisania.

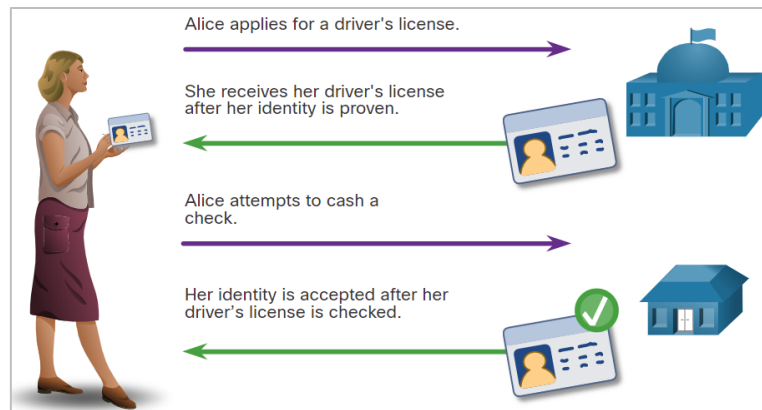




8.6 Organy i system zaufania PKI

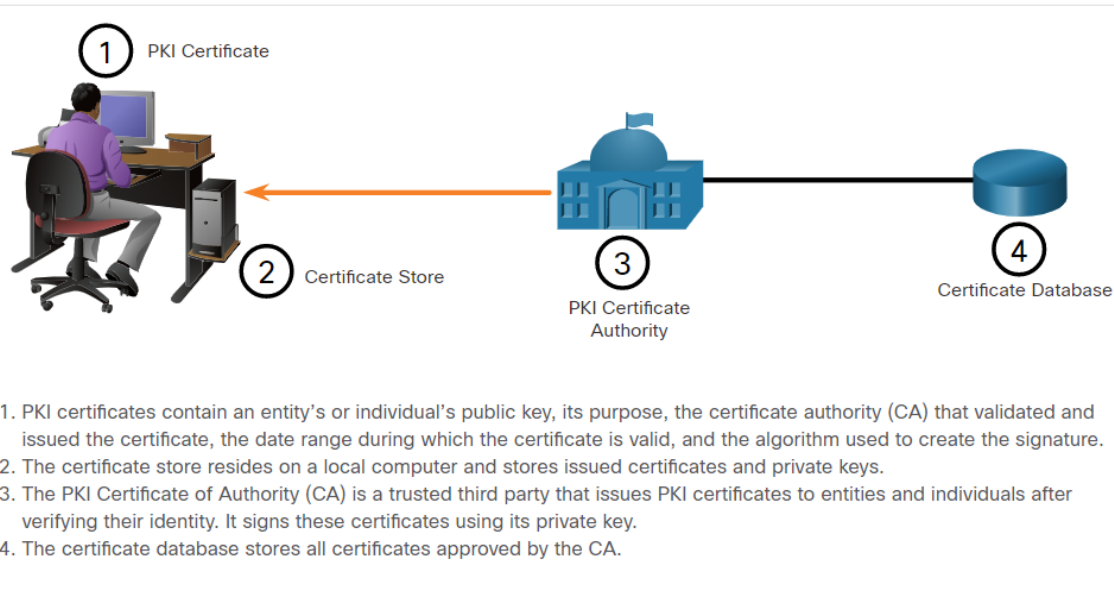
Zarządzanie kluczami publicznymi

- Podczas nawiązywania połączenia asymetrycznego między dwoma hostami, wymieniają one między sobą informacje o swoich kluczach publicznych.
- Zaufane trzecie strony w Internecie (Trusted Third Parties) potwierdzają autentyczność tych kluczy publicznych za pomocą certyfikatów cyfrowych. Trzecia strona wystawia poświadczenia, które są trudne do sfalszowania.
- Od tego momentu wszystkie osoby, które ufają trzeciej stronie, po prostu akceptują poświadczenia wystawiane przez tę stronę.
- Infrastruktura Klucza Publicznego (**Public Key Infrastructure - PKI**) składa się ze specyfikacji, systemów i narzędzi służących do tworzenia, zarządzania, dystrybucji, używania, przechowywania i unieważniania certyfikatów cyfrowych.
- Urząd Certyfikacji (CA) tworzy certyfikaty cyfrowe poprzez powiązanie klucza publicznego z potwierdzoną tożsamością, taką jak strona internetowa lub osoba.

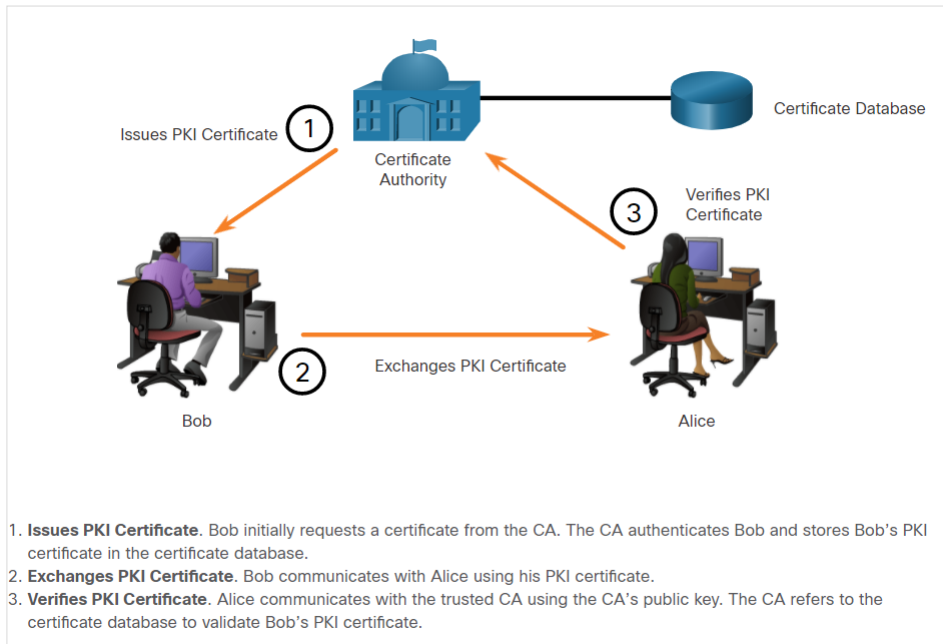


Zarządzanie kluczami publicznymi

- PKI (Infrastruktura Klucza Publicznego) jest niezbędna do obsługi wielkoskalowej dystrybucji oraz identyfikacji publicznych kluczy szyfrujących.
- Ramy PKI umożliwiają tworzenie wysoce skalowalnych relacji zaufania.
- Składa się ona ze sprzętu, oprogramowania, ludzi, polityk oraz procedur potrzebnych do tworzenia, zarządzania, przechowywania, dystrybucji i unieważniania certyfikatów cyfrowych.



Zarządzanie kluczami publicznymi



Uwaga: Nie wszystkie certyfikaty PKI są otrzymywane bezpośrednio od głównego urzędu CA. Urząd Rejestracji (**Registration Authority - RA**) jest podrzędnym organem (subordinate CA), który posiada certyfikację od głównego urzędu (**root CA**) do wystawiania certyfikatów dla określonych celów.

Zarządzanie kluczami publicznymi

Polska:

1. Poziom Główny: Narodowe Centrum Certyfikacji (NCCert)

NCCert, działający w strukturach Narodowego Banku Polskiego, pełni rolę **Głównego Urzędu Certyfikacji dla infrastruktury bezpiecznego podpisu elektronicznego** (Root CA dla usług kwalifikowanych).

Zadanie: Wystawia certyfikaty dla kwalifikowanych dostawców usług zaufania.

Bezpieczeństwo: Klucz prywatny NCCert jest przechowywany w sprzętowych modułach bezpieczeństwa (**HSM – Hardware Security Modules**) o najwyższej klasie odporności, fizycznie odizolowanych od sieci zewnętrznych.

2. Poziom Pośredni: Kwalifikowani Dostawcy Usług Zaufania (QTSP)

Są to podmioty komercyjne lub publiczne, które przeszły rygorystyczny audyt bezpieczeństwa i uzyskały wpis na listę prowadzoną przez Ministerstwo Cyfryzacji (tzw. **TSL – Trusted Service List**).

Podmioty: Należą do nich m.in. **Asseco (Certum)**, **KIR (Szafir)**, **PWPW (Sigillum)**.

Funkcja: Pełnią rolę **Subordinate CA** oraz **RA** (Registration Authority). To one dokonują fizycznej weryfikacji tożsamości obywatela lub firmy i wydają certyfikat kwalifikowany.

3. Poziom Użytkownika Końcowego (End Entity)

To końcowy certyfikat wydany dla konkretnej osoby fizycznej lub prawnej, wykorzystywany do składania podpisów lub pieczęci elektronicznych.

System organów PKI

- Wiele firm (dostawców) oferuje serwery CA jako usługę zarządzaną (managed service) lub jako produkt dla użytkownika końcowego.
- Organizacje mogą również wdrażać **prywatne systemy PKI**, korzystając z rozwiązań takich jak Microsoft Windows Server (Active Directory Certificate Services) lub OpenSSL.
- Organy CA wystawiają certyfikaty w oparciu o **klasy**, które określają stopień zaufania do danego certyfikatu.
- Numer klasy jest ustalany na podstawie tego, jak rygorystyczna była procedura weryfikacji tożsamości posiadacza podczas wystawiania certyfikatu.
- **Im wyższy numer klasy, tym bardziej zaufany jest certyfikat.**
- Niektóre klucze publiczne CA są fabrycznie wgrane do oprogramowania, czego przykładem są listy zaufanych urzędów w przeglądarkach internetowych.

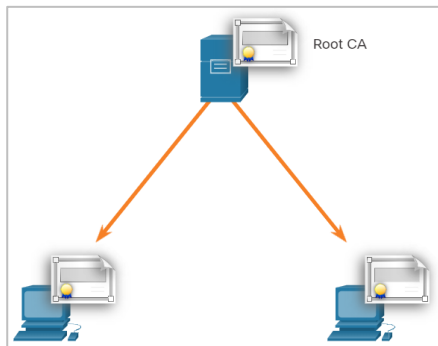
Klasa	Opis
0	Używana do testów w sytuacjach, w których nie przeprowadzono żadnych procesów weryfikacji.
1	Używana przez osoby fizyczne, które wymagają weryfikacji adresu e-mail.
2	Używana przez organizacje, od których wymagany jest dowód tożsamości.
3	Używana do zabezpieczania serwerów oraz podpisywania oprogramowania (software signing).
4	Używana do transakcji biznesowych online pomiędzy firmami (B2B).
5	Używana przez organizacje prywatne lub na potrzeby bezpieczeństwa rządowego.

Uwaga: Przedsiębiorstwo może również wdrożyć system PKI na użytek wewnętrzny. PKI może służyć do uwierzytelniania pracowników uzyskujących dostęp do sieci. W takim przypadku przedsiębiorstwo pełni rolę własnego organu certyfikującego (CA).

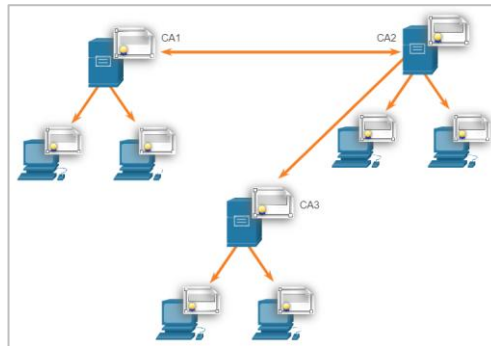
System organów PKI

Systemy PKI mogą tworzyć różne topologie zaufania, do których należą:

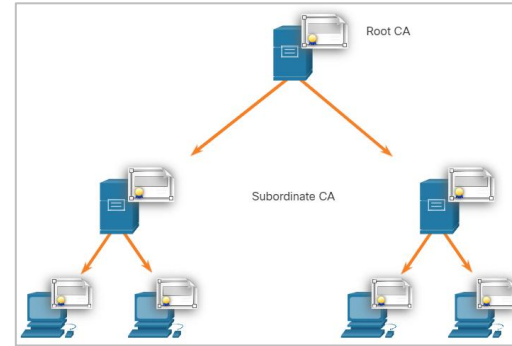
- **Topologia PKI z pojedynczym korzeniem (Single-Root PKI):** Jest to najprostsza struktura. Główny urząd (Root CA) wystawia wszystkie certyfikaty użytkownikom końcowym w ramach tej samej organizacji.
- **Topologie z krzyżową certyfikacją (Cross-certified CA):** Model typu peer-to-peer, w którym poszczególne urzędy CA ustanawiają relacje zaufania z innymi urządami poprzez wzajemne certyfikowanie swoich certyfikatów CA.
- **Hierarchiczne topologie CA:** Główny urząd (Root CA – najwyższy poziom) może wystawiać certyfikaty zarówno użytkownikom końcowym, jak i urządzeniom podrzędnym (Subordinate CA).



Single-Root PKI
Topology



Cross-certified CA
Topologies

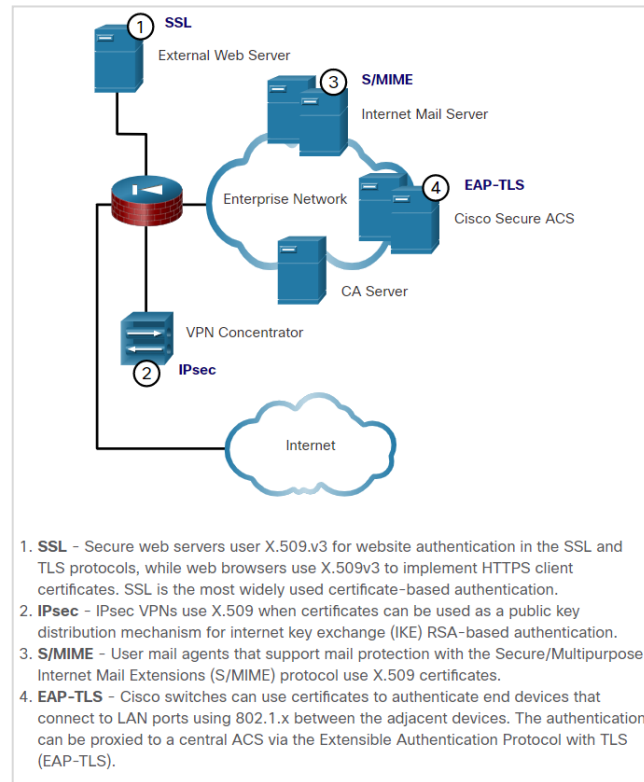


Hierarchical CA Topologies

Interoperacyjność różnych dostawców PKI

- Interoperacyjność (zdolność do współpracy) pomiędzy systemem PKI a usługami wspierającymi jest istotnym wyzwaniem, ponieważ wielu dostawców CA zaproponowało i wdrożyło własne, zamknięte rozwiązania (proprietary solutions).
- Aby rozwiązać ten problem, organizacja IETF opublikowała dokument **RFC 2527** (*Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework*).
- Standard **X.509 w wersji 3 (X.509 v3)** definiuje uniwersalny format certyfikatu cyfrowego.

Uwaga: LDAP oraz X.500 to protokoły używane do odpytywania usług katalogowych (takich jak Microsoft Active Directory) w celu weryfikacji nazwy użytkownika i hasła.

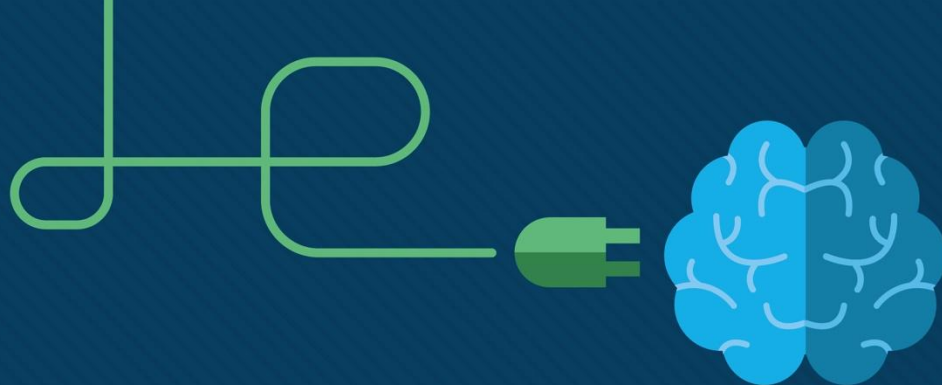


X.509v3 Applications

Rejestracja, uwierzytelnianie i unieważnianie certyfikatów

- Wszystkie systemy korzystające z PKI muszą posiadać klucz publiczny urzędu CA, który nazywany jest **certyfikatem samopodpisanym** (self-signed certificate).
- Klucz publiczny CA weryfikuje wszystkie certyfikaty wystawione przez ten urząd i jest niezbędny do prawidłowego działania PKI.
- Proces **rejestracji certyfikatu** (enrollment) służy systemowi hosta do przyłączenia się do PKI. W tym celu certyfikaty CA są pobierane w trybie *in-band* przez sieć, natomiast uwierzytelnianie odbywa się w trybie *out-of-band* (OOB), na przykład przez telefon.
- System rejestrujący się w PKI kontaktuje się z urzędem CA, aby poprosić o własny cyfrowy certyfikat tożsamości oraz uzyskać samopodpisany certyfikat urzędu CA.
- Ostatni etap polega na weryfikacji autentyczności certyfikatu CA i jest wykonywany metodą pozapasmową (*out-of-band*), np. przez sieć telefoniczną (POTS), w celu uzyskania **odcisku palca** (fingerprint) prawidłowego certyfikatu tożsamości CA.
- Certyfikat cyfrowy może zostać **unieważniony** (revoked), jeśli klucz zostanie naruszony (wycieknie) lub jeśli nie jest już potrzebny.

Uwaga: Tylko główny urząd (root CA) może wystawić certyfikat samopodpisany, który jest uznawany lub weryfikowany przez inne urzędy CA w ramach danej infrastruktury PKI.



Ochrona punktów końcowych

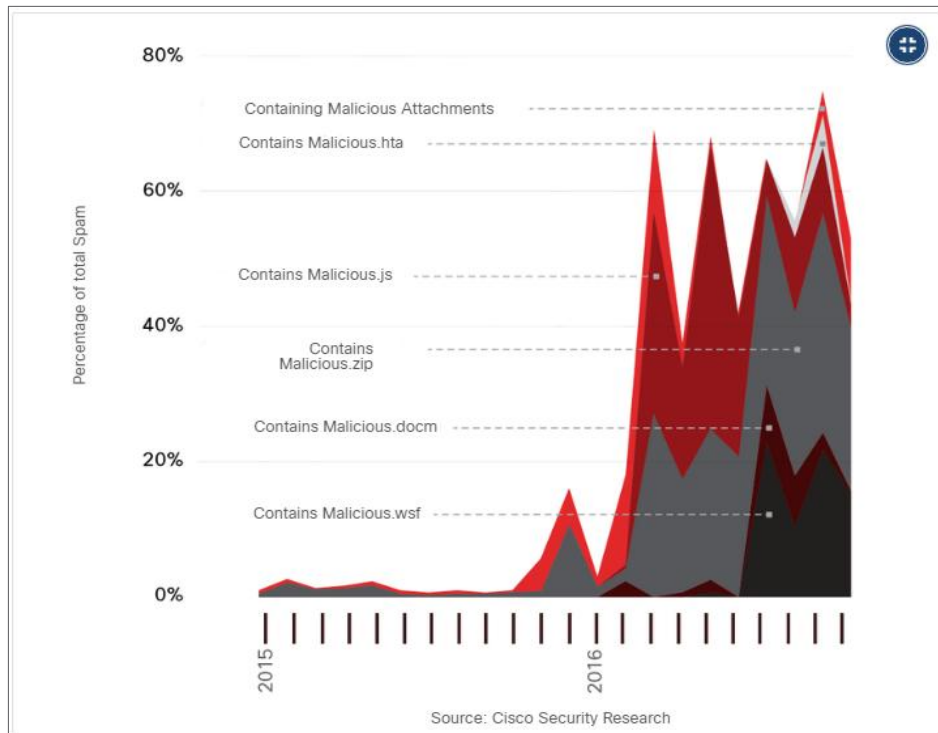
CyberOps Associate v1.0



9.1 Ochrona przed złośliwym oprogramowaniem

Zagrożenia dla punktów końcowych

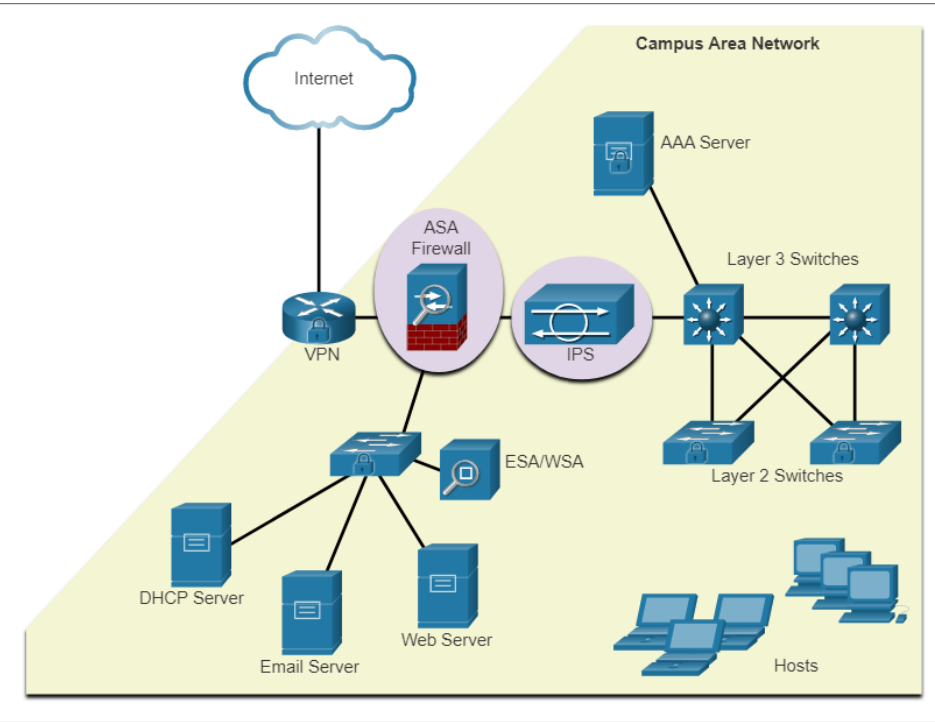
- Punkty końcowe (endpoints) można zdefiniować jako hosty w sieci, które mają dostęp do innych hostów lub same mogą być przez nie dostępne.
- Każdy punkt końcowy stanowi potencjalną drogę dla złośliwego oprogramowania (malware) do uzyskania dostępu do sieci.
- Urządzenia uzyskujące zdalny dostęp do sieci poprzez tunele VPN również są punktami końcowymi, które mogą wprowadzić malware do sieci VPN z sieci publicznej.
- Zaobserwowano, że kilka powszechnych typów złośliwego oprogramowania potrafi znacząco zmienić swoje cechy w czasie krótszym niż 24 godziny, aby uniknąć wykrycia.



Malicious Spam Percentage

Zagrożenia dla punktów końcowych

- Ponieważ wiele ataków ma swój początek wewnątrz sieci, zabezpieczenie wewnętrznej sieci LAN jest niemal tak samo ważne, jak zabezpieczenie zewnętrznego obwodu sieci (perimeter).
- Gdy host wewnętrzny zostanie zainfekowany (zinfiltrowany), może stać się dla atakującego punktem wyjścia do uzyskania dostępu do krytycznych urządzeń systemowych, takich jak serwery, oraz do wrażliwych informacji.
- Istnieją dwa główne elementy wewnętrznej sieci LAN, które należy zabezpieczyć:
 - **Punkty końcowe (Endpoints)** – hosty są podatne na ataki związane ze złośliwym oprogramowaniem (malware).
 - **Infrastruktura sieciowa** – urządzenia infrastruktury LAN (takie jak przełączniki i routery), które łączą ze sobą punkty końcowe.

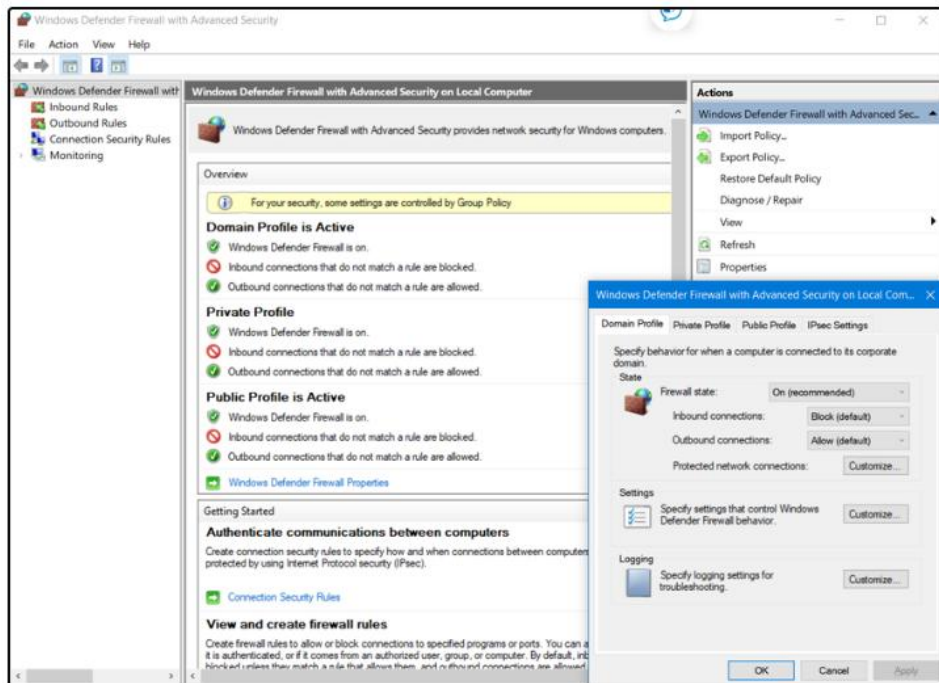


Ochrona hostów przed złośliwym oprogramowaniem

- Oprogramowanie antywirusowe/antymalware oraz zapory ogniowe (firewalle) instalowane na hostach są używane do ochrony urządzeń mobilnych korzystających z połączeń VPN.
- **Oprogramowanie Antywirusowe/Antymalware** Jest to program instalowany bezpośrednio na hoście w celu wykrywania i neutralizowania wirusów oraz złośliwego oprogramowania. Przykłady to: Windows Defender, Cisco AMP for Endpoints (obecnie Cisco Secure Endpoint), Norton Security, McAfee czy Trend Micro.
- Programy antymalware mogą wykrywać wirusy przy użyciu trzech różnych podejść:
 - **Oparte na sygnaturach (Signature-based):** Rozpoznaje charakterystyczne cechy (odciski cyfrowe) znanych plików złośliwego oprogramowania.
 - **Oparte na heurystyce (Heuristics-based):** Rozpoznaje ogólne cechy wspólne dla różnych typów złośliwego oprogramowania (szukanie podobieństw).
 - **Oparte na zachowaniu (Behavior-based):** Wykorzystuje analizę podejrzanych działań wykonywanych przez program w czasie rzeczywistym.
- Ochrona antywirusowa bazująca na hoście, znana również jako **agentowa (agent-based)**, działa na każdej chronionej maszynie.

Ochrona hostów przed złośliwym oprogramowaniem

- **Zapora ogniowa bazująca na hoście (Host-based Firewall)**
- Jest to oprogramowanie zainstalowane bezpośrednio na konkretnym urządzeniu (hoście).
- Ogranicza ono połączenia przychodzące i wychodzące wyłącznie do tych, które zostały zainicjowane przez ten konkretny host lub są przez niego dozwolone.
- Niektóre zapory ogniowe potrafią zapobiec zainfekowaniu hosta oraz powstrzymać zainfekowane urządzenia przed rozprzestrzenianiem złośliwego oprogramowania na inne komputery w sieci. Funkcja ta jest wbudowana w niektóre systemy operacyjne.
- Przykładem jest system Windows, który zawiera narzędzie **Windows Defender Firewall z zabezpieczeniami zaawansowanymi**.



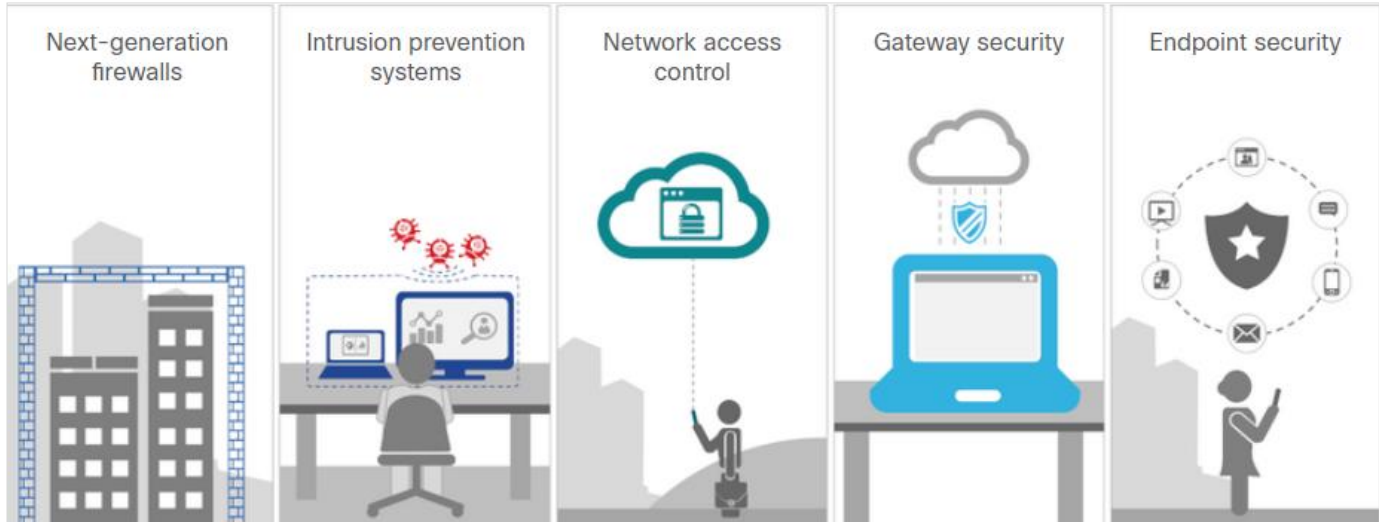
Ochrona hostów przed złośliwym oprogramowaniem

- **Pakiety bezpieczeństwa bazujące na hoście (Host-based Security Suites)**
- Zaleca się instalowanie pakietów produktów bezpieczeństwa na urządzeniach w sieciach domowych i biznesowych, aby zapewnić **warstwową obronę** (layered defense), która ochroni przed większością powszechnych zagrożeń.
- Pakiety te zazwyczaj obejmują:
 - **Antywirus** (antivirus)
 - **Ochronę przed phishingiem** (anti-phishing)
 - **Bezpieczne przeglądanie** (safe browsing)
 - **HIPS** (Host-based Intrusion Prevention System – system zapobiegania włamaniom na hoście)
 - **Zaporę ogniową** (firewall)
- Produkty te pełnią również **funkcję telemetryczną**. Większość oprogramowania zabezpieczającego zawiera rozbudowane funkcje logowania (rejestrowania zdarzeń), które są niezbędne w operacjach cyberbezpieczeństwa.
- Niezależne laboratorium badawcze **AV-TEST** dostarcza wysokiej jakości recenzje tego typu zabezpieczeń, a także informacje o wielu innych produktach z branży security.

Sieciowa ochrona przed złośliwym oprogramowaniem

Urządzenia do zapobiegania złośliwemu oprogramowaniu oparte na sieci są zdolne do wymiany informacji między sobą, co pozwala im na podejmowanie lepszych i bardziej świadomych decyzji.

Ochrona punktów końcowych w sieciach typu „borderless” (bez wyraźnych granic) może być realizowana przy użyciu zarówno technik sieciowych, jak i tych bazujących na hostach.



Advanced Malware Protection Everywhere

Sieciowa ochrona przed złośliwym oprogramowaniem

Rozwiązanie	Opis i funkcjonalność
Advanced Malware Protection (AMP)	Zapewnia ochronę punktów końcowych przed wirusami i złośliwym oprogramowaniem (obecnie znane jako Cisco Secure Endpoint).
Email Security Appliance (ESA)	Odpowiada za filtrowanie spamu oraz potencjalnie złośliwych wiadomości e-mail, zanim dotrą one do punktu końcowego (skrzynki użytkownika).
Web Security Appliance (WSA)	Zapewnia filtrowanie stron internetowych oraz zarządzanie czarnymi listami (blokowanie dostępu do zainfekowanych witryn).
Network Admission Control (NAC)	Pozwala na podłączenie do sieci wyłącznie autoryzowanym i zgodnym z polityką bezpieczeństwa systemom (np. sprawdza, czy komputer ma aktualnego antywirusa).

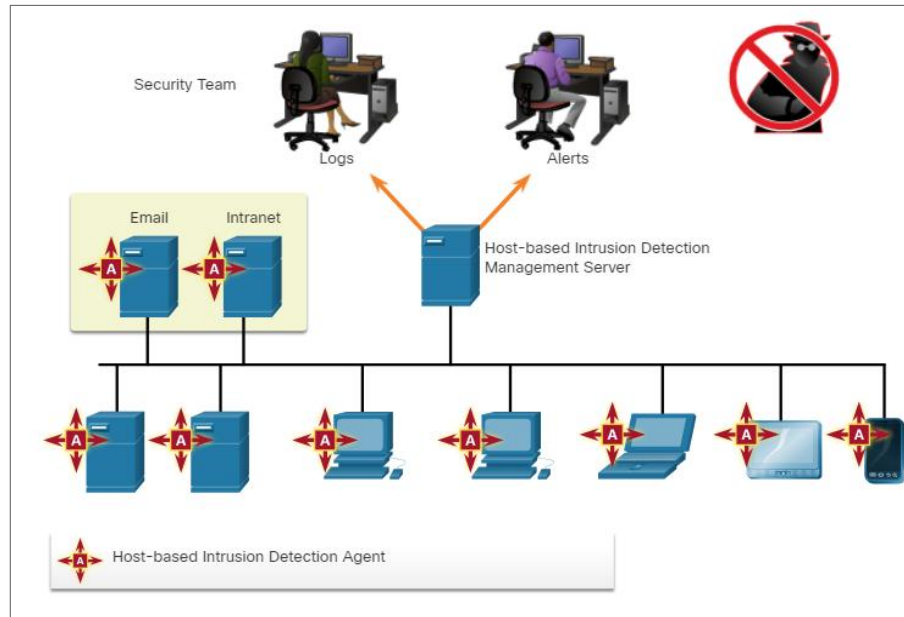
9.2 Ochrona hostów przed włamaniami

Zapory ogniowe bazujące na hoście

- Osobiste zapory ogniowe na hostach to samodzielne programy, które kontrolują ruch wchodzący i wychodzący z komputera. Aplikacje te mogą być również skonfigurowane tak, aby wysyłały powiadomienia do użytkowników w przypadku wykrycia podejrzanego zachowania.
- Przykłady zapór ogniowych na hostach:
 - **Windows Defender Firewall** – wprowadzony po raz pierwszy w systemie Windows XP; rozwiązanie to (wcześniej pod nazwą Zapora systemu Windows) stosuje podejście oparte na profilach (np. profil domowy, publiczny, domenowy).
 - **iptables** – aplikacja umożliwiająca administratorom systemów Linux konfigurowanie reguł dostępu sieciowego, które są częścią modułów Netfilter w jądrze systemu Linux.
 - **nftables** – następca iptables; jest to aplikacja firewall dla systemu Linux, która wykorzystuje prostą maszynę wirtualną działającą wewnątrz jądra systemu.
 - **TCP Wrappers** – system kontroli dostępu oparty na regułach oraz system logowania dla systemów Linux.

Systemy wykrywania włamań bazujące na hoście (HIDS)

- System wykrywania włamań na hoście (**HIDS – Host-based Intrusion Detection System**) został zaprojektowany w celu ochrony urządzeń przed znanym i nieznanym złośliwym oprogramowaniem (malware).
- HIDS potrafi prowadzić szczegółowe monitorowanie oraz raportowanie dotyczące konfiguracji systemu i aktywności aplikacji.
- HIDS to kompleksowa aplikacja zabezpieczająca, która łączy w sobie funkcjonalność programów antywirusowych z możliwościami zapory ogniowej (firewalla).
- Ponieważ HIDS musi działać bezpośrednio na hoście, jest uważany za system typu **agentowego** (agent-based).



Host-based Intrusion Detection Architecture

Operacje systemu HIDS

- System HIDS może zapobiegać włamaniom, ponieważ wykorzystuje **sygnatury** do wykrywania znanego złośliwego oprogramowania i powstrzymywania go przed zainfekowaniem systemu.
- Jednak niektóre rodziny złośliwego oprogramowania wykazują **polimorfizm** (zdolność do zmiany swojego kodu przy każdej infekcji). Aby wykryć włamania oprogramowania, które skutecznie unika detekcji opartej na sygnaturach, stosuje się dodatkowe strategie:
 - **Oparta na anomaliach (Anomaly-based):** Zachowanie systemu hosta jest porównywane z wyuczonym modelem bazowym (**baseline**) normalnego zachowania. Jeśli zostanie wykryte włamanie (odchylenie od normy), HIDS może zarejestrować szczegóły incydentu, wysłać alerty do systemów zarządzania bezpieczeństwem i podjąć działania w celu powstrzymania ataku.
 - **Oparta na politykach (Policy-based):** Normalne zachowanie systemu jest opisane za pomocą predefiniowanych reguł (lub ich naruszeń). Naruszenie tych polityk skutkuje reakcją HIDS, np. zamknięciem procesów oprogramowania.

Produkty klasy HIDS

- Większość systemów HIDS wykorzystuje oprogramowanie zainstalowane na hoście oraz pewnego rodzaju **scentralizowaną funkcjonalność zarządzania bezpieczeństwem**, która umożliwia integrację z usługami monitorowania bezpieczeństwa sieciowego oraz systemami analizy zagrożeń (threat intelligence).
- Przykłady rozwiązań HIDS:
 - **Cisco AMP** (obecnie Cisco Secure Endpoint)
 - **AlienVault USM** (Unified Security Management)
 - **Tripwire** (specjalizujący się w monitorowaniu integralności plików)
 - **OSSEC** (Open Source HIDS SECurity)
- **Charakterystyka systemu OSSEC:**
 - **Struktura Agent-Manager:** OSSEC wykorzystuje centralny serwer zarządzający (Manager) oraz agentów instalowanych na poszczególnych hostach.
 - **Analiza Logów Sieciowych:** Serwer OSSEC (Manager) może również odbierać i analizować alerty z różnych urządzeń sieciowych i zapór ogniowych (firewalli) za pośrednictwem protokołu **syslog**.
 - **Monitorowanie i Integralność:** OSSEC monitoruje logi systemowe na hostach, a także przeprowadza kontrolę integralności plików (**File Integrity Checking**).

Produkty klasy HIDS

Scenariusz: Atak Brute Force na SSH: haker próbuje włamać się na serwer Linux, zgadując hasło do konta root.

- 1. OSSEC na hoście (czujka):
 - W pliku `/var/log/auth.log` pojawiają się setki wpisów w ciągu kilku sekund:
May 14 16:40:01 server sshd[1234]: Failed password for root from 192.168.1.50 port 54321 ssh2
- 2. Manager OSSEC (analiza)
 - Agent OSSEC na serwerze przesyła te logi do Managera. Manager posiada regułę (np. Rule ID: 5712), która mówi:
"Jeśli wystąpi więcej niż 8 nieudanych prób logowania w ciągu 2 minut, podnieś poziom alarmu".

Host-Based Intrusion Protection

Produkty klasy HIDS

3. Alert (widzi administrator)

- Sformatowany alert, który trafia do konsoli lub na e-mail:

** Alert 1715701201.45892: - syslog,sshd,authentication_failed,

2026 May 14 16:40:05 (host-alpha) 192.168.1.10 -> /var/log/auth.log

Rule: 5712 (level 10) -> 'SSHD brute force trying to get access to the system.'

Src IP: 192.168.1.50

User: root

Log: May 14 16:40:01 server sshd[1234]: Failed password for root from 192.168.1.50 port 54321 ssh2

4. Aktywna reakcja

Po wygenerowaniu tego alertu, OSSEC może automatycznie uruchomić skrypt, który doda adres IP atakującego (192.168.1.50) do czarnej listy firewalla (iptables) na 24 godziny. Atak zostaje zduszony w zarodku bez udziału człowieka.

Host-Based Intrusion Protection

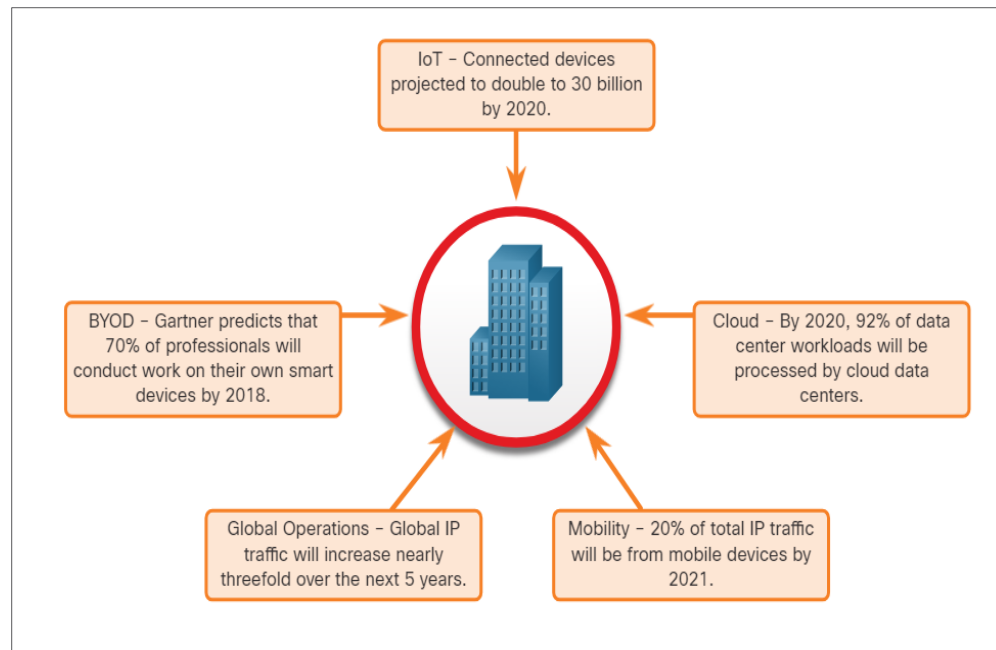
Produkty klasy HIDS

Cecha	HIDS	SIEM	SOAR
Główny cel	Wykrywanie na hoście	Analiza i korelacja danych	Automatyzacja odpowiedzi
Zakres	Lokalny (jeden host)	Globalny (cała firma)	Operacyjny (procesy naprawcze)
Źródło danych	System operacyjny	Wszystkie urządzenia (w tym HIDS)	Alerty z SIEM
Reakcja	Prosta (np. blokada IP)	Głównie raportowanie	Złożona (scenariusze/playbooki)

9.3 Bezpieczeństwo aplikacji

Powierzchnia ataku

- **Powierzchnia ataku** to całkowita suma wszystkich podatności (słabych punktów) w danym systemie, które są dostępne dla atakującego. Im większa powierzchnia ataku, tym łatwiej hakerowi znaleźć drogę do wnętrza Twojej organizacji.
- Może ona obejmować otwarte porty na serwerach lub hostach, oprogramowanie działające na serwerach z dostępem do Internetu, protokoły sieci bezprzewodowych, a nawet samych użytkowników.



An Expanding Attack Surface

Powierzchnia ataku

▪ 1. Sieciowa powierzchnia ataku (Network Attack Surface)

Dotyczy wykorzystywania luk w protokołach sieciowych oraz infrastrukturze.

- **Przykłady:** Otwarte porty (np. zapomniany port 23 dla Telnet), niezaszyfrowane kanały komunikacji, błędy w konfiguracji routerów czy luki w protokołach takich jak SMB czy DNS.
- **Cel atakującego:** Przechwycenie danych w locie, przeprowadzenie ataku Man-in-the-Middle lub penetracja sieci LAN.

▪ 2. Programowa powierzchnia ataku (Software Attack Surface)

Związana z błędami w kodzie aplikacji webowych, chmurowych lub instalowanych lokalnie na hostach.

- **Przykłady:** Brak aktualizacji (niezałatane błędy), podatności typu SQL Injection w formularzach na stronach www, przepełnienia bufora w starym oprogramowaniu.

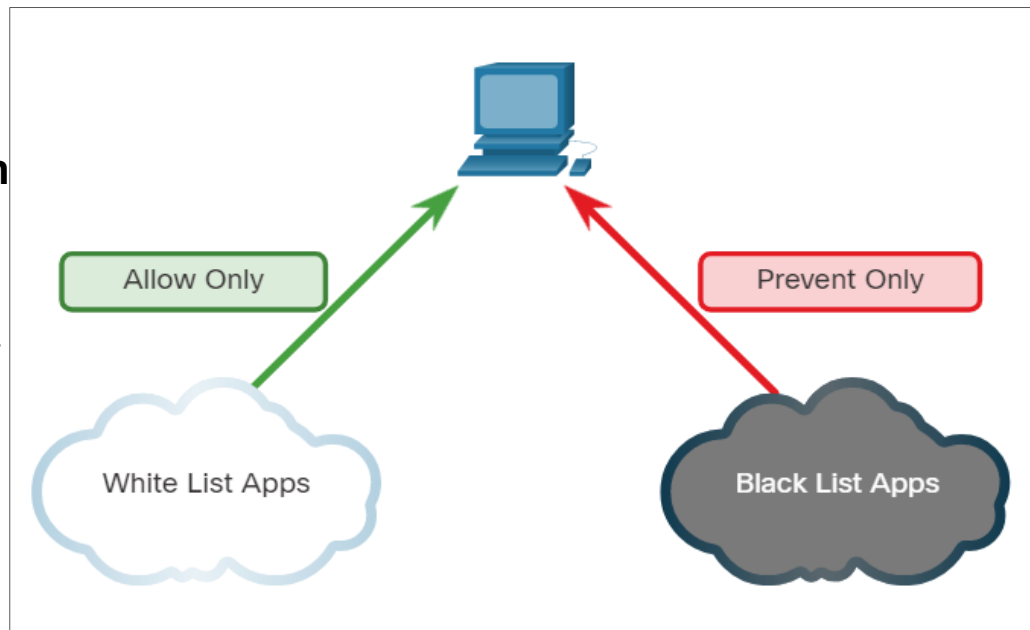
▪ 3. Ludzka powierzchnia ataku (Human Attack Surface)

To najsłabsze ogniwo – błędy i zachowania użytkowników.

- **Przykłady:** Podatność na phishing, używanie słabych haseł, podłączanie znalezionych pendrive'ów, nieświadome udostępnianie wrażliwych informacji w mediach społecznościowych.

Czarne i białe listy aplikacji (Blacklisting vs. Whitelisting)

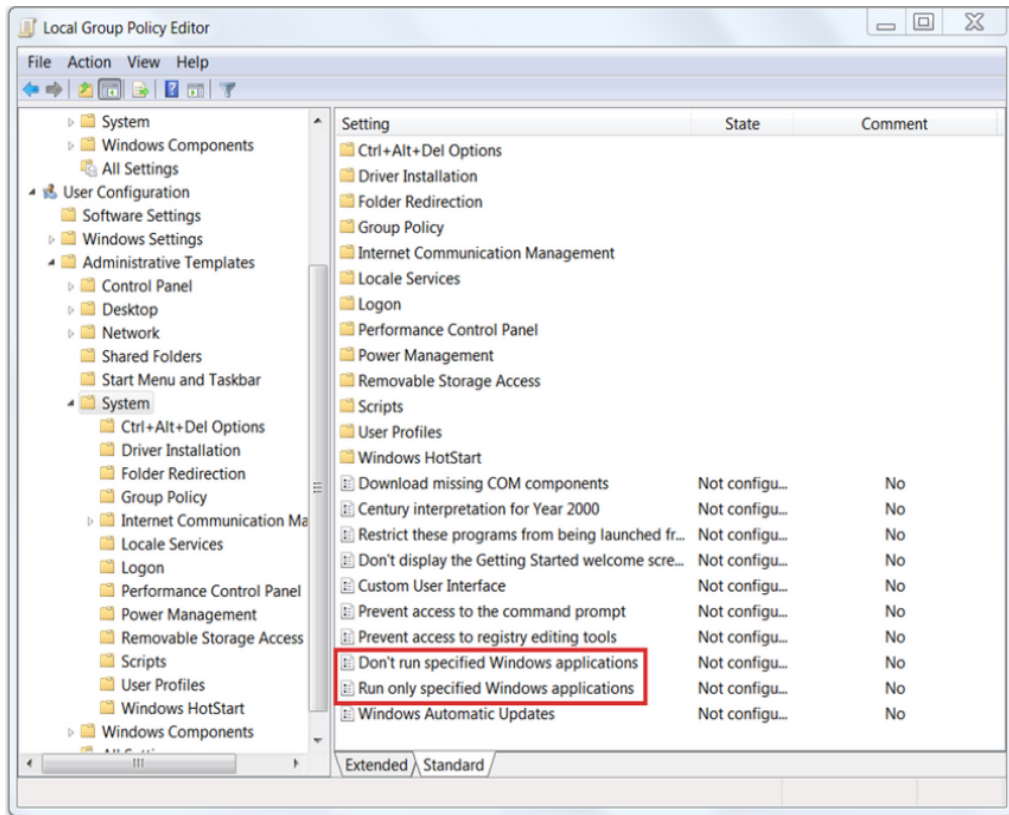
- Ograniczanie dostępu do potencjalnych zagrożeń poprzez tworzenie list zakazanych aplikacji nazywane jest **tworzeniem czarnych list (blacklisting)**.
- Czarne listy aplikacji mogą narzucać, które programy użytkownika nie mają pozwolenia na uruchomienie w systemie.
- **Białe listy (whitelisting)** określają, które programy są dozwolone.
- W ten sposób można zapobiec sytuacji, w której znane, podatne na ataki aplikacje tworzą luki w bezpieczeństwie hostów sieciowych.



Application Blacklisting and Whitelisting

Czarne i białe listy aplikacji

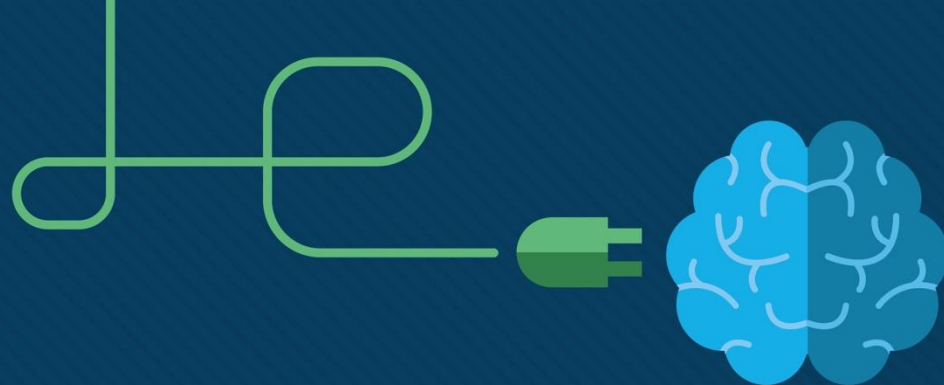
- Strony internetowe, podobnie jak aplikacje, mogą być umieszczane na białych lub czarnych listach.
- Czarne listy mogą być tworzone ręcznie przez administratorów lub pozyskiwane z zewnętrznych serwisów bezpieczeństwa.
- Listy te są stale aktualizowane przez dostawców zabezpieczeń i przesyłane do zapór ogniowych (firewalli) oraz innych systemów ochrony.
- Przykładem jest system zarządzania bezpieczeństwem **Cisco Firepower**, który może korzystać z usługi inteligencji zagrożeń **Cisco Talos**, aby automatycznie pobierać aktualne czarne listy.



Piaskownica systemowa

- **Sandboxing** to technika pozwalająca na uruchamianie i analizowanie podejrzanych plików w bezpiecznym, odizolowanym środowisku.
- **Cuckoo Sandbox** to popularny, darmowy system do analizy złośliwego oprogramowania. Można go uruchomić lokalnie i przesyłać do niego próbki malware w celu przeprowadzenia szczegółowej analizy.
- **ANY.RUN** to narzędzie online, które umożliwia przysyłanie próbek złośliwego oprogramowania do analizy, podobnie jak każda inna piaskownica internetowa.





Ocena podatności punktów końcowych

CyberOps Associate v1.0



9.4 Profilowanie sieci i serwerów

Profilowanie sieci

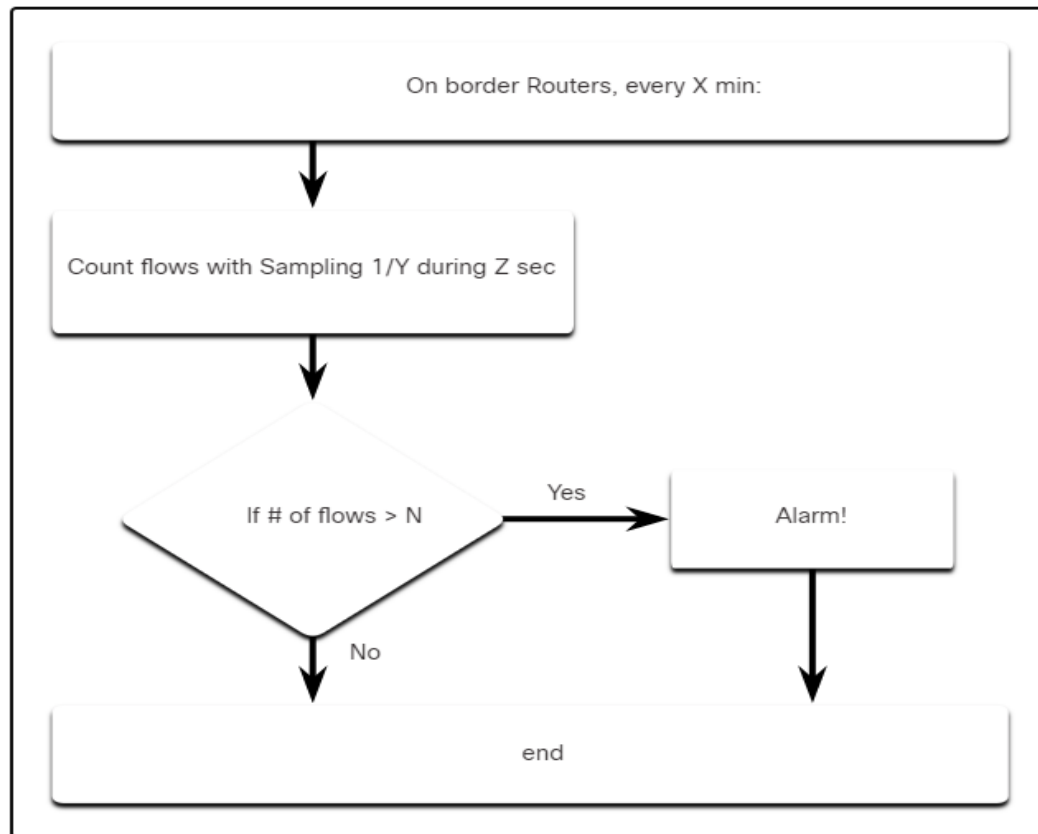
- Profilowanie sieci i urządzeń dostarcza statystycznych informacji bazowych (**baseline**), które mogą służyć jako punkt odniesienia dla normalnej wydajności sieci oraz urządzeń.
- **Elementy profilu sieciowego:**
 - **Czas trwania sesji (Session duration):** Informacja o tym, jak długo zazwyczaj trwają połączenia w sieci.
 - **Całkowita przepustowość (Total throughput):** Miara całkowitej ilości danych przesyłanych w danym czasie.
 - **Przestrzeń adresowa zasobów krytycznych (Critical asset address space):** Zakres adresów IP należących do najważniejszych systemów i serwerów w organizacji.
 - **Typowy rodzaj ruchu (Typical traffic type):** Charakterystyka najczęściej wykorzystywanych protokołów i aplikacji (np. HTTPS, SQL, SSH).

Profilowanie serwerów

- Profil serwera stanowi **punkt odniesienia dla bezpieczeństwa** (security baseline) dla konkretnej maszyny. Profilowanie serwerów jest wykorzystywane do ustalenia akceptowalnego (prawidłowego) stanu operacyjnego serwerów.
- **Elementy profilu serwera są następujące:**
 - **Nasłuchujące porty (Listening ports):** Wykaz otwartych portów, na których serwer nasłuchuje połączeń przychodzących. Każdy port spoza profilu może oznaczać obecność nieautoryzowanej usługi lub „tylnej furtki” (backdoor).
 - **Zalogowani użytkownicy i konta (Logged in users and accounts):** Monitorowanie, kto jest obecnie zalogowany oraz jakie konta lokalne i domenowe mają uprawnienia do dostępu.
 - **Konta usługowe (Service accounts):** Specjalne konta używane przez aplikacje i system operacyjny do uruchamiania usług. Profilowanie ich pomaga wykryć próby eskalacji uprawnień.
 - **Środowisko oprogramowania (Software environment):** Kompletna lista zainstalowanych aplikacji, bibliotek oraz ich wersji. Pozwala to na identyfikację oprogramowania, które wymaga aktualizacji ze względu na nowo odkryte podatności.

Wykrywanie anomalii sieciowych

- Zachowanie sieci jest opisywane przez ogromną ilość różnorodnych danych, takich jak cechy przepływu pakietów (flow), cechy samych pakietów oraz telemetria pochodząca z wielu źródeł.
- Techniki analizy dużych zbiorów danych mogą być wykorzystywane do badania tych informacji i wykrywania odchyleń od stanu bazowego (**baseline**).
- Wykrywanie anomalii pozwala zidentyfikować zainfekowane hosty w sieci, które skanują otoczenie w poszukiwaniu innych podatnych urządzeń.
- Schemat ilustruje uproszczoną wersję algorytmu zaprojektowanego do wykrywania nietypowych stanów na routerach brzegowych przedsiębiorstwa.



Testowanie podatności sieciowych

- Testowanie podatności sieciowych obejmuje analizę ryzyka (**Risk Analysis**), ocenę podatności (**Vulnerability Assessment**) oraz testy penetracyjne (**Penetration Testing**).
- Poniższa tabela przedstawia przykłady działań oraz narzędzi wykorzystywanych podczas testowania podatności:

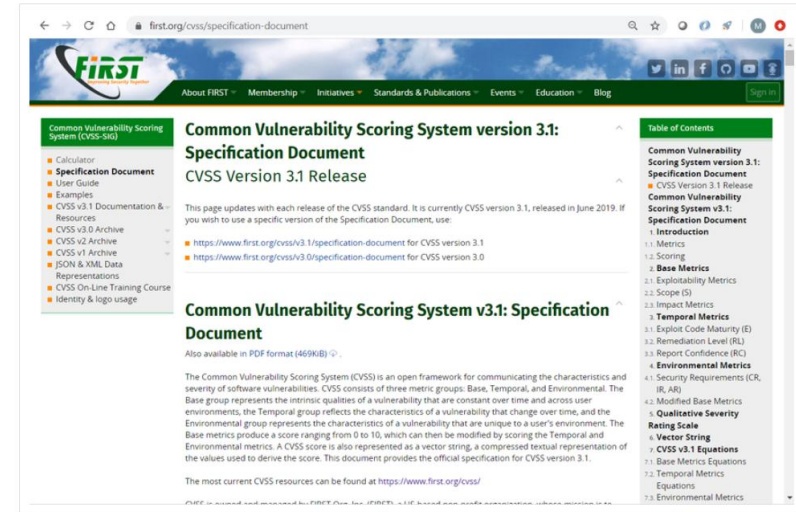
Działanie	Opis	Narzędzia
Analiza ryzyka (Risk analysis)	Kompleksowa analiza wpływu ataków na kluczowe zasoby oraz funkcjonowanie firmy.	Konsultanci wewnętrzni i zewnętrzni, ramy zarządzania ryzykiem (frameworki).
Ocena podatności (Vulnerability Assessment)	Zarządzanie poprawkami, skanowanie hostów, skanowanie portów oraz inne usługi i skany podatności.	OpenVAS, Microsoft Baseline Security Analyzer, Nessus, Qualys, Nmap.
Testy penetracyjne (Penetration Testing)	Wykorzystanie technik i narzędzi hakerskich w celu przełamania zabezpieczeń sieciowych i określenia głębokości potencjalnej penetracji.	Metasploit, CORE Impact, etyczni hakerzy.

9.5 Common Vulnerability Scoring System (CVSS)

Common Vulnerability Scoring System (CVSS)

Przegląd CVSS

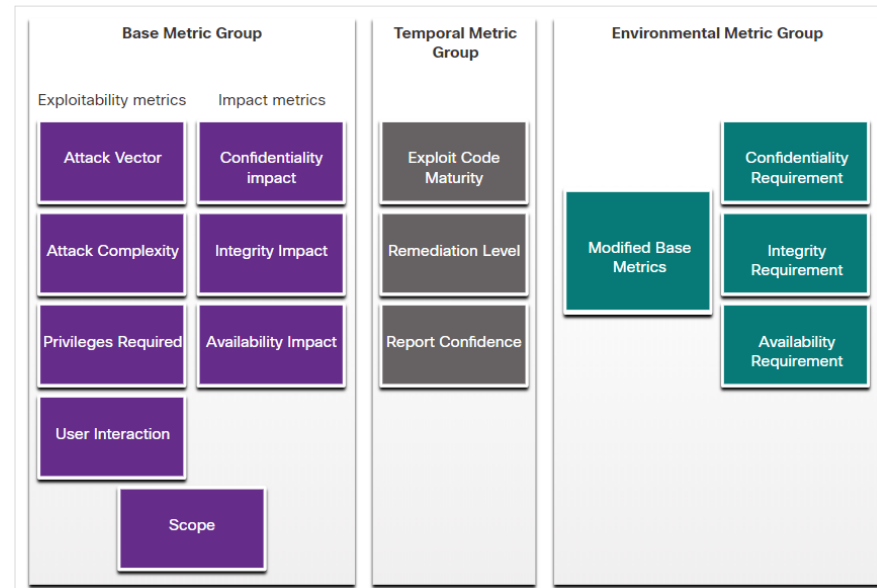
- **Common Vulnerability Scoring System (CVSS)** to narzędzie do oceny ryzyka, zaprojektowane w celu przekazywania wspólnych cech oraz stopnia dotkliwości podatności w systemach sprzętowych i programowych.
- CVSS zapewnia ustandaryzowane wyniki (punkty) dla wykrytych podatności.
- Zapewnia otwarty szkielet (framework) z metrykami dostępnymi dla wszystkich użytkowników.
- CVSS pomaga ustalać priorytety w zarządzaniu ryzykiem (pozwala zdecydować, którą lukę naprawić w pierwszej kolejności).
- Organizacja **FIRST** (Forum of Incident Response and Security Teams) została wyznaczona na opiekuna CVSS, aby promować jego wdrażanie na całym świecie.



Common Vulnerability Scoring System (CVSS)

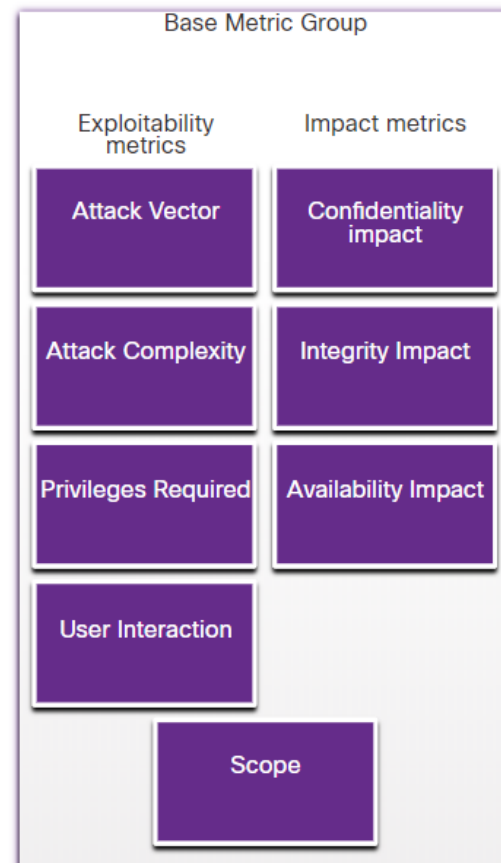
Grupy metryk CVSS

- System CVSS wykorzystuje trzy grupy metryk do oceny podatności, co pozwala na precyzyjne określenie ryzyka w różnych kontekstach:
- Grupa metryk bazowych (Base Metric Group):** Reprezentuje cechy podatności, które są stałe w czasie oraz niezależne od kontekstu (środowiska). To te parametry określają m.in. jak trudny jest atak i jaki ma wpływ na poufność czy integralność danych.
- Grupa metryk czasowych (Temporal Metric Group):** Mierzy cechy podatności, które mogą zmieniać się w czasie, ale są jednakowe dla wszystkich użytkowników. Skupia się na tym, czy istnieje już gotowy kod ataku (exploit) oraz czy producent wydał już oficjalną poprawkę.
- Grupa metryk środowiskowych (Environmental Metric Group):** Mierzy aspekty podatności, które wynikają ze specyficznego środowiska danej organizacji. Pozwala dostosować ogólną ocenę do tego, jak ważne jest dane urządzenie dla Twojej firmy (np. ta sama luka jest groźniejsza na serwerze bankowym niż na komputerze w sali konferencyjnej).



Grupa metryk bazowych CVSS

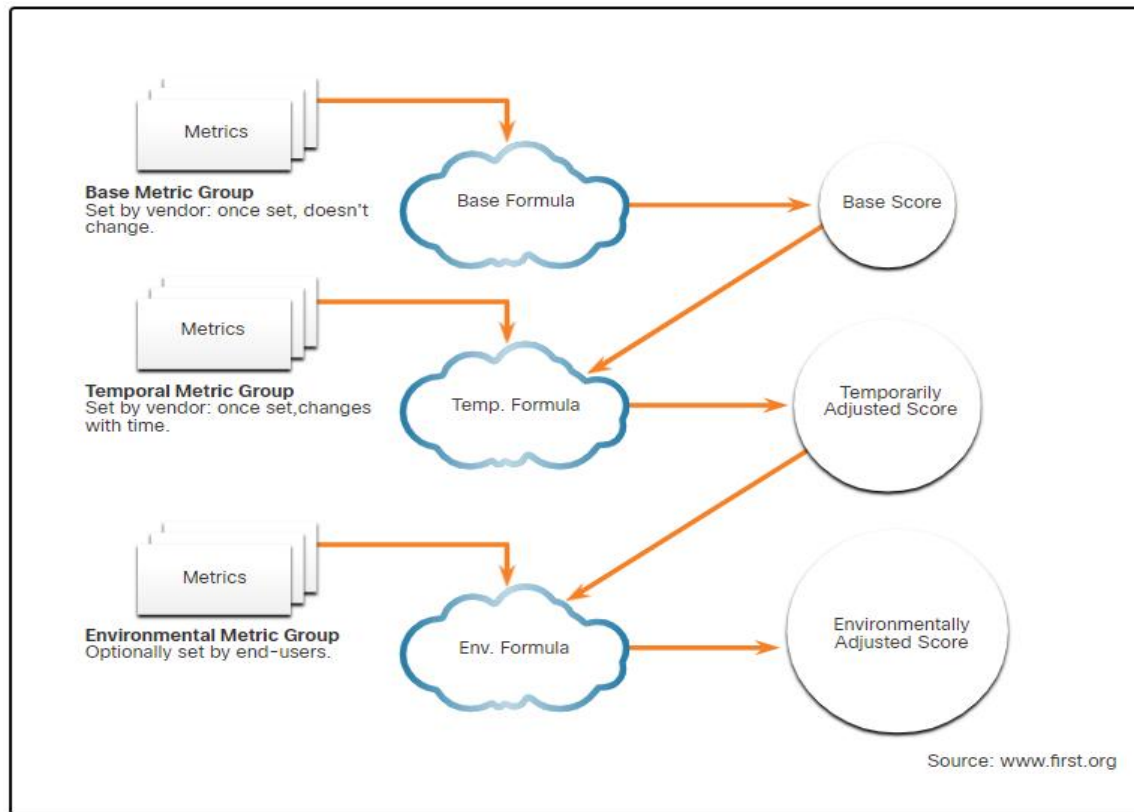
- **Metryki podatności na atak (Exploitability Metrics):**
 - **Wektor ataku (Attack vector):** Droga dotarcia do luki.
 - **Złożoność ataku (Attack complexity):** Poziom trudności wykonania ataku.
 - **Wymagane uprawnienia (Privileges required):** Poziom dostępu niezbędny do ataku.
 - **Interakcja z użytkownikiem (User interaction):** Konieczność działania ze strony ofiary.
 - **Zakres (Scope):** Wpływ na inne komponenty systemu.
- **Metryki wpływu (Impact Metrics):**
 - **Wpływ na poufność (Confidentiality Impact):** Stopień utraty tajności danych.
 - **Wpływ na integralność (Integrity Impact):** Stopień nieautoryzowanej modyfikacji danych.
 - **Wpływ na dostępność (Availability Impact):** Stopień zakłócenia dostępu do usług.



Common Vulnerability Scoring System (CVSS)

CVSS wyznaczanie

- Po uzupełnieniu grupy metryk bazowych, wartości metryk czasowych oraz środowiskowych modyfikują wyniki bazowe, aby zapewnić ogólny wynik końcowy.



CVSS wynik

- Im wyższa ocena dotkliwości, tym większy potencjalny wpływ eksploitu i większa pilność naprawy podatności. Każda podatność przekraczająca wartość **3.9** powinna zostać wyeliminowana.
- Poniższa tabela przedstawia przedziały punktowe oraz ich jakościowe znaczenie:

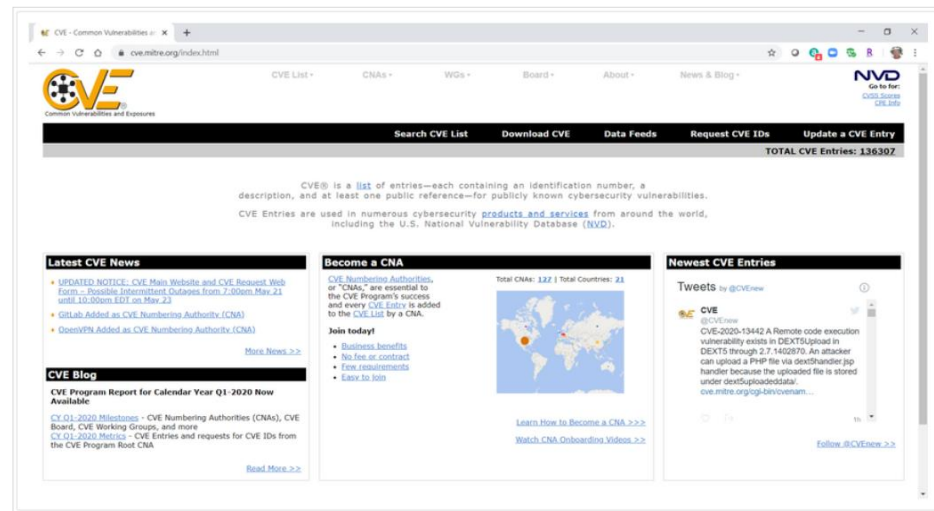
Ocena (Rating)	Wynik CVSS (Score)
Brak (None)	0
Niska (Low)	0.1 – 3.9
Średnia (Medium)	4.0 – 6.9
Wysoka (High)	7.0 – 8.9
Krytyczna (Critical)	9.0 – 10.0

CVSS jak liczyć?

- Proces CVSS wykorzystuje narzędzie zwane **Kalkulatorem CVSS v4 (2023r)**.
- Kalkulator przypomina **kwestionariusz**, w którym dokonuje się wyborów opisujących podatność dla każdej grupy metryk.
- Następnie generowany jest **wynik punktowy** i wyświetlana jest **liczbowa ocena stopnia dotkliwości** (severity rating).
- <https://www.first.org/cvss/calculator/4.0#>

Inne źródła informacji o podatnościach

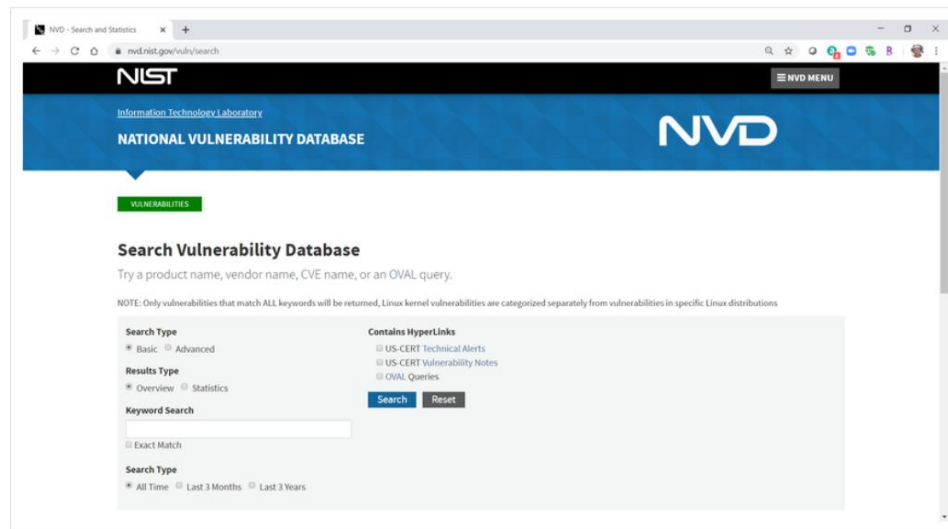
- **Common Vulnerabilities and Exposures (CVE):**
- **Identyfikator CVE** zapewnia standardowy sposób wyszukiwania i odwoływania się do konkretnych podatności.
- Usługi inteligencji zagrożeń (Threat intelligence) wykorzystują identyfikatory CVE, pojawiają się one również w logach różnych systemów bezpieczeństwa.
- Strona internetowa **CVE Details** zapewnia powiązanie pomiędzy wynikami punktowymi **CVSS** a informacjami zawartymi w **CVE**.



Inne źródła informacji o podatnościach

National Vulnerability Database (NVD):

- Wykorzystuje ona identyfikatory **CVE** i dostarcza dodatkowych informacji o podatnościach, takich jak wyniki punktowe zagrożeń **CVSS**, szczegóły techniczne, podmioty dotknięte luką oraz zasoby do dalszego badania sprawy.
- Baza danych została stworzona i jest utrzymywana przez amerykańską rządową agencję **NIST** (National Institute of Standards and Technology – Narodowy Instytut Standardów i Technologii).

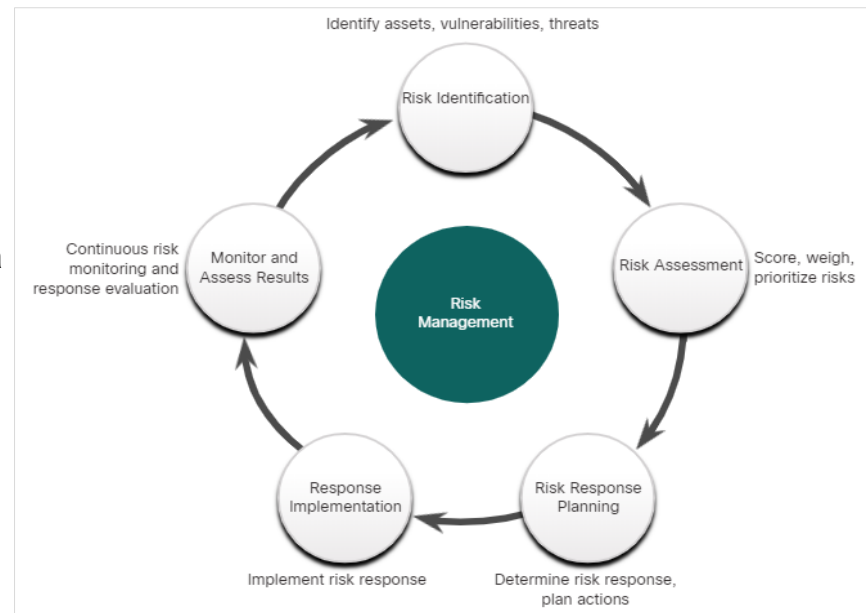


9.6 Bezpieczne zarządzanie urządzeniami

Secure Device Management

Zarządzanie ryzykiem

- Zarządzanie ryzykiem obejmuje wybór i określenie mechanizmów kontroli bezpieczeństwa dla danej organizacji. Obowiązkowym działaniem w ramach oceny ryzyka jest **identyfikacja zagrożeń i podatności**.
- **Sposoby reagowania na zidentyfikowane ryzyko:**
 - **Unikanie ryzyka (Risk avoidance):** Zaprzestanie wykonywania działań, które generują ryzyko (np. wyłączenie niebezpiecznej usługi).
 - **Redukcja ryzyka (Risk reduction):** Podjęcie kroków w celu zmniejszenia podatności (np. zainstalowanie poprawek lub wdrożenie firewalla).
 - **Dzielenie ryzyka (Risk sharing):** Przeniesienie części ryzyka na inne podmioty (np. wykupienie polisy ubezpieczeniowej lub outsourcing usług).
 - **Retencja ryzyka (Risk retention):** Akceptacja ryzyka oraz jego potencjalnych konsekwencji (stosowana, gdy koszt zabezpieczeń przewyższa wartość chronionego zasobu).



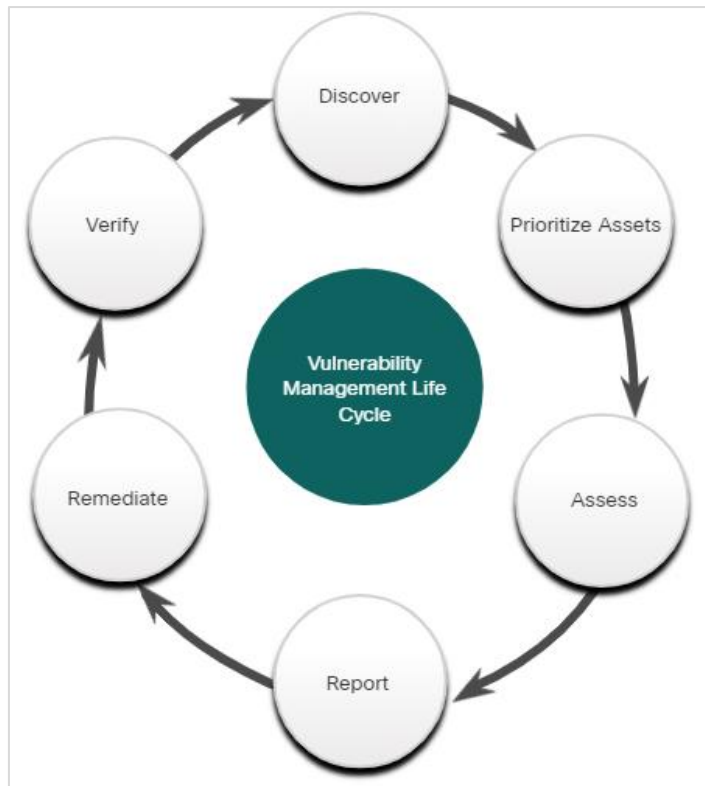
Zarządzanie podatnościami

- Zarządzanie podatnościami to praktyka bezpieczeństwa zaprojektowana w celu proaktywnego zapobiegania wykorzystywaniu luk w infrastrukturze IT.
- **Kroki w Cyklu Życia Zarządzania Podatnościami:**
 - **Odkrywanie (Discover):** Opracowanie stanu bazowego sieci (**baseline**). Identyfikacja luk bezpieczeństwa w ramach regularnego, automatycznego harmonogramu.
 - **Priorytetyzacja zasobów (Prioritize Assets):** Kategoryzacja zasobów na grupy lub jednostki biznesowe oraz przypisanie im wartości biznesowej w oparciu o ich znaczenie dla operacji firmy.
 - **Ocena (Assess):** Określenie bazowego profilu ryzyka w celu wyeliminowania zagrożeń na podstawie krytyczności zasobów, podatności, zagrożeń oraz klasyfikacji zasobów.



Zarządzanie podatnościami

- **Raportowanie (Report):** Pomiar poziomu ryzyka biznesowego powiązanego z Twoimi zasobami zgodnie z przyjętymi politykami bezpieczeństwa. Dokumentowanie planu bezpieczeństwa, monitorowanie podejrzanej aktywności oraz opisywanie znanych podatności.
- **Naprawa (Remediate):** Ustalanie priorytetów zgodnie z ryzykiem biznesowym i eliminowanie podatności w kolejności od najbardziej ryzykownych.
- **Weryfikacja (Verify):** Sprawdzanie, czy zagrożenia zostały wyeliminowane, poprzez audyty sprawdzające (następcze).

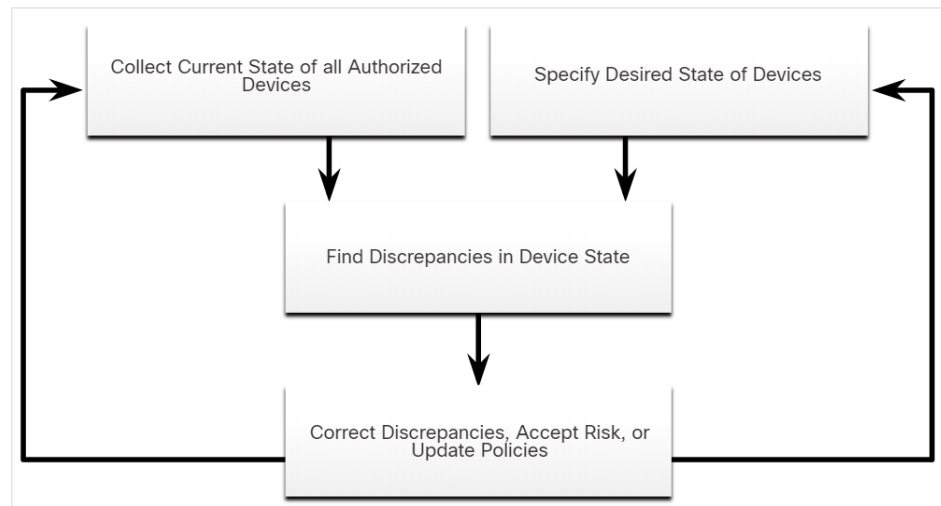


Zarządzanie zasobami

- Zarządzanie zasobami obejmuje wdrażanie systemów, które śledzą lokalizację i konfigurację urządzeń sieciowych oraz oprogramowania w całym przedsiębiorstwie.

Narzędzia i techniki zarządzania zasobami:

- Automatyczne wykrywanie i inwentaryzacja faktycznego stanu urządzeń
- Określenie pożądanego stanu urządzeń
- Identyfikacja niezgodnych autoryzowanych zasobów
- Naprawa lub akceptacja stanu urządzenia
- Regularne powtarzanie procesu



Zarządzanie urządzeniami mobilnymi Mobile Device Management – MDM

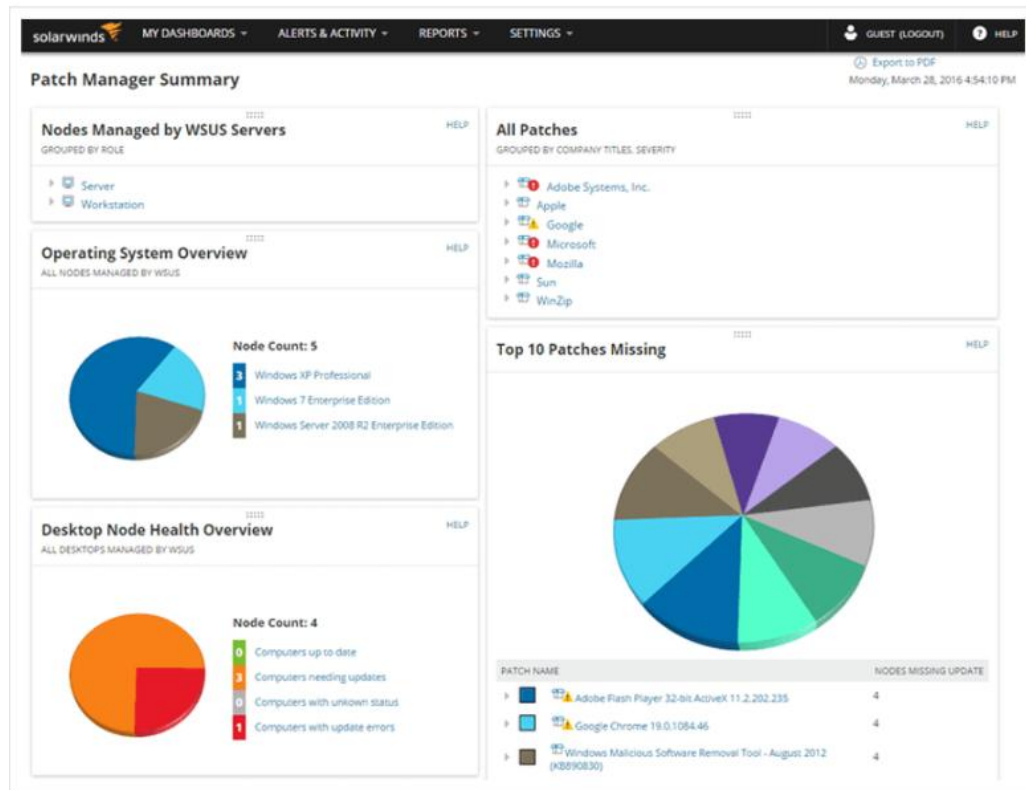
- Urządzenia mobilne nie mogą być fizycznie kontrolowane na terenie organizacji.
- Systemy MDM, takie jak Cisco Meraki Systems Manager, pozwalają personelowi ds. bezpieczeństwa na konfigurowanie, monitorowanie i aktualizowanie bardzo zróżnicowanego zestawu klientów mobilnych bezpośrednio z chmury.
- Kluczowe możliwości systemów MDM:
 - Zdalna konfiguracja: Ustawianie profili Wi-Fi, VPN oraz kont e-mail bez konieczności trzymania urządzenia w ręku.
 - Wymuszanie polityk bezpieczeństwa: Nakładanie obowiązkowych haseł, szyfrowania danych oraz blokowanie niebezpiecznych aplikacji.
 - Zdalne czyszczenie (Remote Wipe): Możliwość całkowitego usunięcia danych z urządzenia w przypadku jego kradzieży lub zgubienia.
 - Monitorowanie zgodności (Compliance): Sprawdzanie, czy urządzenia mają zainstalowane najnowsze poprawki systemu i czy nie zostały poddane procesowi jailbreak lub root.

Zarządzanie konfiguracją

- **Definicja według NIST:** Zarządzanie konfiguracją obejmuje zbiór działań skupionych na ustanawianiu i utrzymywaniu integralności produktów i systemów. Odbywa się to poprzez kontrolę procesów inicjalizacji, wprowadzania zmian oraz monitorowania konfiguracji tych produktów i systemów.
- **Narzędzia do zarządzania konfiguracją:**
 - Puppet
 - Chef
 - Ansible
 - SaltStack

Zarządzanie poprawkami w przedsiębiorstwie

- Zarządzanie poprawkami obejmuje wszystkie aspekty aktualizacji oprogramowania, w tym identyfikowanie wymaganych poprawek, ich pozyskiwanie, dystrybucję, instalację oraz weryfikację.
- **Wymogi prawne:** Zarządzanie poprawkami jest wymagane przez niektóre przepisy dotyczące zgodności, takie jak **Sarbanes-Oxley (SOX)** oraz **Health Insurance Portability and Accountability Act (HIPAA)**.

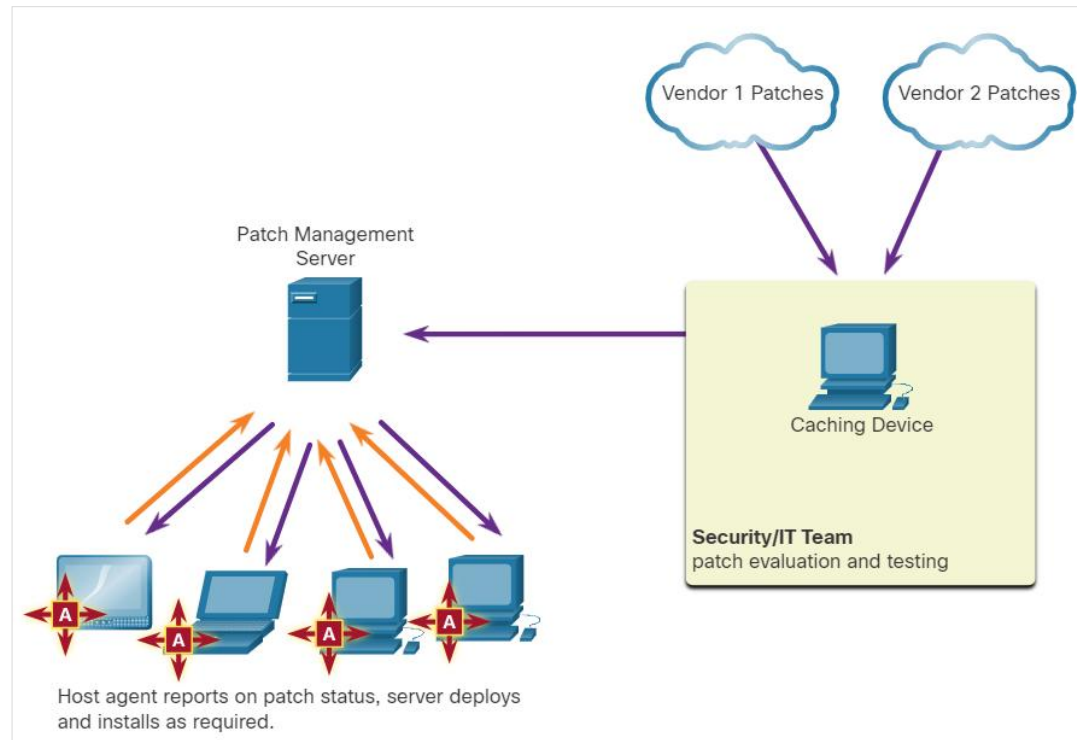


Techniki zarządzania poprawkami

Metoda oparta na agencie (Agent-based):

- Na każdym hoście (urządzeniu), który ma być aktualizowany, działa specjalny **program – agent**.
- Agent raportuje do systemu centralnego, czy na danym hoście zainstalowane jest oprogramowanie posiadające luki bezpieczeństwa.
- Agent komunikuje się z serwerem zarządzania poprawkami, sprawdza, czy istnieją aktualizacje wymagające instalacji, a następnie przeprowadza proces ich **instalowania**.

Podejście oparte na agentach jest **preferowanym sposobem** aktualizacji urządzeń mobilnych.

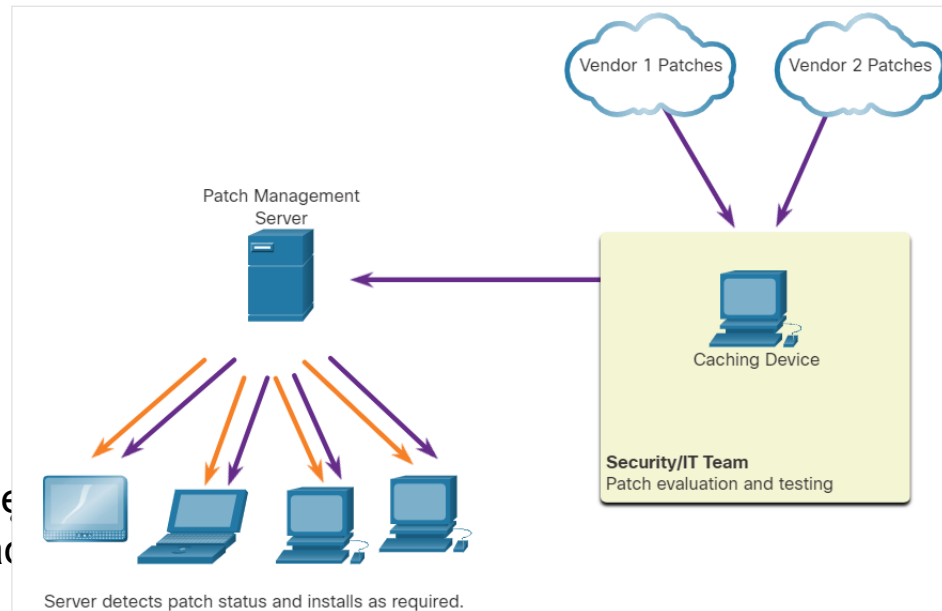


Techniki zarządzania poprawkami

Skonowanie bezagentowe (Agentless Scanning)

- Serwery zarządzania poprawkami samodzielnie skanują sieć w poszukiwaniu urządzeń wymagających aktualizacji.
- Serwer decyduje, które poprawki są niezbędne, a następnie instaluje je bezpośrednio na urządzeniach końcowych (klientach).

Ograniczenie: Tylko urządzenia znajdujące się w skanowanych segmentach sieci mogą zostać zaktualizowane. Stanowi to istotny problem w przypadku urządzeń mobilnych, które często zmieniają lokalizację lub łączą się z sieciami zewnętrznymi.

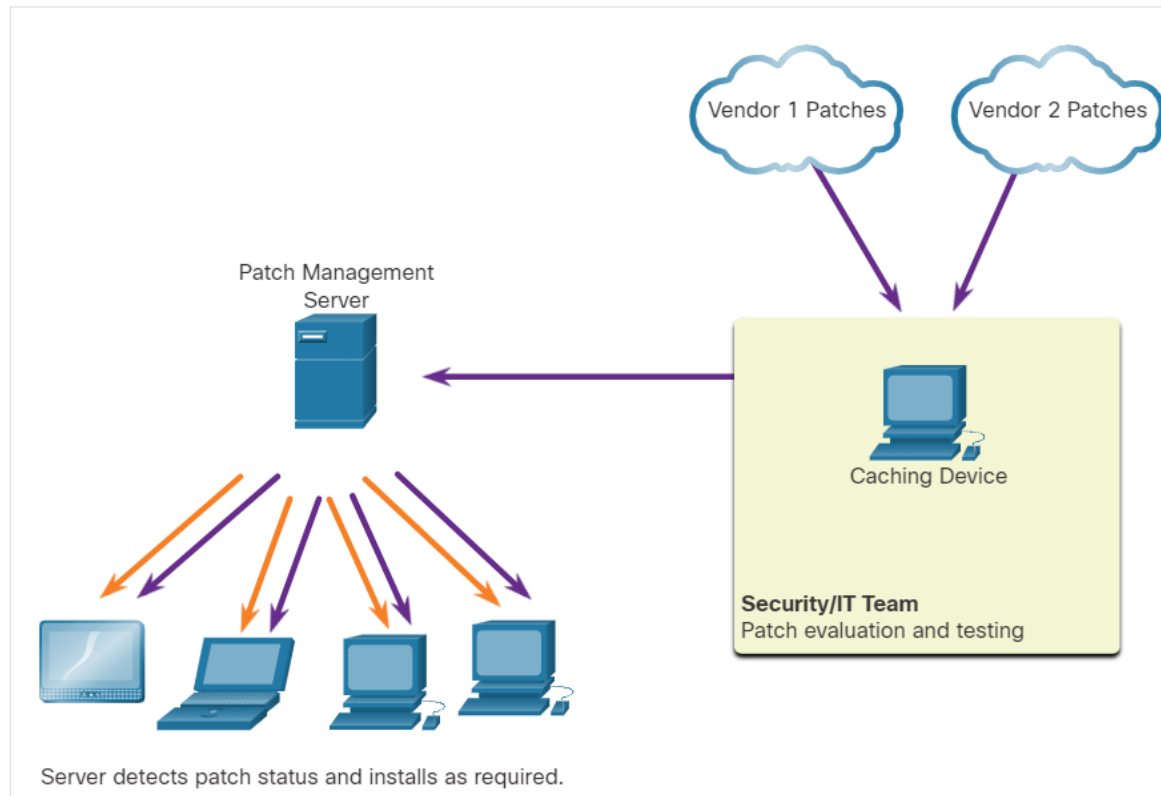


Techniki zarządzania poprawkami

Pasywne monitorowanie sieci (Passive Network Monitoring)

- Urządzenia wymagające aktualizacji są identyfikowane poprzez **monitorowanie ruchu sieciowego**.

Podejście to jest skuteczne wyłącznie w przypadku oprogramowania, które przesyła informacje o swojej wersji bezpośrednio w ruchu sieciowym.



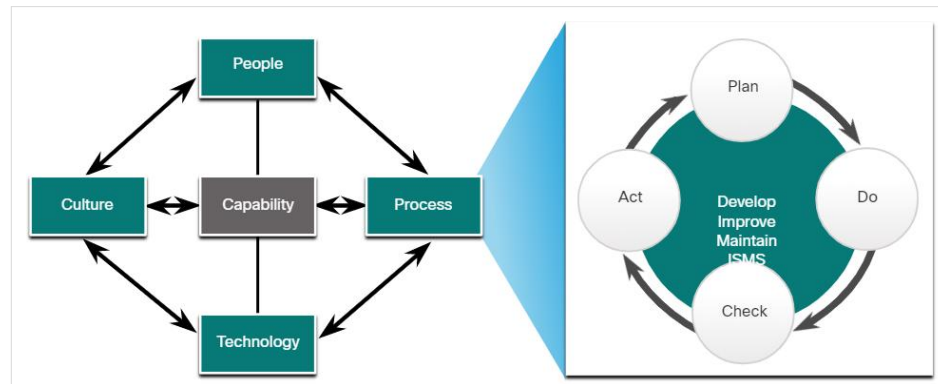
Techniki zarządzania poprawkami

Cecha	Metoda oparta na agencie (Agent-based)	Skanowanie bezagentowe (Agentless)	Pasywne monitorowanie (Passive)
Sposób działania	Oprogramowanie zainstalowane lokalnie na hoście.	Serwer skanuje hosty zdalnie przez sieć.	Analiza ruchu sieciowego (podsluchiwanie).
Zastosowanie	Urządzenia mobilne , laptopy, pracownicy zdalni.	Serwery, stacje robocze w sieci lokalnej (LAN).	Systemy, których nie można skanować (np. niektóre urządzenia IoT/OT).
Dokładność	Bardzo wysoka – pełny wgląd w system.	Wysoka – wymaga jednak uprawnień admina.	Niska – zależy od danych przesyłanych w pakietach.
Wpływ na sieć	Minimalny (tylko raportowanie zmian).	Wysoki podczas skanowania całych podsieci.	Brak (system tylko nasłuchuje).
Wymagania	Instalacja i utrzymanie agenta na każdym urządzeniu.	Brak agentów, ale konieczne otwarcie portów i dostęp zdalny.	Dostęp do ruchu sieciowego (porty SPAN/TAP).
Główna wada	Trudność w zarządzaniu dużą liczbą agentów.	Nie widzi urządzeń poza siecią firmową.	Nie wykrywa luk, które nie są widoczne w ruchu sieciowym.

9.7 Systemy zarządzania bezpieczeństwem informacji

Systemy zarządzania bezpieczeństwem

- Information Security Management System (ISMS) składa się z ram zarządczych (framework), które służą do identyfikacji, analizy i adresowania ryzyk związanych z bezpieczeństwem informacji.
- ISMS dostarcza modele, które prowadzą organizację przez proces planowania, wdrażania, zarządzania i oceniania programów bezpieczeństwa informacji.
- System ten wykorzystuje strukturę „**plan-do-check-act**” (zaplanuj – wykonaj – sprawdź – popraw), znaną jako cykl Deminga.
- ISMS jest postrzegany jako rozwinięcie modelu **Ludzie-Procesy-Technologia-Kultura**, który opisuje zdolności operacyjne organizacji.



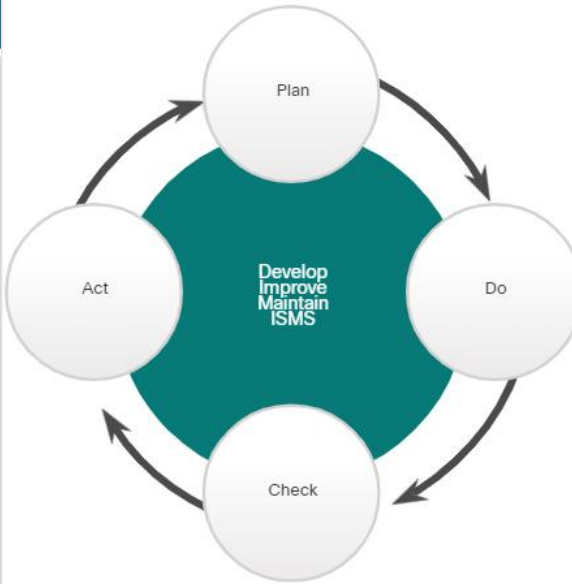
A General Model for Organizational Capability

Information Security Management Systems

ISO-27001

- Rodzina norm **ISO/IEC 27000** to międzynarodowo uznane standardy, które ułatwiają prowadzenie biznesu między krajami. Norma **ISO 27001** to globalna, branżowa specyfikacja dla Systemu Zarządzania Bezpieczeństwem Informacji (ISMS).
- Poniższa tabela przedstawia działania w ramach cyklu **PDCA** (Plan-Do-Check-Act) zgodnie z tą normą:

Plan (Zaplanuj)	Do (Wykonaj)	Check (Sprawdź)	Act (Popraw/Działaj)
•Zrozumienie celów biznesowych. •Określenie zakresu działań. •Pozyskanie wsparcia i zarządzanie nim. •Ocena i definiowanie ryzyka. •Zarządzanie zasobami i ocena podatności.	•Stworzenie i wdrożenie planu zarządzania ryzykiem. •Ustanowienie i egzekwowanie polityk oraz procedur. •Szkolenie personelu i przydzielanie zasobów.	•Monitorowanie realizacji i wykonania. •Sporządzanie raportów. •Wsparcie dla zewnętrznych audytów certyfikujących.	•Ciągły audyt procesów. •Ciągłe doskonalenie procesów. •Podejmowanie działań korygujących. •Podejmowanie działań zapobiegawczych.



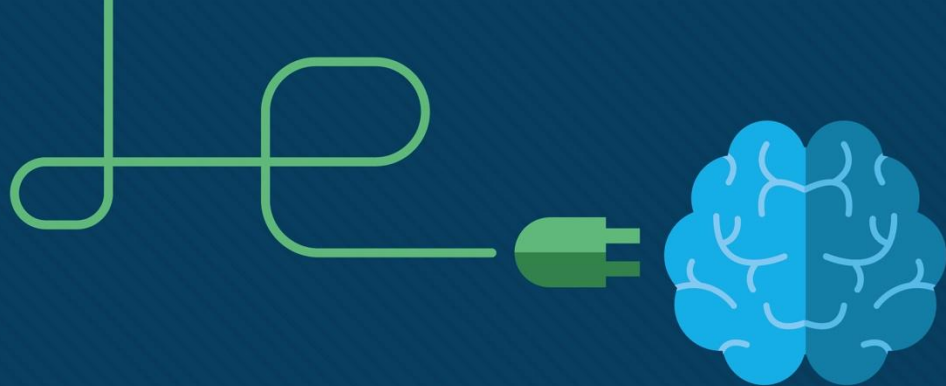
Information Security Management Systems

NIST Cybersecurity Framework

- **NIST Cybersecurity Framework** – to zestaw standardów zaprojektowanych w celu zintegrowania istniejących norm, wytycznych i praktyk, aby pomóc w lepszym zarządzaniu i redukcji ryzyka cybernetycznego.

Core Function	Description
IDENTIFY (Identyfikacja)	Rozwijanie zrozumienia organizacji w celu zarządzania ryzykiem cybernetycznym dla systemów, zasobów, danych i możliwości.
PROTECT (Ochrona)	Opracowanie i wdrażanie odpowiednich zabezpieczeń w celu zapewnienia świadczenia usług infrastruktury krytycznej.
DETECT (Wykrywanie)	Opracowanie i wdrażanie odpowiednich działań w celu zidentyfikowania wystąpienia zdarzenia związanego z cyberbezpieczeństwem.
RESPOND (Reagowanie)	Opracowanie i wdrażanie odpowiednich działań w celu podjęcia reakcji na wykryte zdarzenie związane z cyberbezpieczeństwem.
RECOVER (Odzyskiwanie)	Opracowanie i wdrażanie odpowiednich działań w celu utrzymania planów odporności i przywrócenia wszelkich możliwości lub usług, które zostały naruszone w wyniku zdarzenia cybernetycznego.





Technologie i protokoły

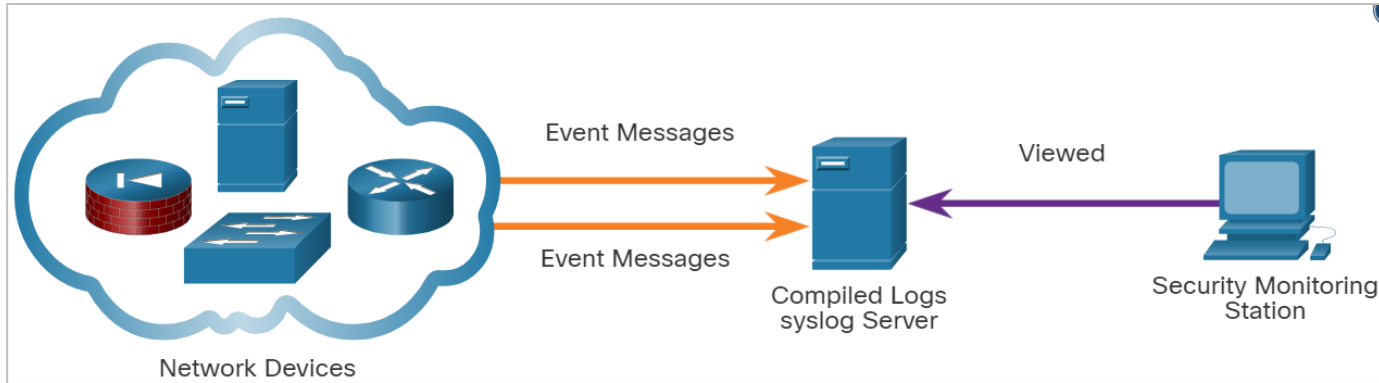
CyberOps Associate v1.0



10.1 Protokoły

Syslog i NTP

- **Syslog** oraz **Network Time Protocol (NTP)** są kluczowymi narzędziami w pracy analityka ds. cyberbezpieczeństwa.
- Standard **Syslog** jest używany do rejestrowania komunikatów o zdarzeniach (logów) z urządzeń sieciowych oraz punktów końcowych. Standard ten zapewnia niezależny od systemu sposób przesyłania, przechowywania i analizowania komunikatów.
- Wiele typów urządzeń od różnych dostawców może używać protokołu Syslog do wysyłania wpisów dziennika do centralnych serwerów, na których działa usługa Syslog (syslog daemon). Taka centralizacja zbierania logów sprawia, że monitorowanie bezpieczeństwa staje się praktyczne i wykonalne. Serwery obsługujące Syslog zazwyczaj nasłuchują na porcie **UDP 514**.



Syslog i NTP

- Ponieważ Syslog odgrywa tak ważną rolę w monitorowaniu bezpieczeństwa, serwery Syslog mogą stać się bezpośrednim celem atakujących.
- Niektóre ataki, takie jak te związane z eksfiltracją (wykrradaniem) danych, mogą trwać bardzo długo ze względu na powolne i skryte sposoby, w jakie dane są potajemnie wyprowadzane z sieci. Część napastników próbuje ukryć ten fakt, atakując serwery Syslog, które zawierają informacje mogące doprowadzić do wykrycia incydentu.
- Hakerzy mogą próbować zablokować przesyłanie danych z klientów Syslog do serwerów, manipulować przy danych logów (zmieniać je) lub je niszczyć, a także modyfikować oprogramowanie, które tworzy i przesyła komunikaty o zdarzeniach.
- Implementacja Syslog nowej generacji (next generation), znana jako **syslog-ng**, oferuje ulepszenia, które mogą pomóc w zapobieganiu niektórym atakom wymierzonym w protokół Syslog.

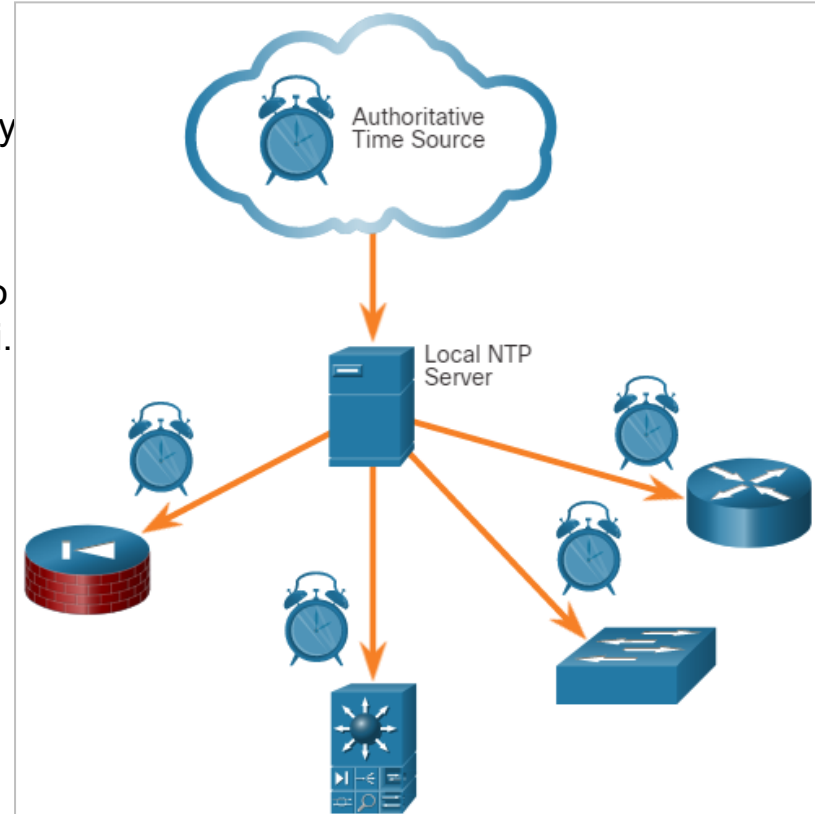
Syslog i NTP

- Tradycyjny Syslog (UDP 514) wysyła logi jawnym tekstem i nie gwarantuje ich dostarczenia. Wersja **syslog-ng** wprowadza kluczowe poprawki:
- **Szyfrowanie TLS:** Uniemożliwia podglądanie logów w sieci oraz zapobiega atakom typu *Man-in-the-Middle*.
- **Transport przez TCP:** Gwarantuje, że żaden log nie zgubi się po drodze (w przeciwieństwie do zawodnego UDP).
- **Filtrowanie i anonimizacja:** Pozwala na usuwanie wrażliwych danych (np. haseł, które ktoś przez przypadek wpisał w pole użytkownika) zanim trafią one do bazy danych.

Technologies and Protocols

NTP

- Komunikaty Syslog są zazwyczaj opatrywane znacznikiem czasu (timestamp). Ponieważ logi pochodzą z wielu różnych maszyn, kluczowe jest, aby wszystkie urządzenia współdzieliły spójny i zsynchronizowany zegar. Można to osiągnąć za pomocą protokołu **NTP (Network Time Protocol)**.
- NTP wykorzystuje hierarchię autorytatywnych źródeł czasu do dystrybucji informacji o czasie pomiędzy urządzeniami w sieci. Protokół NTP działa na porcie **UDP 123**.
- Atakujący mogą próbować uderzyć w infrastrukturę NTP, aby sfałszować lub zakłócić informacje o czasie, co uniemożliwia późniejszą korelację logów podczas analizy incydentów. Ponadto zdarzały się przypadki, w których hakerzy wykorzystywali systemy NTP do przeprowadzania ataków **DDoS** (poprzez podatności w oprogramowaniu klienckim lub serwerowym), co może doprowadzić do całkowitego zablokowania dostępności sieci.



DNS

- Protokół DNS jest obecnie wykorzystywany przez wiele rodzajów złośliwego oprogramowania (malware). Niektóre odmiany malware używają go do komunikacji z serwerami dowodzenia i kontroli (**CnC – Command-and-Control**) oraz do eksfiltracji (wykradania) danych, maskując ten ruch jako zwykłe zapytania DNS.
- Malware może zakodować skradzione dane jako część subdomeny w zapytaniu DNS o domenę, której serwer nazw (nameserver) znajduje się pod kontrolą atakującego.
- Zapytanie DNS o strukturze `dlugi-ciag-wykradzionych-danych.example.com` zostanie przekazane do serwera nazw domeny `example.com`. Serwer ten zarejestruje fragment `dlugi-ciag-wykradzionych-danych` i odeśle do złośliwego oprogramowania zakodowaną odpowiedź.
- Wspomniane wykorzystanie subdomeny DNS polega na tym, że eksfiltrowanymi danymi jest zakodowany tekst umieszczony w zapytaniu. Atakujący zbiera te zakodowane fragmenty, dekoduje je i łączy ze sobą, uzyskując w ten sposób dostęp do całego skradzionego pliku.



DNS

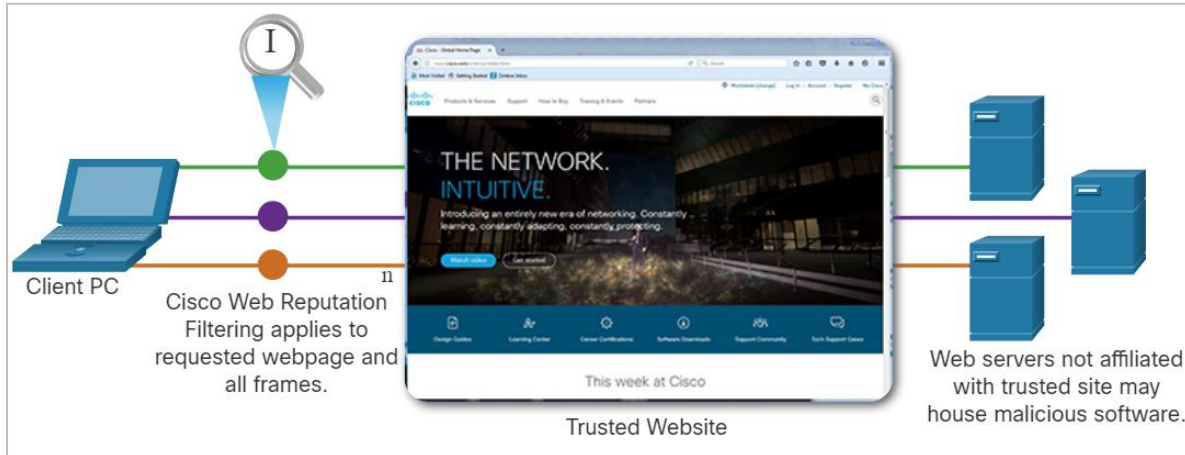
- Jest bardzo prawdopodobne, że część zawierająca subdomenę w takich zapytaniach będzie znacznie dłuższa niż w przypadku zwykłego ruchu. Analitycy ds. cyberbezpieczeństwa mogą wykorzystać rozkład długości subdomen w zapytaniach DNS do zbudowania modelu matematycznego opisującego normalny ruch sieciowy.
- Następnie mogą użyć tego modelu do porównania go z bieżącymi obserwacjami i zidentyfikowania nadużyć w procesie zapytań DNS. Na przykład sytuacja, w której host w sieci wysłał zapytanie do subdomeny takiej jak `aW4gcGxhY2UgdG8gcHJvdGVjdC.example.com`, nie powinna być uznana za normalną.
- Zapytania DNS o losowo wygenerowane nazwy domen lub o niezwykle długie, wyglądające na losowe subdomeny, należy traktować jako podejrzane – zwłaszcza jeśli częstotliwość ich występowania w sieci gwałtownie rośnie.
- Do wykrywania takich anomalii można analizować logi z serwerów proxy DNS. Alternatywnie, do blokowania zapytań do podejrzanych domen CnC oraz domen powiązanych z atakami można wykorzystać usługi takie jak pasywny DNS od **Cisco Umbrella**.

HTTP i HTTPS

- **HTTP (Hypertext Transfer Protocol)** to podstawowy protokół stanowiący kręgosłup sieci World Wide Web.
- Wszystkie informacje przesyłane za pomocą protokołu HTTP są transmitowane w postaci **czystego tekstu (plaintext)** od komputera źródłowego do miejsca docelowego w internecie.
- HTTP nie chroni danych przed ich modyfikacją lub przejęciem przez złośliwe podmioty, co stanowi poważne zagrożenie dla prywatności, tożsamości oraz bezpieczeństwa informacji. W związku z tym całą aktywność związaną z przeglądaniem stron internetowych za pomocą tego protokołu należy uznać za zagrożoną.

HTTP i HTTPS

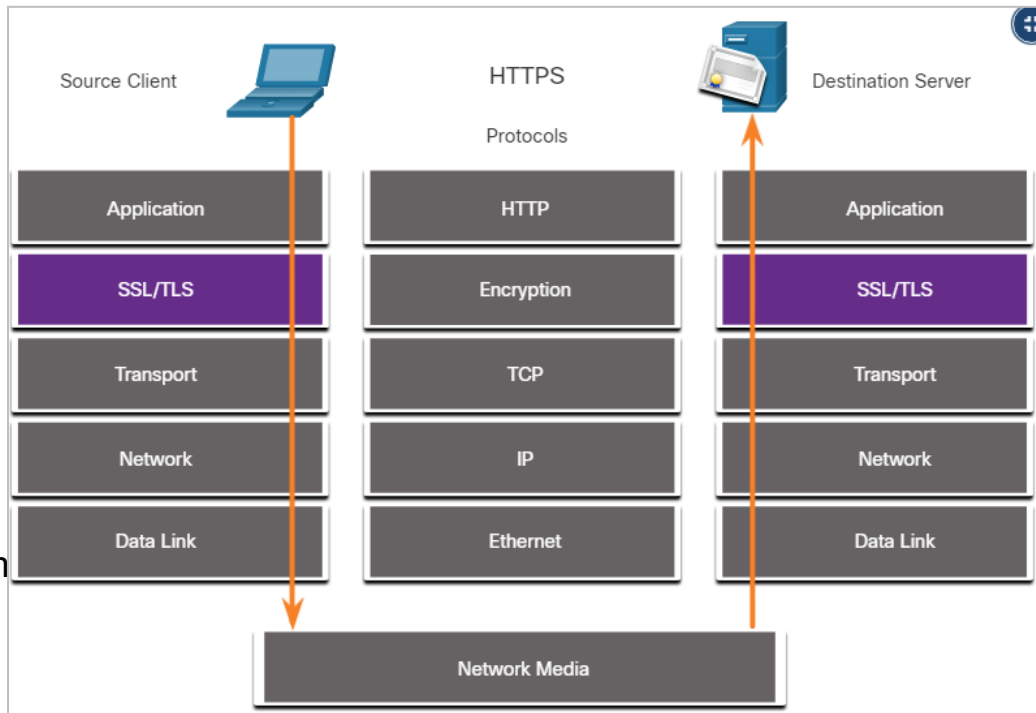
- Powszechnym atakiem na protokół HTTP jest tzw. **iFrame injection** (wstrzykiwanie ramek *inline frame*). W tym scenariuszu atakujący przejmując kontrolę nad serwerem WWW i umieszcza na nim złośliwy kod, który tworzy niewidoczną ramkę iFrame na często odwiedzanej stronie internetowej.
- Gdy ramka iFrame zostanie załadowana przez przeglądarkę użytkownika, automatycznie pobierane jest złośliwe oprogramowanie – najczęściej z zupełnie innego adresu URL niż ten, pod którym znajduje się przeglądana strona.
- Sieciowe usługi bezpieczeństwa, takie jak filtrowanie reputacji stron WWW (**Cisco Web Reputation filtering**), potrafią wykryć sytuację, w której witryna próbuje przesłać do hosta zawartość pochodzącą z niezaufanej domeny, nawet jeśli ta zawartość jest przekazywana za pośrednictwem ukrytej ramki iFrame.



HTTP i HTTPS

- Aby zapobiec modyfikacji oraz przechwytywaniu poufnych danych, wiele organizacji wdrożyło protokół HTTPS lub wprowadziło politykę korzystania wyłącznie z HTTPS (HTTPS-only) w celu ochrony użytkowników odwiedzających ich strony i serwisy.
- HTTPS dodaje warstwę szyfrowania do standardowego protokołu HTTP poprzez wykorzystanie protokołu **SSL/TLS**.
- Dzięki temu dane HTTP stają się całkowicie nieczytelne od momentu, gdy opuszczają komputer źródłowy, aż do chwili, gdy dotrą do serwera docelowego.
- **Uwaga:** HTTPS nie jest mechanizmem służącym do zabezpieczania samego serwera WWW. Chroni on wyłącznie ruch protokołu HTTP podczas jego przesyłania przez sieć (w tranzycie).

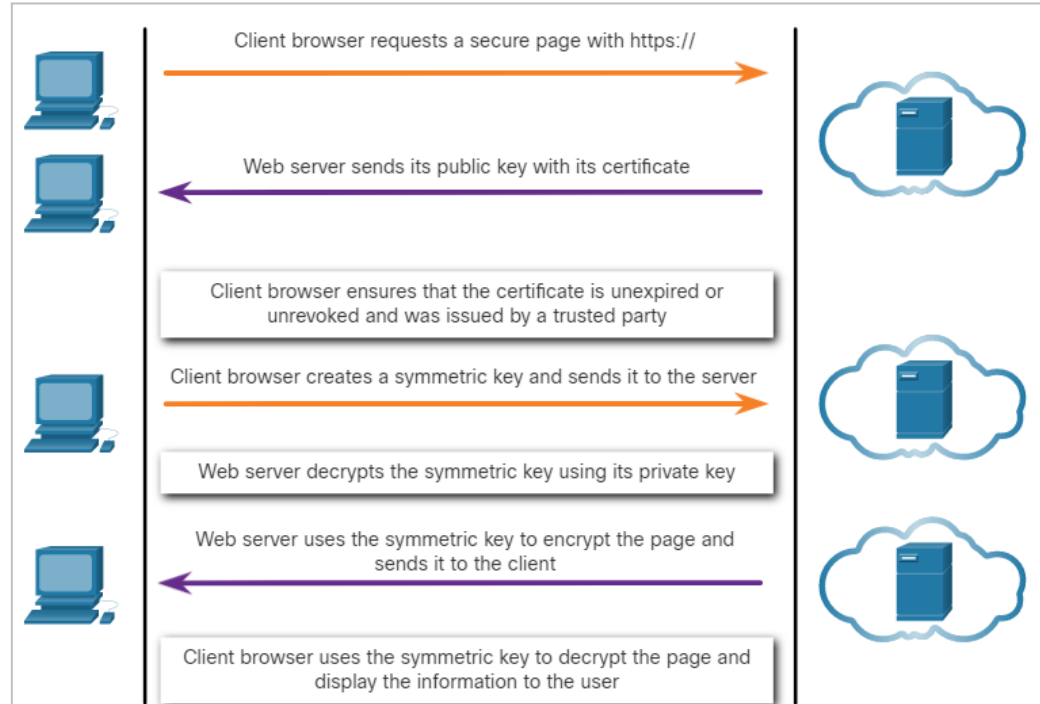
HTTPS Protocol Diagram



HTTP i HTTPS

- Niestety, zaszyfrowany ruch HTTPS komplikuje monitorowanie bezpieczeństwa sieci.
- Niektóre urządzenia oferują funkcję deszyfrowania i inspekcji ruchu SSL (SSL decryption and inspection); niesie to jednak ze sobą problemy związane z wydajnością przetwarzania danych oraz ochroną prywatności.
- HTTPS zwiększa również złożoność przechwytywania pakietów (packet captures) ze względu na dodatkową wymianę komunikatów wymaganą do ustanowienia szyfrowanego połączenia. Proces ten stanowi dodatkowe obciążenie (overhead) nałożone na standardowy protokół HTTP.

HTTPS Transactions

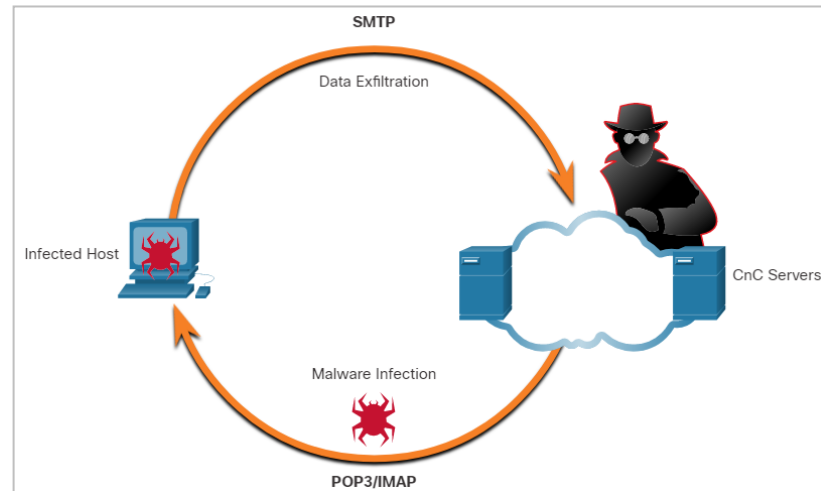


Technologies and Protocols

Protokoły email

- Protokoły poczty elektronicznej, takie jak **SMTP**, **POP3** oraz **IMAP**, mogą być wykorzystywane przez atakujących do rozprzestrzeniania złośliwego oprogramowania (malware), eksfiltracji (wykradania) danych lub jako kanały komunikacji z serwerami dowodzenia i kontroli (CnC), co przedstawiono na rysunku.
- **SMTP (Simple Mail Transfer Protocol)**: Służy do przesyłania danych z hosta do serwera pocztowego oraz pomiędzy samymi serwerami pocztowymi (wysyłanie wiadomości).
- **IMAP (Internet Message Access Protocol) oraz POP3 (Post Office Protocol v3)**: Są używane do pobierania wiadomości e-mail z serwera pocztowego na komputer użytkownika. To właśnie te protokoły warstwy aplikacji są odpowiedzialne za dostarczenie złośliwego oprogramowania bezpośrednio na stację końcową.
- Dzięki monitorowaniu bezpieczeństwa sieciowego analitycy są w stanie precyzyjnie zidentyfikować moment, w którym złośliwy załącznik przedostał się do sieci, oraz ustalić, który host został zainfekowany jako pierwszy (tzw. *Patient Zero*).

Email Protocol Threats



ICMP

- Protokół **ICMP** może być wykorzystywany do identyfikacji aktywnych hostów w sieci, mapowania struktury sieci oraz określania systemów operacyjnych działających na urządzeniach. Może również służyć jako narzędzie do przeprowadzania różnych rodzajów ataków typu **DoS** (Denial of Service).
- ICMP bywa także używany do eksfiltracji (wykradania) danych.
- Ponieważ większość obaw skupia się wokół tego, że ICMP może posłużyć do rekonesansu lub blokowania usług z *zewnątrz* organizacji, ruch ICMP generowany *wewnątrz* sieci jest czasami pomijany i bagatelizowany przez systemy obronne.
- Niektóre odmiany złośliwego oprogramowania wykorzystują odpowiednio spreparowane pakiety ICMP do przesyłania plików z zainfekowanych hostów do serwerów atakujących. Technika ta znana jest jako **tunelowanie ICMP (ICMP tunneling)**.

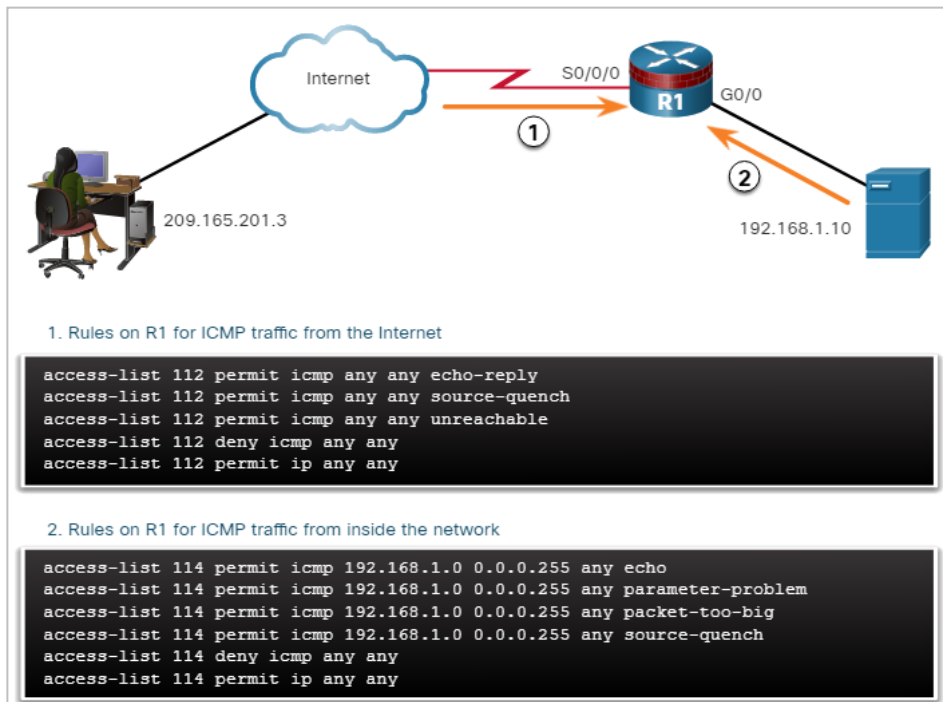
10.2 Technologie bezpieczeństwa

Security Technologies

ACLs

- Listy kontroli dostępu (**ACL – Access Control Lists**) oraz filtrowanie pakietów to technologie, które stanowią fundament ewoluujących mechanizmów ochrony bezpieczeństwa sieciowego.
- Powyższy rysunek przedstawia wykorzystanie list ACL do zezwalania wyłącznie na określone typy ruchu ICMP. Serwer o adresie 192.168.1.10 znajduje się w sieci wewnętrznej (inside network) i ma pozwolenie na wysyłanie żądań ping (*ICMP echo request*) do hosta zewnętrznego o adresie 209.165.201.3.
- Ruch powrotny ICMP od hosta zewnętrznego jest dopuszczany tylko wtedy, gdy jest to odpowiedź na ping (*ICMP echo reply*) lub dowolny komunikat o nieosiągalności celu (*ICMP destination unreachable*). Wszystkie inne typy ruchu ICMP są blokowane (denied).

Mitigating ICMP Abuse



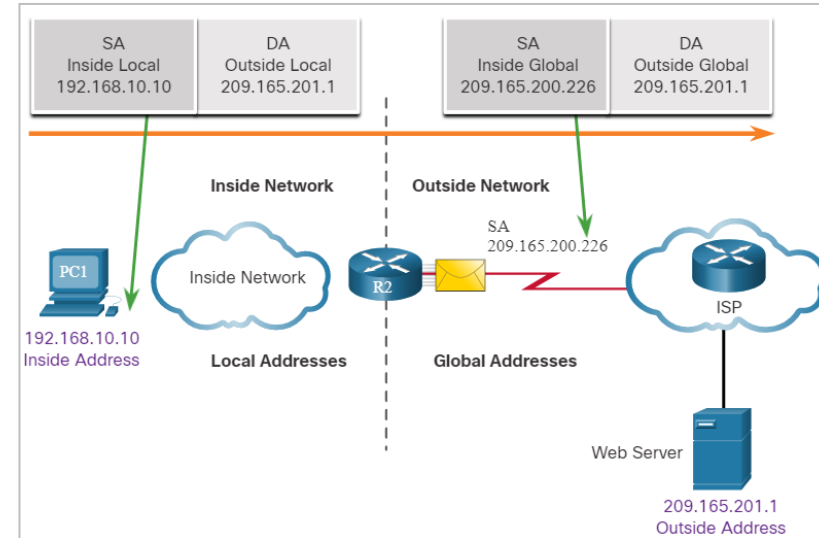
ACLs

- Atakujący potrafią ustalić, jakie adresy IP, protokoły i porty są przepuszczane przez listy ACL. Mogą tego dokonać poprzez skanowanie portów, testy penetracyjne lub inne formy rekonesansu sieciowego.
- Ponadto napastnicy potrafią tworzyć pakiety wykorzystujące sfalszowane źródłowe adresy IP (**IP spoofing**).
- Współczesne aplikacje potrafią nawiązywać połączenia na niestandardowych, dowolnych portach. Inne cechy ruchu protokołów również mogą być manipulowane – na przykład flaga ESTABLISHED w segmentach TCP (co pozwala oszukać proste firewalle bezstanowe, wmawiając im, że pakiet jest częścią już istniejącej, bezpiecznej sesji). Niemożliwe jest przewidzenie i skonfigurowanie reguł dla wszystkich nowo powstających technik manipulacji pakietami.
- Aby wykrywać manipulacje pakietami i na nie reagować, konieczne jest zastosowanie bardziej wyrafinowanych środków opartych na **analizie behawioralnej** oraz **kontekście**.
- Rozwiązania takie jak zapory sieciowe nowej generacji (**Cisco Next-Generation Firewalls - NGFW**), systemy ochrony przed zaawansowanym złośliwym oprogramowaniem (**Cisco Secure Endpoint / dawniej AMP**) oraz dedykowane urządzenia do filtrowania poczty i zawartości WWW są w stanie uzupełnić niedoskonałości systemów bezpieczeństwa opartych wyłącznie na sztywnych regułach.

NAT i PAT

- Translacja adresów sieciowych (**NAT – Network Address Translation**) oraz translacja portów (**PAT – Port Address Translation**) mogą znacząco skomplikować monitorowanie bezpieczeństwa sieci.
- Rysunek przedstawia relację pomiędzy adresami wewnętrznymi i zewnętrznymi, które są używane jako adresy źródłowe (**SA – Source Address**) oraz adresy docelowe (**DA – Destination Address**).
- Jeśli w sieci działa mechanizm PAT, dokładne ustalenie i zarejestrowanie w logach, które konkretne urządzenie wewnętrzne żądało ruchu i ten ruch odebrało, może być trudne w momencie, gdy pakiety przekraczają granicę sieci.
- Problem ten jest szczególnie istotny w przypadku analizy danych **NetFlow**. Przepływy NetFlow są jednokierunkowe i definiuje się je na podstawie współdzielonych adresów IP oraz portów.

Network Address Translation



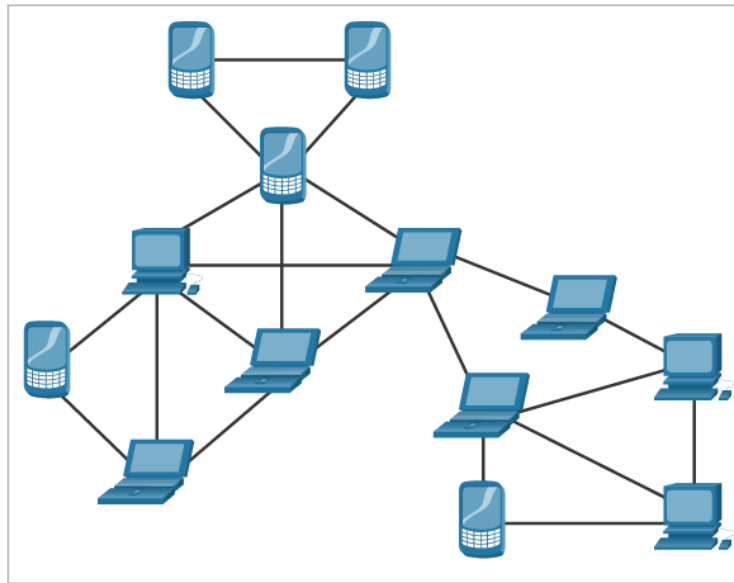
Szyfrowanie, enkapsulacja i tunelowanie

- Szyfrowanie może stanowić wyzwanie dla monitorowania bezpieczeństwa, ponieważ sprawia, że szczegółowe dane zawarte w pakietach stają się nieczytelne.
- Szyfrowanie jest nieodłączną częścią technologii **VPN (Virtual Private Network)**. W sieciach VPN protokół IP jest wykorzystywany do przenoszenia zaszyfrowanego ruchu. Taki zaszyfrowany ruch w zasadzie ustanawia wirtualne połączenie punkt-punkt (point-to-point) pomiędzy sieciami za pośrednictwem publicznej infrastruktury. Szyfrowanie powoduje, że ruch staje się całkowicie nieczytelny dla jakichkolwiek innych urządzeń poza punktami końcowymi tunelu VPN (VPN endpoints).
- Analogiczna technologia może zostać wykorzystana do stworzenia wirtualnego połączenia punkt-punkt pomiędzy wewnętrznym hostem a urządzeniami atakującego.
- Złośliwe oprogramowanie (malware) może ustanowić zaszyfrowany tunel, który opiera się na powszechnie używanym i zaufanym protokole, a następnie wykorzystać go do niepostrzeżonej eksfiltracji (wykradania) danych z sieci.

Sieci Peer-to-Peer i Tor

- W sieciach typu **Peer-to-Peer (P2P)** hosty mogą odgrywać jednocześnie rolę zarówno klienta, jak i serwera.
- Trzy główne typy zastosowań technologii P2P to:
 - Udostępnianie plików (*file sharing*),
 - Współdzielenie mocy obliczeniowej procesora (*processor sharing*),
 - Komunikatory internetowe (*instant messaging*).
- W sieciach P2P służących do udostępniania plików, zasoby znajdujące się na maszynie jednego z uczestników są bezpośrednio udostępniane pozostałym członkom sieci P2P. Przykładem działania opartego na architekturze P2P jest kryptowaluta **Bitcoin**, natomiast popularną siecią P2P służącą do wymiany plików jest **BitTorrent**.
- Aplikacje P2P służące do współdzielenia plików **nie powinny być dozwolone w sieciach korporacyjnych**. Ruch generowany przez sieci P2P potrafi skutecznie omijać zabezpieczenia zapór sieciowych (firewalli) i stanowi powszechny wektor rozprzestrzeniania się złośliwego oprogramowania.

P2P

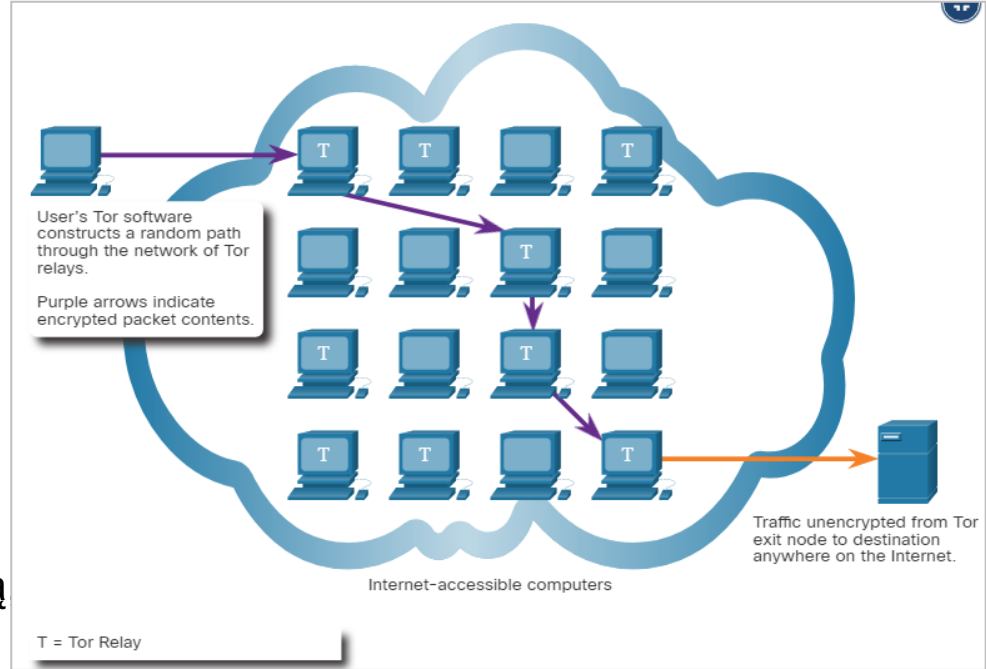


Sieci Peer-to-Peer i Tor

- Architektura P2P jest ze swej natury niezwykle dynamiczna. Jej działanie polega na łączeniu się z wieloma różnymi docelowymi adresami IP, a ponadto może ona wykorzystywać dynamiczną numerację portów.
- Sieci P2P służące do współdzielenia mocy obliczeniowej (*processor sharing*) polegają na nieodpłatnym przekazywaniu cykli pracy procesora na rzecz rozproszonych zadań obliczeniowych. Z takiego rozwiązania – polegającego na rozproszonym przetwarzaniu danych przy użyciu podarowanej mocy obliczeniowej – korzystają m.in. projekty badawcze nad rakiem, programy poszukiwania cywilizacji pozaziemskich oraz inne zaawansowane projekty naukowe.
- Komunikatory internetowe (**IM – Instant Messaging**) również są zaliczane do aplikacji typu P2P.
- Komunikatory mają realną, uzasadnioną wartość biznesową w organizacjach, które posiadają zespoły projektowe rozproszone geograficznie. W takich przypadkach dostępne są wyspecjalizowane aplikacje IM – takie jak platforma **Webex Teams** – które są znacznie bezpieczniejsze niż komunikatory korzystające z publicznych serwerów.

Sieci Peer-to-Peer i Tor

- **Tor (The Onion Router)** to platforma programistyczna oraz sieć hostów działających w architekturze P2P, które pełnią funkcję routerów internetowych wewnątrz sieci Tor.
- Sieć ta pozwala użytkownikom na w pełni anonimowe przeglądanie internetu. Dostęp do niej uzyskuje się za pomocą specjalnie zmodyfikowanej przeglądarki (tzw. **Tor Browser**).
- Gdy użytkownik rozpoczyna przeglądanie stron, jego przeglądarka buduje warstwową szyfrowaną ścieżkę typu end-to-end (od punktu początkowego do docelowego) przechodzącą przez sieć serwerów Tor, co zostało przedstawione na rysunku.



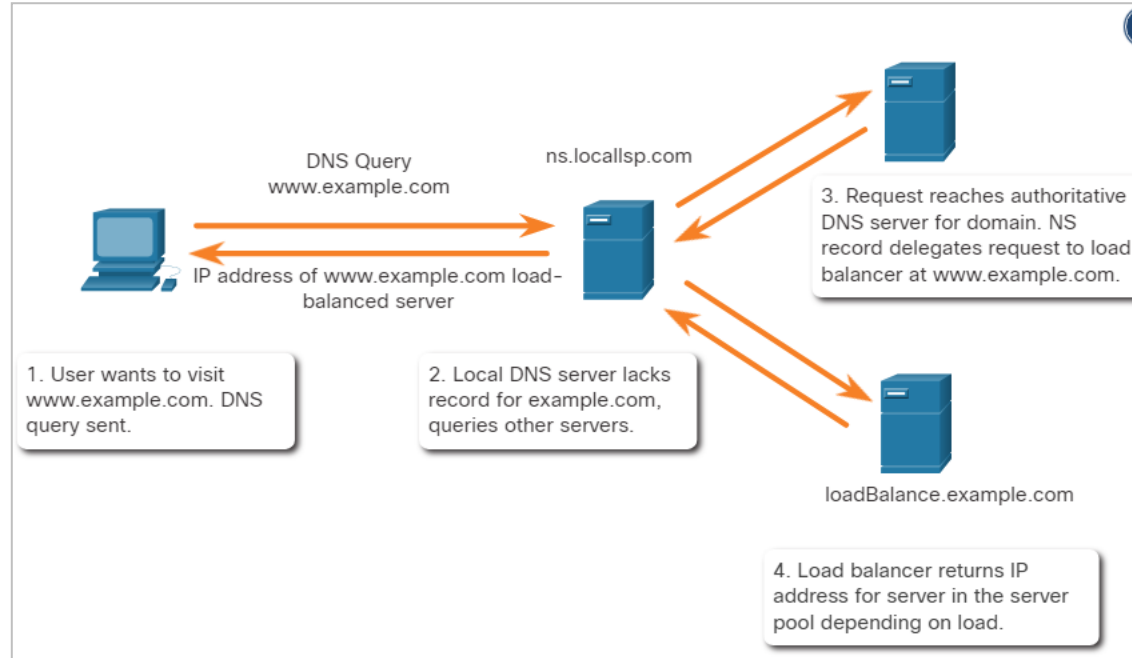
Sieci Peer-to-Peer i Tor

- Każda zaszyfrowana warstwa jest „obierana” niczym warstwy cebuli, gdy ruch przechodzi przez węzeł sieci Tor. Warstwy zawierają zaszyfrowane informacje o kolejnym skoku (next-hop), które mogą być odczytane wyłącznie przez ten router, który musi te informacje odczytać.
- W ten sposób żadne pojedyncze urządzenie nie zna całej ścieżki do celu, a informacje o routingu są czytelne tylko dla tego urządzenia, które tego wymaga.
- Ostatecznie, na końcu ścieżki Tor, ruch dociera do swojego celu w internecie. Gdy ruch powraca do źródła, ponownie budowana jest zaszyfrowana, warstwowa ścieżka.
- Tor stawia przed analitykami ds. cyberbezpieczeństwa szereg wyzwań. Po pierwsze, Tor jest powszechnie wykorzystywany przez organizacje przestępcze w „dark necie”. Ponadto Tor jest używany jako kanał komunikacyjny dla serwerów dowodzenia i kontroli (CnC) złośliwego oprogramowania. Ponieważ docelowy adres IP ruchu Tor jest maskowany przez szyfrowanie i znany jest tylko węzeł następnego skoku, ruch Tor omija czarne listy skonfigurowane na urządzeniach bezpieczeństwa.

Równoważenie obciążenia

- Równoważenie obciążenia polega na dystrybucji ruchu pomiędzy urządzeniami lub ścieżkami sieciowymi, aby zapobiec przeciążeniu zasobów sieciowych zbyt dużą ilością ruchu.
- Jeśli istnieją zasoby nadmiarowe (redundantne), algorytm lub urządzenie równoważące obciążenie będzie dystrybuować ruch pomiędzy tymi zasobami, jak przedstawiono na rysunku.
- Jednym ze sposobów, w jaki się to odbywa, są techniki wykorzystujące protokół DNS do kierowania ruchu do zasobów, które posiadają tę samą nazwę domeny, ale wiele różnych adresów IP.

Load Balancing with DNS Delegation



Równoważenie obciążenia

- W niektórych przypadkach ruch może być dystrybuowany do serwerów rozproszonych geograficznie. Skutkuje to sytuacją, w której jedna transakcja internetowa jest reprezentowana przez wiele adresów IP w pakietach przychodzących. Może to powodować pojawienie się podejrzanych cech w przechwyconych pakietach (packet captures).
- Ponadto niektóre urządzenia zarządzające równoważeniem obciążenia (LBM – Load Balancing Manager) wykorzystują sondy (probes) do testowania wydajności różnych ścieżek oraz stanu sprawności poszczególnych urządzeń.
- Urządzenie LBM może wysyłać sondy do różnych serwerów, pomiędzy które rozdziela ruch, w celu wykrycia, czy serwery te funkcjonują prawidłowo. Działanie to ma na celu uniknięcie kierowania ruchu do zasobu, który jest niedostępny.
- Sondy te mogą wyglądać jak podejrzany ruch sieciowy, jeśli analityk ds. cyberbezpieczeństwa nie jest świadomy, że ruch ten stanowi część operacji wykonywanych przez urządzenie LBM.



Dane dotyczące bezpieczeństwa sieci



10.3 Typy danych bezpieczeństwa

Network Security Data

Dane z alertów

- Dane z alertów składają się z komunikatów generowanych przez systemy zapobiegania włamaniom (IPS) lub systemy wykrywania włamań (IDS) w odpowiedzi na ruch sieciowy, który narusza regułę lub pasuje do sygnatury znanego exploita.
- Sieciowy system IDS (NIDS), taki jak Snort, dostarczany jest z prekonfigurowanymi regułami dla znanych exploitów.
- Alerty są generowane przez program Snort, a następnie udostępniane w czytelnej i możliwej do przeszukiwania formie przez aplikacje Sguil oraz Squert, które wchodzi w skład pakietu narzędzi do monitorowania bezpieczeństwa sieci (NSM) o nazwie Security Onion.

The screenshot shows the Sguil console interface. The main window displays a list of events with columns for ST, CNT, Sensor, Alert ID, Date/Time, Src IP, SPort, Dst IP, DPort, Pri, and Event Message. One alert is highlighted in yellow: 'GPL ATTACK_RESPONSE id check returned root'. Below the event list, the 'System Msgs' tab is active, showing a detailed view of the alert with fields for IP Resolution, Agent Status, Snort Statistics, System Msgs, and User Msgs. The 'System Msgs' section shows the alert message: 'alert ip any any -> any any (msg \"GPL ATTACK_RESPONSE id check returned root\", content: \"uid=0[root]29\", fast_pattern:only, classtype:bad-unknown, sid:2100498, rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23;) /msm/server_data/securityonion/rules/seconion-ens192-1/downloaded.rules: Line 700'. The 'Show Rule' section shows the rule details: 'GPL ATTACK_RESPONSE id check returned root'. The 'Show Rule' section also shows the rule details: 'GPL ATTACK_RESPONSE id check returned root'. The 'Show Rule' section also shows the rule details: 'GPL ATTACK_RESPONSE id check returned root'.

Sguil Console Showing Test Alert from Snort IDS

Dane sesji i dane transakcyjne

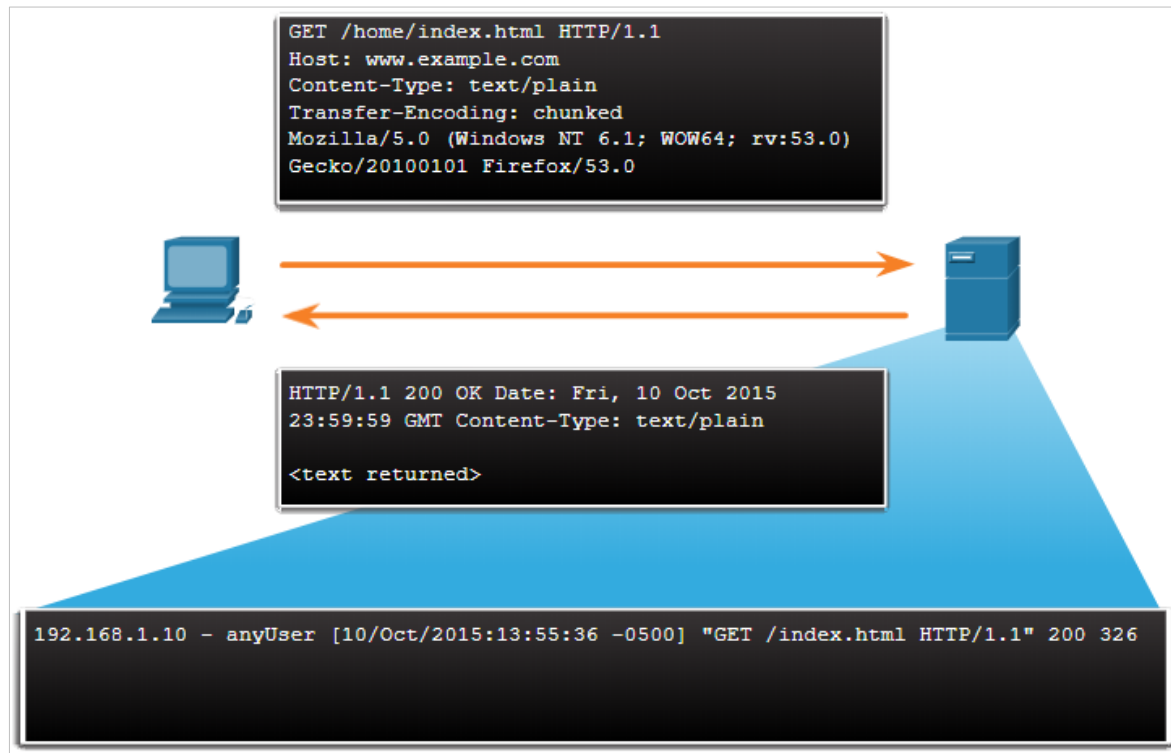
- Dane sesji (session data) stanowią zapis komunikacji pomiędzy dwoma punktami końcowymi sieci. Obejmują one tak zwaną piątkę parametrów (five-tuple): źródłowy i docelowy adres IP, źródłowy i docelowy numer portu oraz kod IP używanego protokołu.
- Dane dotyczące sesji zawierają identyfikator sesji (session ID), ilość danych przesłanych przez źródło i cel oraz informacje związane z czasem trwania sesji.
- Rysunek przedstawia częściowy wynik dla trzech sesji HTTP pochodzący z logu połączeń systemu Zeek.

1	2	3	4	5	6	7	8	9	10	11	12	13
ts	uid	id.orig_h	id.orig_p	id.resp_h	id.resp_p	proto	service	duration	orig_bytes	resp_bytes	orig_pkts	resp_pkts
1320279567	CEv1Z54N5gT3PwJLog	192.168.2.76	52034	174.129.249.33	80	tcp	http	0.082899	389	1495	5	4
1320279567	Ci6Ueb3SkSJHwASNN4	192.168.2.76	52035	184.72.234.3	80	tcp	http	2.56194	905	731	9	8
1320279567	CaTMSv1Sb8HtFunqj	192.168.2.76	52033	184.72.234.3	80	tcp	http	3.345539	1856	1445	15	13

1. **ts**: session start timestamp
2. **uid**: unique session ID
3. **id.orig_h**: IP address of host that originated the session (source address)
4. **id.orig_p**: protocol port for the originating host (source port)
5. **id.resp_h**: IP address of host responding to the originating host (destination address)
6. **id.resp_p**: protocol of responding host (destination port)
7. **proto**: transport layer protocol for session
8. **service**: application layer protocol
9. **duration**: duration of the session
10. **orig_bytes**: bytes from originating host
11. **resp_bytes**: bytes from responding host
12. **orig_packets**: packets from the originating host
13. **resp_packets**: packets from responding host

Dane sesji i dane transakcyjne

- Dane transakcyjne składają się z komunikatów, które są wymieniane podczas trwania sesji sieciowych.
- Transakcje te można przeglądać w postaci zapisów tekstowych z przechwyconych pakietów (packet capture transcripts).
- Transakcje odzwierciedlające żądania (requests) oraz odpowiedzi (replies) byłyby rejestrowane w logu dostępu (access log) na serwerze lub przez system klasy NIDS, taki jak Zeek.
- Sesja może obejmować pobieranie zawartości z serwera WWW, co zostało przedstawione na rysunku.



Pełne przechwytywanie pakietów

- Pełne przechwytywanie pakietów (full packet captures / PCAP) stanowi najbardziej szczegółowe dane sieciowe, jakie są powszechnie gromadzone. Zawiera ono właściwą treść prowadzonych rozmów, taką jak tekst wiadomości e-mail, kod HTML stron internetowych oraz pliki, które trafiają do sieci lub ją opuszczają.

- Z pełnych zrzutów pakietów można wyodrębnić i odzyskać zawartość (extracted content), a następnie poddać ją analizie pod kątem obecności złośliwego oprogramowania lub zachowań użytkowników, które naruszają polityki biznesowe i zasady bezpieczeństwa.

- Prezentowany rysunek przedstawia interfejs modułu Network Analysis Monitor, będącego częścią systemu Cisco Prime Infrastructure, który posiada funkcję wyświetlania pełnych zrzutów pakietów.

The screenshot shows the Cisco NAM Packet Analyzer interface. At the top, there's a 'Capture Session' bar for 'http_1.pcap' with 1,432,711 packets. Below this is a table of captured packets. The selected packet (No. 38333) is highlighted in green. Below the table, the packet details are shown in a hierarchical view: Frame 1 (1504 bytes on wire), Ethernet II, Internet Protocol Version 4, Transmission Control Protocol, and Hypertext Transfer Protocol. At the bottom, the raw packet data is displayed in hexadecimal and ASCII.

No.	Time	Source	Destination	Protocol	Length	Info
38333	2.691194	1.3.2.178	1.2.0.2	TCP	70	[TCP Dup ACK 34839#1] [TCP ACKed unseen segment] 54735 > http [ACK]
38334	2.691167	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38335	2.691175	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38336	2.691189	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38337	2.691193	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38338	2.691214	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38339	2.691231	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...

Frame 1: 1504 bytes on wire (12032 bits), 1500 bytes captured (12000 bits)

Ethernet II, Src: 02:1a:c5:01:00:00 (02:1a:c5:01:00:00), Dst: 02:1a:c5:02:00:00 (02:1a:c5:02:00:00)

Internet Protocol Version 4, Src: 1.2.0.2 (1.2.0.2), Dst: 1.3.1.229 (1.3.1.229)

Transmission Control Protocol, Src Port: http (80), Dst Port: 55998 (55998), Seq: 1, Ack: 1438

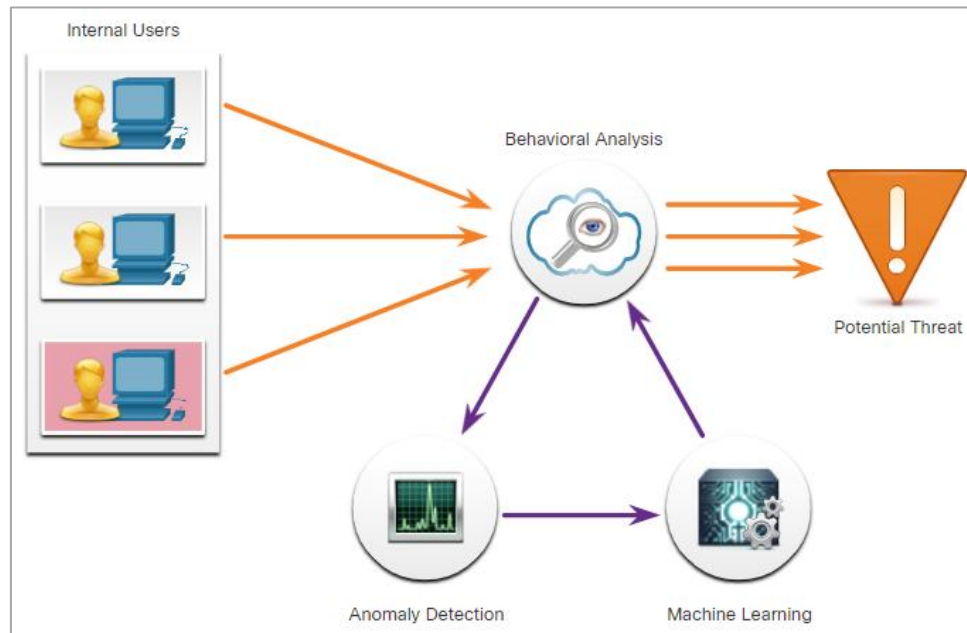
Hypertext Transfer Protocol

```

0000  02 1A C5 02 00 00 02 1A C5 01 00 00 08 00 45 00  .....E.
0010  05 DC 87 D5 40 00 20 06 C9 5B 01 02 00 02 01 03  ....@.  .[.....
0020  01 E5 00 50 DA BE CF D0 19 4F DA E7 D9 80 18    ...P.....O.....
0030  1C 48 BE E1 00 00 01 01 08 0A AC 19 04 03 AB C7  .H.....
0040  79 16 37 BE 45 A5 2F B6 30 9C 7E 72 D7 50 D1 17  y.7.E./0..r.P..
0050  38 71 79 A9 68 D0 D0 B8 17 58 97 B8 42 C7 9E 55  ;qy.k...X..B..U
0060  FF 2F 83 02 04 72 00 26 16 89 3C 21 68 B8 04 E0  ./...r.&..<|h...
0070  DD D4 DE 59 AB 69 AA A3 A0 BC D8 C9 61 B8 C4 CB  ...Y.i.....o...
0080  FF 1E 7F BB 5A DC B3 FB DC 55 93 D0 A9 79 83 35  ....Z...U...y.S
  
```


Dane statystyczne

- Dane statystyczne dotyczą ruchu sieciowego i są tworzone poprzez analizę innych form danych sieciowych. Statystyki mogą być wykorzystywane do określenia normalnych zakresów zmienności w zarysach (wzorcach) ruchu sieciowego, co pozwala na identyfikację stanów sieci, które znacząco wykraczają poza te zakresy.
- Przykładem narzędzia NSM, które wykorzystuje analizę statystyczną, jest rozwiązanie Cisco Cognitive Threat Analytics. Jest ono w stanie wykryć złośliwą aktywność, która ominęła mechanizmy kontroli bezpieczeństwa lub przedostała się do sieci kanałami niemonitorowanymi (w tym poprzez nośniki wymienne) i działa wewnątrz środowiska organizacji.
- Rysunek przedstawia architekturę systemu Cisco Cognitive Threat Analytics.



10.4 Logi urządzeń końcowych

Logi hosta

- Hostowe systemy wykrywania włamań (**HIDS – Host-based Intrusion Detection Systems**) działają na poszczególnych (indywidualnych) hostach.
- Wiele systemów zabezpieczeń typu host-based przesyła logi do scentralizowanych serwerów zarządzania logami, które można przeszukiwać z poziomu jednej, centralnej lokalizacji za pomocą narzędzi NSM.
- Logi hostów z systemem Microsoft Windows są widoczne lokalnie za pośrednictwem narzędzia **Podgląd zdarzeń (Event Viewer)**. Podgląd zdarzeń przechowuje cztery główne typy logów:
 - **Logi aplikacji (Application logs)** – zawierają zdarzenia rejestrowane przez różne aplikacje.
 - **Logi systemowe (System logs)** – obejmują zdarzenia dotyczące działania sterowników, procesów oraz sprzętu.
 - **Logi instalacji (Setup logs)** – rejestrują informacje o instalacji oprogramowania, w tym o aktualizacjach systemu Windows.
 - **Logi zabezpieczeń (Security logs)** – rejestrują zdarzenia związane z bezpieczeństwem, takie jak próby logowania oraz operacje powiązane z zarządzaniem plikami lub obiektami i dostępem do nich.
 - **Logi wiersza poleceń (Command-line logs)** - atakujący, którzy uzyskali dostęp do systemu, a także niektóre rodzaje złośliwego oprogramowania, wykonują polecenia z poziomu interfejsu wiersza poleceń (**CLI – Command-Line Interface**), a nie za pomocą interfejsu graficznego (GUI). Logowanie wykonywanych poleceń wiersza tekstowego zapewnia widoczność tego typu incydentów.

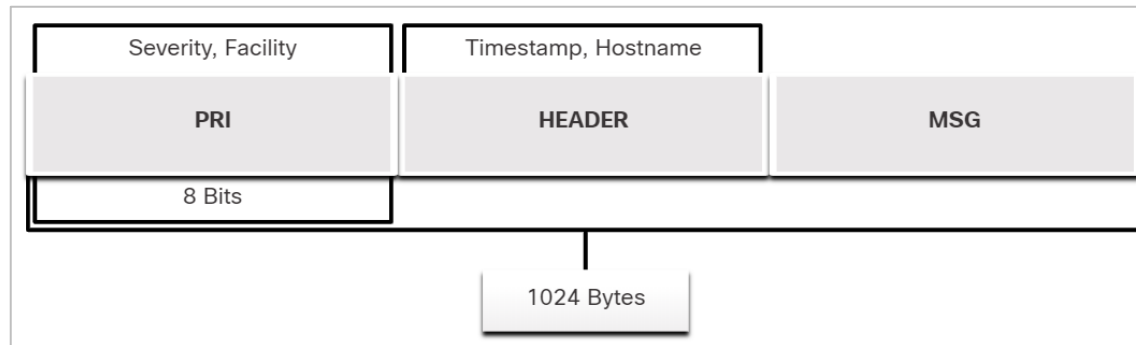
End Device Logs

Logi hosta

Typ zdarzenia (Event Type)	Opis (Description)
Error	Jest to zdarzenie wskazujące na istotny problem, taki jak utrata danych lub funkcjonalności. Na przykład, jeśli usługa nie ładuje się podczas uruchamiania systemu, rejestrowane jest zdarzenie błędu.
Warning	Jest to zdarzenie, które niekoniecznie musi być krytyczne, ale może wskazywać na potencjalny problem w przyszłości. Na przykład, gdy kończy się wolne miejsce na dysku, rejestrowane jest zdarzenie ostrzeżenia. Jeśli aplikacja odzyska sprawność po wystąpieniu jakiegoś zdarzenia bez utraty funkcjonalności lub danych, może sklasyfikować je jako ostrzeżenie.
Information	Opisuje pomyślne działanie aplikacji, sterownika lub usługi. Na przykład, gdy sterownik sieciowy ładuje się pomyślnie, właściwym działaniem może być zarejestrowanie zdarzenia informacyjnego. Należy pamiętać, że zazwyczaj niewskazane jest, aby aplikacja desktopowa rejestrowała zdarzenie przy każdym swoim uruchomieniu.
Success Audit	Jest to zdarzenie, które rejestruje poddaną inspekcji (audytowi) i zakończoną sukcesem próbę dostępu związaną z bezpieczeństwem. Na przykład udana próba zalogowania się użytkownika do systemu stanowi zdarzenie inspekcji sukcesów.
Failure Audit	Jest to zdarzenie, które rejestruje poddaną inspekcji (audytowi) próbę dostępu związaną z bezpieczeństwem, która zakończyła się niepowodzeniem. Na przykład, jeśli użytkownik próbuje uzyskać dostęp do dysku sieciowego i to się nie udaje, próba ta jest rejestrowana jako zdarzenie inspekcji niepowodzeń.

Syslog

- Standard Syslog obejmuje specyfikacje formatów komunikatów, strukturę aplikacji typu klient-serwer oraz protokół sieciowy. Jest to protokół klasy klient/serwer.
- Wiele różnych typów urządzeń sieciowych może zostać skonfigurowanych w taki sposób, aby wykorzystywały standard Syslog do rejestrowania zdarzeń na scentralizowanych serwerach Syslog.
- Pełny format komunikatu Syslog składa się z trzech wyraźnych części: **PRI** (priorytet), **HEADER** (nagłówek) oraz **MSG** (tekst komunikatu).
- Element PRI składa się z dwóch składników: **Facility** (kategoria/źródło) oraz **Severity** (poziom ważności) komunikatu. Oba te składniki są wartościami całkowitymi (integer).
 - Facility** określa źródło, które wygenerowało komunikat, takie jak system, proces lub aplikacja.
 - Severity** to wartość z zakresu od 0 do 7, która definiuje poziom ważności danego komunikatu.



Syslog

- Kodom Facility z przedziału między 15 a 23 (od local0 do local7) nie przypisano żadnego stałego słowa kluczowego ani nazwy.
- Mogą mieć one przypisywane różne znaczenia w zależności od kontekstu zastosowania. Zaobserwowano również, że różne systemy operacyjne wykorzystują zarówno kategorię 9, jak i 15 do obsługi komunikatów związanych z zegarem systemowym.

Wartość (Value)	Poziom ważności (Severity)
0	Emergency (Sytuacja awaryjna): system nie nadaje się do użytku
1	Alert (Alarm): działania muszą zostać podjęte natychmiast
2	Critical (Stan krytyczny): warunki krytyczne, które powinny zostać naprawione natychmiast; wskazuje na awarię w systemie
3	Error (Błąd): awaria, która nie jest pilna, powinna zostać rozwiązana w określonym czasie
4	Warning (Ostrzeżenie): błąd obecnie nie występuje, ale pojawi się w przyszłości, jeśli sytuacja nie zostanie rozwiązana
5	Notice (Uwaga): zdarzenie, które nie jest błędem, ale jest uważane za nietypowe. Nie wymaga natychmiastowego działania.
6	Informational (Informacja): komunikaty wydawane w związku z normalnym działaniem
7	Debug (Debugowanie): komunikaty interesujące dla programistów

Syslog

- **Priorytet (Priority)**
- Wartość Priorytetu (PRI) oblicza się poprzez pomnożenie wartości składnika Facility przez 8, a następnie dodanie do niej wartości składnika Severity, jak przedstawiono poniżej:

$$\text{Priority} = (\text{Facility} * 8) + \text{Severity}$$

- Wartość priorytetu jest pierwszą wartością w pakiecie i występuje wewnątrz nawiasów ostrych <>

Logi serwera

- Logi serwerowe stanowią kluczowe źródło danych dla monitorowania bezpieczeństwa sieci.
- Szczególnie istotne są logi serwerów proxy DNS, które dokumentują wszystkie zapytania i odpowiedzi DNS występujące w sieci.
- Dwoma ważnymi plikami logów są logi dostępu serwera WWW Apache (Apache webserver access logs) oraz logi dostępu serwera Microsoft Internet Information Services (IIS access logs).

Apache Access Log

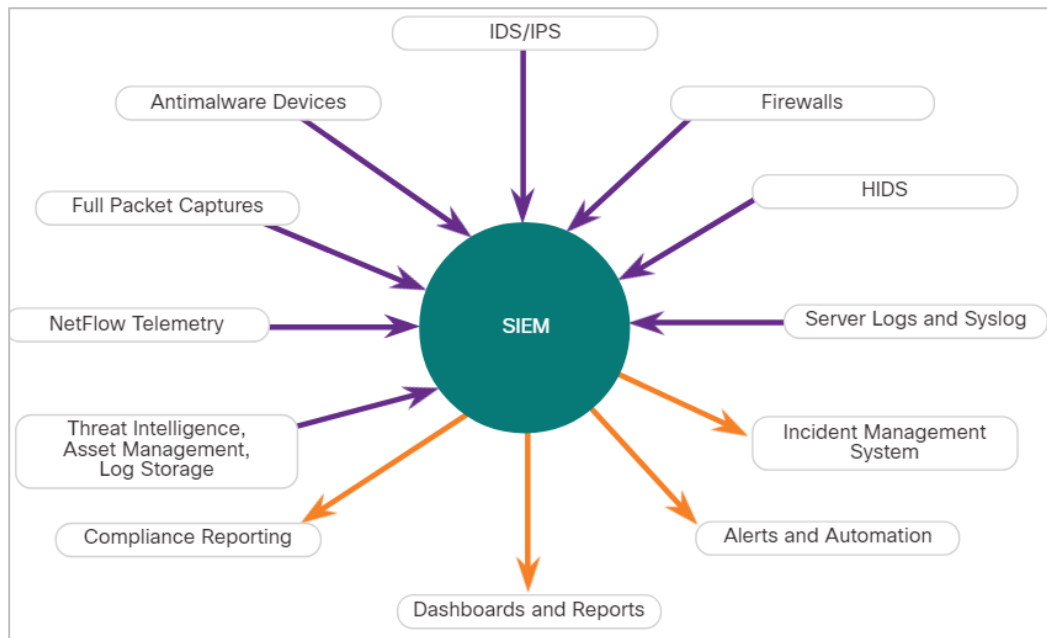
```
203.0.113.127 - dsmith [10/Oct/2016:10:26:57 - 0500] "GET /logo_sm.gif HTTP/1.0" 200 2254  
""http://www.example.com/links.html"" "Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:47.0) Gecko/20100101  
Firefox/47.0"
```

IIS Access Log

```
6/14/2016, 16:22:43, 203.0.113.24, -, W3SVC2, WEB3, 198.51.100.10, 80, GET, /home.htm, -, 200, 0, 15321,  
159, 15, HTTP/1.1, Mozilla/5.0 (compatible; MSIE 9.0; Windows Phone OS 7.5; Trident/5.0; IEMobile/9.0),  
-, http://www.example.com
```


SIEM i zbieranie logów

Technologia **SIEM (Security Information and Event Management)** jest wykorzystywana w wielu organizacjach w celu zapewnienia raportowania w czasie rzeczywistym oraz długoterminowej analizy zdarzeń związanych z bezpieczeństwem, co zostało przedstawione na rysunku.



SIEM Inputs and Outputs

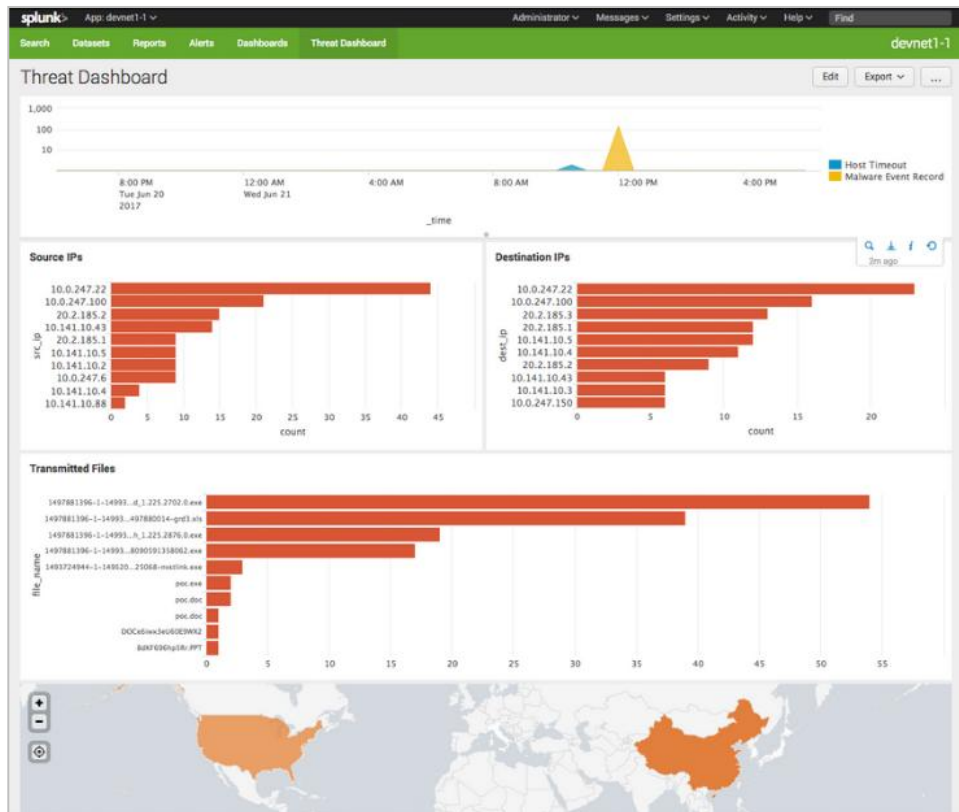
SIEM i zbieranie logów

- Systemy SIEM łączą w sobie kluczowe funkcje narzędzi klasy SEM (Security Event Management) oraz SIM (Security Information Management), zapewniając pełny wgląd w sieć przedsiębiorstwa za pomocą następujących mechanizmów:
 - **Zbieranie logów (Log collection)** – zapisy zdarzeń pochodzące ze źródeł w całej organizacji dostarczają ważnych informacji z zakresu informatyki śledczej (forensics) i pomagają w spełnianiu wymogów dotyczących raportowania zgodności (compliance).
 - **Normalizacja (Normalization)** – proces ten mapuje komunikaty logów z różnych systemów do wspólnego modelu danych, umożliwiając organizacji powiązanie i analizowanie pokrewnych zdarzeń, nawet jeśli pierwotnie zostały one zarejestrowane w różnych formatach źródłowych.
 - **Korelacja (Correlation)** – łączy ona logi i zdarzenia pochodzące z odmiennych systemów lub aplikacji, co przyspiesza wykrywanie zagrożeń bezpieczeństwa oraz reagowanie na nie.
 - **Agregacja (Aggregation)** – zmniejsza objętość danych o zdarzeniach poprzez konsolidację (łączenie) duplikujących się rekordów zdarzeń.
 - **Raportowanie (Reporting)** – prezentuje skorelowane i zagregowane dane o zdarzeniach w formie monitoringu w czasie rzeczywistym oraz podsumowań długoterminowych, w tym na graficznych, interaktywnych panelach kontrolnych (dashboards).
 - **Zgodność (Compliance)** – polega na raportowaniu mającym na celu spełnienie wymagań różnych przepisów i regulacji prawnych dotyczących zgodności.

SIEM i zbieranie logów

- Popularnym systemem SIEM jest Splunk, stworzony przez partnera firmy Cisco. Rysunek przedstawia panel zagrożeń systemu Splunk (Splunk Threat Dashboard). Splunk jest szeroko stosowany w centrach operacji bezpieczeństwa (SOC).
- Z powodu braku specjalistów ds. cyberbezpieczeństwa, którzy mogliby monitorować i analizować ogromne ilości danych dotyczących bezpieczeństwa, kluczowe znaczenie ma możliwość integracji narzędzi od wielu różnych dostawców w ramach jednej platformy.
- Zintegrowane platformy bezpieczeństwa wykraczają poza możliwości systemów SIEM oraz SOAR, łącząc wiele różnych technologii bezpieczeństwa w celu stworzenia spójnego środowiska pracy dla zespołu.

Splunk Threat Dashboard



10.5 Logi sieciowe

Tcpdump

- Narzędzie wiersza poleceń tcpdump to bardzo popularny analizator pakietów. Może ono wyświetlać przechwytywane pakiety w czasie rzeczywistym lub zapisywać je do pliku. Przechwytuje ono szczegółowe dane dotyczące protokołów oraz zawartości pakietów.
- Wireshark to graficzny interfejs użytkownika (GUI) zbudowany w oparciu o funkcjonalność narzędzia tcpdump.
- Struktura zrzutów generowanych przez tcpdump różni się w zależności od przechwytywanego protokołu oraz żądanych pól danych.

NetFlow

- NetFlow to protokół opracowany przez firmę Cisco jako narzędzie do rozwiązywania problemów sieciowych (network troubleshooting) oraz rozliczania opartego na sesjach (session-based accounting).
- NetFlow zapewnia ważny zestaw usług dla aplikacji IP, obejmujący rozliczanie ruchu sieciowego, fakturowanie sieciowe oparte na zużyciu, planowanie sieci, bezpieczeństwo, monitorowanie ataków typu DoS (Denial-of-Service) oraz ogólny monitoring sieci. Dostarcza również informacji o użytkownikach i aplikacjach sieciowych, godzinach szczytowego obciążenia oraz trasowaniu ruchu (traffic routing).
- Protokół ten rejestruje informacje o przepływie pakietów (packet flow), w tym metadane. Firma Cisco opracowała NetFlow, a następnie pozwoliła na wykorzystanie go jako podstawy do stworzenia standardu IETF o nazwie **IPFIX** (IP Flow Information Export).
- Informacje z systemu NetFlow można przeglądać za pomocą takich narzędzi jak nfdump.
- Narzędzie nfdump udostępnia program wiersza poleceń służący do przeglądania danych NetFlow pochodzących z demona przechwytyującego (kolektora) o nazwie nfcapd.

NetFlow

```
Date      flow start      Duration  Proto Src IP Addr:Port  Dst IP Addr:Port  Flags Tos Packets Bytes
Flows2017-08-30 00:09:12.596  00.010    TCP    10.1.1.2:80      -> 13.1.1.2:8974    .AP.SF  0    62
3512    1
```

```
Traffic Contribution: 8% (3/37)Flow information:IPV4 SOURCE ADDRESS:10.1.1.2IPV4 DESTINATION
ADDRESS:13.1.1.2INTERFACE INPUT:Se0/0/1TRNS SOURCE PORT:8974TRNS DESTINATION PORT:80IP TOS:0x00IP
PROTOCOL:6FLOW SAMPLER ID:0FLOW DIRECTION:Inputipv4 source mask:/0ipv4 destination mask:/8counter
bytes:205ipv4 next hop address:13.1.1.2tcp flags:0x1binterface output:Fa0/0counter packets:5timestamp
first:00:09:12.596timestamp last:00:09:12.606ip source as:0ip destination as:0
```

- Dostępna jest ogromna liczba atrybutów opisujących przepływ (flow). Rejestr podmiotów IPFIX prowadzony przez organizację IANA (Internet Assigned Numbers Authority) wymienia ich kilkaset, z czego pierwsze 128 jest stosowanych najpowszechniej.
- NetFlow stanowi niezwykle użyteczne narzędzie podczas analizy incydentów bezpieczeństwa sieciowego. Może zostać wykorzystany do odtworzenia osi czasu naruszenia bezpieczeństwa (timeline of compromise), zrozumienia zachowania poszczególnych hostów, a także do śledzenia przemieszczania się napastnika lub exploita między kolejnymi hostami wewnątrz sieci (lateral movement).

Widoczność i kontrola aplikacji

- System **Cisco Application Visibility and Control (AVC)** łączy wiele technologii w celu rozpoznawania, analizowania oraz kontrolowania ponad 1000 aplikacji.
- Obejmują one transmisje głosowe i wideo, pocztę e-mail, udostępnianie plików, gry, sieci peer-to-peer (P2P) oraz aplikacje oparte na chmurze (cloud-based).
- System AVC wykorzystuje technologię **Cisco NBAR2** (Next-Generation Network-Based Application Recognition wersja 2), znaną również jako NBAR nowej generacji, do wykrywania i klasyfikowania aplikacji używanych w sieci.
- Silnik rozpoznawania aplikacji NBAR2 obsługuje ponad 1000 aplikacji sieciowych.

Widoczność i kontrola aplikacji



System identyfikuje aplikacje przy użyciu danych z warstw od L3 do L7 (modelu OSI).

Obsługuje ponad **1000**

aplikacji, w tym:

- Usługi chmurowe (Cloud services)
- Cisco WebEx
- YouTube
- Skype
- Sieci P2P (Peer-to-Peer)

NBAR2



System zbiera metryki w celu ich eksportu do narzędzia zarządzającego. Metryki te obejmują:

- Wykorzystanie przepustowości (Bandwidth usage)
- Czas odpowiedzi (Response time)
- Opóźnienie (Latency)
- Utratę pakietów (Packet loss)
- Jitter (Zmienność opóźnień pakietów)
- P2P (Ruch w sieciach peer-to-peer)

NetFlow v9 | Flexible NetFlow | IPFIX



Management and Reporting Tools

System umożliwia apro wizację sieci (network provisioning), zbieranie danych oraz raportowanie wydajności aplikacji za pomocą następujących funkcji:

- Generowanie raportów (Report generation)
- Zarządzanie politykami (Policy Management)

Cisco Prime | Inne oprogramowanie firm trzecich (3rd Party Software)



High: VoIP
Medium: Browsing
Low: Streaming
Blocked: P2P

System kontroluje wykorzystanie aplikacji w celu maksymalizacji wydajności sieci poprzez następujące mechanizmy:

- Priorytetyzacja aplikacji (Application prioritization)
- Wymuszanie limitów przepustowości dla aplikacji (Application bandwidth enforcement)

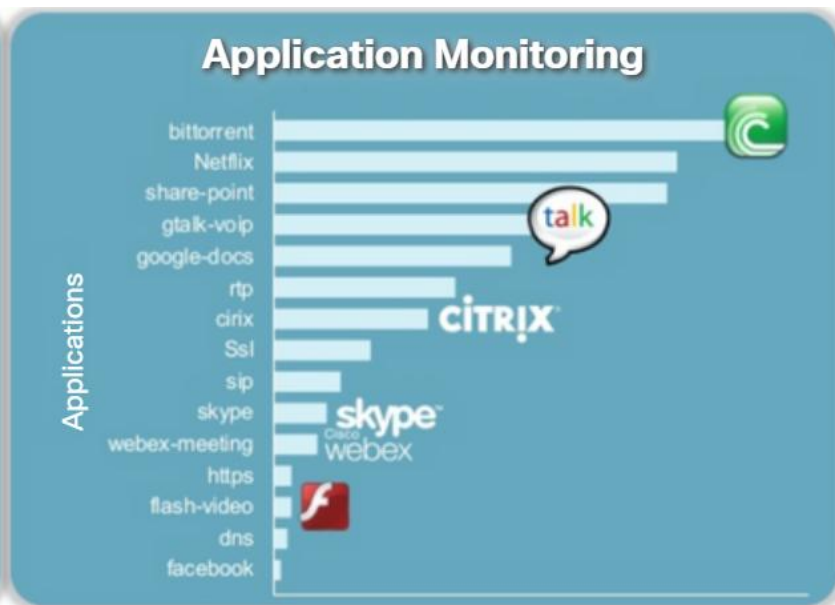
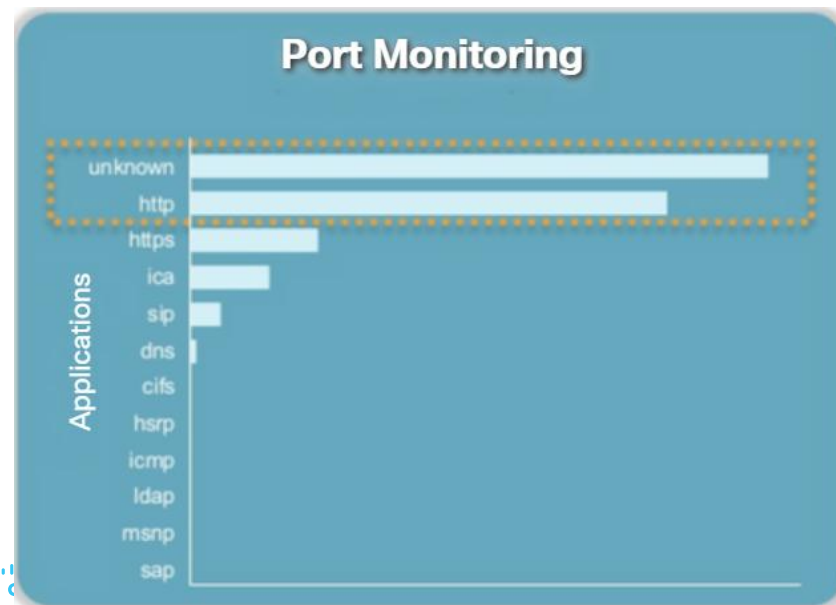
QoS (Quality of Service - Jakość usługi)

Widoczność i kontrola aplikacji

Monitorowanie portów a monitorowanie aplikacji

System zarządzania i raportowania analizuje oraz prezentuje dane z analizy aplikacji w formie raportów na panelach kontrolnych (dashboards), z których korzysta personel monitorujący sieć.

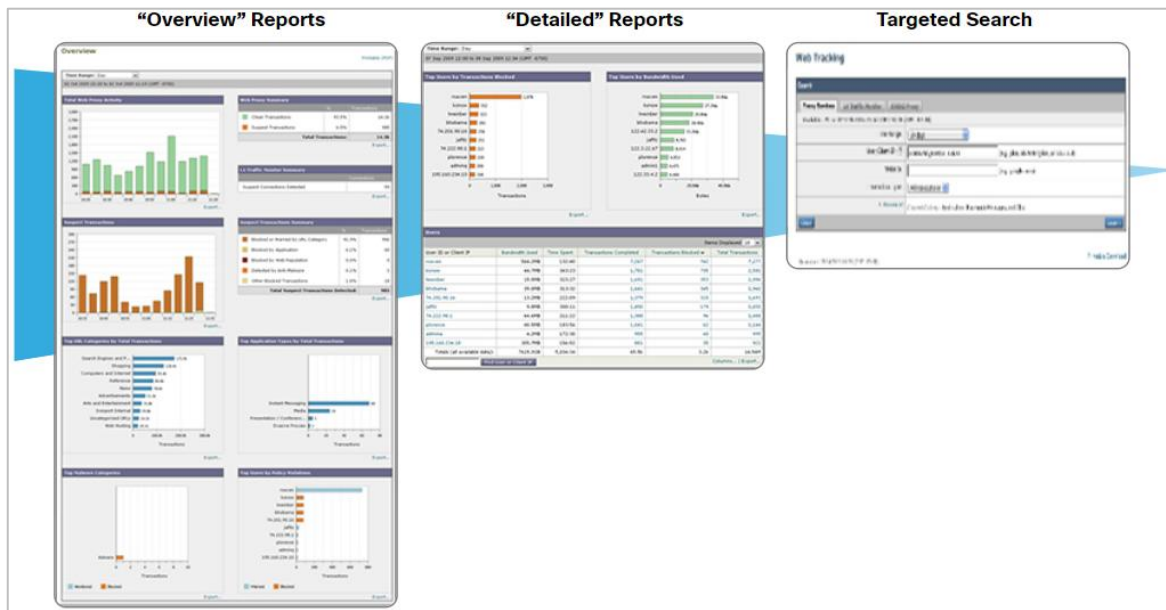
Wykorzystanie aplikacji może być również kontrolowane za pomocą klasyfikacji jakości usług (QoS) oraz polityk sieciowych wdrażanych w oparciu o informacje dostarczane przez system AVC (Application Visibility and Control).



Logi filtrów zawartości

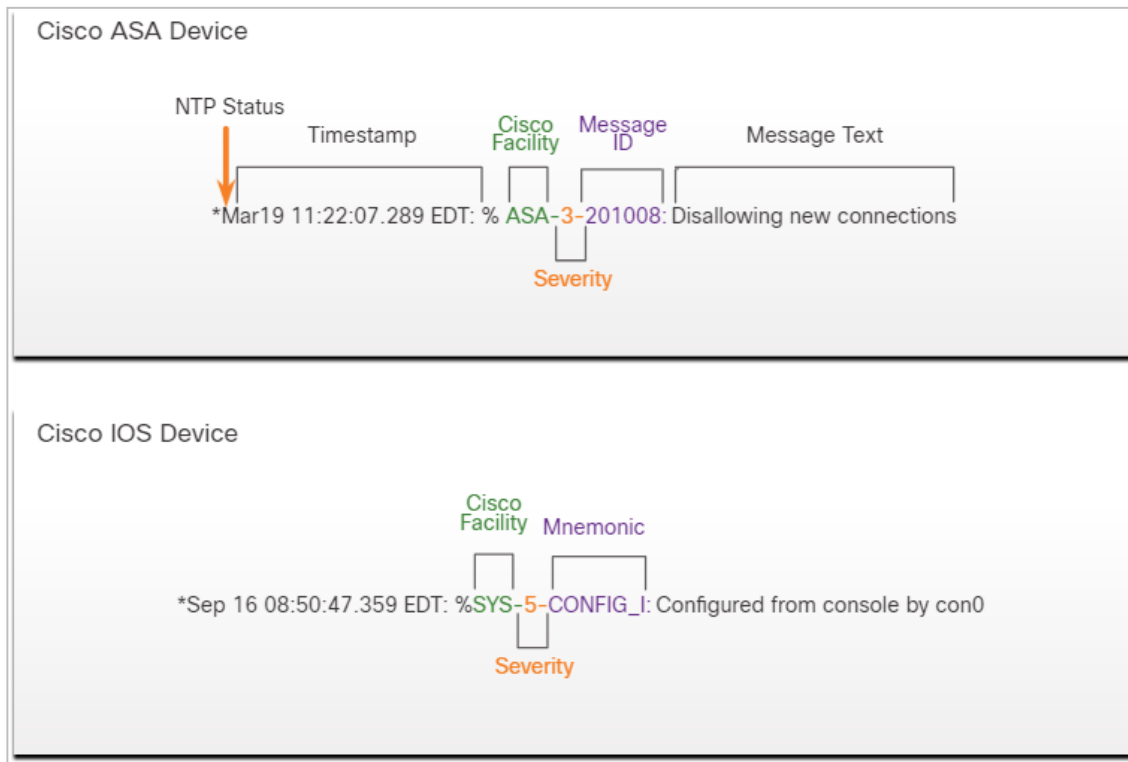
•Urządzenia zapewniające filtrowanie zawartości, takie jak **Cisco Email Security Appliance (ESA)** oraz **Cisco Web Security Appliance (WSA)**, oferują szeroki zakres funkcjonalności w obszarze monitorowania bezpieczeństwa.

•Rysunek przedstawia panele kontrolne (dashboards) pochodzące z urządzeń Cisco do filtrowania zawartości. Kliknięcie poszczególnych elementów raportów ogólnych (Overview) powoduje wyświetlenie bardziej szczegółowych, powiązanych danych. Z kolei wyszukiwanie celowane (Target searches) dostarcza precyzyjnie skupionych informacji.



Logowanie z urządzeń Cisco

- Urządzenia bezpieczeństwa firmy Cisco mogą być skonfigurowane tak, aby przysyłać zdarzenia i alerty do platform zarządzania bezpieczeństwem przy użyciu protokołów SNMP lub Syslog.
- Rysunek przedstawia komunikat Syslog wygenerowany przez urządzenie Cisco ASA oraz komunikat Syslog wygenerowany przez urządzenie Cisco IOS.
- W komunikatach Syslog urządzeń Cisco termin **Facility** stosuje się w dwóch różnych znaczeniach:
 - Pierwsze to standardowy zestaw wartości Facility, które zostały określone przez oficjalne normy i standardy protokołu Syslog.
 - Druga wartość Facility jest przypisywana wewnętrznie przez Cisco i pojawia się bezpośrednio w części tekstowej komunikatu (**MSG**).



Logi serwerów proxy

- Serwery pośredniczące (proxy), takie jak te używane do obsługi żądań WWW (web) oraz DNS, generują niezwykle wartościowe logi, które stanowią jedno z głównych źródeł danych w monitorowaniu bezpieczeństwa sieciowego.
- Serwer proxy żąda zasobów w imieniu klienta, zwraca je do niego, a następnie generuje logi zawierające rejestr wszystkich tych żądań i odpowiedzi. Logi te mogą być później poddawane analizie w celu ustalenia, które hosty wysyłają zapytania, czy miejsca docelowe są bezpieczne, czy potencjalnie złośliwe, a także w celu uzyskania wglądu w rodzaj pobieranych zasobów.
- Web proxy (pośrednicy sieci Web) dostarczają danych, które pomagają ustalić, czy odpowiedzi z sieci Web zostały wygenerowane w następstwie legalnych żądań, czy też zostały zmanipulowane tak, aby tylko udawały prawidłowe odpowiedzi, będąc w rzeczywistości exploitami.
- Istnieje również możliwość wykorzystania serwerów web proxy do inspekcji ruchu wychodzącego w ramach systemów zapobiegania wyciekom danych (**DLP – Data Loss Prevention**). Technologia DLP polega na skanowaniu ruchu wychodzącego w celu wykrycia, czy dane opuszczające sieć nie zawierają informacji wrażliwych, poufnych lub stanowiących tajemnicę firmy.

Logi serwerów proxy

- Rozwiązanie **Cisco Umbrella** (dawniej OpenDNS) oferuje usługę hostowanego DNS, która rozszerza standardowe możliwości protokołu DNS o zaawansowane funkcje bezpieczeństwa.
- Cisco Umbrella przeznaczona na zarządzanie systemem DNS znacznie większe zasoby, niż większość organizacji jest w stanie samodzielnie sfinansować. Pod tym względem Cisco Umbrella działa częściowo jako „super proxy” dla ruchu DNS.
- Pakiet produktów bezpieczeństwa Cisco Umbrella wykorzystuje analizę zagrożeń w czasie rzeczywistym (real-time threat intelligence) do zarządzania dostępem do usług DNS oraz do zabezpieczania samych rekordów DNS.
- Poniżej przedstawiono przykład logu z serwera DNS proxy:

```
"2015-01-16 17:48:41","ActiveDirectoryUserName",  
"ActiveDirectoryUserName,ADSite,Network",  
"10.10.1.100","24.123.132.133","Allowed","1 (A)",  
"NOERROR","domain-visited.com.",  
"Chat,Photo Sharing,Social Networking,Allow List"
```

Zapory sieciowe nowej generacji

- Urządzenia typu **Next-Generation Firewall (NGFW)** rozszerzają bezpieczeństwo sieciowe daleko poza adresy IP i numery portów warstwy 4., przenosząc je do warstwy aplikacji oraz wyższych.
- Zapory sieciowe nowej generacji to zaawansowane urządzenia, które oferują znacznie większą funkcjonalność niż poprzednie generacje sieciowych rozwiązań zabezpieczających. Jedną z takich funkcji są panele raportowania (dashboards) z interaktywnymi opcjami, które umożliwiają szybkie generowanie bardzo szczegółowych raportów za pomocą kilku kliknięć, bez konieczności wdrażania systemów SIEM czy innych korelatorów zdarzeń.
- Urządzenia NGFW wykorzystują usługi **Firepower Services** w celu skonsolidowania wielu warstw zabezpieczeń w ramach jednej platformy. Usługi Firepower obejmują:
 - Widoczność i kontrolę aplikacji (Application Visibility and Control)
 - System zapobiegania włamaniom nowej generacji – **Firepower NGIPS** (Next-Generation IPS)
 - Filtrowanie adresów URL oparte na reputacji oraz kategoriach tematycznych (Reputation and category-based URL filtering)
 - Zaawansowaną ochronę przed złośliwym oprogramowaniem – **AMP** (Advanced Malware Protection)

Zapory sieciowe nowej generacji

Typowe zdarzenia NGFW obejmują:

- Zdarzenie połączenia (Connection Event)
- Zdarzenie włamania (Intrusion Event)
- Zdarzenie hosta lub punktu końcowego (Host or Endpoint Event)
- Zdarzenie wykrywania sieci (Network Discovery Event)
- Zdarzenie Netflow (Netflow Event)

Services Provided by NGFW



